



Australian Government

Department of Defence
Intelligence and Security



2012

Australian Government
Information Security Manual

CONTROLS





Australian Government

Department of Defence
Intelligence and Security

DSD

Cyber operations.
Discover a new frontier.

Apply Now

6AAAAABbi8uDwx4zwDPSigOK
ETLCiAM8AHQrg8EBg8MB6+wz
/7/z+TEct0SlpGf5dRy153US
YQEE56Ri7Kdkj8IAABkcOsw=

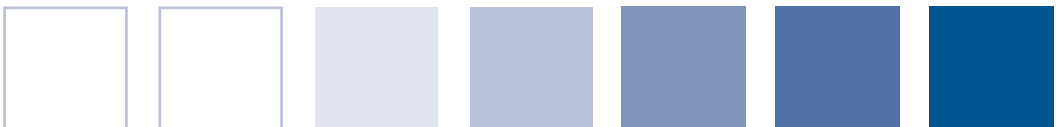
dsd.gov.au

DSD | Reveal Their Secrets – Protect Our Own

2012

Australian Government
Information Security Manual

CONTROLS



© Commonwealth of Australia 2011

All material presented in this publication is provided under a Creative Commons Attribution 3.0 Australia licence. For the avoidance of doubt, this means this licence only applies to material as set out in this document.



The details of the relevant licence conditions are available on the Creative Commons website as is the full legal code for the CC BY 3.0 AU licence.

<http://creativecommons.org/licenses/by/3.0/au/deed.en>

<http://creativecommons.org/licenses/by/3.0/legalcode>

Use of the Coat of Arms

The terms under which the Coat of Arms can be used are detailed on the Department of the Prime Minister and Cabinet's website.

<http://www.dpmc.gov.au/guidelines/index.cfm>

Contact us

Inquiries regarding the licence and any use of this document are welcome at:

Defence Signals Directorate

Locked Bag 5076

Kingston ACT 2604

1300 CYBER1 (1300 292 371)

assist@dsd.gov.au.

Foreword

Advances in information technology have greatly benefited the conduct of government and commercial business, and have become essential to everyday communication. Information technology is providing greater accessibility, mobility, convenience and, importantly, efficiency and productivity. Australia's prosperity is dependent on taking full advantage of the digital revolution and all it offers.

But advances in information technology can be a double-edged sword. Australian networks, whether government, commercial or personal, are facing an unprecedented level of intrusion activities. Threats to information can come from a wide range of sources, including individuals, issue motivated groups, organised criminal syndicates and nation states.

It is important to know that things can be done to mitigate the security risks presented by this evolving threat environment. DSD supports agencies in embracing the latest technology by providing the information and tools which enable them to minimise the risks involved. Ultimately, technology will change faster than people's behaviour around it. Helping people make better decisions about new technology will allow us to stay ahead of the curve.

The *Australian Government Information Security Manual* forms an important part of the Government's strategy to enhance its information security capability. The 2012 release of the Manual comprises, for the first time, three complementary documents designed to provide greater accessibility and understanding at all levels of government. The accompanying controls manual provides a set of detailed measures which can be implemented to help mitigate security risks to agencies' information and systems.

I encourage you to apply the controls described here and to ensure you have effective security governance arrangements in place. Doing so will provide assurance that the information entrusted to you is properly protected.

Ian McKenzie Director
Defence Signals Directorate



Contents

ABOUT INFORMATION SECURITY	1
AUSTRALIAN GOVERNMENT INFORMATION SECURITY MANUAL	2
Using This Manual	2
Applicability, Authority and Compliance	9
INFORMATION SECURITY GOVERNANCE	11
INFORMATION SECURITY ENGAGEMENT	12
Government Engagement	12
Industry Engagement and Outsourcing	15
ROLES AND RESPONSIBILITIES	17
The Chief Information Security Officer	17
The Information Technology Security Advisor	18
Information Technology Security Managers	19
Information Technology Security Officers	20
System Owners	21
INFORMATION SECURITY DOCUMENTATION	22
Documentation Fundamentals	22
Information Security Policies	25
Security Risk Management Plans	26
System Security Plans	28
Standard Operating Procedures	30
Incident Response Plans	33
Emergency Procedures	34
SYSTEM ACCREDITATION	35
Accreditation Framework	35
Conducting Accreditations	39
Conducting Certifications	42
Conducting Audits	44
INFORMATION SECURITY MONITORING	47
Vulnerability Management	47
Change Management	50
Business Continuity and Disaster Recovery	52
CYBER SECURITY INCIDENTS	54
Detecting Cyber Security Incidents	54
Reporting Cyber Security Incidents	56
Managing Cyber Security Incidents	58

PHYSICAL SECURITY	63
PHYSICAL SECURITY FOR SYSTEMS	64
Facilities and Network Infrastructure	64
Servers and Network Devices	66
ICT Equipment and Media	68
PERSONNEL SECURITY	71
PERSONNEL SECURITY FOR SYSTEMS	72
Information Security Awareness and Training	72
Authorisations, Security Clearances and Briefings	75
Using the Internet	78
COMMUNICATIONS SECURITY	81
COMMUNICATIONS INFRASTRUCTURE	82
Cable Management Fundamentals	82
Cable Management for Non-Shared Government Facilities	87
Cable Management for Shared Government Facilities	89
Cable Management for Shared Non-Government Facilities	91
Cable Labelling and Registration	95
Cable Patching	98
Emanation Security Threat Assessments	100
COMMUNICATIONS SYSTEMS AND DEVICES	102
Radio Frequency, Infrared and Bluetooth Devices	102
Fax Machines and Multifunction Devices	105
Telephones and Telephone Systems	108
INFORMATION TECHNOLOGY SECURITY	111
PRODUCT SECURITY	112
Product Selection and Acquisition	112
Product Installation and Configuration	117
Product Classifying and Labelling	119
Product Maintenance and Repairs	121
Product Sanitisation and Disposal	123
MEDIA SECURITY	125
Media Handling	125
Media Usage	128
Media Sanitisation	131
Media Destruction	136
Media Disposal	140



SOFTWARE SECURITY	142
Standard Operating Environments	142
Application Whitelisting	148
Web Content and Connections	150
Email Applications	153
Software Application Development	156
Web Application Development	158
Databases	159
ACCESS CONTROL	161
Identification and Authentication	161
System Access	169
Privileged Access	171
Remote Access	173
Event Logging and Auditing	174
CRYPTOGRAPHY	178
Cryptographic Fundamentals	178
DSD Approved Cryptographic Algorithms	182
DSD Approved Cryptographic Protocols	185
Secure Sockets Layer and Transport Layer Security	187
Secure Shell	188
Secure Multipurpose Internet Mail Extension	191
Internet Protocol Security	192
Key Management	195
NETWORK SECURITY	200
Network Management	200
Virtual Local Area Networks	203
Wireless Local Area Networks	205
Video Conferencing and Internet Protocol Telephony	208
Email Infrastructure	213
Intrusion Detection and Prevention	218
Internet Protocol Version 6	221
Data Transfers	223
Peripheral Switches	226
Ensuring Service Continuity	227
GATEWAY SECURITY	228
Gateways	228
Data Import and Export	236
Content Filtering	238
Traffic Flow Filters	240
Diodes	242
WORKING OFF-SITE	244
Mobile Devices	244
Working Outside the Office	249
Working From Home	251



SUPPORTING INFORMATION	253
GLOSSARIES AND INDEX	254
Glossary of Abbreviations	254
Glossary of Terms	257



ABOUT
INFORMATION
SECURITY



About Information Security

Australian Government Information Security Manual

Using This Manual

Objective

The *Australian Government Information Security Manual* (ISM) is used for the risk-based application of information security to information and systems.

Scope

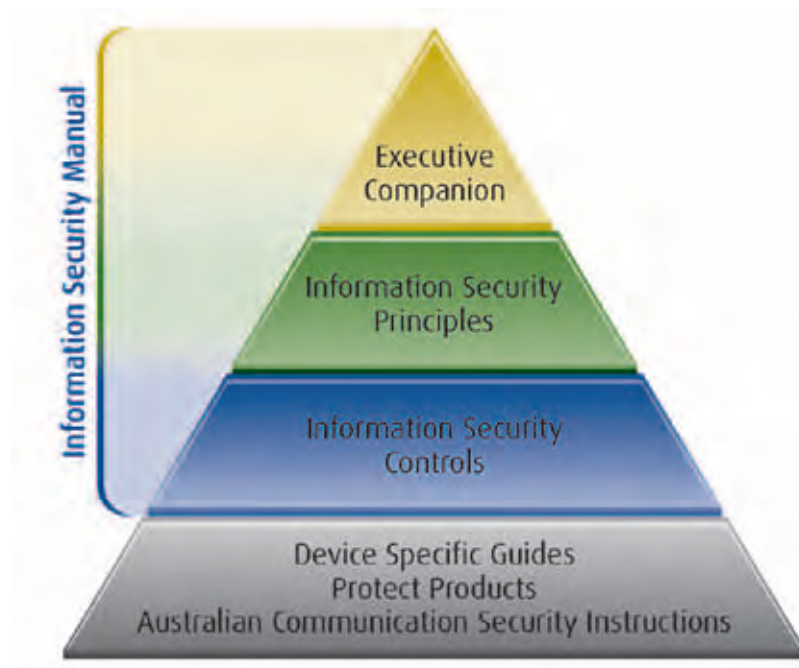
This section describes how to interpret the content and layout of this manual.

Context

Purpose of the Australian Government Information Security Manual

The purpose of this manual is to assist Australian government agencies in applying a risk-based approach to protecting their information and systems. While there are other standards and guidelines designed to protect information systems, the advice in this manual is specifically based on activity observed by Defence Signals Directorate (DSD) on Australian government networks.

Format of the Australian Government Information Security Manual



The three parts of the new format manual are designed to complement each other and provide agencies with the necessary information to conduct informed risk-based decisions based on their own business requirements, specific circumstances and risk appetite.

The executive companion is targeted towards the most senior executives in each agency, such as Deputy Secretaries, Secretaries and Chief Executive Officers, and comprises broader strategic messaging about key information security issues.

The principles document is aimed at Security Executives, Chief Information Security Officers, Chief Information Officers and senior decision makers across government and focuses on providing them with a better understanding of the cyber threat environment and rationale to assist them in developing informed information security policies within their agencies.

The controls manual is aimed at Information Technology Security Advisors, Information Technology Security Managers, infosec-registered assessors and security practitioners across government. This manual provides a set of detailed controls which, when implemented, will help agencies adhere to the higher level principles document.

DSD provides further information security advice in the form of device specific guides, Australian Communications Security Instructions (ACSIs) and 'Protect' products – such as the *Top 35 Strategies to Mitigate Targeted Cyber Intrusions*. While these products reflect the policy specified in this manual, not all requirements in this manual can be implemented on all devices or in all environments. In these cases, device specific advice may take precedence over the non-platform specific advice in this manual.

Framework

This manual uses a framework to present information in a consistent manner. The framework consists of a number of headings in each section:

- Objective—the desired outcome of complying with the controls specified in the section, expressed as if the outcome has already been achieved
- Scope and Context—the scope and applicability of the section. It can also include definitions, legislative context and background information
- Controls—procedures with associated compliance requirements for reducing the level of security risks
- References—external sources of information that can assist in interpreting or implementing controls.

System applicability

Each control in this manual has an applicability indicator that indicates the information and systems to which the control applies. The applicability indicator has up to five elements, indicating whether the control applies to:

- G: Government systems containing unclassified but sensitive information not intended for public release, such as Dissemination Limiting Marker information; note 'Government' is not a security classification under the *Australian Government Security Classification System*
- P: PROTECTED information and systems
- C: CONFIDENTIAL information and systems
- S: SECRET information and systems
- TS: TOP SECRET information and systems.

Public systems

Agencies deploying public systems can determine their own security measures based on their risk appetite and security risks to their systems. However, DSD encourages such agencies to use this manual, particularly the objectives, as a guide when determining security measures for their systems.

Applicability of controls

While this manual provides controls for various technologies, not all systems will use all of the technologies mentioned. When agencies develop systems they will need to determine the appropriate scope of the systems and which controls in this manual are applicable.

Authority to approve non-compliance

Each control specifies the authority that must provide approval for non-compliance with the control. The authority indicator indicates one of the three authorities:

- DSD: Director DSD
- AH: agency head
- AA: accreditation authority.

Compliance language

There are two categories of compliance associated with the controls in this manual – ‘must’ and ‘should’. These compliance requirements are determined according to the degree of security risk an agency will be accepting by not implementing the associated control. While the majority of controls can be risk managed within an agency, the compliance requirements provide an indication of the appropriate level within the agency where any residual security risks must be accepted in order to grant non-compliance. The full implications need to be considered before granting non-compliance with a control.

Non-compliance with multiple controls

When an agency is non-compliant with multiple controls, they may choose to logically group the areas of non-compliance when following the processes for non-compliance.

Controls

Granting non-compliance

Non-compliance with ‘must’ and ‘must not’ controls are likely to represent a high security risk to information and systems. Therefore, the agency head, in association with the accreditation authority, is required to consider the justification for non-compliance and accept the associated residual security risk. Non-compliance with controls relating to High Grade Cryptographic Equipment must be granted by the Director DSD. These controls are marked accordingly in this manual.

Non-compliance with ‘should’ and ‘should not’ controls are likely to represent a medium-to-low security risk to information and systems. As the risk for non-compliance is not as high as those with a ‘must’ and ‘must not’ compliance requirement, the accreditation authority can consider the justification for non-compliance and accept the associated residual security risk without the input of the agency head.

Control: 0001; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: DSD

System owners seeking approval for non-compliance with any control with a ‘must’ or ‘must not’ compliance requirement must be granted non-compliance from their accreditation authority and their agency head and, if the authority field on a control is “DSD”, the Director DSD.

Control: 1061; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

System owners seeking approval for non-compliance with any control with a ‘should’ or ‘should not’ compliance requirement must be granted non-compliance from their accreditation authority.

Justification for non-compliance

Without sufficient justification, and consideration of the security risks, the agency head or their authorised delegate will lack the appropriate information to make an informed decision on whether to accept the residual security risk and grant non-compliance to the system owner.

Control: 0710; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

System owners seeking approval for non-compliance with any control must document:

- the justification for non-compliance
- the alternative mitigation measures to be implemented, if any
- an assessment of the security risks.

Consultation on non-compliance

When an agency processes, stores or communicates information on their systems that belongs to another agency or foreign government they have an obligation to inform that third party when they desire to risk manage the controls specified in this manual. If the agency fails to do so, the third party will be unaware that their information has been placed at a heightened risk of compromise. The third party is thus denied the opportunity to consider additional security measures for their information.

The extent of consultation with other agencies and foreign governments may include:

- a notification of the intent to be non-compliant
- the justification for non-compliance
- any mitigation measures that may have been implemented
- an assessment of the security risks relating to the information they have been entrusted with.

Control: 0711; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

If a system processes, stores or communicates information from another agency, that agency must be consulted as part of granting non-compliance with any control.

Control: 0712; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

If a system processes, stores or communicates information from a foreign government, that government must be consulted as part of granting non-compliance with any control.

Notification of non-compliance

The purpose of notifying authorities of any decisions to grant non-compliance with controls is two-fold: firstly to ensure that an accurate picture of the state of information security across government can be maintained, and secondly as feedback to ensure the continuing refinement of this manual.

Control: 0713; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must notify the Cyber Security Operations Centre at DSD when granting non-compliance with any control.

Reviewing non-compliance

When seeking approval for non-compliance, the system owner must provide a justification for non-compliance, outline any alternative mitigation measures to be implemented and conduct an assessment of the security risks. As the justification for non-compliance may change, and the risk environment will continue to evolve over time, it is important that the system owner update their approval for non-compliance at least every two years. In doing so it should be resubmitted to the appropriate authority for review and have any decision to grant non-compliance either reaffirmed or, if necessary, rejected if the justification or residual security risk is no longer acceptable.

Control: 0876; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should review decisions to grant non-compliance with any control, including the justification, any mitigation measures and security risks, at least every two years or when significant changes occur to ensure its continuing relevance, adequacy and effectiveness.

Recording non-compliance

Without appropriate records of decisions to grant non-compliance with controls, agencies have no record of the status of their security posture. Furthermore, a lack of such records will hinder any auditing activities that may be conducted by the agency or by external parties such as the Australian National Audit Office (ANAO). Failing to maintain such records is also a breach of the *Archives Act 1983* (the Archives Act).

Control: 0003; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must retain a copy of decisions to grant non-compliance with any control from this manual.

References

This manual is updated regularly. It is therefore important that agencies ensure that they are using the latest baseline comprising the latest release, errata and interim policy releases. This manual, additional information, tools and discussion topics can be accessed from the OnSecure website at <https://members.onsecure.gov.au/>.

Supplementary information to this manual can be found in the following documents.

TOPIC	DOCUMENTATION	AUTHOR
Archiving of information	<i>The Archives Act 1983</i>	National Archives of Australia (NAA)
	<i>Administrative Functions Disposal Authority – Revised 2010</i>	NAA
	<i>General Disposal Authority for Encrypted Records Created in Online Security Processes</i>	NAA
Business continuity	HB 221:2004, <i>Business Continuity Management</i>	Standards Australia
	HB 292-2006, <i>A practitioners guide to business continuity management</i>	Standards Australia
	HB 293-2006, <i>Executive guide to business continuity management</i>	Standards Australia
Cabinet information	<i>Cabinet Handbook, Security and Handling of Cabinet Documents</i>	Department of Prime Minister and Cabinet
Cable security	ACSI 61, <i>Guidelines for the Installation of Communications and Information Processing Equipment and Systems</i>	DSD
Communications security roles and responsibilities	ACSI 53, <i>Communications Security Handbook</i>	DSD
Communications security incident reporting	ACSI 107, <i>Reporting and Evaluating Communications Security Incidents</i>	DSD

TOPIC	DOCUMENTATION	AUTHOR
Emanation security	ACSI 71, <i>A guide to the Assessment of Electromagnetic Security in Military and High-risk Environments</i>	DSD
Information and records management for information and communications technology systems	<i>Australian Government Recordkeeping Metadata Standard V2.0</i>	NAA
	ISO 16175-1:2010, <i>Principles and functional requirements for records in electronic office environments – Part 1: Overview and statement of principles</i>	International Organization for Standardization (ISO)
	ISO 16175-2:2011, <i>Principles and functional requirements for records in electronic office environments – Part 2: Guidelines and functional requirements for digital records management systems</i>	ISO
	ISO 16175-3:2010, <i>Principles and functional requirements for records in electronic office environments – Part 3: Guidelines and functional requirements for records in business systems</i>	ISO
Information security management	<i>Australian Government Information Security Management Protocol</i>	Attorney-General's Department (AGD)
	ISO/IEC 27000:2009, <i>Information technology – Security techniques – Information security management systems – Overview and vocabulary</i>	ISO / International Electrotechnical Commission (IEC)
	AS/NZS ISO/IEC 27001:2006, <i>Information technology – Security techniques – Information security management systems – Requirements</i>	Standards Australia
	AS/NZS ISO/IEC 27002:2006, <i>Information technology – Security techniques – Code of practice for information security management</i>	Standards Australia
	ISO/IEC 27003:2010, <i>Information technology – Security techniques – Information security management systems implementation guidance</i>	ISO/IEC
	ISO/IEC 27004:2009, <i>Information technology – Security techniques – Information security management – Measurement</i>	ISO/IEC
Key management – commercial grade	AS 11770.1-2003, <i>Information technology – Security techniques – Key management – Framework</i>	Standards Australia
Key management – high grade	ACSI 105, <i>Cryptographic Controlling Authorities and Keying Material Management</i>	DSD
Management of electronic records that may be used as evidence	HB 171-2003, <i>Guidelines for the management of IT evidence</i>	Standards Australia

TOPIC	DOCUMENTATION	AUTHOR
Personnel security	<i>Australian Government Personnel Security Management Protocol</i>	AGD
Physical security	<i>Australian Government Physical Security Management Protocol</i>	AGD
Privacy requirements	<i>The Privacy Act 1988</i>	AGD
Protective security	<i>Australian Government Protective Security Policy Framework</i>	AGD
Risk management	<i>AS/NZS ISO 31000:2009, Risk Management – Principles and guidelines</i>	Standards Australia
	<i>HB 327:2010, Communicating and consulting about risk (Companion to AS/NZS ISO 31000:2009)</i>	Standards Australia
	<i>ISO/IEC Guide 73, Risk Management – Vocabulary – Guidelines for use in Standards</i>	ISO/IEC
	<i>ISO/IEC 27005:2008, Information technology – Security techniques – Information security risk management</i>	ISO/IEC
	<i>HB 167:2006, Security risk management</i>	Standards Australia
	<i>HB 231:2004, Information security risk management guidelines</i>	Standards Australia
	<i>NIST SP 800-30, Risk Management Guide for Information Technology Systems</i>	National Institute of Standards and Technology (NIST)

Applicability, Authority and Compliance

Objective

Requirements in the ISM are complied with.

Scope

This manual is the primary policy produced by DSD relating to information security. Its role is to promote a consistent risk-based approach to information security across all Australian federal, state and territory agencies and bodies for the protection of information and systems.

Context

Applicability

This manual applies to:

- Australian government agencies that are subject to the *Financial Management and Accountability Act 1997*
- bodies that are subject to the *Commonwealth Authorities and Companies Act 1997* and that have received notice in accordance with that Act that the ISM applies to them as a general policy of the Government
- other bodies established for a public purpose under the law of the Commonwealth and other Australian government agencies, where the body or agency has received a notice from their Portfolio Minister that the ISM applies to them
- state and territory agencies that hold or access federal sensitive or classified information
- organisations that have entered a Deed of Agreement with the Government to have access to sensitive or classified information.

Authority

The *Intelligence Services Act 2001* (the ISA) states that two functions of DSD are:

- to provide material, advice and other assistance to Commonwealth and State authorities on matters relating to the security and integrity of information that is processed, stored or communicated by electronic or similar means
- to provide assistance to Commonwealth and State authorities in relation to cryptography, and communication and computer technologies.

This manual represents the considered advice of DSD provided in accordance with its designated functions under the ISA. Therefore agencies are not required as a matter of law to comply with this manual, unless legislation, or a direction given under legislation or by some other lawful authority, compels them to comply with it.

Compliance by smaller agencies

As smaller agencies may not always have sufficient personnel or budgets to comply with this manual, they may choose to consolidate their resources with another larger host agency to undertake a joint approach to compliance.

In such circumstances, smaller agencies may choose to either operate on systems fully hosted by another agency using their information security policies and security resources, or share security resources to jointly develop information security policies and systems for use by both agencies. In these cases, the requirements in this manual can be interpreted as either relating to the host agency or to both agencies, depending on the approach taken.

In situations where agencies choose a joint approach to compliance, especially when an agency agrees to fully host another agency, the agency heads may choose to seek a memorandum of understanding regarding their security responsibilities.

Legislation and legal considerations

This manual does not override any obligations imposed by legislation or law. Furthermore, if this manual conflicts with legislation or law the later takes precedence.

While this manual contains examples of when legislation or laws may be relevant for agencies, there is no comprehensive consideration of such issues. Accordingly, agencies should rely on their own inquiries in that regard.

Auditing of compliance by the Australian National Audit Office

All controls in this manual are capable of being audited for compliance by the ANAO.

Controls

Compliance

By using the latest baseline of this manual for system design activities, agencies will be taking steps to protect themselves from the current threats to Australian government systems.

DSD produces information security policies in addition to this manual, such as the ACSI suite. These policies may be updated to address specific security risks to government information and systems. In such cases, specific timeframes for compliance may be specified.

Control: 0007; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies undertaking system design activities for in-house or out-sourced projects must use the latest baseline of this manual for security requirements.

Control: 0008; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must comply with any specified compliance timeframes for information security policies that DSD determines are of particular importance.

References

Nil.



Information Security Governance

Information Security Engagement

Government Engagement

Objective

Security personnel are aware of and use security services offered in the Australian Government.

Scope

This section describes the agencies and bodies involved in providing information security advice.

Context

Defence Signals Directorate

The Defence Signals Directorate (DSD) is required under the *Intelligence Services Act 2001* (the ISA) to perform various functions, including the provision of material, advice and other assistance to Commonwealth and State authorities on matters relating to the security of information that is processed, stored or communicated by electronic or similar means.

DSD provides assistance to Commonwealth and State authorities in relation to cryptography, communications and computer technologies.

DSD works with industry to develop new cryptographic products. It has established the Australian Information Security Evaluation Program in order to deal with the increasing requirement to evaluate products with security functionality.

DSD can be contacted for advice and assistance in implementing this manual through any of an agency's Information Technology Security Managers (ITSMs) or its Information Technology Security Advisor (ITSA). ITSMs and ITSAs can send questions to DSD by email at assist@dsd.gov.au or phone on 1300 CYBER1 (1300 292 371).

DSD can be contacted for advice and assistance on cyber security incidents. DSD's response will be commensurate with the urgency of the cyber security incident. There is a 24-hour, seven day a week service available if necessary. The Cyber Security Operations Centre can be contacted by email at assist@dsd.gov.au or phone on 1300 CYBER1 (1300 292 371).

DSD can be contacted for advice and assistance on the purchasing, provision, deployment, operation and disposal of High Grade Cryptographic Equipment. The Crypto Liaison section can also be contacted by email at assist@dsd.gov.au.

Other government agencies and bodies

The table below contains a brief description of the other government agencies and bodies that have a role in information security in government.

AGENCY OR BODY	SERVICES
Attorney-General's Department	Responsible for information security policy and cyber security incident preparation, preparedness, response and recovery arrangements across government.
Attorney-General's Department – Protective Security Training Centre	Protective security training
Australasian Information Security Evaluation Program	Scheme implemented by Australia and New Zealand to evaluate products with security functionality
Australian Federal Police – Australian High Tech Crime Centre	Law enforcement in relation to electronic and other high tech crimes
Australian Government Information Management Office	Development, coordination and oversight of policy on electronic commerce, online services and the Internet
Australian National Audit Office	Performance audits on information security
Australian Security Intelligence Organisation – T4 Protective Security	Protective security advice and training, technical surveillance counter-measures, physical security certifications, protective security risk reviews and physical security equipment testing
Computer Emergency Response Team Australia	Provides the private sector with information and assistance to help them protect their Information and Communications Technology (ICT) infrastructure from cyber threats and vulnerabilities; coordination role during a serious cyber incident
Cyber Security Policy and Coordination Committee	Coordinates the development of cyber security policy for the Australian Government
Department of Foreign Affairs and Trade	Policy and advice for security overseas
Department of the Prime Minister and Cabinet	Coordination of cyber and information security policy and initiatives across government
National Archives of Australia	Provides standards and advice on capturing and managing records to ensure their integrity as evidence is maintained; authorises the disposal of all Commonwealth records, including those relating to ICT and security processes and incidents
Protective Security Policy Committee	Coordinates the development of protective security policy
Security Construction and Equipment Committee	Oversees the evaluation of security equipment

Controls

Organisations providing information security services

If security personnel are unaware of the roles government organisations play in the information security space, they could miss out on valuable insight and assistance in developing effective security measures.

Control: 0879; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Security personnel should familiarise themselves with the information security roles and services provided by Australian Government agencies and bodies.

References

The following websites can be used to obtain additional information about agencies and bodies involved in the security of government information and systems:

- <http://www.dsd.gov.au/>
- <http://www.ag.gov.au/pspf>
- <http://www.ag.gov.au/cybersecurity>
- <http://www.ag.gov.au/identitysecurity>
- http://www.ag.gov.au/www/agd/agd.nsf/Page/Security_training
- <http://www.dsd.gov.au/infosec/aisep.htm>
- <http://www.afp.gov.au/>
- <http://www.finance.gov.au/agimo/index.html>
- <http://www.anao.gov.au/>
- <http://www.asio.gov.au/>
- <http://www.cert.gov.au/>
- <http://www.dfat.gov.au/>
- <http://www.pmc.gov.au/>
- <http://www.naa.gov.au/records-management/index.aspx>
- <http://www.scec.gov.au/>

Industry Engagement and Outsourcing

Objective

Industry partners handle information appropriately and implement the same security measures as their sponsoring agency.

Scope

This section describes information on outsourcing information technology services and functions to industry as well as providing them with access to information in order to undertake their duties.

Context

Cloud computing

Cloud computing is a form of outsourcing information technology services and functions over the Internet. The requirements in this section equally apply to providers of cloud computing services.

Controls

Accrediting service providers' systems

Service providers can be provided with information as long as their systems are accredited to process, store and communicate the information. This ensures that when they are provided with information that it receives an appropriate level of protection.

Control: 0872; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Systems used by service providers for the provision of information technology services and functions must be accredited to the same minimum standard as the sponsoring agency's systems.

Service providers' systems

While this manual recommends against the outsourcing of information technology services and functions outside of Australia it does not preclude the use of services of foreign owned service providers in Australia. When such service providers are engaged agencies are strongly encouraged to ensure that all information provided to the service provider is hosted in Australia and does not leave Australian borders.

Control: 0873; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Service providers' systems should be located in Australia.

Control: 1073; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should not; Authority: AA

Service providers should not allow information to leave Australian borders unless approved by the sponsoring agency.

Service providers' Information Technology Security Manager

When an agency engages a service provider for the provision of information technology services and functions, having a central point of contact for information security issues will greatly assist incident response and reporting procedures.

Control: 0744; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Service providers should provide a single point of contact who will act as an equivalent to an ITSM.

Developing an industry security program

The development of an industry security program will assist the agency in undertaking a coordinated approach to the engagement and use of service providers for outsourcing and provision of information technology services and functions.

Control: 1052; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should develop an industry security program to manage service providers that have been approved for the provision of information technology services and functions.

References

Additional information regarding cloud computing security considerations can be found in the *Cloud Computing Security Considerations* document on the DSD website at <http://www.dsd.gov.au/infosec/cloudsecurity.htm>.

Roles and Responsibilities

The Chief Information Security Officer

Objective

The Chief Information Security Officer (CISO) sets the strategic direction for information security.

Scope

This section describes the information security role of a CISO.

Context

The Security Executive and their Chief Information Security Officer role

The requirement to appoint a member of the Senior Executive Service, or in an equivalent management position, to the role of CISO does not require a new dedicated position to be created in each agency. This role is intended to be performed by the Security Executive, which is a position in each agency mandated by the *Australian Government Protective Security Policy Framework*. The introduction of the CISO role is aimed at providing a more meaningful title for a subset of the Security Executive's responsibilities that relate to information security.

Controls

Requirement for a Chief Information Security Officer

The role of the CISO is based on industry best practice and has been introduced to ensure that information security is managed at the senior executive level. The CISO is typically responsible for:

- facilitating communications between security personnel, Information and Communications Technology (ICT) personnel and business personnel to ensure alignment of business and security objectives
- providing strategic-level guidance for the agency security program
- ensuring compliance with national policy, standards, regulations and legislation.

Control: 0714; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must appoint a senior executive, commonly referred to as the CISO, who is responsible for coordinating communication between security and business functions as well as overseeing the application of controls and security risk management processes.

References

Nil.

The Information Technology Security Advisor

Objective

The Information Technology Security Advisor (ITSA) coordinates information technology security.

Scope

This section describes the information security role of an Information Technology Security Manager (ITSM) when designated as the ITSA. Information on the responsibilities of ITSMs can be found in the *Information Technology Security Managers* section of this chapter.

Context

The Information Technology Security Advisor

The ITSM who has responsibility for information technology security management across the agency is designated as the ITSA. This title reflects the responsibility this ITSM has as the first point of contact for the CISO and external agencies on any information technology security management issues.

Controls

Requirement for an Information Technology Security Advisor

An ITSM, when fulfilling the designation of ITSA, still maintains full responsibilities for their role as an ITSM in addition to ITSA responsibilities. An ITSA traditionally has the added responsibility of coordinating other ITSMs to ensure that security measures and efforts are undertaken in a coordinated manner.

Control: 0013; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must designate an ITSM as the ITSA, to have responsibility for information technology security management across the agency.

Contacting Information Technology Security Advisors

As security personnel in agencies often need to communicate with security personnel from other agencies, often to provide warnings of threats to their systems, it is important that a consistent contact method is available across government to facilitate such communication.

Control: 0025; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should maintain an email address for their ITSA in the form of ITSA@agency

References

Nil.

Information Technology Security Managers

Objective

ITSMs provide information security leadership and management.

Scope

This section describes the information security role of ITSMs.

Context

Information Technology Security Managers

ITSMs are executives that coordinate the strategic directions provided by the CISO and the technical efforts of Information Technology Security Officers (ITSOs). The main area of responsibility of an ITSM is that of the day-to-day management of information security within an agency.

Controls

Requirement for Information Technology Security Managers

ITSMs are generally considered information security experts and are typically responsible for:

- managing the implementation of security measures
- monitoring information security for systems and responding to any cyber security incidents
- identifying and incorporating appropriate security measures in the development of ICT projects and the information security program
- establishing contracts and service-level agreements on behalf of the CISO
- assisting the CISO to develop security budget projections and resource allocations
- providing regular reports on cyber security incidents and other areas of particular concern to the CISO
- helping system owners to understand and respond to reported audit failures
- guiding the selection of appropriate strategies to achieve the direction set by the CISO with respect to disaster recovery policies and standards
- delivering information security awareness and training programs to personnel.

Control: 0741; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must appoint at least one executive, commonly referred to as an ITSM, to manage the day-to-day operations of information security within the agency, in line with the strategic directions provided by the CISO.

References

Nil.

Information Technology Security Officers

Objective

ITSOs provide information security operational support.

Scope

This section describes information security role of ITSOs.

Context

Information Technology Security Officers

ITSOs implement technical solutions under the guidance of an ITSM to ensure that the strategic direction for information security within the agency set by the CISO is achieved.

Appointing Information Technology Security Officers

The ITSO role may be combined with that of the ITSM. Small agencies may choose to assign both ITSM and ITSO responsibilities to one person under the title of the ITSA. Furthermore, agencies may choose to have this role performed by existing system administrators with an additional reporting chain to an ITSM for the security aspects of their role.

Controls

Requirement for Information Technology Security Officers

Appointing a person whose responsibility is to ensure the technical security of systems is essential to comply with the controls in this manual. The main responsibility of ITSOs is the implementation and monitoring of technical security measures for systems. Other responsibilities often include:

- conducting vulnerability assessments and taking actions to mitigate threats and remediate vulnerabilities
- working with ITSMs to respond to cyber security incidents
- assisting ITSMs with technical remediation activities required as a result of audits
- assisting in the selection of security measures to achieve the strategies selected by ITSMs with respect to disaster recovery
- raising awareness of information security issues with system owners and personnel.

Control: 0768; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must appoint at least one expert, commonly referred to as an ITSO, in administering and configuring a broad range of systems as well as analysing and reporting on information security issues.

References

Nil.

System Owners

Objective

System owners obtain and maintain accreditation of their systems.

Scope

This section describes the information security role of system owners.

Context

The system owner is the person responsible for an information resource.

Controls

Requirement for system owners

While the system owner is responsible for the operation of the system, they will delegate the day-to-day management and operation of the system to a system manager or managers.

While it is strongly recommended that a system owner is a member of the Senior Executive Service, or in an equivalent management position, it does not imply that the system managers should also be at such a level.

Control: 1071; **Revision:** 0; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Each system must have a system owner who is responsible for the operation of the system.

Control: 1072; **Revision:** 0; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

System owners should be a member of the Senior Executive Service or in an equivalent management position.

Accreditation responsibilities

The system owner is responsible for the secure operation of their system and needs to ensure it is accredited. If modifications are undertaken to a system the system owner will need to ensure that the changes are undertaken and documented in an appropriate manner, and that any necessary reaccreditation activities are completed.

Control: 0027; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

System owners must obtain and maintain accreditation for their systems.

References

Nil.

Information Security Documentation

Documentation Fundamentals

Objective

Information security documentation is produced for systems.

Scope

This section describes the information security documentation that each agency needs to develop.

Context

The suite of documents outlined in this chapter forms the Information Security Management Framework, as mandated in the *Australian Government Information Security Management Protocol*.

Documentation is vital to any information security regime as it supports the accurate and consistent application of policy and procedures within an agency. Documentation also provides increased accountability and a standard against which compliance can be measured.

More detailed information about each document can be found in the relevant sections of this chapter.

Controls

Information Security Policy

The Information Security Policy (ISP) is a statement of high-level information security policies and is therefore an essential part of information security documentation.

Control: 0039; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
Agencies must have an ISP.

Security Risk Management Plan

The Security Risk Management Plan (SRMP) is a best practice approach to identifying and reducing potential security risks. Depending on the documentation framework chosen, multiple systems could refer to, or build upon, a single SRMP.

Control: 0040; **Revision:** 0; **Updated:** Sep-08; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
Agencies must ensure that every system is covered by a SRMP.

System Security Plan

The System Security Plan (SSP) is derived from this manual and the SRMP and describes the implementation and operation of controls for a system. Depending on the documentation framework chosen, some details common to multiple systems could be consolidated in a higher level SSP.

Control: 0041; **Revision:** 0; **Updated:** Sep-08; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
Agencies must ensure that every system is covered by a SSP.

Standard Operating Procedures

Standard Operating Procedures (SOPs) provide a step-by-step guide to undertaking security related tasks. They provide assurance that tasks can be undertaken in a repeatable manner, even by system users without strong knowledge of the system. Depending on the documentation framework chosen, some procedures common to multiple systems could be consolidated into a higher level SOP.

Control: 0042; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should ensure that SOPs are developed for systems.

Incident Response Plan

Having an Incident Response Plan (IRP) ensures that when a cyber security incident occurs, a plan is in place to respond appropriately to the situation. In most situations, the aim of the response will be to preserve any evidence relating to the cyber security incident and to prevent the incident escalating.

Control: 0043; **Revision:** 0; **Updated:** Sep-08; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
Agencies must develop an IRP and supporting procedures.

Developing content

It is likely that the most useful and accurate information security documentation will be developed by personnel who are knowledgeable about both information security issues and the business requirements.

Control: 0886; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should ensure that information security documentation is developed by personnel with a good understanding of both the subject matter and the business requirements.

Documentation content

As the SRMP, SSP, SOPs and IRP form a documentation suite for a system, it is essential that they are logically connected and consistent. Furthermore, each documentation suite developed for a system will need to be consistent with the ISP.

Control: 0044; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should ensure that their SRMP, SSP, SOPs and IRP are logically connected and consistent for each system and with the ISP.

Using a documentation framework

Having a documentation framework for information security documents ensures that they are accounted for and maintained appropriately. Furthermore, the framework can be used to describe relationships between documents, especially when higher level documents are used to avoid repetition of information in lower level documents.

Control: 0787; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should create and maintain a document framework including a hierarchical listing of all information security documentation and their relationships.

Control: 0885; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should adopt the naming conventions provided in this manual for their information security documentation.

Outsourcing development of content

Agencies outsourcing the development of information security documentation still need to review and control the contents to make sure it meets their requirements.

Control: 0046; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

When information security documentation development is outsourced, agencies should:

- review the documents for suitability
- retain control over the content
- ensure that all policy requirements are met.

Obtaining formal approval

If information security policy does not have formal approval, security personnel will have difficulty ensuring appropriate systems security procedures are in place. Having formal approval not only assists in the implementation of procedures, it also ensures senior managers are aware of information security issues and security risks.

Control: 0047; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

All information security documentation should be formally approved by a person with an appropriate level of seniority and authority.

Control: 0887; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure that:

- all high-level information security documentation is approved by the agency head or their delegate
- all system-specific documentation is approved by the system owner and an Information Technology Security Manager (ITSM).

Publication of documentation

If stakeholders are not made aware of new information security documentation, or changes to existing information security documentation, they will not know about any changes they may need to make to the security measures for their systems.

Control: 1153; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Once information security documentation has been approved it should be published and communicated to all stakeholders.

Documentation maintenance

The threat environment and agencies' businesses are dynamic. If an agency fails to keep their information security documentation current to reflect the changing environment, their security measures and processes may cease to be effective. In that situation, resources could be devoted to areas that have reduced effectiveness, or are no longer relevant.

Control: 0888; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should review information security documentation:

- at least annually
- in response to significant changes in the environment, business or system.

Control: 1154; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should record the date of the most recent review on each information security document.

References

Nil.

Information Security Policies

Objective

ISPs set the strategic direction for information security.

Scope

This section describes the development of ISPs.

Context

ISPs are a component of an agency's Information Security Management Framework, as mandated in the *Australian Government Information Security Management Protocol*.

Information about other mandatory documentation can be found in the *Documentation Fundamentals* section of this chapter.

Controls

Contents of Information Security Policies

Agencies may wish to consider the following when developing their ISP:

- the policy objectives
- how the policy objectives will be achieved
- the guidelines and legal framework under which the policy will operate
- the stakeholders
- what resourcing will be available to support the implementation of the policy
- what performance measures will be established to ensure that the policy is being implemented effectively.

In developing the contents of the ISP, agencies may also consult any agency-specific directives that could be applicable to information security.

Agencies should avoid including controls for systems in their ISP. Instead, they should be documented in the SSP.

Control: 0049; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
The ISP should describe information security policies, standards and responsibilities.

Control: 0890; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
The ISP should cover topics such as:

- accreditation processes
- personnel responsibilities
- configuration control
- access control
- networking and connections with other systems
- physical security and media control
- emergency procedures and cyber security incident management
- change management
- information security awareness and training.

References

Nil.

Security Risk Management Plans

Objective

SRMPs identify security risks and appropriate mitigation measures for systems.

Scope

This section describes the development of SRMPs, focusing on security risks related to the operation of systems.

Context

SRMPs are a component of an agency's Information Security Management Framework, as mandated in the *Australian Government Information Security Management Protocol*.

Information about other mandatory documentation can be found in the *Documentation Fundamentals* section of this chapter.

Controls

System specific security risks

While a baseline of controls are provided in this manual, agencies will almost certainly have differing circumstances to those considered during the development of this manual. In such cases an agency needs to follow its own security risk management processes to determine its risk appetite and associated risk acceptance, risk avoidance and risk tolerance thresholds.

Control: 0009; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should determine system specific security risks that could warrant additional controls to those specified in this manual.

Contents of Security Risk Management Plans

Security risks cannot be managed if they are not known. Even if they are known, failing to deal with them is a failure of security risk management. For this reason SRMPs consist of two components, a security risk assessment and a corresponding risk treatment strategy.

Control: 0788; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

The SRMP should contain a security risk assessment and a corresponding risk treatment strategy.

Agency risk management

If an agency fails to incorporate SRMPs for systems into their wider agency risk management plan then the agency will be unable to manage risks in a coordinated and consistent manner across the agency.

Control: 0893; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should incorporate their SRMP into their wider agency risk management plan.

Risk management standards

For security risk management to be of true value to an agency it should relate to the specific circumstances of an agency and its systems, as well as being based on an industry recognised approach to risk management, such as those produced by Standards Australia and the International Organization for Standardization (ISO) / International Electrotechnical Commission (IEC).

Standards Australia produces AS/NZS ISO 31000:2009, *Risk Management – Principles and guidelines* while the ISO/IEC has developed the risk management standard ISO/IEC 27005:2008, *Information technology – Security techniques – Information security risk management*, as part of the ISO/IEC 27000 family of standards.

Control: 0894; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should develop their SRMP in accordance with Australian or international standards for risk management.

References

Information on the development of SRMPs can be found in HB 231:2004, *Information security risk management guidelines*. In particular, section 5 discusses documentation. It is available from Standards Australia at <http://www.standards.org.au/>.

System Security Plans

Objective

SSPs specify the security measures for systems.

Scope

This section describes the development of SSPs.

Context

SSPs are a component of an agency's Information Security Management Framework, as mandated in the *Australian Government Information Security Management Protocol*.

Information about other mandatory documentation can be found in the *Documentation Fundamentals* section of this chapter.

Further information to be included in SSPs about specific functionality or technologies that could be implemented for a system can be found in the applicable areas of this manual.

Stakeholders

There can be many stakeholders involved in defining a SSP, including representatives from the:

- project, who must deliver the capability (including contractors)
- owners of the information to be handled
- system users for whom the capability is being developed
- management audit authority
- information management planning areas
- infrastructure management.

Controls

Contents of System Security Plans

This manual provides a list of controls that are potentially applicable to a system based on its classification, its functionality and the technology it is implementing. Agencies need to determine which controls are in scope of the system and translate those controls to the SSP. These controls will then be assessed on their implementation and effectiveness during the accreditation process for the system.

In performing accreditations against the latest baseline of this manual, agencies are ensuring that they are taking the most recent threat environment into consideration. The Defence Signals Directorate continually monitors the threat environment and conducts research into the security impact of emerging trends. With each release of this manual, controls can be added, rescinded or modified depending on changes in the threat environment.

Control: 0895; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must select controls from this manual to be included in the SSP based on the scope of the system with additional system specific controls being included as a result of the associated SRMP or higher-level SSP.

Control: 0067; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should use the latest baseline of this manual when developing, and updating, their SSPs as part of accreditation and reaccreditation of their systems.

References

Nil.

Standard Operating Procedures

Objective

SOPs ensure security procedures are followed in an appropriate and repeatable manner.

Scope

This section describes the development of security related SOPs.

Context

SOPs are a component of an agency's Information Security Management Framework, as mandated in the *Australian Government Information Security Management Protocol*.

Information about other mandatory documentation can be found in the *Documentation Fundamentals* section of this chapter.

Controls

Development of Standard Operating Procedures

To ensure that personnel undertake their duties appropriately, with a minimum of confusion, it is important that the roles of ITSMs, Information Technology Security Officers (ITSOs), system administrators and system users are covered by SOPs. Furthermore, ensuring that SOPs are consistent with SSPs reduces the potential for confusion resulting from conflicts in policy and procedures.

Control: 0051; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should develop SOPs for each of the following roles:

- ITSM
- ITSO
- system administrator
- system user.

Information Technology Security Manager Standard Operating Procedures

The ITSM SOPs cover the management and leadership activities related to system operations.

Control: 0789; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

The following procedures should be documented in the ITSM's SOPs.

TOPIC	PROCEDURES TO BE INCLUDED
Cyber security incidents	Reporting and managing cyber security incidents

Information Technology Security Officer Standard Operating Procedures

The ITSO SOPs cover the operationally focused activities related to system operations.

Control: 0790; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

The following procedures should be documented in the ITSO's SOPs.

TOPIC	PROCEDURES TO BE INCLUDED
Access control	Authorising access rights to applications and data
Asset musters	Labelling, registering and mustering assets, including media
Audit logs	Reviewing system audit trails and manual logs, particularly for privileged users
Configuration control	Approving and releasing changes to the system software or configurations
Cyber security incidents	Detecting potential cyber security incidents
	Establishing the cause of any cyber security incident, whether accidental or deliberate
	Actions to be taken to recover and minimise the exposure from a cyber security incident
Data transfers	Managing the review of media containing information that is to be transferred off-site
	Managing the review of incoming media for viruses or unapproved software
Information and Communications Technology (ICT) equipment	Managing the destruction of unserviceable ICT equipment and media
System integrity audit	Reviewing system user accounts, system parameters and access controls to ensure that the system is secure
	Checking the integrity of system software
	Testing access controls
	Inspecting ICT equipment and cabling
System maintenance	Managing the ongoing security and functionality of system software, including: maintaining awareness of current software vulnerabilities, testing and applying software patches/updates/signatures, and applying appropriate hardening techniques
User account management	Authorising new system users

System administrator Standard Operating Procedures

The system administrator SOPs support the ITSO SOPs; however, they focus on the administrative activities related to system operations.

Control: 0055; **Revision:** 1; **Updated:** Sep-09; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

The following procedures should be documented in the system administrator's SOPs.

TOPIC	PROCEDURES TO BE INCLUDED
Access control	Implementing access rights to applications and data
Configuration control	Implementing changes to the system software or configurations
System backup and recovery	Backing up data, including audit logs
	Securing backup tapes
	Recovering from system failures
User account management	Adding and removing system users
	Setting system user privileges
	Cleaning up directories and files when a system user departs or changes roles

System user Standard Operating Procedures

The system user SOPs focus on day-to-day activities that system users need to know about, and comply with, when using systems.

Control: 0056; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

The following procedures should be documented in the system user's SOPs.

TOPIC	PROCEDURES TO BE INCLUDED
Cyber security incidents	What to do in the case of a suspected or actual cyber security incident
End of day	How to secure systems at the end of the day
Media control	Procedures for handling and using media
Passphrases	Choosing and protecting passphrases
Temporary absence	How to secure systems when temporarily absent

Agreement to abide by Standard Operating Procedures

When SOPs are produced the intended audience needs to be made aware of their existence and acknowledge that they have read, understood and agree to abide by their contents.

Control: 0057; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
ITSMs, ITSOs, system administrators and system users should sign a statement that they have read and agree to abide by their respective SOPs.

References

Nil.

Incident Response Plans

Objective

IRPs outline actions to take in response to a cyber security incident.

Scope

This section describes the development of IRPs to address cyber security incidents. It does not cover physical security incidents.

Context

IRPs are a component of an agency's Information Security Management Framework, as mandated in the *Australian Government Information Security Management Protocol*.

Information about other mandatory documentation can be found in the *Documentation Fundamentals* section of this chapter.

Controls

Contents of Incident Response Plans

The guidance provided on the content of IRPs ensures that agencies have a baseline to develop an IRP with sufficient flexibility, scope and level of detail to address the majority of cyber security incidents that could arise.

Control: 0058; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must include, as a minimum, the following content in their IRP:

- broad guidelines on what constitutes a cyber security incident
- the minimum level of cyber security incident response and investigation training for system users and system administrators
- the authority responsible for initiating investigations of a cyber security incident
- the steps necessary to ensure the integrity of evidence supporting a cyber security incident
- the steps necessary to ensure that critical systems remain operational
- how to formally report cyber security incidents.

Control: 0059; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should include the following content in their IRP:

- clear definitions of the types of cyber security incidents that are likely to be encountered
- the expected response to each cyber security incident type
- the authority responsible for responding to cyber security incidents
- the criteria by which the responsible authority would initiate or request formal, police or Australian Security Intelligence Organisation investigations of a cyber security incident
- other authorities which need to be informed in the event of an investigation being undertaken
- the details of the system contingency measures or a reference to these details if they are located in a separate document.

References

Nil.

Emergency Procedures

Objective

Information and systems are secured before personnel evacuate a facility in the event of an emergency.

Scope

This section describes the requirements for securing information and systems as part of the procedures for evacuating a facility in the event of an emergency.

Context

Emergency procedures are a component of an agency's Information Security Management Framework, as mandated in the *Australian Government Information Security Management Protocol*.

Information about other mandatory documentation can be found in the *Documentation Fundamentals* section of this chapter.

Controls

Evacuating facilities

During the evacuation of a facility it is important that personnel secure information and systems as they would at the end of operational hours. This includes, but is not limited to, securing media and logging off workstations. This is important as an attacker could use such an opportunity to gain access to applications or databases that a system user had already authenticated to, or use another system user's credentials, for a malicious purpose.

Control: 0062; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must include in evacuation procedures the requirement to secure information and systems before the evacuation; unless the chief warden, to avoid serious injury or loss of life, authorises personnel to evacuate immediately without securing information and systems.

Preparing for the evacuation of facilities

The warning phase before the evacuation of a facility alerts personnel that they may be required to evacuate the facility. This warning phase is the ideal time for personnel to begin securing information and systems to ensure that if they need to evacuate the facility they can do so immediately.

Control: 1159; **Revision:** 0; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should include in evacuation procedures the requirement to secure information and systems during the warning phase before the evacuation.

References

Nil.

System Accreditation

Accreditation Framework

Objective

Accreditation formalises the acceptance of security risks relating to the operation of a system.

Scope

This section describes the accreditation framework for systems and agencies' responsibilities.

Context

All systems must be accredited before they can be put into operation.

Accreditation is the process by which the accreditation authority formally recognises and accepts the residual security risk to a system and the information it processes, stores and communicates.

The accreditation framework comprises three layers:

- audit:
 - reviewing the information security documentation
 - assessing the appropriateness of the controls applied to the system
 - assessing the effectiveness of the implementation of the controls
- certification:
 - providing independent assurance and acceptance of the audit
 - determining the residual security risk relating to the operation of the system
- accreditation:
 - formally accepting the residual security risk
 - awarding approval to operate the system.

Detailed information about the processes and the requirements for conducting accreditations, certification and audits is given in the *Conducting Accreditations*, *Conducting Certifications* and *Conducting Audits* sections of this chapter.

Controls

Accreditation framework

Developing an accreditation framework ensures that accreditation activities are conducted in a repeatable and consistent manner across the agency.

Control: 0791; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must develop an accreditation framework.

Accreditation

Accreditation of a system ensures that either sufficient security measures have been put in place or that deficiencies in such measures have been accepted by an appropriate authority. When systems are awarded accreditation the accreditation authority accepts that the residual security risks are appropriate for the sensitivity or classification of the information that the system processes, stores or communicates.

Monitoring the accredited systems will assist in assessing changes to the environment and operation and to determine the implications for the security risk profile and accreditation status of the system.

Control: 0064; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure that all systems are awarded accreditation before they are used to process, store or communicate sensitive or classified information.

Control: 0065; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure that all systems are awarded accreditation before connecting them via a gateway.

Control: 0086; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure information security monitoring activities are conducted on accredited systems.

Determining authorities

For multi-national and multi-agency systems, determining the certification and accreditation authorities through a formal agreement between the parties ensures that the system owner has appropriate points of contact and does not receive conflicting advice from different authorities.

Control: 0793; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

For multi-national and multi-agency systems, the certification and accreditation authorities should be determined by a formal agreement between the parties involved.

Notifying authorities

In advising the certification and accreditation authorities of their intent to seek certification and accreditation for a system, the system owner can seek information on the latest processes and requirements for their system.

The list of accreditation and certification authorities is given in the *Conducting Accreditations* and *Conducting Certifications* sections of this chapter.

Control: 0082; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Before beginning the accreditation process, the system owner should advise the certification and accreditation authorities of their intent to seek certification and accreditation for their system.

Due diligence

When an agency is connecting to a system not under their control or passing information to another party, the agency needs to be aware of the security measures that have been implemented to protect the agency's information. More importantly, the agency needs to accept the security risks associated with non-compliance with controls in this manual by the other party before connecting or passing information to them. The security risks include the system potentially being used as a platform to attack the agency's system or spilling information onto a system not under their control and requiring subsequent cleanup of the spilled information.

Methods that an agency may use to ensure compliance with security requirements, and to assist in security risks being identified and accepted by the agency, include:

- conducting an accreditation of the non-agency system
- having an information security review performed by an infosec-registered assessor on the non-agency system
- reviewing a copy of an existing certification report for the non-agency system in order to make an accreditation decision on the non-agency system.

Control: 0071; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

If information is processed, stored or communicated by a system not under an agency's control, the agency must ensure that the non-agency system has appropriate security measures in place to protect the agency's information.

Control: 0900; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should review an accreditation report when determining whether the non-agency system has appropriate security measures in place to protect the agency's information.

Control: 0072; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure that security requirements are documented in either:

- contract provisions
- a memorandum of understanding.

Control: 0073; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure that a process is in place to provide assurance to its management that a non-agency system meets, and will continue to meet, the agency's security requirements.

Processing restrictions

When security is applied to systems, security measures are put in place based on the sensitivity or classification that will be processed, stored or communicated by the system. If information is placed on a system, and its sensitivity or classification is higher than the level of accreditation for the system, the information will be inadequately protected and will be exposed to a greater risk of compromise.

Control: 0076; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must not; Authority: AH

Agencies must not allow a system to process, store or communicate information above the sensitivity or classification for which the system has received accreditation.

Accrediting systems bearing a caveat or compartment

When processing caveated or compartmented information on a system, agencies need to ensure that the system has received accreditation for the caveated or compartmented information.

Control: 0077; Revision: 1; Updated: Sep-09; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

A system that processes, stores or communicates caveated or compartmented information must be accredited for such caveated or compartmented information.

Requirement for Australian control

As Australian Eyes Only (AUSTEO) and Australian Government Access Only (AGAO) systems process, store and communicate information that is particularly sensitive to the government of Australia, it is essential that control of such systems is maintained by Australian citizens working for the government of Australia.

Control: 0078; Revision: 2; Updated: Nov-10; Applicability: P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure that systems processing, storing or communicating AUSTEO or AGAO information remain at all times under the control of an Australian national working for the government.

Reaccreditation

Agencies should reaccredit their systems every two years. However, they can be given an additional year's grace if they follow the procedures defined in this manual for non-compliance with 'should' requirements: that is, providing a suitable justification, conducting a security risk assessment and obtaining formal approval from the accreditation authority.

Once three years has elapsed since the last accreditation, the agency needs to either reaccredit the system or seek approval for non-compliance from the agency head.

Other reasons an agency could seek reaccreditation include:

- changes in information security policies
- detection of new or emerging threats to systems
- the discovery that controls are not operating as effectively as planned
- a major cyber security incident
- changes to the system or the security risk profile.

Control: 0069; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should ensure that the period between accreditations of systems does not exceed two years.

Control: 0070; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must ensure that the period between accreditations of systems does not exceed three years.

References

Nil.

Conducting Accreditations

Objective

Systems are accredited before they are used operationally.

Scope

This section describes conducting an accreditation for a system.

Context

Accreditation aim

The aim of accreditation is to formally recognise and accept the residual security risk to a system and the information it processes, stores or communicates.

Accreditation authorities

For standard systems the accreditation authority is the agency head or their delegate, which is strongly recommended to be the Chief Information Security Officer (CISO).

For systems that process, store or communicate caveated or compartmented information there may be an accreditation authority external to the agency operating the system.

For multi-national and multi-agency systems the accreditation authority is determined by a formal agreement between the parties involved.

For gateway services of commercial providers the accreditation authority is the agency head or their delegate, which is strongly recommended to be the CISO.

For commercial providers supporting agencies the accreditation authority is the head of the supported agency or their authorised delegate, which is strongly recommended to be the CISO.

In all cases the accreditation authority will be at least a senior executive who has an appropriate level of understanding of the security risks they are accepting on behalf of the agency.

Depending on the circumstances and practices of an agency, the agency head can choose to delegate their authority to multiple senior executives who have the authority to accept security risks for the specific business functions; for example the CISO and the business owner.

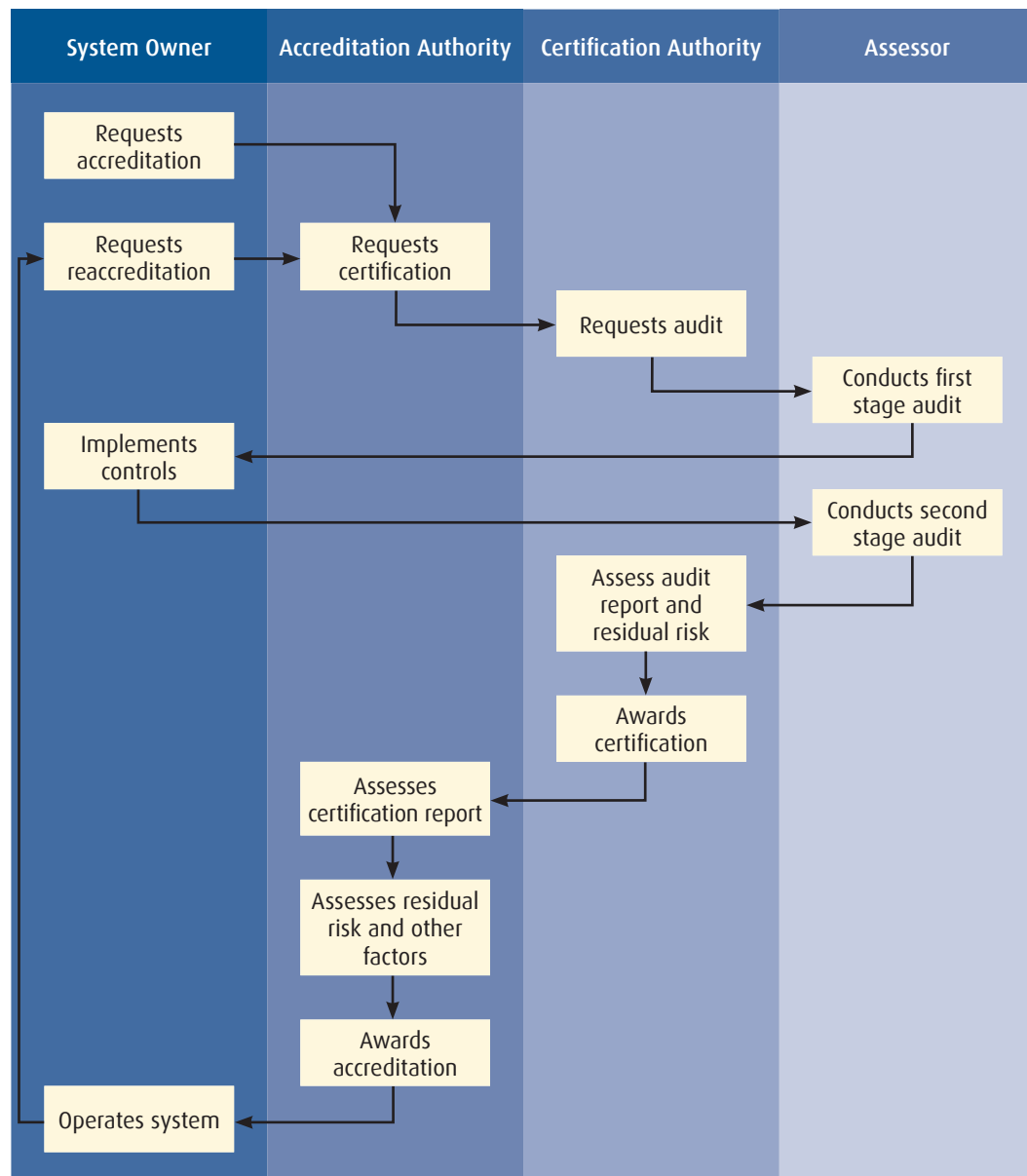
Accreditation outcomes

Accreditation is awarded when the accreditation authority accepts the residual security risk relating to the operation of the system and gives formal approval for the system to operate. However, in some cases the accreditation authority may not accept the residual security risk relating to the operation of the system. This is predominantly due to security risks being insufficiently considered and documented in the Security Risk Management Plan (SRMP), resulting in security measures being inaccurately scoped in the System Security Plan (SSP). In such cases the accreditation authority may request that the SRMP and SSP be amended and security measures reassessed before reconsidering the system for accreditation.

In awarding accreditation for a system, the accreditation authority may specify a shorter period before reaccreditation than that specified in this manual. The accreditation authority may also place restrictions on the use of the system which must be enforced until reaccreditation takes place or until required changes are made to the system.

Accreditation process

The following diagram shows, at a high level, the process of accreditation.



Controls

Certification

Certification (described in the *Conducting Certifications* section of this chapter) provides the accreditation authority with information on the security posture of a system. This allows the accreditation authority to make an informed decision on whether the residual security risk of allowing the system to operate is acceptable.

Control: 0795; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

All systems must be certified as part of the accreditation process; unless the accreditation authority is satisfied that if the system is not immediately operational it would have a devastating and potentially long lasting effect on operations.

Accreditation decision

The purpose of conducting an accreditation of a system is to determine the security posture of the system and the security risk that it poses to information. In giving approval for the system to operate, the accreditation authority is accepting the residual security risk to information that is processed, stored or communicated by the system.

To assist in making an accreditation decision, the accreditation authority may review:

- the SRMP for the system
- the report of compliance from the audit
- the certification report from the certification authority
- any decisions to be non-compliant with any controls specified in this manual
- any additional security risk reduction strategies that have been implemented.

To assist in making an informed accreditation decision, the accreditation authority may also seek advice from technical experts on the technical components of information presented to them during the accreditation process.

Control: 0808; **Revision:** 0; **Updated:** Sep-09; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

The accreditation authority must accept the residual security risk relating to the operation of a system in order to award accreditation.

References

Nil.

Conducting Certifications

Objective

The effectiveness of security measures for systems is accepted.

Scope

This section describes conducting a certification as part of the accreditation process for a system.

Context

Certification aim

The aim of certification is to ensure the audit for a system was conducted in an appropriate manner and to a sufficiently high standard.

Certification outcome

The outcome of certification is a certificate to the system owner acknowledging that the system has been appropriately audited and that the controls identified by the system owner have been implemented effectively.

Certification authorities

For TOP SECRET systems the certification authority is the Defence Signals Directorate (DSD).

For SECRET or below systems the certification authority is the Information Technology Security Advisor (ITSA).

For systems that process, store or communicate caveated or compartmented information there may be a mandated certification authority external to the agency operating the system.

For multi-national and multi-agency systems the certification authority is determined by a formal agreement between the parties involved.

For commercial providers of gateway services intended for use by multiple agencies across government, DSD performs the role of the certification authority as an independent third party.

For commercial providers supporting agencies the certification authority is the ITSA of the agency sponsoring the organisation.

Controls

Audit

The aim of an audit is to assess the actual implementation and effectiveness of controls for a system. The process of conducting an audit is described in the *Conducting Audits* section of this chapter.

Control: 1141; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

All systems must undergo an audit as part of the certification process.

Certification decision

To award certification for a system the certification authority needs to be satisfied that the controls identified by the system owner have been implemented and are operating effectively. However, certification only acknowledges that the identified controls were implemented and are operating effectively and not that the residual security risk is acceptable or an approval to operate has been awarded.

Control: 1142; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

The certification authority must accept the effectiveness of controls for the system in order to award certification.

Assessment of residual security risks

Before the certification authority can make a recommendation to the accreditation authority, an assessment of the residual security risk must be done. The purpose of the assessment is to assess the residual security risk relating to the operation of a system following the audit.

Even if, after the audit, the system is non-conformant, the certification authority may be able to recommend to the accreditation authority that accreditation be awarded. For example, since the audit, the system owner may have taken corrective actions to address areas of non-compliance, or the residual security risk may not be great enough to preclude accreditation.

Control: 0807; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Following the audit, the certification authority should produce a certification report for the accreditation authority containing an assessment of the residual security risks relating to the operation of the system and a recommendation on whether to award accreditation or not.

Certification of gateway services

Commercial providers of gateway services may be used by multiple agencies across government, agencies must ensure gateway services of commercial providers have undergone an audit conducted by an infosec-registered assessor and received certification from DSD. Even though DSD may certify a gateway service from a commercial provider, agencies using the service still need to decide whether accreditation should be awarded or not.

Control: 0100; Revision: 3; Updated: Sep-11; Applicability: G, P; Compliance: must; Authority: AH

Agencies must ensure that gateway services of commercial providers, intended for use by multiple agencies, have undergone an audit by an infosec-registered assessor and received certification from DSD.

References

Nil.

Conducting Audits

Objective

The effectiveness of security measures for systems is assessed.

Scope

This section describes conducting an audit as part of the certification process for a system.

Context

Audit aim

The aim of an audit is to review the system architecture (including the information security documentation) and assess the actual implementation and effectiveness of controls for a system.

Audit outcome

The outcome of an audit is a report to the certification authority describing areas of compliance and non-compliance for a system and any suggested remediation actions.

Who can conduct an audit

Audits for TOP SECRET systems can only be undertaken by DSD and infosec-registered assessors.

Audits for SECRET and below systems can be undertaken by Information Technology Security Managers (ITSMs) and infosec-registered assessors.

Who can assist with an audit

A number of agencies and personnel are often consulted during an audit.

Agencies or personnel who can be consulted on physical security aspects of information security include:

- the Australian Security Intelligence Organisation for TOP SECRET sites
- the Department of Foreign Affairs and Trade for systems located at overseas posts and missions
- the Agency Security Advisor (ASA) for all other systems.

The ASA can be consulted on personnel security aspects of information security.

An ITSM or communications security officer can be consulted on communications security aspects of information security.

Independent audits

An audit can be conducted by agency assessors; however, the agency may choose to add an extra level of objectivity by engaging the services of an infosec-registered assessor to undertake the audit.

Connections to certain inter-agency systems could require an independent audit from an infosec-registered assessor as a prerequisite to certification of the system. Such requirements can be obtained from the inter-agency system owners.

Controls

Independence of assessors

As there can be a perceived conflict of interest in the system owner assessing the security of their own system, the assessor should be independent of the system owner and certification authority. This does not preclude an appropriately qualified system owner from assessing the security of a system that they are not responsible for.

Control: 0902; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should ensure that assessors conducting audits are not also the system owner or certification authority.

Audit preparation

Ensuring that the system owner has approved the system architecture and associated information security documentation assists assessors in determining the scope of work for the first stage of the audit.

Control: 0797; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Before undertaking the audit, the system owner must approve the system architecture and associated information security documentation.

Audit (first stage)

The purpose of the first stage of the audit is to determine that the system architecture (including information security documentation) is based on sound security principles and has addressed all applicable controls from this manual. During this stage, the statement of applicability for the system will also be assessed along with any justification for non-compliance with applicable controls from this manual.

Control: 0798; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
The system architecture should be reviewed by the assessor to ensure that it is based on sound security principles and meets security requirements.

Control: 0799; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
The Information Security Policy should be reviewed by the assessor to ensure that policies have been developed or identified to protect information that is processed, stored or communicated by systems.

Control: 0800; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
The SRMP, SSP, Standard Operating Procedures and Incident Response Plan must be reviewed by the assessor to ensure that they are comprehensive and appropriate for the environment the system is to operate in.

Control: 0802; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
The SSP must be reviewed by the assessor to ensure that all relevant controls specified in this manual are addressed.

Control: 0904; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
The system owner should provide a statement of applicability for the system which includes the following topics:

- the baseline of this manual used for determining controls
- controls that are, and are not, applicable to the system
- controls that are applicable but are not being complied with
- any additional controls implemented as a result of the SRMP.

Implementing controls

Without implementing the controls for a system, their effectiveness cannot be assessed during the second stage of the audit.

Control: 0084; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Before undertaking the second stage of the audit the system owner must implement the controls for the system.

Audit (second stage)

The purpose of the second stage of the audit is to determine whether the controls, as approved by the system owner and reviewed during the first stage of the audit, have been implemented and are operating effectively.

Control: 0805; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

The implementation of controls must be assessed to determine whether they have been implemented and are operating effectively.

Control: 0806; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

The assessor must ensure that, where applicable, a physical security certification has been awarded by an appropriate physical security certification authority.

Control: 0905; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

The physical security certification should be less than 5 years old at the time of the audit.

Report of compliance

The report of compliance helps the certification authority assess the residual security risk relating to the operation of a system following the audit and any remediation activities the system owner may have undertaken.

Control: 1140; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

The assessor must produce a report of compliance for the certification authority outlining areas of non-compliance for a system and any suggested remediation actions.

References

Policy and Procedures for the InfoSec-Registered Assessor Program contains a definition of the range of activities infosec-registered assessors are authorised to perform. It can be obtained from DSD's website at <http://www.dsd.gov.au/infosec/irap.htm>.

Information Security Monitoring

Vulnerability Management

Objective

Vulnerability management activities contribute to the security of systems.

Scope

This section describes agencies' requirements for conducting vulnerability management activities for their systems.

Context

Information security monitoring practices can help ensure that new vulnerabilities are addressed and security is maintained through unforeseen events and changes, whether internal to the system or in the system's operating environment. Such practices allow agencies to be proactive in identifying, prioritising and responding to security risks. Measures to monitor and manage vulnerabilities in, and changes to, a system can provide an agency with a wealth of valuable information about its level of exposure to threats, as well as assisting agencies in keeping up to date with industry and product advances.

Controls

Vulnerability management strategy

Agencies should maintain vulnerability management activities such as regular vulnerability assessments, analysis and mitigation as threat environments change over time. Vulnerability assessments allow agencies to identify security weaknesses caused by misconfigurations, bugs or flaws.

Control: 1163; **Revision:** 0; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should implement a vulnerability management strategy by:

- conducting vulnerability assessments on systems throughout their lifecycle to identify vulnerabilities and risks
- analysing identified vulnerabilities to determine their potential impact and appropriate mitigations or treatments based on effectiveness, cost and existing security controls
- using a risk-based approach to prioritise the implementation of identified mitigations or treatments
- monitoring new information on vulnerabilities in operating systems, software and devices as well as other elements which may adversely impact on the security risks associated with a system.

Conducting vulnerability assessments

Conducting vulnerability assessments prior to systems being used, and after significant changes, can allow the agency to establish a baseline for further information security monitoring activities.

Conducting vulnerability assessments annually can help ensure that the latest threat environment is being addressed and that systems are configured in accordance with associated information security documentation.

It is recommended that vulnerability assessments are conducted by personnel independent of the target or by an independent third party. This ensures that there is no conflict of interest, perceived or otherwise, and that the assessment is undertaken in an objective manner.

An agency may choose to undertake a vulnerability assessment either:

- as a result of a specific cyber security incident
- after a change to a system or its environment that significantly impacts on the agreed and implemented system architecture and information security policy
- as part of a regular scheduled assessment.

Agencies will find it useful to gather appropriate information before they start a vulnerability assessment. This will help to ensure that the assessment is undertaken to a degree that is commensurate with the threat environment, and if applicable, the sensitivity or classification of information that is involved.

Depending on the scope and subject of the vulnerability assessment, agencies may gather information on areas such as:

- agency priorities and business requirements
- threat data
- likelihood and consequence estimates
- effectiveness of existing counter-measures
- other possible counter-measures
- best practices.
- Vulnerability assessments can consist of:
 - conducting threat and risk assessments and high level security reviews of planned systems
 - manual testing to provide a detailed, in-depth assessment
 - supplementing manual testing with automated tools to perform routine, repeatable security testing.

Control: 0911; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should conduct vulnerability assessments on systems:

- before the system is deployed, this includes conducting assessments during the system design and development stages
- after a significant change to the system
- after significant changes to the threats or risks faced by a system, for example, a software vendor announces a critical vulnerability in a product used by the agency
- at least annually, or as specified by an Information Technology Security Manager or the system owner.

Control: 0909; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should have vulnerability assessments conducted by personnel independent to the target of the assessment or by an independent third party.

Analysing and mitigating vulnerabilities

Agencies are encouraged to monitor information about new vulnerabilities that could affect their systems. However, they should not be complacent if no vulnerabilities are disclosed in specific products used in their systems.

Vulnerabilities can be introduced as a result of poor security practices or accidental activities. Therefore, even if no new vulnerabilities in deployed products have been disclosed there is still value to be gained from conducting regular vulnerability analyses.

Furthermore, by monitoring vulnerabilities, conducting vulnerability analyses, keeping up to date with industry and product advances, and keeping up to date with changes to this manual, agencies will become aware of factors which may adversely impact the security risk profile of their systems.

Agencies may wish to consider that discovered vulnerabilities could be a result of their security practices, accidental activities or malicious activities and not just as the result of a technical issue.

To determine the potential impact and possible mitigations to a system, comprehensive documentation and an understanding of the system are required. External sources that can be monitored for information on new vulnerabilities are vendor published vulnerability information, other open sources and subscription services.

Mitigation efforts are best prioritised using a risk-based approach in order to address the most significant vulnerabilities first. Where two or more vulnerabilities are of similar importance, the mitigations with lower cost (in time, staff and capital) can be implemented first.

Control: 0112; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must analyse any vulnerabilities to determine their potential impact on the agency and determine appropriate mitigations or other treatments.

Control: 0113; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Auth AH

Agencies must mitigate or otherwise treat identified vulnerabilities as soon as possible.

References

Nil.

Change Management

Objective

Information security is an integral part of the change management process.

Scope

This section describes the importance of maintaining the security of systems when implementing routine and urgent changes.

Context

Identifying the need for change

The need for change can be identified in various ways, including:

- identification of security vulnerabilities, new attacks and associated mitigations
- system users identifying problems or enhancements
- vendors notifying upgrades to software or Information and Communications Technology (ICT) equipment
- vendors notifying the end of life to software or ICT equipment
- advances in technology in general
- implementing new systems that necessitate changes to existing systems
- identifying new tasks requiring updates or new systems
- organisational change
- business process change
- standards evolution
- government policy or Cabinet directives
- other incidents or continuous improvement activities.

Types of system change

A proposed change to a system could involve either:

- an upgrade to, or introduction of, ICT equipment
- an upgrade to, or introduction of, software
- major changes to security controls.

Controls

Change management process

As part of any change process it is important that all stakeholders are consulted before the change is implemented. In the case of changes that will affect the security of a system, the accreditation authority will need to be consulted and approval sought.

The change management process ensures that changes to systems are made in an accountable manner with due consideration and with appropriate approval. Furthermore, the change management process provides an opportunity for the security impact of the change to be considered and, if necessary, reaccreditation processes initiated.

The most likely scenario for bypassing change management processes is when an urgent change needs to be made to a system. Before and after an urgent change is implemented, it is essential that the change management process strongly enforces appropriate actions to be taken.

Control: 0115; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure that for routine and urgent changes:

- the change management process, as defined in the relevant information security documentation, is followed
- the proposed change is approved by the relevant authority
- any proposed change that could impact the security of a system is submitted to the accreditation authority for approval
- all associated information security documentation is updated to reflect the change.

Control: 0117; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

The change management process must define appropriate actions to be followed before and after urgent changes are implemented.

Control: 0912; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure their change management process includes:

- documenting the changes to be implemented
- formal approval of the change request
- conducting vulnerability management activities when significant changes have been made to the system
- testing and implementing the approved changes
- updating the relevant information security documentation including the Security Risk Management Plan, System Security Plan and Standard Operating Procedures
- notifying and educating system users of the changes that have been implemented as close as possible to the time the change is applied
- continually educating system users in regard to changes.

Changes impacting the security of a system

The accreditation for a system is the acceptance of the residual security risk relating to the operation of the system. It is important therefore that, when a change occurs that impacts the overall security risk for the system, the accreditation authority is consulted on whether that residual security risk is still acceptable.

Control: 0809; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

When a configuration change impacts the security of a system, and is subsequently assessed as having changed the overall security risk for the system, the system must undergo reaccreditation.

References

Nil.

Business Continuity and Disaster Recovery

Objective

Business continuity minimises the disruption to the availability of information and systems after a disaster.

Scope

This section describes the role of business continuity and disaster recovery plans in ensuring continuing operation of agencies' critical systems.

Context

Business continuity and disaster recovery plans work to maintain security in the face of unexpected events and changes.

Additional information relating to business continuity can be found in the *Ensuring Service Continuity* section of the *Network Security* chapter.

Controls

Availability requirements

As availability requirements will vary based on business requirements they cannot be stipulated in this manual. Agencies will need to determine their own availability requirements and implement appropriate security measures to achieve them.

Control: 0118; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must determine availability requirements for their systems and implement appropriate security measures to support these requirements.

Backup strategy

Having a backup strategy in place is an important part of business continuity planning. The backup strategy ensures that critical business information is not accidentally lost.

Control: 0119; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should:

- back up all information identified as critical to their business
- store backups of critical information, with associated documented recovery procedures, at a remote location secured in accordance with the requirements for the sensitivity or classification of the information
- test backup and restoration processes regularly to confirm their effectiveness.

Business continuity plan

Developing a business continuity plan can help ensure that critical functions of systems continue to operate when the system is in a degraded state. For example, when limited bandwidth is available on networks agencies may choose to strip all large attachments from emails.

Control: 0913; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should develop a business continuity plan.

Disaster recovery plan

Developing a disaster recovery plan will reduce the time between a disaster occurring and critical functions of systems being restored.

Control: 0914; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should develop a disaster recovery plan.

References

Additional information relating to business continuity is contained in HB 221:2004, *Business Continuity Management*.

Cyber Security Incidents

Detecting Cyber Security Incidents

Objective

Tools and appropriate procedures are in place to detect cyber security incidents.

Scope

This section describes controls aimed at detecting cyber security incidents. It does not cover detecting physical and personnel security incidents.

Context

Additional information relating to detecting cyber security incidents can be found in the following chapters and sections:

- *Information Security Monitoring: Vulnerability Management*
- *Personnel Security for Systems: Information Security Awareness and Training*
- *Access Control: Event Logging and Auditing*
- *Network Security: Intrusion Detection and Prevention.*

Controls

Preventing and detecting cyber security incidents

The activities listed for assisting in detecting cyber security incidents will assist in mitigating the most common methods of attack used to exploit systems.

Many potential cyber security incidents are noticed by personnel rather than software tools. However, for this to happen, personnel must be well trained and aware of information security issues and know how to recognise possible cyber security incidents.

Automated tools are only as good as the quality of the analysis they provide. If tools are not adequately configured to assess potential security risks, it will not be evident when a weakness emerges. Additionally, if the tools are not regularly updated to include knowledge of new vulnerabilities their effectiveness will be reduced.

Agencies may consider some of the tools described below for detecting potential cyber security incidents.

TOOL	DESCRIPTION
Anomaly detection systems	Monitor network and host activities that do not conform to normal system activity.
Intrusion prevention systems	Some Intrusion Detection Systems (IDSs) are combined with functionality to repel detected attacks. Caution and assessment of the potential impact need to be exercised if this capability is to be used.
Log analysis	Involves collecting and analysing event logs using pattern recognition to detect anomalous activities.

TOOL	DESCRIPTION
Network and host IDSs	Monitor and analyse network and host activity, usually relying on a list of known attack signatures to recognise potential cyber security incidents.
System integrity verification	Used to detect changes to critical system components such as files, directories or services. These changes may alert a system administrator to unauthorised changes that could signify an attack on the system and inadvertent system changes that render the system open to attack.

Control: 0120; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must develop, implement and maintain tools and procedures covering the detection of potential cyber security incidents, incorporating:

- counter-measures against malicious code
- intrusion detection strategies
- audit analysis
- system integrity checking
- vulnerability assessments.

Control: 0121; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should use the results of the security risk assessment to determine the appropriate balance of resources allocated to prevention as opposed to detection of cyber security incidents.

References

Nil.

Reporting Cyber Security Incidents

Objective

Reported cyber security incidents assist in maintaining an accurate threat environment picture for government systems.

Scope

This section describes agencies' responsibilities for reporting cyber security incidents. It does not cover reporting physical or personnel security incidents.

Context

Cyber security incidents and outsourcing

The requirement to lodge a cyber security incident report applies even when an agency has outsourced some or all of its information technology functions and services.

Categories of cyber security incidents

The Cyber Security Incident Reporting (CSIR) scheme defines cyber security incidents that should be reported to the Defence Signals Directorate (DSD).

Controls

Reporting cyber security incidents

Reporting cyber security incidents to an Information Technology Security Manager (ITSM) as soon as possible after it occurs provides management with a means to assess the overall damage to a system and to take remedial action, including seeking advice from DSD if necessary.

Control: 0123; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must direct personnel to report cyber security incidents to an ITSM as soon as possible after the cyber security incident is discovered.

Control: 0124; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should:

- encourage personnel to note and report any observed or suspected security weaknesses in, or threats to, systems or services
- establish and follow procedures for reporting software malfunctions
- put mechanisms in place to enable the types, volumes and costs of cyber security incidents and malfunctions to be quantified and monitored
- deal with the violation of information security policies and procedures by personnel through a formal disciplinary process.

Reporting cyber security incidents to the Defence Signals Directorate

DSD uses cyber security incident reports as the basis for identifying and responding to cyber security events across government. Cyber security incidents are also used for developing new policies, procedures, techniques and training measures to prevent the recurrence of similar cyber security incidents across government. Agencies are recommended to coordinate their reporting of cyber security incidents to DSD e.g. through their Information Technology Security Advisor (ITSA).

Where agencies have outsourced information technology services and functions, they may request that the service provider report cyber security incidents directly to DSD. This could be specified in either a Memorandum of Understanding or as part of the contract of services. In such cases it is recommended that the agency's ITSA be made aware of all reporting of cyber security incidents to DSD by the service provider.

Control: 0139; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must report cyber security incidents to DSD.

How to report cyber security incidents to the Defence Signals Directorate

Reporting cyber security incidents to DSD through the appropriate channels ensures that appropriate and timely assistance can be provided. In addition, it allows DSD to maintain an accurate threat environment picture for government systems.

Control: 0140; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should formally report cyber security incidents using the CSIR scheme.

Outsourcing and cyber security incidents

When an agency outsources information technology services and functions, they are still responsible for the reporting of cyber security incidents. The agency must ensure that the service provider informs them of all cyber security incidents to allow them to formally report these to DSD.

Control: 0141; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies that outsource their information technology services and functions must ensure that the service provider consults with the agency when a cyber security incident occurs.

Cryptographic keying material

Reporting any cyber security incident involving the loss or misuse of cryptographic keying material is particularly important. Systems users rely on the use of cryptographic keying material for the confidentiality and integrity of their secure communications.

Control: 0142; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must notify all communications security custodians of any suspected loss or compromise of keying material.

High grade cryptographic keying material

Australian Communications Security Instruction (ACSI) 107 applies to all agencies including contractors. Its requirements cover all High Grade Cryptographic Equipment (HGCE) used to process classified information.

For cyber security incidents involving the suspected loss or compromise of HGCE keying material, DSD will investigate the possibility of compromise and, where possible, initiate action to reduce the impact of the compromise.

Control: 0143; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: DSD
Agencies must notify DSD of any suspected loss or compromise of keying material associated with HGCE in accordance with ACSI 107.

References

Further information on reporting cyber security incidents is located on the DSD website at <http://www.dsd.gov.au/infosec/reportincident.htm>.

Further information on the categories of cyber security incidents can be found in http://www.dsd.gov.au/publications/Cyber_Security_Incident_Report.pdf.

Managing Cyber Security Incidents

Objective

Appropriate remedies assist in preventing future cyber security incidents.

Scope

This section describes agencies' responsibilities for managing cyber security incidents. It does not cover managing physical or personnel security incidents.

Context

The management of physical and personnel security incidents is not covered in this section unless it directly impacts on the protection of systems (for example, breaching physical protection for a server room).

Controls

Cyber security incident management documentation

Documenting responsibilities and procedures for cyber security incidents in relevant System Security Plans (SSPs), Standard Operating Procedures (SOPs) and the Incident Response Plan (IRP) ensures that when a cyber security incident does occur, personnel can respond in an appropriate manner. In addition, ensuring that system users are aware of reporting procedures assists in capturing any cyber security incidents that an ITSM, Information Technology Security Officer or system owner fail to notice.

Control: 0122; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must detail cyber security incident responsibilities and procedures for each system in the relevant SSP, SOPs and IRP.

Recording cyber security incidents

The purpose of recording cyber security incidents in a register is to highlight the nature and frequency of the cyber security incidents so that corrective action can be taken. This information can subsequently be used as an input into future security risk assessments of systems.

Control: 0125; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure that all cyber security incidents are recorded in a register.

Control: 0126; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should include, at a minimum, the following information in their register:

- the date the cyber security incident was discovered
- the date the cyber security incident occurred
- a description of the cyber security incident, including the personnel and locations involved
- the action taken
- to whom the cyber security incident was reported
- the file reference.

Control: 0916; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should use their register as a reference for future security risk assessments.

Handling data spills

Assuming that information is compromised as a result of a cyber security incident allows an agency to apply procedures in response to a worst case scenario.

Control: 0129; Revision: 1; Updated: Sep-09; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
When a data spill occurs agencies must assume that the information has been compromised.

Control: 0130; Revision: 1; Updated: Sep-09; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must include in standard procedures for all personnel with access to systems a requirement that they notify an ITSM of any data spillage and access to any data which they are not authorised to access.

Control: 0131; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must document procedures for dealing with data spills in their IRP.

Control: 0132; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must treat any data spill as a cyber security incident and follow the IRP to deal with it.

Control: 0133; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
When a data spill occurs, agencies must report the details of the data spill to the information owner.

Containing data spills

The spillage of information onto a system not accredited to handle it is considered a cyber security incident under the DSD CSIR scheme.

An affected system can be segregated by powering off the system, removing network connectivity to the device or applying access controls on information associated with the data spill to prevent access. However it should be noted that powering off the system could destroy information that would be useful for forensics activities at a later date.

Control: 0134; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must not; Authority: AH
When information is introduced onto a system not accredited to handle the information, personnel must not delete the information until advice is sought from an ITSM.

Control: 0135; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should not; Authority: AA
When information is introduced onto a system not accredited to handle the information, personnel should not copy, view, print or email the information.

Control: 0136; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
When information is introduced onto a system not accredited to handle the information, agencies should segregate the affected system from the network.

Handling malicious code infection

The guidance for handling malicious code infections is provided to help prevent the spread of the infection and to prevent reinfecting the system. An important consideration is the infection date of the machine. However, when determining the infection date, it is important to bear in mind that the record could be inaccurate as a result of the infection.

A complete operating system reinstallation, or an extensive comparison of characterisation information, is the only reliable way to ensure that malicious code is eradicated.

Control: 0917; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should follow the steps described below when malicious code is detected:

- isolate the infected system
- decide whether to request assistance from DSD, and if such assistance is requested and agreed to, delay any further action until advised by DSD to continue
- scan all previously connected systems, and any media used in a set period leading up to the cyber security incident, for malicious code
- isolate all infected systems and media to prevent reinfecting the system
- change all passwords and key material stored or potentially accessed from compromised systems
- advise system users of any relevant aspects of the compromise, including changing all passphrases on the compromised systems and any other system that uses the same passphrase
- use current antivirus or other Internet security software to remove the infection from the systems or media
- report the cyber security incident and perform any other activities specified in the IRP.

Allowing continued attacks

Agencies allowing an attacker to continue an attack against a system in order to seek further information or evidence will need to establish with their legal advisors whether the actions are breaching the *Telecommunications (Interception and Access) Act 1979* (the TIA Act).

Control: 0137; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies considering allowing an attacker to continue some actions under controlled conditions for the purpose of seeking further information or evidence should seek legal advice.

Integrity of evidence

While gathering evidence it is important to maintain the integrity of the information, this includes maintaining metadata about the information, who used it, and how it was used. Even though in most cases an investigation does not directly lead to a police prosecution, it is important that the integrity of evidence such as manual logs, automatic audit trails and intrusion detection tool outputs be protected.

When storing raw audit trails onto meet it is important that it is done in accordance with relevant retention requirements as documented in the National Archives of Australia's *Administrative Functions Disposal Authority*.

Control: 0138; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should:

- transfer a copy of raw audit trails onto media for secure archiving, as well as securing manual log records for retention
- ensure that all personnel involved in the investigation maintain a record of actions undertaken to support the investigation.

Seeking assistance

If the integrity of evidence of a cyber security incident is compromised, it reduces DSD's ability to assist agencies. DSD therefore requests that no actions which could affect the integrity of the evidence be carried out before DSD's involvement.

Control: 0915; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure that any requests for DSD assistance are made as soon as possible after the cyber security incident is detected and that no actions, which could affect the integrity of the evidence, are carried out before DSD's involvement.

References

Further information relating to the management of Information and Communications Technology evidence is contained in HB 171:2003, *Guidelines for the management of information technology evidence*.



PHYSICAL SECURITY



Physical Security

Physical Security for Systems

Facilities and Network Infrastructure

Objective

Physical security measures are applied to facilities and network infrastructure to protect systems.

Scope

This section describes the requirements for the physical security of facilities and network infrastructure.

Context

Information on servers, network devices, Information and Communications Technology (ICT) equipment and media can be found in other sections of this chapter. Information on encryption requirements can be found in the *Cryptographic Fundamentals* section of the *Cryptography* chapter.

Facilities

In the context of this manual a facility is an area that facilitates government business. For example, a facility can be a building, a floor of a building or a designated space on the floor of a building.

Physical security certification authorities

The certification of physical security measures is undertaken by:

- the Agency Security Advisor (ASA) for Zone Two to Zone Four security areas
- the Australian Security Intelligence Organisation (ASIO) for Zone Five security areas.

For facilities that process or store caveated or compartmented information there may be a certification authority external to the agency operating the facility.

For multi-national and multi-agency facilities the certification authority is determined by a formal agreement between the parties involved.

For commercial providers of gateway services intended for use by multiple agencies across government, ASIO performs the role of the certification authority as an independent third party.

For commercial providers supporting agencies the certification authority is the ASA of the agency sponsoring the organisation.

Physical security accreditation authorities

The accreditation of physical security measures for Zone Two to Zone Five security areas is undertaken by the ASA.

For facilities that process or store caveated or compartmented information there may be an accreditation authority external to the agency operating the facility.

For multi-national and multi-agency facilities the accreditation authority is determined by a formal agreement between the parties involved.

For gateway services of commercial providers the accreditation authority is the ASA.

For commercial providers supporting agencies the accreditation authority is the ASA.

Facilities located outside of Australia

Agencies operating sites in posts or missions located outside of Australia should contact the Department of Foreign Affairs and Trade to determine requirements.

Controls

Facility and network infrastructure physical security

The application of defence-in-depth to the protection of systems is enhanced through the use of successive layers of physical security. The first layer of security is the use of Security Zones for the facility, the second layer is the use of a higher Security Zone or security room for the server room and the final layer is the use of security containers or lockable commercial cabinets. All layers are designed to limit access to those with the appropriate authorisation to access the system and infrastructure.

Deployable platforms need to meet physical security certification requirements as per any other system. Physical security certification authorities dealing with deployable platforms can have specific requirements that supersede the requirements of this manual and as such security personnel should contact their appropriate physical security certification authority to seek guidance.

In the case of deployable platforms, physical security requirements may also include perimeter controls, building standards and manning levels.

Control: 0810; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must ensure that any facility containing a system, including deployable systems, is certified and accredited against the requirements in the *Australian Government Physical Security Management Protocol*.

Network infrastructure in unsecured spaces

Agencies do not have control over sensitive or classified information when it is communicated over public network infrastructure or over infrastructure in unsecured spaces (Zone One security areas). They must ensure information is encrypted to a sufficient level that if it was captured it would not be cost-effective to retrieve the original information.

Control: 0157; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies communicating sensitive or classified information over public network infrastructure or over infrastructure in unsecured spaces (Zone One security areas) must use encryption approved for communicating such information over public network infrastructure.

Preventing observation by unauthorised people

Facilities without sufficient perimeter security are often exposed to the potential for observation through windows. Ensuring information on workstation screens is not visible will assist in reducing this security risk. This can be achieved by using blinds or drapes on the inside of the windows.

Control: 0164; **Revision:** 1; **Updated:** Sep-09; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should prevent unauthorised people from observing systems, in particular, displays and keyboards.

References

Further information relating to physical security is contained in the *Australian Government Physical Security Management Protocol*.

Servers and Network Devices

Objective

Server and communication rooms protect servers and network devices.

Scope

This section describes the requirements for the physical security of servers and network devices.

Context

Information relating to the physical security of facilities, network infrastructure and ICT equipment and media can be found in other sections of this chapter.

Server and communications rooms

Agencies must certify and accredit the physical security of a facility and server or communications room against the requirements in the *Australian Government Physical Security Management Protocol*. In such cases, because of the additional layer of security described in this manual, the requirements for physical storage of server and communications equipment in the *Australian Government Physical Security Management Protocol* can be lowered according to the *Physical security of ICT equipment systems and facilities* guideline.

Controls

Securing server rooms, communications rooms and security containers

If personnel leave server rooms, communications rooms and security containers or rooms unlocked, with keys in the locks or with security functions disabled, it negates the purpose of providing security. Such activities will compromise the security efforts and must not be permitted.

Control: 1053; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure that servers and network devices are secured in either security containers or rooms as specified in the *Australian Government Physical Security Management Protocol*.

Control: 0813; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must not; Authority: AH

Agencies must not leave server rooms, communications rooms and security containers or rooms in an unsecured state.

Control: 1074; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure that keys or equivalent access mechanisms to server rooms, communications rooms and security containers or rooms are appropriately controlled.

No-lone zones

Areas containing particularly sensitive materials or ICT equipment can be provided with additional security through the use of a designated no-lone zone. The aim of this designation is to enforce two-person integrity, where all actions are witnessed by at least one other person.

Control: 0150; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies operating no-lone zones must suitably signpost the area and have all entry and exit points appropriately secured.

References

Further information relating to physical security is contained in the *Australian Government Physical Security Management Protocol*.

ICT Equipment and Media

Objective

ICT equipment and media is physically secured during operational and non-operational hours.

Scope

This section describes the physical security of ICT equipment and media. This includes but is not limited to workstations, printers, photocopiers, scanners, Multifunction Devices, optical media, flash drives, portable hard drives and memory cards.

Context

Additional information relating to ICT equipment and media can be found in the *Fax Machines and Multifunction Devices* section of the *Communications Systems and Devices* chapter as well as in the *Product Security* and *Media Security* chapters. Sanitisation information can be found in the *Media Sanitisation* section of the *Media Security* chapter while information on the encryption of media can be found in the *Cryptographic Security* chapter.

Controls

Accounting for Information and Communications Technology equipment and media

Ensuring that ICT equipment and media is accounted for by using a register and regular audits will assist in preventing theft and alerting appropriate authorities if theft occurs. Individual media not contained in ICT equipment needs to be individually tracked while media in ICT equipment can be tracked at the equipment level.

Control: 0159; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must account for all sensitive and classified ICT equipment and media.

Control: 0336; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must register all ICT equipment and media with a unique identifier in an appropriate register.

Securing Information and Communications Technology equipment and media

During operational and non-operational hours, ICT equipment and media needs to be stored in accordance with the *Australian Government Physical Security Management Protocol*.

The physical security requirements of the *Australian Government Physical Security Management Protocol* can be achieved by:

- ensuring ICT equipment and media always resides in an appropriate Security Zone
- storing ICT equipment and media during non-operational hours in an appropriate security container or room
- using ICT equipment with a removable hard drive which is stored during non-operational hours in an appropriate security container or room as well as sanitising the ICT equipment's Random Access Memory (RAM)
- using ICT equipment without a hard drive as well as sanitising the ICT equipment's RAM
- using an encryption product to reduce the physical storage requirements of the hard drive in ICT equipment to an unclassified level as well as sanitising the ICT equipment's RAM.

Control: 0161; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure that ICT equipment and media with sensitive or classified information is secured in accordance with the requirements for storing sensitive or classified information in the *Australian Government Physical Security Management Protocol*.

Reducing the physical storage requirements for Information and Communications Technology equipment

In some circumstances it may not be feasible to secure ICT equipment during non-operational hours by storing it in a security container or room, using a removable hard drive, using ICT equipment without a hard drive or using approved encryption. In such cases the *Australian Government Physical Security Management Protocol* allows for the reduction of physical storage requirements for ICT equipment if appropriate logical controls are applied. This can be achieved by configuring systems to prevent the storage of sensitive or classified information on the hard drive (e.g. storing profiles and work documents on network shares) and enforcing scrubbing of the operating system swap file and other temporary data at logoff or shutdown in addition to the standard practice of sanitising the ICT equipment's RAM.

The security measures described in the previous paragraph do not constitute sanitisation of the hard drive in the ICT equipment. Therefore, the hard drive retains its classification for the purposes of reuse, reclassification, declassification, sanitisation, destruction and disposal as specified in this manual.

As hybrid hard drives and solid state drives cannot be sanitised in the same manner as standard magnetic hard drives, refer to the *Media Sanitisation* section of the *Media Security* chapter, the logical controls described above are not approved as a method of lowering the physical storage requirements of the ICT equipment.

There is no guarantee that techniques such as preventing the storage of sensitive or classified information on hard drives and scrubbing the operating system swap file and other temporary data at logoff or shutdown will always work effectively or will not be bypassed due to unexpected circumstances such as an unexpected loss of power to the workstation. As such these security risks need to be considered when implementing such a solution and documented in the System Security Plan (SSP).

Control: 0162; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies preventing the storage of sensitive or classified information on hard drives and enforcing scrubbing of the operating systems swap files and other temporary data at logoff or shutdown should:

- assess the security risks associated with such a practice
- in the SSP specify the processes and conditions for their application.

References

For further information on physical security and media security see the *Australian Government Physical Security Management Protocol* and *Australian Government Information Security Management Protocol*.



PERSONNEL SECURITY



Personnel Security

Personnel Security for Systems

Information Security Awareness and Training

Objective

A security culture is fostered through continual information security awareness and training tailored to roles and responsibilities.

Scope

This section describes information security awareness and training that should be provided to personnel.

Context

The following sections of this chapter contain information on areas that specifically need to be covered by the training provided.

Additional information that should be included in information security awareness and training is provided in the *Web Content and Connections* and *Email Applications* sections of the *Software Security* chapter and the *Internet Protocol Telephony* section of the *Network Security* chapter.

Controls

Information security awareness and training

Information security awareness and training programs are designed to help personnel to:

- become familiar with their roles and responsibilities
- understand and support security requirements
- learn how to fulfil their security responsibilities.

Control: 0252; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must provide ongoing information security awareness and training for personnel on information security policies including topics such as responsibilities, consequences of non-compliance, and potential security risks and counter-measures.

Information security awareness and training responsibility

Agencies are responsible for ensuring that an appropriate information security awareness and training program is provided to personnel. Without management support, security personnel might not have sufficient resources to facilitate awareness and training for other personnel.

Personnel will naturally lose awareness or forget training over time. Providing ongoing information security awareness and training helps keep personnel aware of issues and their responsibilities.

Methods that can be used to continually promote awareness include logon banners, system access forms and departmental bulletins or memoranda.

Control: 0251; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must ensure that all personnel who have access to a system have sufficient information security awareness and training.

Degree and content of information security awareness and training

The exact degree and content of information security awareness and training depends on the objectives of the agency. Personnel with responsibilities beyond that of a general user should have tailored training to meet their needs.

Guidance provided to personnel should include sufficient emphasis on activities that are not allowed on systems. The minimum list of content given below ensures that personnel are sufficiently exposed to issues that, if they are ignorant of them, could cause a cyber security incident.

Control: 0253; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should align the exact degree and content of information security awareness and training to a person's roles and responsibilities.

Control: 0922; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure that information security awareness and training includes:

- the purpose of the training or awareness program
- security appointments and contacts
- the legitimate use of system accounts, software and information
- the security of accounts, including shared passphrases
- security risks associated with unnecessarily exposing email addresses and other personal details
- authorisation requirements for applications, databases and data
- the security risks associated with non-agency systems, particularly the Internet
- reporting any suspected compromises or anomalies
- reporting requirements for cyber security incidents, suspected compromises or anomalies
- classifying, marking, controlling, storing and sanitising media
- protecting workstations from unauthorised access
- informing the support section when access to a system is no longer needed
- observing rules and regulations governing the secure operation and authorised use of systems.

Control: 0255; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure that information security awareness and training includes advice to personnel not to attempt to:

- physically damage systems
- bypass, strain or test security measures
- introduce or use unauthorised Information and Communications Technology (ICT) equipment or software on a system
- assume the roles and privileges of others
- attempt to gain access to information for which they have no authorisation
- relocate ICT equipment without proper authorisation.

System familiarisation training

A TOP SECRET system needs increased awareness by personnel. Ensuring familiarisation with information security policies and procedures, the secure operation of the system and basic information security training, provides them with specific knowledge relating to these types of systems.

Control: 0256; Revision: 1; Updated: Sep-09; Applicability: TS; Compliance: must; Authority: AH

Agencies must provide all system users with familiarisation training on the information security policies and procedures and the secure operation of the system before being granted unsupervised access to the system.

Disclosure of information while on courses

Government personnel attending courses with non-government personnel may not be aware of the consequences of disclosing information relating to the security of their systems. Raising awareness of such consequences should prevent any disclosure that could lead to a targeted attack being launched against their systems.

Control: 0257; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should advise personnel attending courses along with non-government personnel not to disclose any details that could be used to compromise security.

References

Nil.

Authorisations, Security Clearances and Briefings

Objective

Only appropriately authorised, cleared and briefed personnel are allowed access to systems.

Scope

This section describes the authorisations, security clearances and briefings required by personnel to access systems. Information on the technical implementation of access controls for systems can be found in the *System Access* section of the *Access Control* chapter.

Context

Security clearances – Australian and foreign

Where this manual refers to security clearances, the reference applies to Australian security clearances or security clearances from a foreign government which are recognised by Australia under a security of information arrangement.

Controls

Documenting authorisations, security clearance and briefing requirements

Ensuring that the requirements for access to a system are documented and agreed upon helps determine if personnel have appropriate authorisations, security clearances and need-to-know to access the system.

Types of system accounts for which access requirements need to be documented include general users, privileged users, contractors and visitors.

Control: 0432; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must specify in the System Security Plan any authorisations, security clearances and briefings necessary for system access.

Authorisation and system access

Personnel seeking access to a system need to have a genuine business requirement to access the system as verified by their manager. Once a requirement to access a system is established, personnel should only be given the privileges that they need to undertake their duties. Providing all personnel with privileged access when there is no requirement for privileged access can be a significant threat to a system.

Control: 0405; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must:

- limit system access on a need-to-know basis
- have any requests for access to a system authorised by the person's manager
- provide personnel with the least amount of privileges needed to undertake their duties
- review system access and privileges at least annually and when personnel change roles
- when reviewing access, ensure a response from the person's manager confirming the need to access the system is still valid, otherwise access will be removed.

Recording authorisation for personnel to access systems

A record of a completed system account request form signed by the person's manager should be retained. This is required to ensure there is a record of all personnel authorised to access a system, their user identification, who provided the authorisation, when the authorisation was granted and when the access was reviewed.

Control: 0407; **Revision:** 1; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should:

- maintain a secure record of:
- all personnel authorised to a system
- their user identification
- who provided the authorisation to access the system
- when the authorisation was granted
- when the access was reviewed
- maintain the record for the life of the system to which access is granted.

Security clearance for system access

A security clearance provides assurance that personnel can be trusted with access to sensitive or classified information that is processed, stored or communicated by a system.

Control: 0434; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
Agencies must ensure that personnel hold an appropriate security clearance according to the requirements in the *Australian Government Personnel Security Management Protocol* before being granted access to a system.

System access briefings

Some systems may contain caveated or compartmented information. There may be unique briefings that personnel need before being granted access to such systems.

Control: 0435; **Revision:** 1; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
All personnel must have received any necessary briefings before being granted access to a system.

Access by foreign nationals to particularly sensitive systems

Australian Eyes Only (AUSTEO) information is restricted to Australian nationals.

Australian Government Access Only (AGAO) information is restricted to Australian nationals, with the exception of seconded foreign nationals, who may access such information to undertake their assigned duties.

Control: 0409; **Revision:** 2; **Updated:** Nov-10; **Applicability:** P, C, S, TS; **Compliance:** must not; **Authority:** AH
Agencies must not allow foreign nationals, including seconded foreign nationals, to have access to systems that process, store or communicate AUSTEO information unless effective controls and procedures are in place to ensure AUSTEO information is not passed to, or made accessible by, foreign nationals, including seconded foreign nationals.

Control: 0411; **Revision:** 2; **Updated:** Nov-10; **Applicability:** P, C, S, TS; **Compliance:** must not; **Authority:** AH
Agencies must not allow foreign nationals, excluding seconded foreign nationals, to have access to systems that process, store or communicate AGAO information unless effective controls and procedures are in place to ensure AGAO information is not passed to, or made accessible by, foreign nationals, excluding seconded foreign nationals.

Access by foreign nationals to Australian systems

When information from foreign nations is entrusted to the Australian Government, care needs to be taken to ensure that foreign nationals do not have access to such information unless it has also been released to their country.

Control: 0816; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must not; **Authority:** AH

Where systems process, store or communicate information with nationality releasability markings, agencies must not allow foreign nationals, including seconded foreign nationals, to have access to such information that is not marked as releasable to their nation.

Temporary access to classified information

Under strict circumstances access to systems may be granted to personnel who lack the appropriate security clearance.

Control: 0440; **Revision:** 3; **Updated:** Sep-11; **Applicability:** P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must follow the *Temporary access to classified information* requirements in the *Australian Government Personnel Security Management Protocol* before granting personnel temporary access to a system.

Controlling temporary access

When personnel are granted access to a system under the provisions of temporary access they need to be closely supervised or have their access controlled in such a way that they only have access to information they require to undertake their duties.

Control: 0441; **Revision:** 3; **Updated:** Sep-11; **Applicability:** P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies granting personnel temporary access to a system must ensure that either:

- effective controls are in place to restrict access to only information that is necessary to undertake their duties
- they are continually supervised by another system user who has the appropriate security clearances to access the system.

Granting emergency access

Emergency access to a system may be granted where there is an immediate and critical need to access information for which personnel do not have the appropriate security clearance.

Control: 0442; **Revision:** 3; **Updated:** Sep-11; **Applicability:** P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must follow the *Temporary access to classified information* requirements in the *Australian Government Personnel Security Management Protocol* before granting personnel emergency access to a system.

Accessing systems without necessary security clearances and briefings

Temporary or emergency access to systems processing, storing or communicating caveated or compartmented information is not permitted.

Control: 0443; **Revision:** 2; **Updated:** Sep-11; **Applicability:** P, C, S, TS; **Compliance:** must not; **Authority:** AH

Agencies must not grant personnel temporary access or emergency access to systems that process, store or communicate caveated or compartmented information.

References

The *Australian Government Personnel Security Management Protocol* contains Australian government policy on security clearances.

Using the Internet

Objective

Personnel use Internet services in a responsible and security conscience manner.

Scope

This section describes the policy and awareness considerations that personnel using Internet services need to know and why personnel should not use web-based email and peer-to-peer applications over the Internet.

Context

This section applies to services utilising the Internet such as web browsing, Instant Messaging (IM), Internet Relay Chat (IRC), Internet Protocol (IP) telephony, video conferencing and peer-to-peer applications. Agencies need to be aware and educate personnel that unless applications using these communications methods are evaluated and approved by the Defence Signals Directorate they must not be used for communicating sensitive or classified information over the Internet.

Additional technical information and controls are in the *Web Content and Connections* and *Email Applications* sections of the *Software Security* chapter and the *Internet Protocol Telephony* section of the *Network Security* chapter.

Controls

Using the Internet

Agencies need to determine what constitutes suspicious contact in their own work environment such as being contacted by an unknown source and ensure personnel know how to report these events. Suspicious contact may relate to questions regarding the work duties of personnel or the specifics of projects being undertaken by personnel.

Control: 0817; **Revision:** 1; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must ensure personnel know how to report any suspicious contact and what suspicious contact is, especially contact from external sources using Internet services.

Awareness of web usage policies

There is little value in having web usage policies if personnel are not made aware of their existence.

Control: 0818; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must make personnel aware of their web usage policies.

Monitoring web usage

Agencies should monitor breaches of web usage policies—for example attempts to access blocked websites such as pornographic and gambling websites—as well as compiling a list of personnel who excessively download or upload data without a legitimate business requirement.

Control: 0819; **Revision:** 0; **Updated:** Sep-09; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should implement measures to monitor their personnel's compliance with their web usage policies.

Posting official information on websites

Personnel need to take special care not to accidentally post sensitive or classified information on public websites, especially in forums, blogs and social networking sites. Even unclassified information that appears to be benign in isolation, such as the Global Positioning System information in a picture, could, along with other information, have a considerable security impact on the government.

To ensure that personal opinions of personnel are not interpreted as official policy, personnel will need to maintain separate professional and personal accounts when using websites, especially when using online social networks.

Control: 0820; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure personnel are instructed to take special care not to post sensitive or classified information on public websites and how to report cases where such information is posted.

Control: 1146; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure personnel posting information on websites maintain separate professional accounts from any personal accounts they have for websites.

Control: 1147; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure personnel are aware of the approved websites on which personnel can post information authorised for release into the public domain.

Posting personal information on websites

Personnel need to be aware that any personal information they post on websites could be used to develop a detailed profile of their lifestyle and hobbies in order to attempt to build a trust relationship with them or others. This relationship could then be used to attempt to elicit sensitive or classified information from them or implant malicious software on systems by having them, for example, open emails or visit websites with malicious content.

Personnel should use the privacy settings on websites to restrict who can view their information and not allow public access. The privacy settings should be regularly reviewed for changes to the website policy and ensure the settings maintain privacy.

Control: 0821; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure that personnel are informed of the security risks associated with posting personal information on websites, especially for those personnel holding higher level security clearances.

Control: 0924; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Personnel should avoid posting personal information, such as the following, on websites:

- past and present employment details
- personal details
- schools/institutions
- clubs/hobbies
- educational qualifications
- current work duties
- work contact details.

Control: 1148; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Personnel should use the privacy settings on websites to restrict access to personal information they post to only those they authorise to view it.

Awareness of email usage policies

There is little value in having email usage policies for personnel if they are not made aware of their existence.

Control: 0266; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
Agencies must make personnel aware of their email usage policies.

Monitoring email usage

Agencies should monitor breaches of email usage policies—for example, attempts to send prohibited file types or executables, attempts to send excessively sized attachments or attempts to send sensitive or classified information without appropriate protective markings.

Control: 0822; **Revision:** 0; **Updated:** Sep-09; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should implement measures to monitor their personnel's compliance with email usage policies.

Public web-based email services

Using public web-based email services allows personnel to bypass security measures that agencies have put in place to protect against malicious code or phishing attempts distributed via email. Web-based email is email accessed using a web browser; examples of web-based email services include Gmail, Hotmail and email portals provided by Internet service providers.

Control: 0267; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must not; **Authority:** AH
Agencies must not allow personnel to send and receive emails using public web-based email services.

Peer-to-peer applications

Personnel using peer-to-peer file sharing applications are often unaware of the extent of files that are being shared from their workstation. In most cases peer-to-peer file sharing applications will scan workstations for common file types and share them automatically for public consumption. Examples of peer-to-peer file sharing applications include Shareaza, KaZaA, eMule and uTorrent.

Some peer-to-peer IP telephony applications, such as Skype, use proprietary protocols and make heavy use of encrypted tunnels to bypass firewalls. Because of this their use cannot be regulated or monitored. It is important that agencies implementing an IP telephony solution over the Internet choose applications that use protocols that are open to inspection by Intrusion Detection Systems.

Control: 0823; **Revision:** 0; **Updated:** Sep-09; **Applicability:** G, P, C, S, TS; **Compliance:** should not; **Authority:** AA
Agencies should not allow personnel to use peer-to-peer applications over the Internet.

Sending and receiving files via peer-to-peer applications

When personnel send or receive files via peer-to-peer file sharing, including IM and IRC applications, they bypass security measures put in place to detect and quarantine malicious code. Personnel should be encouraged to send and receive files via agency established methods such as email to ensure they are appropriately marked and scanned for malicious code.

Control: 0824; **Revision:** 1; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should not; **Authority:** AA
Agencies should not allow personnel to send or receive files via peer-to-peer applications.

References

Nil.



COMMUNICATIONS SECURITY



Communications Security

Communications Infrastructure

Cable Management Fundamentals

Objective

Cable management systems are implemented to allow easy integration of systems across government.

Scope

This section describes cable distribution systems used in facilities in Australia. When designing cable management systems, the *Cable Labelling and Registration* and *Cable Patching* sections of this chapter also apply.

Context

Applicability of controls in this section

The controls in this section only apply to new cable installations or upgrades. Agencies are not required to retro-fit existing cabling infrastructure to align with changes to controls in this manual. The controls are applicable to all facilities. For deployable platforms or facilities outside of Australia, consult the *Emanation Security Threat Assessments* section of this chapter.

Common implementation scenarios

This section provides common requirements for non-shared government facilities, shared government facilities and shared non-government facilities. Further specific requirements for each scenario can be found in the other sections of this chapter.

Cabling

For cabling, the cable's protective sheath is not considered to be a conduit. For fibre optic cables with subunits, the cable's outer protective sheath is considered to be a conduit.

Government systems

All references to 'Government' systems in the tables relate to systems containing unclassified but sensitive information not intended for public release, such as Dissemination Limiting Marker information. 'Government' is not a classification under the *Australian Government Security Classification System* as mandated by the Attorney-General's Department.

Controls

Cabling standards

All cabling must be installed by an endorsed cable installer to the relevant Australian Standards to ensure personnel safety and system availability.

Control: 0181; **Revision:** 1; **Updated:** Sep-09; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must install all cabling in accordance with the relevant Australian Standards as directed by the Australian Communications and Media Authority.

Cable colours

The use of defined cable colours provides an easily recognisable cable management system.

Control: 0926; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S; Compliance: should; Authority: AA
Agencies should comply with the cable colours specified in the following table.

SYSTEM	CABLE COLOUR
SECRET	Pink
CONFIDENTIAL	Green
PROTECTED	Blue
Government	Black or grey

Control: 0186; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
In TOP SECRET areas, agencies must comply with the cable colours specified in the following table.

SYSTEM	CABLE COLOUR
TOP SECRET	Red
SECRET	Pink
CONFIDENTIAL	Green
PROTECTED	Blue
Government	Black or grey

Cable colours for foreign systems in Australian facilities

Different cable colours for foreign systems in Australian facilities helps prevent unintended patching of Australian and foreign systems.

Control: 0825; Revision: 0; Updated: Sep-09; Applicability: G, P, C, S; Compliance: should not; Authority: AA
Agencies should not allow cable colours for foreign systems installed in Australian facilities to be the same colour as cables used for Australian systems.

Control: 0827; Revision: 0; Updated: Sep-09; Applicability: TS; Compliance: must not; Authority: AH
Agencies must not allow cable colours for foreign systems installed in Australian facilities to be the same colour as cables used for Australian systems.

Control: 0826; Revision: 0; Updated: Sep-09; Applicability: G, P, C, S; Compliance: should; Authority: AA
The cable colour to be used for foreign systems should be agreed between the host agency, the foreign system owner and the accreditation authority.

Control: 0828; Revision: 0; Updated: Sep-09; Applicability: TS; Compliance: must; Authority: AH
The cable colour to be used for foreign systems must be agreed between the host agency, the foreign system owner and the accreditation authority.

Cable groupings

Grouping cables provides a method of sharing conduits and cable reticulation systems in the most efficient manner.

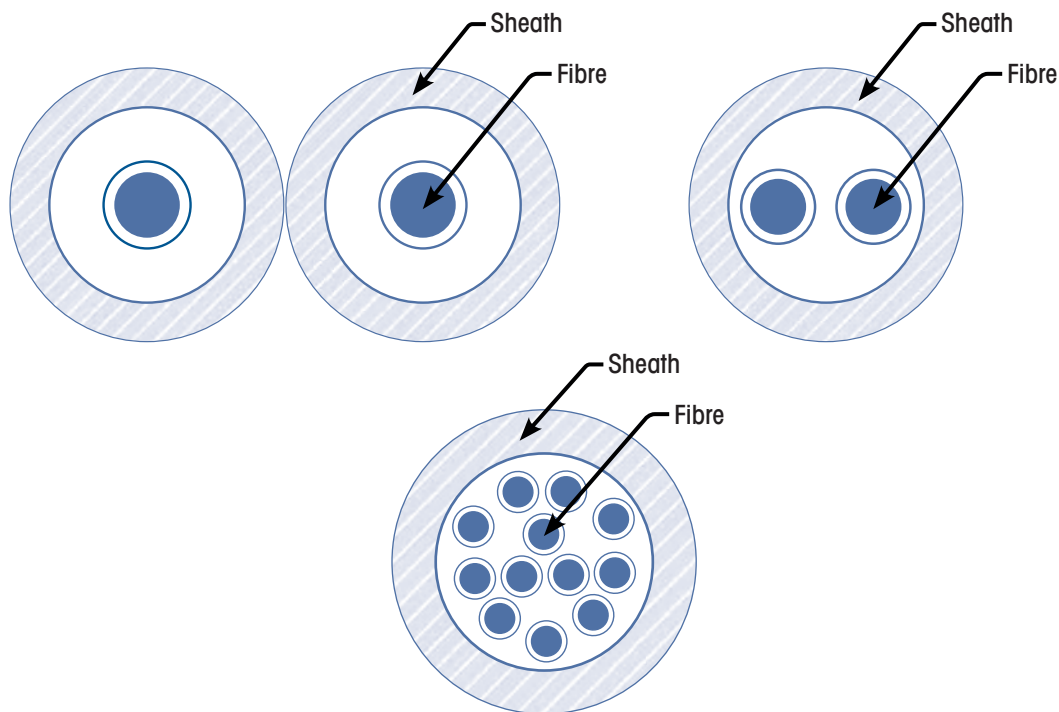
Control: 0187; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must not; Authority: AH
 Agencies must not deviate from the approved group combinations for cables as indicated below.

GROUP	APPROVED COMBINATION
1	Government
	PROTECTED
2	CONFIDENTIAL
	SECRET
3	TOP SECRET

Fibre optic cables sharing a common conduit

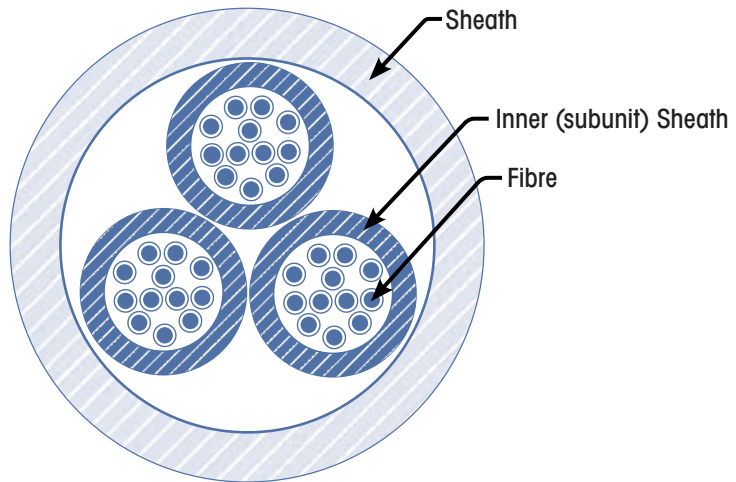
Fibre optic cables of various cable groups can share a common conduit to reduce installation costs.

Control: 0189; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
 With fibre optic cables the fibres in the sheath, as shown below, must only carry a single group.



Control: 0190; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

If a fibre optic cable contains subunits, as shown below, each subunit must only carry a single group; however, each subunit in the cable can carry a different group.



Terminating cabling in cabinets

Having individual or divided cabinets for each classification prevents accidental or deliberate cross patching and makes visual inspection of cabling and patching easier.

Control: 1098; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S; Compliance: should; Authority: AA

Cabling should terminate in either:

- individual cabinets
- one cabinet with a division plate to delineate classifications for small systems.

Control: 1099; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S; Compliance: must; Authority: AH

In TOP SECRET areas, cabling must terminate in either:

- individual cabinets
- one cabinet with a division plate to delineate classifications for small systems.

Control: 1100; Revision: 0; Updated: Nov-10; Applicability: TS; Compliance: must; Authority: AH

TOP SECRET cabling must terminate in an individual TOP SECRET cabinet.

Connecting cable reticulation systems to cabinets

Strictly controlling the routing from cable management systems to cabinets prevents unauthorised modifications and tampering and provides easy inspection of cabling.

Control: 1101; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Reticulation systems leading into cabinets in secured communications and server rooms should terminate as close as possible to the cabinet.

Control: 1102; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S; Compliance: should; Authority: AA

Reticulation systems leading into cabinets not in a secure communications or server room should terminate as close as possible to the cabinet.

Control: 1103; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

In TOP SECRET areas, reticulation systems leading into cabinets not in a secure communications or server room must terminate at the boundary of the cabinet.

Audio secure spaces

Audio secure spaces are designed to prevent audio conversations from being heard outside the walls. Penetrating an audio secure space in an unapproved manner can degrade this. Consultation with the Australian Security Intelligence Organisation (ASIO) needs to be undertaken before any modifications are done to audio secure spaces. For physical security measures regarding Security Zone requirements, refer to the *Australian Government Physical Security Management Protocol*.

Control: 0198; **Revision:** 1; **Updated:** Nov-10; **Applicability:** TS; **Compliance:** must; **Authority:** AH

When penetrating an audio secured space, agencies must consult with ASIO and comply with all directions provided.

Wall outlet terminations

Wall outlet boxes are the main method of connecting cable infrastructure to workstations. They allow the management of cabling and the type of connectors allocated to various systems.

Control: 1104; **Revision:** 0; **Updated:** Nov-10; **Applicability:** G, P, C, S; **Compliance:** must; **Authority:** AH

Cable groups sharing a wall outlet must:

- use fibre optic cabling
- use different connectors on opposite sides of the wall outlet for each group.

Control: 1105; **Revision:** 0; **Updated:** Nov-10; **Applicability:** TS; **Compliance:** must not; **Authority:** AH

TOP SECRET cabling must not share a wall outlet with another classification.

Control: 1106; **Revision:** 0; **Updated:** Nov-10; **Applicability:** TS; **Compliance:** must; **Authority:** AH

In areas containing outlets for both TOP SECRET systems and systems of other classifications, agencies must ensure that the connectors for the TOP SECRET systems are different from those of the other systems.

Wall outlet colours

The colouring of wall outlets makes it easy to identify TOP SECRET infrastructure.

Control: 1107; **Revision:** 0; **Updated:** Nov-10; **Applicability:** G, P, C, S; **Compliance:** must not; **Authority:** AH

Wall outlets must not be coloured red.

Control: 1108; **Revision:** 0; **Updated:** Nov-10; **Applicability:** TS; **Compliance:** must; **Authority:** AH

Wall outlets must be coloured red.

Wall outlet covers

Transparent covers on wall outlets allows for inspection of cabling for cross patching and tampering.

Control: 1109; **Revision:** 0; **Updated:** Nov-10; **Applicability:** G, P, C, S; **Compliance:** should; **Authority:** AA

Faceplates on wall outlets should be clear plastic.

Control: 1110; **Revision:** 0; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

In TOP SECRET areas, faceplates on wall outlets must be clear plastic.

References

Australian Standards for cabling can be obtained from http://www.acma.gov.au/WEB/STANDARD/pc=PC_2459.

Further information relating to physical security is contained in the *Australian Government Physical Security Management Protocol*.

Cable Management for Non-Shared Government Facilities

Objective

Cable management systems are implemented in non-shared government facilities.

Scope

This section describes cabling installed in facilities where the entire facility and personnel are cleared to the highest level of information processed in the facility. This section is to be applied in addition to common requirements for cabling as outlined in the *Cable Management Fundamentals* section of this chapter.

Context

Applicability of controls in this section

The controls in this section only apply to new cable installations or upgrades. Agencies are not required to retro-fit existing cabling infrastructure to align with changes to controls in this manual. The controls are applicable to all facilities that process sensitive or classified information. For deployable platforms or facilities outside of Australia, consult the *Emanation Security Threat Assessments* section of this chapter.

Controls

Use of fibre optic cabling

Fibre optic cabling does not produce, and is not influenced by, electromagnetic emanations, and therefore offers the highest degree of protection from electromagnetic emanation effects.

Fibre cabling is more difficult to tap than copper cabling.

Many more fibres can be run per cable diameter than wired cables, reducing cable infrastructure costs.

Fibre cable is the best method to future proof cabling infrastructure—it protects against unforeseen threats and facilitates upgrading secure cabling to higher classifications in the future.

Control: 1111; **Revision:** 0; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should use fibre optic cabling.

Cabling inspectability

Regular inspections of cable installations are necessary to detect any illicit tampering or degradation.

Control: 1112; **Revision:** 1; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agency cabling should be inspectable at a minimum of five-metre intervals.

Cables sharing a common reticulation system

Laying cabling in a neat and controlled manner that allows for inspections reduces the need for individual cable trays for each classification.

Control: 1114; **Revision:** 0; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Approved cable groups can share a common reticulation system but should have either a dividing partition or a visible gap between the differing cable groups.

Cabling in walls

Cabling run correctly in walls allows for neater installations while maintaining separation and inspectability requirements.

Control: 1115; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should use flexible or plastic conduit in walls to run cabling from cable trays to wall outlets.

Cabinet separation

Having a definite gap between cabinets allows for ease of inspections for any illicit cabling or cross patching.

Control: 1116; Revision: 1; Updated: Sep-11; Applicability: TS; Compliance: should; Authority: AA

Agencies should ensure there is a visible gap between TOP SECRET cabinets and cabinets of a lower classification.

References

Nil.

Cable Management for Shared Government Facilities

Objective

Cable management systems are implemented in shared government facilities.

Scope

This section describes cabling installed in facilities where the facility and personnel are cleared at different levels. This section is to be applied in addition to common requirements for cabling as outlined in the *Cable Management Fundamentals* section of this chapter.

Context

Applicability of controls in this section

The controls in this section only apply to new cable installations or upgrades. Agencies are not required to retro-fit existing cabling infrastructure to align with changes to controls in this manual. The controls are applicable to all facilities that process sensitive or classified information. For deployable platforms or facilities outside of Australia, consult the *Emanation Security Threat Assessments* section of this chapter.

Controls

Use of fibre optic cabling

Fibre optic cabling does not produce, and is not influenced by, electromagnetic emanations, and therefore offers the highest degree of protection from electromagnetic emanation effects.

Fibre cabling is more difficult to tap than copper cabling.

Many more fibres can be run per cable diameter than wired cables, reducing cable infrastructure costs.

Fibre cable is the best method to future proof cabling infrastructure—it protects against unforeseen threats and facilitates upgrading secure cabling to higher classifications in the future.

Control: 1117; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should use fibre optic cabling.

Cabling inspectability

In a shared government facility it is important that cabling systems be inspected for illicit tampering and damage on a regular basis and that they have tighter controls than in a non-shared government facility.

Control: 1118; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S; Compliance: should; Authority: AA
Cabling should be inspectable at a minimum of five-metre intervals.

Control: 1119; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
In TOP SECRET areas, cables should be fully inspectable for their entire length.

Cables sharing a common reticulation system

In a shared government facility, tighter controls are placed on sharing reticulation systems.

Control: 1120; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Approved cable groups can share a common reticulation system but should have either a dividing partition or a visible gap between the individual cable groups.

Cabling in walls

In a shared government facility, cabling run correctly in walls allows for neater installations while maintaining separation and inspectability requirements.

Control: 1121; **Revision:** 0; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Cabling from cable trays to wall outlets should run in flexible or plastic conduit.

Wall penetrations

Penetrating a wall into a lesser-classified space by cabling requires the integrity of the classified space to be maintained. All cabling is encased in conduit with no gaps in the wall around the conduit. This prevents any visual access to the secure space. For physical security measures regarding Security Zone requirements refer to the *Australian Government Physical Security Management Protocol*.

Control: 1122; **Revision:** 0; **Updated:** Nov-10; **Applicability:** TS; **Compliance:** should; **Authority:** AA

For wall penetrations that exit into a lower classified space, cabling should be encased in conduit with all gaps between the conduit and the wall filled with an appropriate sealing compound.

Power reticulation

In a shared government facility with lesser-classified systems, it is important that TOP SECRET systems have control over the power system to prevent denial of service by deliberate or accidental means.

Control: 1123; **Revision:** 0; **Updated:** Nov-10; **Applicability:** TS; **Compliance:** should; **Authority:** AA

TOP SECRET facilities should have a power distribution board located in the TOP SECRET area with a feed from an Uninterruptible Power Supply (UPS) to power all Information and Communications Technology (ICT) equipment.

Cabinet separation

Having a definite gap between cabinets allows for ease of inspections for any illicit cabling or cross patching.

Control: 1124; **Revision:** 1; **Updated:** Sep-11; **Applicability:** TS; **Compliance:** should; **Authority:** AA

Agencies should ensure there is a visible gap between TOP SECRET cabinets and cabinets of a lower classification.

References

Further information relating to physical security is contained in the *Australian Government Physical Security Management Protocol*.

Cable Management for Shared Non-Government Facilities

Objective

Cable management systems are implemented in shared non-government facilities.

Scope

This section describes cabling installed in facilities shared by agencies and non-government organisations. This section is to be applied in addition to common requirements for cabling as outlined in the *Cable Management Fundamentals* section of this chapter.

Context

Applicability of controls in this section

The controls in this section only apply to new cable installations or upgrades. Agencies are not required to retro-fit existing cabling infrastructure to align with changes to controls in this manual. The controls are applicable to all facilities that process sensitive or classified information. For deployable platforms or facilities outside of Australia, consult the *Emanation Security Threat Assessments* section of this chapter.

Controls

Use of fibre optic cabling

Due to the higher degree of associated risk, greater consideration should be applied to the use of fibre optic cabling in shared non-government facilities. Fibre optic cabling does not produce, and is not influenced by, electromagnetic emanations, and therefore offers the highest degree of protection from electromagnetic emanation effects.

Fibre cabling is more difficult to tap than copper cabling.

Many more fibres can be run per cable diameter than wired cables, reducing cable infrastructure costs.

Fibre cable is the best method to future proof cabling infrastructure—it protects against unforeseen threats and facilitates upgrading secure cabling to higher classifications in the future.

Control: 1125; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S; Compliance: should; Authority: AA
Agencies should use fibre optic cabling.

Control: 0182; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
In TOP SECRET areas, agencies must use fibre optic cabling.

Cabling inspectability

In a shared non-government facility it is imperative that cabling systems be inspected for illicit tampering and damage on a regular basis and that they have tighter controls where the threats are closer and unknown.

Control: 1126; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S; Compliance: should; Authority: AA
Cabling should be inspectable at a minimum of five-metre intervals.

Control: 0184; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
In TOP SECRET areas, cables must be fully inspectable for their entire length.

Cables sharing a common reticulation system

In a shared non-government facility, tighter controls are placed on sharing reticulation systems as the threats to tampering and damage are increased.

Control: 1127; **Revision:** 0; **Updated:** Nov-10; **Applicability:** G, P, C, S; **Compliance:** should; **Authority:** AA

Approved cable groups can share a common reticulation system but should have either a dividing partition or a visible gap between the differing cable groups.

Control: 1128; **Revision:** 0; **Updated:** Nov-10; **Applicability:** G, P, C, S; **Compliance:** must; **Authority:** AH

In TOP SECRET areas, approved cable groups can share a common reticulation system but must have either a dividing partition or a visible gap between the differing cable groups.

Control: 1129; **Revision:** 1; **Updated:** Sep-11; **Applicability:** TS; **Compliance:** must not; **Authority:** AH

TOP SECRET cabling must not share a common reticulation system unless it is in an enclosed reticulation system and has dividing partitions or visible gaps between the differing cable groups.

Enclosed cable reticulation systems

In a shared non-government facility, TOP SECRET cabling is enclosed in a sealed reticulation system to prevent access and enhance cable management.

Control: 1130; **Revision:** 1; **Updated:** Sep-11; **Applicability:** G, P, C, S; **Compliance:** should; **Authority:** AA

Cables should be run in an enclosed cable reticulation system.

Control: 1131; **Revision:** 1; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

In TOP SECRET areas, cables must be run in an enclosed cable reticulation system.

Covers for enclosed cable reticulation systems

Clear covers on enclosed reticulation systems are a convenient method of maintaining inspectability and control requirements. Having clear covers face inwards increases their inspectability.

Control: 1164; **Revision:** 0; **Updated:** Sep-11; **Applicability:** G, P, C, S; **Compliance:** should; **Authority:** AA

Conduits or the front covers of ducts, cable trays in floors and ceilings, and associated fittings should be clear plastic.

Control: 1165; **Revision:** 0; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Conduits or the front covers of ducts, cable trays in floors and ceilings, and associated fittings must be clear plastic.

Cabling in walls

In a shared non-government facility, cabling run correctly in walls allows for neater installations while maintaining separation and inspectability requirements. Controls are more stringent than in a non-shared government facility or a shared government facility.

Control: 1132; **Revision:** 0; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Cabling from cable trays to wall outlets must run in flexible or plastic conduit.

Cabling in party walls

In a shared non-government facility, cabling is not allowed in a party wall. A party wall is a wall shared with an unsecured space where there is no control over access. An inner wall can be used to run cabling where the space is sufficient for inspection of the cabling.

Control: 1133; **Revision:** 0; **Updated:** Nov-10; **Applicability:** TS; **Compliance:** must not; **Authority:** AH

Cabling must not run in a party wall.

Sealing conduits

In a shared non-government facility, where the threat of access to cabling is increased, all conduits are sealed with a visible smear of glue to prevent access to cabling.

Control: 0194; Revision: 1; Updated: Nov-10; Applicability: TS; Compliance: must; Authority: AH

Agencies must use a visible smear of conduit glue to seal:

- all plastic conduit joints
- conduit runs connected by threaded lock nuts.

Sealing reticulation systems

In a shared non-government facility, where the threats of access to cable reticulation systems is increased, Security Construction and Equipment Committee (SCEC) endorsed seals are required to provide evidence of any tampering or illicit access.

Control: 0195; Revision: 2; Updated: Sep-11; Applicability: TS; Compliance: must; Authority: AH

Agencies must use SCEC endorsed tamper evident seals to seal all removable covers on reticulation systems, including:

- box section front covers
- conduit inspection boxes
- outlet and junction boxes
- T-pieces.

Control: 0196; Revision: 1; Updated: Nov-10; Applicability: TS; Compliance: must; Authority: AH

Tamper evident seals must be uniquely identifiable.

Wall penetrations

Penetrating a wall to a lesser-classified space by cabling requires the integrity of the classified space be maintained. All cabling is encased in conduit with no gaps in the wall around the conduit. This prevents any visual access to the secure space. For physical security measures regarding Security Zone requirements refer to the *Australian Government Physical Security Management Protocol*.

Control: 1134; Revision: 0; Updated: Nov-10; Applicability: TS; Compliance: must; Authority: AH

For wall penetrations that exit into a lower classified space, cabling must be encased in conduit with all gaps between the conduit and the wall filled with an appropriate sealing compound.

Power reticulation

In a shared non-government facility, it is important that TOP SECRET systems have control over the power system to prevent denial of service by deliberate or accidental means. The addition of a UPS is required to maintain availability of the TOP SECRET systems.

Control: 1135; Revision: 0; Updated: Nov-10; Applicability: TS; Compliance: must; Authority: AH

TOP SECRET facilities must have a power distribution board located in the TOP SECRET area with a feed from a UPS to power all ICT equipment.

Cabinet separation

Having a definite gap between cabinets allows for ease of inspections for any illicit cabling or cross patching.

Control: 1136; Revision: 1; Updated: Sep-11; Applicability: TS; Compliance: must; Authority: AH

Agencies must ensure there is a visible gap between TOP SECRET cabinets and cabinets of a lower classification.

References

The SCEC endorses seals to be used for various sealing requirements. Further information on endorsed seals is available in the *Security Equipment Catalogue* produced by SCEC at <http://www.scec.gov.au/>.

Further information relating to physical security is contained in the *Australian Government Physical Security Management Protocol*.

Cable Labelling and Registration

Objective

Cable registers are used to record cables and labels.

Scope

This section describes the labelling of cabling infrastructure installed in secured spaces.

Context

Applicability of controls in this section

The controls are applicable to all facilities that process sensitive or classified information. For deployable platforms or facilities outside of Australia, consult the *Emanation Security Threat Assessments* section of this chapter.

Controls

Conduit label specifications

Conduit labels must be a specific size and colour to allow easy identification of secure conduits carrying cables.

Control: 0201; Revision: 1; Updated: Nov-10; Applicability: TS; Compliance: must; Authority: AH

Labels for TOP SECRET conduits must be:

- a minimum size of 2.5cm x 1cm
- attached at 5m intervals
- marked as 'TS RUN'.

Control: 0202; Revision: 1; Updated: Nov-10; Applicability: TS; Compliance: must; Authority: AH

Conduit labels in areas where uncleared personnel could frequently visit must have red text on a clear background.

Control: 0203; Revision: 1; Updated: Nov-10; Applicability: TS; Compliance: must; Authority: AH

Conduit labels in areas that are not clearly observable must have red text on a white background.

Installing conduit labelling

Conduit labelling in public or reception areas could draw unwanted attention to the level of classified processing and lead to a disclosure of capabilities.

Control: 0204; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Conduit labels installed in public or visitor areas should not draw undue attention from people who do not have a need-to-know of the existence of such cabling.

Labelling wall outlet boxes

Clear labelling of wall outlet boxes diminishes the possibility of incorrectly attaching ICT equipment of a lesser classification to the wrong outlet.

Control: 1095; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S; Compliance: should; Authority: AA

Wall outlet boxes should denote the classification, cable number and outlet number.

Control: 0205; Revision: 1; Updated: Nov-10; Applicability: TS; Compliance: must; Authority: AH

Wall outlet boxes must denote the classification, cable number and outlet number.

Standard Operating Procedures

Recording labelling conventions in Standard Operating Procedures (SOPs) makes cabling and fault finding easier.

Control: 0206; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
The SOPs should record the site conventions for labelling and registration.

Labelling cables

Labelling cables with the correct source and destination information minimises the likelihood of cross patching and aids in fault finding and configuration management.

Control: 1096; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S; Compliance: should; Authority: AA
Agencies should label cables at each end, with sufficient source and destination details to enable the physical identification and inspection of the cable.

Control: 0207; Revision: 1; Updated: Nov-10; Applicability: TS; Compliance: must; Authority: AH
Agencies must label cables at each end, with sufficient source and destination details to enable the physical identification and inspection of the cable.

Cable register

Cable registers provide a source of information that assessors can view to verify compliance.

Control: 0208; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S; Compliance: should; Authority: AA
Agencies should maintain a register of cables.

Control: 0210; Revision: 1; Updated: Nov-10; Applicability: TS; Compliance: must; Authority: AH
Agencies must maintain a register of cables.

Cable register contents

Cable registers allow installers and assessors to trace cabling for inspections, malice or accidental damage. It tracks all cable management changes through the life of the system.

Control: 0209; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S; Compliance: should; Authority: AA
The cable register should record at least the following information:

- cable identification number
- classification
- source
- destination
- site/floor plan diagram
- seal numbers if applicable.

Control: 1097; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
For cables in TOP SECRET areas, the cable register must record at least the following information:

- cable identification number
- classification
- source
- destination
- site/floor plan diagram
- seal numbers if applicable.

Cable inspections

Cable inspections, at pre-defined periods, are a method of checking the cable management system with the cable register.

Control: 0211; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should inspect cables for inconsistencies with the cable register in accordance with the frequency defined in the System Security Plan.

References

Nil.

Cable Patching

Objective

Communications systems are designed to prevent patching between different classifications and security domains.

Scope

This section describes the configuration and installation of patch panels, patch cables and fly leads associated with communications systems.

Context

Applicability of controls in this section

The controls in this section only apply to new cable installations or upgrades. Agencies are not required to retro-fit existing cabling infrastructure to align with changes to controls in this manual. The controls are applicable to all facilities that process sensitive or classified information. For deployable platforms or facilities outside of Australia, consult the *Emanation Security Threat Assessments* section of this chapter.

Controls

Terminations to patch panels

Connecting a system to another system of a lesser classification will result in a data spill. A data spill could result in the following issues:

- inadvertent or deliberate access by non-cleared personnel
- the lesser system not meeting the appropriate requirements to secure the classified information from unauthorised access or tampering.

Control: 0213; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
Agencies must ensure that only approved cable groups terminate on a patch panel.

Patch cable and fly lead connectors

Ensuring that cables are equipped with connectors of a different configuration to all other cables prevents inadvertent connection to systems of lower classifications.

Control: 1093; **Revision:** 0; **Updated:** Nov-10; **Applicability:** G, P, C, S; **Compliance:** should; **Authority:** AA
In areas containing cabling for systems of different classifications, agencies should ensure that the connectors for each system are different from those of the other systems; unless the length of the higher classified patch cables is less than the distance between the higher classified patch panel and any patch panel of a lower classification.

Control: 0214; **Revision:** 2; **Updated:** Nov-10; **Applicability:** TS; **Compliance:** must; **Authority:** AH
In areas containing cabling for both TOP SECRET systems and systems of other classifications, agencies must ensure that the connectors for the TOP SECRET systems are different from those of the other systems.

Control: 1094; **Revision:** 0; **Updated:** Nov-10; **Applicability:** G, P, C, S; **Compliance:** should; **Authority:** AA
In areas containing cabling for systems of different classifications, agencies should document the selection of connector types.

Control: 0215; **Revision:** 2; **Updated:** Nov-10; **Applicability:** TS; **Compliance:** must; **Authority:** AH

In areas containing cabling for both TOP SECRET systems and systems of other classifications, agencies must document the selection of connector types for TOP SECRET systems.

Physical separation of patch panels

Appropriate physical separation between a TOP SECRET system and a system of a lesser classification:

- reduces or eliminates the chances of cross patching between the systems
- reduces or eliminates the possibility of unauthorised personnel gaining access to TOP SECRET system elements.

Control: 0216; **Revision:** 1; **Updated:** Nov-10; **Applicability:** TS; **Compliance:** should; **Authority:** AA

Agencies should physically separate TOP SECRET and non-TOP SECRET patch panels by installing them in separate cabinets.

Control: 0217; **Revision:** 2; **Updated:** Nov-10; **Applicability:** TS; **Compliance:** must; **Authority:** AH

Where spatial constraints demand patch panels of a lower classification than TOP SECRET be located in the same cabinet, agencies must:

- provide a physical barrier in the cabinet to separate patch panels
- ensure that only personnel cleared to TOP SECRET have access to the cabinet
- obtain approval from the relevant accreditation authority prior to installation.

Fly lead installation

Keeping the lengths of fly leads to a minimum prevents clutter around desks, prevents damage to fibre optic cabling and reduces the chance of cross patching and tampering. If lengths become excessive, cabling needs to be treated as infrastructure and run in conduit or fixed infrastructure such as desk partitioning.

Control: 0218; **Revision:** 1; **Updated:** Nov-10; **Applicability:** TS; **Compliance:** should; **Authority:** AA

Agencies should ensure that the fibre optic fly leads used to connect wall outlets to ICT equipment either:

- do not exceed 5m in length
- if they exceed 5m in length:
 - are run in the facility's fixed infrastructure in a protective and easily inspected pathway
 - are clearly labelled at the equipment end with the wall outlet designator
 - are approved by the accreditation authority.

References

Nil.

Emanation Security Threat Assessments

Objective

A valid threat assessment is used to determine the appropriate counter-measures to minimise compromising emanations.

Scope

This section describes emanation security threat assessment advice, so agencies can implement appropriate counter-measures to minimise the loss of sensitive or classified information through compromising emanations.

Context

This section is only applicable to:

- agencies located outside of Australia
- facilities in Australia that have transmitters
- mobile platforms and deployable assets that process sensitive or classified information.

Controls

Emanation security threat assessments in Australia

Obtaining the current threat advice from the Defence Signals Directorate (DSD) on potential adversaries and applying the appropriate counter-measures is vital in maintaining the confidentiality of sensitive and classified systems from an emanation security attack.

Failing to implement required counter-measures against an emanation security attack can lead to compromise. Having a good cable infrastructure and installation methodology will provide a strong backbone that will not need updating if the threat increases. Infrastructure costs are very expensive and time consuming to retro-fit.

Control: 0247; **Revision:** 1; **Updated:** Nov-10; **Applicability:** C, S, TS; **Compliance:** must; **Authority:** AH

Agencies designing and installing systems with Radio Frequency transmitters inside or co-located with their facility must:

- contact DSD for an emanation security threat assessment in accordance with the latest version of Australian Communications Security Instruction (ACSI) 71
- install cabling and ICT equipment in accordance with this manual plus any specific installation criteria derived from the emanation security threat assessment.

Control: 0248; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S; **Compliance:** must; **Authority:** AH

Agencies designing and installing systems with Radio Frequency (RF) transmitters that co-locate with systems of a higher classification must:

- contact DSD for an emanation security threat assessment in accordance with the latest version of ACSI 71
- install cabling and ICT equipment in accordance with this manual plus any specific installation criteria derived from the emanation security threat assessment.

Control: 1137; Revision: 0; Updated: Nov-10; Applicability: TS; Compliance: must; Authority: AH

Agencies designing and installing systems in shared facilities with non-Australian government entities must:

- contact DSD for an emanation security threat assessment in accordance with the latest version of ACSI 71
- install cabling and ICT equipment in accordance with this manual plus any specific installation criteria derived from the emanation security threat assessment.

Emanation security threat assessments outside Australia

Fixed sites and deployed military platforms are more vulnerable to emanation security attack and require a current threat assessment and counter-measure implementation. Failing to implement recommended counter-measures and SOPs to reduce threats could result in the platform emanating compromising signals, which if intercepted and analysed, could lead to platform compromise with serious consequences.

Control: 0932; Revision: 3; Updated: Sep-11; Applicability: G, P; Compliance: should; Authority: AA

Agencies deploying systems overseas should:

- contact DSD for emanation security threat advice
- install cabling and ICT equipment in accordance with this manual plus any specific installation criteria derived from the emanation security threat assessment.

Control: 0249; Revision: 1; Updated: Nov-10; Applicability: C, S, TS; Compliance: must; Authority: AH

Agencies deploying systems overseas in military and fixed locations must:

- contact DSD for an emanation security threat assessment in accordance with the latest version of ACSI 71
- install cabling and ICT equipment in accordance with this manual plus any specific installation criteria derived from the emanation security threat assessment.

Early identification of emanation security issues

It is important to identify the need for emanation security controls for a system early in the project lifecycle as this can reduce costs for the project. Costs are much greater if changes have to be made once the system has been designed and deployed.

Control: 0246; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies needing an emanation security threat assessment should do so as early as possible in project lifecycles as emanation security controls can have significant cost implications.

Information and Communications Technology equipment in highly sensitive areas

While ICT equipment in a TOP SECRET area in Australia may not need certification to TEMPEST standards, the equipment still needs to meet applicable industry and government standards.

Control: 0250; Revision: 2; Updated: Nov-10; Applicability: TS; Compliance: must; Authority: AH

Agencies must ensure that ICT equipment in TOP SECRET areas meets industry and government standards relating to electromagnetic interference/electromagnetic compatibility.

References

Additional information on cabling and separation standards, as well as the potential dangers of operating RF transmitters near systems is documented in the latest version of ACSI 61.

Additional information on conducting an emanation security threat assessment is found in the latest version of ACSI 71.

Communications Systems and Devices

Radio Frequency, Infrared and Bluetooth Devices

Objective

Only approved RF, infrared and Bluetooth devices are brought into secured areas.

Scope

This section describes the use of RF, infrared and Bluetooth devices in secured spaces. Information on the use of RF devices outside secured spaces can be found in the *Working Off-Site* chapter.

Context

Exemptions for the use of infrared devices

An infrared device can be used in a secured space provided it does not communicate sensitive or classified information.

Exemptions for the use of Radio Frequency devices

The following devices, at the discretion of the accreditation authority, can be exempted from the controls associated with RF transmitters:

- pagers that can only receive messages
- garage door openers
- car lock/alarm keypads
- medical and exercise equipment that uses RF to communicate between sub-components
- communications radios that are secured by approved cryptography.

Controls

Pointing devices

Since wireless RF pointing devices can pose an emanation security risk they are not to be used in TOP SECRET areas unless in a RF screened building.

Control: 0221; **Revision:** 1; **Updated:** Nov-10; **Applicability:** TS; **Compliance:** must not; **Authority:** AH

Wireless RF pointing devices must not be used in TOP SECRET areas unless used in a RF screened building.

Infrared keyboards

When using infrared keyboards with CONFIDENTIAL or SECRET systems, drawn curtains that block infrared transmissions are an acceptable method of protection.

When using infrared keyboards with a TOP SECRET system, windows with curtains that can be opened are not acceptable as a method of permanently blocking infrared transmissions.

Control: 0222; **Revision:** 1; **Updated:** Sep-09; **Applicability:** G, P; **Compliance:** should; **Authority:** AA

Agencies using infrared keyboards should ensure that infrared ports are positioned to prevent line of sight and reflected communications travelling into an unsecured space.

Control: 0223; Revision: 3; Updated: Sep-11; Applicability: C, S; Compliance: must not; Authority: AH

Agencies using infrared keyboards must not allow:

- line of sight and reflected communications travelling into an unsecured space
- multiple infrared keyboards for different systems in the same area
- other infrared devices in the same area
- infrared keyboards to be operated in areas with unprotected windows.

Control: 0224; Revision: 3; Updated: Sep-11; Applicability: TS; Compliance: must not; Authority: AH

Agencies using infrared keyboards must not allow:

- line of sight and reflected communications travelling into an unsecured space
- multiple infrared keyboards for different systems in the same area
- other infrared devices in the same area
- infrared keyboards in areas with windows that have not had a permanent method of blocking infrared transmissions applied to them.

Bluetooth and wireless keyboards

Bluetooth has a number of known weaknesses in the protocol that potentially enable attacker exploitation. While there have been a number of revisions to the protocol that have made incremental improvements to security, there have been trade-offs that have limited the improvements. These include maintaining backward compatibility to earlier versions of the protocol and limits to the capabilities of some devices.

Though newer revisions of the Bluetooth protocol have addressed many of the historical security concerns, it is still very important that agencies consider the security risks posed by enabling Bluetooth technology.

As part of an agency's security risk assessment, things to consider are:

- using the strongest security modes available
- educating system users of the known weaknesses of the technology and their responsibilities in complying with policy in the absence of strong technical controls
- man in the middle pairing
- maintaining an inventory of all Bluetooth devices addresses (BD_ADDRs).

Agencies must use Bluetooth version 2.1 or later as secure simple pairing and extended inquiry response was introduced. Secure simple pairing improves the pairing experience for Bluetooth devices, while increasing the strength as it uses a form of public key cryptography. Extended inquiry response provides more information during the inquiry procedure to allow better filtering of devices before connecting.

The device class can be used to restrict the range that the Bluetooth communications will operate over. Typically Bluetooth class 1 devices can communicate up to 100 metres, class 2 devices can communicate up to 10 metres and class 3 devices can communicate up to 5 metres.

Control: 1058; Revision: 0; Updated: Nov-10; Applicability: G, P; Compliance: should not; Authority: AA

Agencies should not use Bluetooth and wireless keyboards unless in a RF screened building.

Control: 1155; Revision: 0; Updated: Nov-10; Applicability: C, S, TS; Compliance: must not; Authority: AH

Agencies must not use Bluetooth and wireless keyboards unless in a RF screened building.

Control: 1166; Revision: 0; Updated: Sep-11; Applicability: G, P; Compliance: must; Authority: AH

Agencies must use Bluetooth version 2.1 or later if Bluetooth keyboards are used.

Control: 1167; Revision: 0; Updated: Sep-11; Applicability: G, P; Compliance: should; Authority: AA

Agencies should restrict the range of Bluetooth keyboards to less than 10 metres by only using class 2 or class 3 devices.

Radio Frequency devices in secured spaces

RF devices with voice capability pose an audio security threat to secured spaces as they are capable of picking up and transmitting sensitive or classified background conversations. Furthermore, many RF devices can connect to ICT equipment and act as unauthorised data storage devices.

Control: 0830; Revision: 0; Updated: Sep-09; Applicability: C, S; Compliance: should; Authority: AA

Agencies should prevent RF devices from being brought into secured spaces unless authorised by the accreditation authority.

Control: 0225; Revision: 1; Updated: Sep-09; Applicability: TS; Compliance: must; Authority: AH

Agencies must prevent RF devices from being brought into TOP SECRET areas unless authorised by the accreditation authority.

Detecting Radio Frequency devices in secured spaces

As RF devices are prohibited in highly classified environments, agencies are encouraged to deploy security measures that detect and respond to the unauthorised use of such devices.

Control: 0829; Revision: 2; Updated: Sep-11; Applicability: C, S, TS; Compliance: should; Authority: AA

Agencies should deploy security measures to detect and respond to active RF devices in secured spaces.

Radio Frequency controls

Minimising the output power of wireless devices and using RF shielding on facilities will assist in limiting the wireless communications to areas under the control of the agency.

Control: 0929; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should limit the effective range of communications outside their area of control by either:

- minimising the output power level of wireless devices
- RF shielding.

References

Nil.

Fax Machines and Multifunction Devices

Objective

Fax machines and Multifunction Devices (MFDs) are used in a secure manner.

Scope

This section describes fax machines and MFDs connected to the Public Switched Telephone Network (PSTN), High Grade Cryptographic Equipment (HGCE) or computer networks.

Context

Further information on MFDs communicating via network gateways can be found in the *Data Import and Export* section of the *Gateway Security* chapter.

Controls

Fax machine and Multifunction Device usage policy

As fax machines and MFDs are capable of communicating sensitive or classified information, and are a potential source of cyber security incidents, it is important that agencies develop a policy governing their use.

Control: 0588; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must develop a policy governing the use of fax machines and MFDs.

Sending fax messages

Once a fax machine or MFD has been connected to cryptographic equipment and used to send a sensitive or classified fax message, it can no longer be trusted when connected directly to unsecured telecommunications infrastructure or the PSTN. For example, if a fax machine fails to send a sensitive or classified fax message the device will continue attempting to send the fax message even if it has been disconnected from the cryptographic device and connected directly to the PSTN. In such cases, the fax machine could then send the sensitive or classified fax message in the clear, causing a cyber security incident.

Control: 1092; **Revision:** 0; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must have separate fax machines or MFDs for sending sensitive or classified and unclassified fax messages.

Control: 0241; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies sending sensitive or classified fax messages must ensure that the fax message is encrypted to an appropriate level when communicated over unsecured telecommunications infrastructure or the PSTN.

Sending fax messages using High Grade Cryptographic Equipment

Using the correct procedure for sending a classified fax message will ensure that it is sent securely to the correct recipient.

Using the correct memory erase procedure will prevent a classified fax message being communicated in the clear.

Implementing the correct procedure for establishing a secure call will prevent sending a classified fax message in the clear.

Witnessing the receiving of a fax message and powering down the receiving machine or clearing the memory after transmission will prevent someone without a need-to-know from accessing the fax message.

Ensuring fax machines and MFDs are not connected to unsecured phone lines will prevent accidentally sending classified messages stored in memory.

Control: 0242; **Revision:** 3; **Updated:** Sep-11; **Applicability:** C, S, TS; **Compliance:** must; **Authority:** DSD

Agencies intending to use fax machines or MFDs to send classified information must comply with additional requirements in ACSI 129 and ACSI 131.

Receiving fax messages

While the communications path between fax machines and MFDs may be appropriately protected, personnel need to be aware of the need-to-know of the information that is being communicated. It is therefore important that fax messages are collected from the receiving fax machine or MFD as soon as possible. Furthermore, if an expected fax message is not received it may indicate that there was a problem with the original transmission or the fax message has been taken by an unauthorised person.

Control: 1075; **Revision:** 0; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

The sender of a fax message should make arrangements for the receiver to:

- collect the fax message as soon as possible after it is received
- notify the sender if the fax message does not arrive in an agreed amount of time.

Connecting Multifunction Devices to telephone networks

When a MFD is connected to a computer network and a digital telephone network the device can act as a bridge between the two. The telephone network therefore needs to be accredited to the same level as the computer network.

Control: 0244; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G; **Compliance:** should not; **Authority:** AA

Agencies should not enable a direct connection from a MFD to a digital telephone network unless the telephone network is accredited to at least the same level as the computer network to which the device is connected.

Control: 0245; **Revision:** 3; **Updated:** Sep-11; **Applicability:** P, C, S, TS; **Compliance:** must not; **Authority:** AH

Agencies must not enable a direct connection from a MFD to a digital telephone network unless the telephone network is accredited to at least the same level as the computer network to which the device is connected.

Connecting Multifunction Devices to computer networks

As network connected MFDs are considered to be devices that reside on a computer network, they need to have the same security measures as other devices on the computer network.

Control: 0590; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Where MFDs connected to computer networks have the ability to communicate via a gateway to another network, agencies must ensure that:

- each MFD applies user identification, authentication and audit functions for all information communicated by that device
- these mechanisms are of similar strength to those specified for workstations on that network
- each gateway can identify and filter the information in accordance with the requirements for the export of data via a gateway.

Copying documents on Multifunction Devices

As networked MFDs are capable of sending scanned or copied documents across a connected network, personnel need to be aware that if they scan or copy documents at a level higher than that of the network the device is connected to they could be causing a data spill.

Control: 0589; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must not; Authority: AH

Agencies must not permit MFDs connected to computer networks to be used to copy documents above the sensitivity or classification of the connected network.

Observing fax machine and Multifunction Device use

Placing fax machines and MFDs in public areas can help reduce the likelihood of any suspicious use going unnoticed.

Control: 1036; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure that fax machines and MFDs are located in an area where their use can be observed.

References

Specific information regarding the procedures for fax machines and MFDs attached to HGCE is found in ACSI 129 and ACSI 131.

Telephones and Telephone Systems

Objective

Telephone systems are prevented from communicating unauthorised information.

Scope

This section describes the secure use of fixed telephones, including cordless telephones, as well as the systems they use to communicate information.

Context

Information regarding mobile phones and smartphones is covered in the *Mobile Devices* section of the *Working Off-Site* chapter while information regarding Internet Protocol telephony, including Voice over Internet Protocol, and encryption of data in transit is covered in the *Internet Protocol Telephony* section of the *Network Security* chapter and the *Cryptographic Fundamentals* section of the *Cryptography* chapter.

Controls

Telephones and telephone systems usage policy

All non-secure telephone networks are subject to interception. Accidentally or maliciously revealing sensitive or classified information over a public telephone network can lead to interception.

Control: 1078; **Revision:** 0; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must develop a policy governing the use of telephones and telephone systems.

Personnel awareness

As there is a high risk of unintended disclosure of sensitive or classified information when using telephones, it is important that personnel are made aware of what they can discuss on particular telephone systems, as well as the audio security risk associated with the use of telephones.

Control: 0229; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must advise personnel of the permitted sensitive or classified information that can be discussed on both internal and external telephone connections.

Control: 0230; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should advise personnel of the audio security risk posed by using telephones in areas where sensitive or classified conversations can occur.

Visual indication

When single telephone systems are approved to hold conversations at different levels, alerting the user to the sensitive or classified information that can be discussed will assist in reducing the risk of unintended disclosure of sensitive or classified information.

Control: 0231; **Revision:** 0; **Updated:** Sep-08; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies permitting different levels of conversation for different kinds of connections should use telephones that give a visual indication of what kind of connection has been made.

Use of telephone systems

When sensitive or classified conversations are to be held using telephone systems, the conversation needs to be appropriately protected through the use of encryption measures.

Control: 0232; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies intending to use telephone systems for the transmission of sensitive or classified information must ensure that:

- the system has been accredited for the purpose
- all sensitive or classified traffic that passes over external systems is appropriately encrypted.

Cordless telephones

Cordless telephones have minimal transmission security; therefore they must not be used for sensitive or classified communications.

Control: 0233; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must not; **Authority:** AH

Agencies must not use cordless telephones for sensitive or classified conversations.

Cordless telephones with secure telephony devices

As the data between cordless handsets and base stations is not appropriately secured, cordless telephones must not be used for sensitive or classified communications even if the device is connected to a secure telephony device.

Control: 0234; **Revision:** 0; **Updated:** Sep-08; **Applicability:** G, P, C, S, TS; **Compliance:** must not; **Authority:** AH

Agencies must not use cordless telephones in conjunction with secure telephony devices.

Speakerphones

As speakerphones are designed to pick up and transmit conversations in the vicinity of the device, they must not be used in TOP SECRET areas as the audio security risk is too high. However, if the agency is able to reduce the audio security risk through the use of an audio secure room that is secured during conversations, then they may be used. For physical security measures regarding Security Zone requirements refer to the *Australian Government Physical Security Management Protocol*.

Control: 0235; **Revision:** 2; **Updated:** Nov-10; **Applicability:** TS; **Compliance:** must not; **Authority:** AH

Agencies must not use speakerphones on telephones in TOP SECRET areas unless:

- it is located in a room rated as audio secure
- the room is audio secure during any conversations
- only personnel involved in discussions are present in the room.

Off-hook audio protection

Providing off-hook security minimises the chance of sensitive and classified conversations being accidentally coupled into handsets and speakerphones. Limiting the time an active microphone is open limits this threat.

Simply providing an off-hook audio protection feature is not sufficient to meet the requirement for its use. To ensure that the protection feature is used appropriately, personnel need to be made aware of the protection feature and trained in its proper use.

Control: 0236; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S; **Compliance:** should; **Authority:** AA

Agencies should ensure that off-hook audio protection features are used on all telephones that are not accredited for the transmission of sensitive or classified information in areas where such information could be discussed.

Control: 0931; **Revision:** 3; **Updated:** Sep-11; **Applicability:** S; **Compliance:** should; **Authority:** AA

Agencies should use push-to-talk handsets in open areas, and where telephones are shared.

Control: 0237; Revision: 2; Updated: Nov-10; Applicability: TS; Compliance: must; Authority: AH

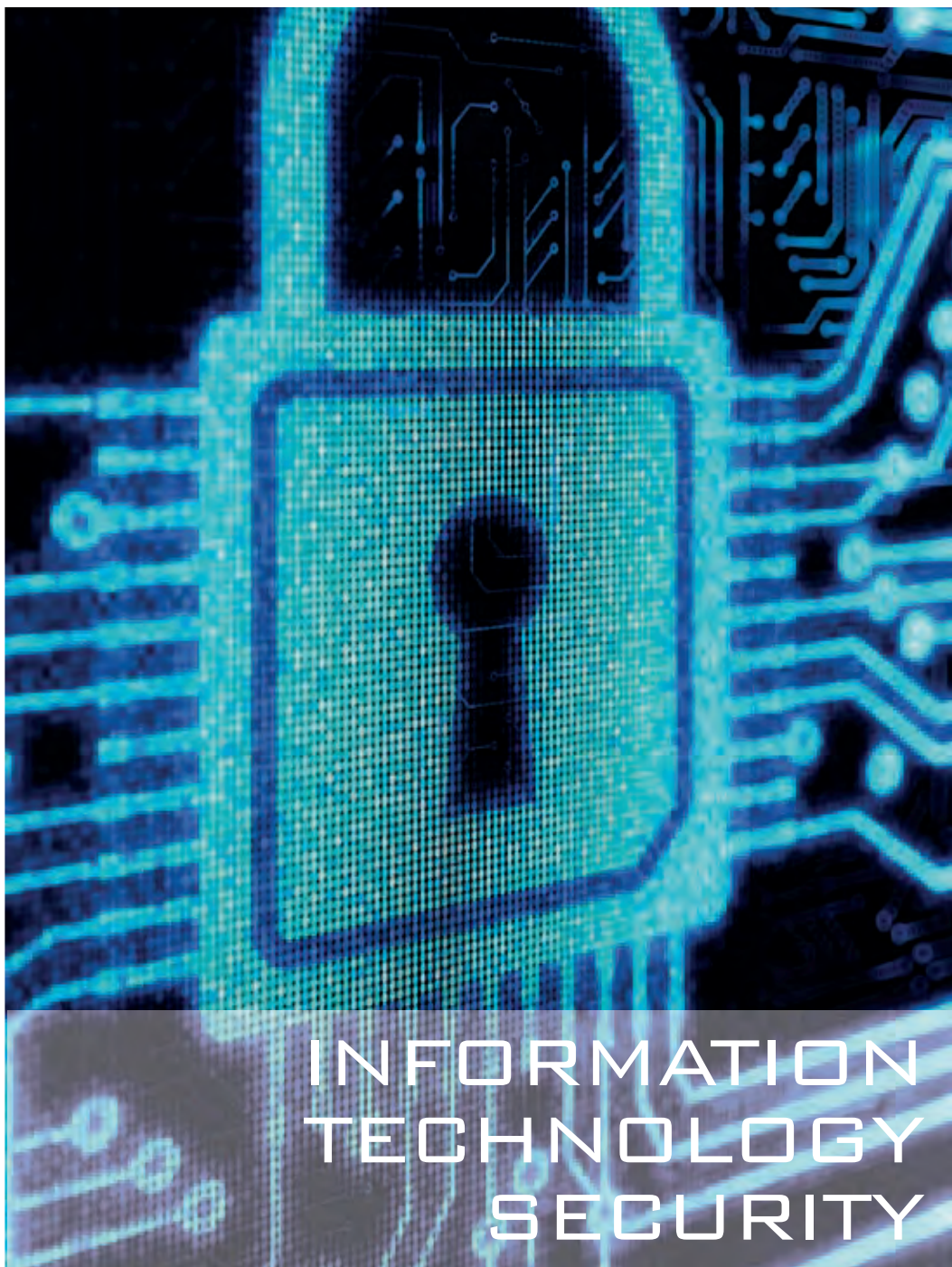
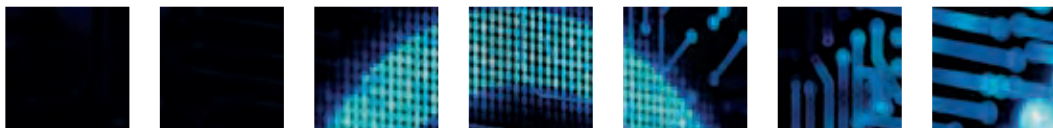
Agencies must ensure that off-hook audio protection features are used on all telephones that are not accredited for the transmission of classified information in areas where such information could be discussed.

Control: 0238; Revision: 0; Updated: Sep-08; Applicability: TS; Compliance: should; Authority: AA

Agencies should use push-to-talk handsets to meet the requirement for off-hook audio protection.

References

Further information relating to physical security is contained in the *Australian Government Physical Security Management Protocol*.



Information Technology Security

Product Security

Product Selection and Acquisition

Objective

Products providing security functions for the protection of information are formally evaluated.

Scope

This section describes selecting and acquiring products that provide security functionality. It does not describe selecting or acquiring products that do not provide security functionality or physical security products.

Agencies selecting products that do not provide a security function, or selecting products whose security functions will not be used and are disabled, do not need to comply with these requirements.

Context

Agencies need confidence that products perform as claimed by the vendor. This confidence is best achieved through a formal, and impartial, assessment of the product by an independent entity. The Defence Signals Directorate (DSD) publishes and maintains a list of products that have been formally, and independently, evaluated on their Evaluated Products List (EPL) on the DSD website.

Agencies can select products from any of DSD's recognised evaluation programs. The Australasian Information Security Evaluation Program (AISEP) is DSD's Common Criteria scheme that uses licensed commercial evaluation facilities to perform evaluations. Through the AISEP, DSD recognises evaluations from foreign Common Criteria schemes. Other DSD evaluation programs include a DSD Cryptographic Evaluation (DCE), high assurance evaluation and cross domain evaluation.

The scope of an evaluation and recommendations for the secure use of a product is provided in each of DSD's different evaluation programs. However, many products require third party hardware and software to operate, which can introduce new vulnerabilities that are not tested in the evaluation. This is a natural outcome of greater product convergence and inter-network connectivity. Therefore, agencies must read documentation associated with each evaluation to determine what the evaluation included and any recommendations for the product's secure use.

Product specific requirements

For DSD evaluated products, a consumer guide is made available on the EPL. Where consumer guides exist for evaluated products, the requirements in the consumer guides take precedence over those in this manual.

Agencies must comply with specific guidance on high assurance products and High Grade Cryptographic Equipment (HGCE) for handling CONFIDENTIAL and above information. Such guidance is published in Australian Communications Security Instructions (ACSIIs) by DSD. The requirements in ACSIIs take precedence over those in this manual.

Convergence

Convergence is the integration of a number of discrete technologies into one product, such as mobile devices that integrate voice and data services. Converged solutions can include the advantages of each discrete technology but also present the vulnerabilities of each discrete technology at the same time. Furthermore, some vulnerabilities may be unique to converged products due to combination of technologies present in the product and their interaction with each other. When products have converged elements, the relevant areas of this manual for each of the discrete elements are applicable.

Controls

Product selection preference order

Products evaluated in the AISEP under the international Common Criteria standard are the most commonly listed products on the EPL. Common Criteria evaluations have an Evaluation Assurance Level (EAL) number from 1-7, of which 1-4 inclusive are internationally recognised under the Common Criteria Mutual Recognition Arrangement. Product vendors select an EAL number based on their customer demands. Product vendors also determine the scope of any evaluation activities, which may or may not include the security functionality an agency requires. The scope of the evaluation is not related to the EAL number. Agencies can read the Security Target and Certification Report for a product to understand what security functionality was included in an evaluation. This will allow the agency to determine if the security functionality evaluated in the product meets their needs.

To assist agencies in selecting appropriate products; DSD has introduced approved Protection Profiles for specific technologies. A Protection Profile is a document that stipulates the security functionality that must be included in a Common Criteria evaluation. Agencies can have confidence that the scope of an evaluation against a DSD approved Protection Profile covers the necessary security functionality expected of the evaluated product and known security vulnerabilities will have been addressed.

Products entered into the AISEP for evaluation against a DSD approved Protection Profile will be given the highest priority for evaluation. These evaluations are expected to be faster than traditional evaluations, which will enable the AISEP to keep pace with evaluating updates to products. Cryptographic security functionality is also included in scope of products evaluated against a DSD approved Protection Profile; however, DSD will continue to require a DCE for products intended for use with PROTECTED information.

DSD is currently establishing cryptographic testing as part of AISEP Common Criteria evaluations. When this is established, evaluations against a DSD approved Protection Profile will not require a separate DCE and evaluations will be completed much faster.

The *Network Device Protection Profile* (NDPP) is the first DSD approved Protection Profile and is to be used for layer 3 network infrastructure devices such as routers and firewalls. Specific security functionality will be added to the NDPP, such as firewall traffic filtering, as part of maintaining technical currency of the Protection Profile. All DSD approved Protection Profiles are published on the EPL.

Other technology Protection Profiles may be developed in the Common Criteria that are recognised by DSD through the Common Criteria Recognition Arrangement. However, Protection Profiles that are not marked as DSD approved Protection Profiles will not be given any priority for evaluation in the AISEP.

While products evaluated against a DSD approved Protection Profile will fulfil the Common Criteria EAL requirements, the EAL number will not be published on the EPL. This is due to requirements for EAL numbers being gradually replaced by DSD approved Protection Profiles in this manual.

An agency may find that a product they wish to use is not available through the product selection preference order. If it is a technology gap, agencies should recommend DSD evaluate the product through sponsorship. If agencies select a product that has not completed an evaluation, the decision must be documented and the security risks accepted by the agency.

Control: 0280; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must select products in the following order of preference, depending on their needs:

- first preference – products that have completed either:
 - a DSD high grade or high assurance evaluation
 - a Common Criteria evaluation against a DSD approved Protection Profile
 - a Common Criteria evaluation through the AISEP or a Common Criteria scheme recognised under the Common Criteria Recognition Arrangement
- second preference – products that are currently in evaluation in the AISEP or DSD
- third preference – products in evaluation in a scheme where the outcome will be recognised by DSD when the evaluation is completed and published on the EPL or Common Criteria portal.
- fourth preference – products that are neither in evaluation or have completed an evaluation.

Control: 0282; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must document the justification for selecting a product that has not completed an evaluation and accept any security risk introduced by the use of such a product.

Product selection

Agencies can determine that an evaluated product from the EPL is suitable by reviewing its evaluation documentation. This documentation includes the Security Target, Certification Report and Consumer Guide. In particular, agencies need to determine if the scope or target of evaluation (including security functionality and the operational environment) is suitable for their needs.

When selecting a product with security functionality, whether it has or has not been evaluated, agencies must implement best practice security measures. The EPL cannot include all products and versions and even an evaluated product from the EPL will need to have its security managed continuously as new vulnerabilities are constantly being discovered in products.

A product listed on the EPL might not meet an agency's security requirements if the scope of the evaluation does not include its intended use or the operational environment differs from that assumed in the evaluation.

Products that are in evaluation will not have a Certification Report and may not have a published Security Target. A draft Security Target can be obtained from DSD for products that are in evaluation through the AISEP. For products that are in evaluation through a foreign scheme, the product vendor can be contacted directly for further information.

Control: 0279; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should select products that have their desired security functionality in the scope of the product's evaluation and are applicable to the intended environment.

Product specific requirements

A Consumer Guide is provided on the EPL which gives specific guidance on the evaluated products use. Additionally product specific requirements may also be produced for high assurance products and HGCE

Control: 0463; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must check consumer guides for products, where available, to determine any product specific requirements.

Control: 0464; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Where product specific requirements exist in a consumer guide for a product, agencies must comply with the requirements outlined in the consumer guide.

Control: 0283; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies selecting high assurance products and HGCE must contact DSD and comply with any product specific requirements.

Delivery of products

It is important that agencies ensure that the product that is intended for use is the actual product that is received. For evaluated products, if the product received differs from the evaluated version, then the assurance gained from any evaluation may not necessarily apply. For unevaluated products that do not have evaluated delivery procedures, it is recommended agencies assess whether the vendor's delivery procedures are sufficient to maintain the integrity of the product.

Other factors to consider when assessing delivery procedures include:

- the intended environment of the product
- the types of attackers that the product will defend against
- the resources of any potential attackers
- the likelihood of an attack
- the importance of maintaining confidentiality of the product purchase
- the importance of ensuring adherence to delivery timeframes.

Delivery procedures can vary greatly from product to product. For most products the standard commercial practice for packaging and delivery could be sufficient for agencies' requirements. Examples of other secure delivery procedures can include tamper evident seals, cryptographic checksums and signatures, and secure transportation.

Agencies will also need to confirm the integrity of the software that has been delivered before deploying it on an operational system to ensure that no unintended software is installed at the same time. Software delivered on physical media, and software delivered over the Internet, could contain malicious code or malicious content that is installed along with the legitimate software.

Control: 0285; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure that products are delivered in a manner consistent with any delivery procedures defined in associated documentation.

Control: 0286; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: DSD

Agencies procuring high assurance products and HGCE must contact DSD and comply with any product specific delivery procedures.

Control: 0937; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure that products purchased without the delivery assurances provided through the use of formally evaluated procedures are delivered in a manner that provides confidence that they receive the product that they expect to receive in an unaltered state.

Control: 0284; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should:

- verify the integrity of software using vendor supplied checksums when available
- validate the software's interaction with the operating system and network in a test environment prior to use on operational systems.

Leasing arrangements

Agencies should consider security and policy requirements when entering into a leasing agreement for products in order to avoid potential cyber security incidents during maintenance, repairs or disposal processes.

Control: 0287; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should ensure that leasing agreements for products take into account the:

- difficulties that could be encountered when the product needs maintenance
- difficulties that could be encountered in sanitising a product before returning it
- the possible requirement for destruction if sanitisation cannot be performed.

Ongoing maintenance of assurance

Developers that have demonstrated a commitment to continuous evaluation of product versions are more likely to ensure that security updates and changes are independently assessed.

A developer's commitment to continuity of assurance can be gauged through the number of evaluations undertaken and whether assurance maintenance has been performed on previous evaluations.

Control: 0938; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should choose products from developers that have made a commitment to the continuing maintenance of the assurance of their product.

References

Additional information on the EPL, AISEP, Protection Profiles and the Common Criteria can be found at:

- <http://www.dsd.gov.au/infosec/epl.htm>
- <http://www.dsd.gov.au/infosec/aisep.htm>
- <http://www.commoncriteriaportal.org/>
- <http://www.commoncriteriaportal.org/schemes.html>
- <http://www.commoncriteriaportal.org/ccra/>.

Product Installation and Configuration

Objective

Products are installed and configured using best practice security.

Scope

This section describes installing and configuring evaluated products that provide security functionality. It does not describe installing and configuring general products or physical security products.

Context

Evaluated configuration

An evaluated product is considered to be operating in its evaluated configuration if:

- functionality that it uses was in the scope or target of evaluation and implemented in the specified manner
- only product updates that have been assessed through a formal assurance continuity process have been applied
- the environment complies with assumptions or organisational security policies stated in the product's Security Target or similar document.

Unevaluated configuration

An evaluated product is considered to be operating in an unevaluated configuration when it does not meet the requirements of the evaluated configuration and guidance provided from the Certification Report.

Patching evaluated products

Agencies need to consider that evaluated products may have had patches applied since the time they were evaluated. In the majority of cases, the latest patched product version is more secure than the older evaluated product version. While the application of security patches will normally not place a product in an unevaluated configuration, some product vendors incorporate new functionality with security patches, which have not been evaluated. In such cases agencies will need to use their judgement to determine whether the product remains in an evaluated configuration or whether sufficiently new functionality has been incorporated into the product such that it no longer remains in an evaluated configuration.

Controls

Installation and configuration of evaluated products

Evaluation of products provides assurance that the product will work as expected in a clearly defined configuration. The scope or target of evaluation specifies the security functionality that can be used and how the product is configured and operated.

Using an evaluated product in a manner for which it was not intended could result in the introduction of new vulnerabilities that were not considered as part of the evaluation.

For products evaluated under the Common Criteria, information is available from the product vendor in the product's installation, administrator and user guidance documentation. Further information is also available in the Security Target and Certification Report. For high assurance products and HGCE configuration guidance, documents can be obtained from DSD.

Control: 0289; **Revision:** 1; **Updated:** Sep-09; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should install, configure, operate and administer evaluated products in accordance with available documentation resulting from the product's evaluation.

Control: 0290; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** DSD

Agencies must ensure that high assurance products and HGCE are installed, configured, operated and administered in accordance with all product specific guidance produced by DSD.

Use of evaluated products in unevaluated configurations

When using a product in a manner for which it was not intended, a security risk assessment must be conducted upon the unevaluated configuration. The further a product deviates from its evaluated configuration, the less assurance can be gained from the evaluation.

Given the potential threat vectors and the value of the information being protected, high assurance products and HGCE must be configured in accordance with DSD's guidance.

Control: 0291; **Revision:** 3; **Updated:** Sept-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies wishing to use an evaluated product in an unevaluated configuration must undertake a security risk assessment including:

- the necessity of the unevaluated configuration
- testing of the unevaluated configuration in the agency's environment
- new vulnerabilities introduced due to the product being used outside of its evaluated configuration.

Control: 0292; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must not; **Authority:** DSD

High assurance products and HGCE must not be used in an unevaluated configuration.

References

Nil.

Product Classifying and Labelling

Objective

Products and Information and Communications Technology (ICT) equipment are classified and appropriately labelled.

Scope

This section describes classifying and labelling of both evaluated products and general ICT equipment.

Context

Non-essential labels

Non-essential labels are labels other than protective marking and asset labels.

Controls

Classifying Information and Communications Technology equipment

When media is used in ICT equipment there is no guarantee that the equipment has not automatically accessed information from the media and stored it locally without the knowledge of the system user. The ICT equipment therefore needs to be afforded the same degree of protection as that of the associated media.

Control: 0293; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must classify ICT equipment based on the sensitivity or classification of information for which the equipment and any associated media in the equipment are approved for processing, storing or communicating.

Labelling Information and Communications Technology equipment

The purpose of applying protective markings to all ICT equipment in an area is to reduce the likelihood that a system user will accidentally input sensitive or classified information into another system residing in the same area that is not accredited to handle that information.

Applying protective markings to assets helps determine the appropriate sanitisation, disposal or destruction requirements of the ICT equipment based on its sensitivity or classification.

Control: 0294; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must clearly label all ICT equipment capable of storing information, with the exception of HGCE, with the appropriate protective marking.

Control: 1168; **Revision:** 0; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

When using non-textual protective markings for ICT equipment due to operational security reasons, agencies must document the labelling scheme and train personnel appropriately.

Labelling high assurance products

High assurance products often have tamper-evident seals placed on their external surfaces. To assist system users in noticing changes to the seals, and to prevent functionality being degraded, agencies must limit the use of non-essential labels.

Control: 0295; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must not; **Authority:** AH

Agencies must not have any non-essential labels applied to external surfaces of high assurance products.

Labelling High Grade Cryptographic Equipment

HGCE often have tamper-evident seals placed on their external surfaces. To assist system users in noticing changes to the seals, and to prevent functionality being degraded, agencies must only place seals on equipment when approved by DSD to do so.

Control: 0296; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: DSD

Agencies must seek DSD authorisation before applying labels to external surfaces of HGCE.

References

Nil.

Product Maintenance and Repairs

Objective

Products and ICT equipment are repaired by cleared or appropriately escorted personnel.

Scope

This section describes maintaining and repairing of both evaluated products and general ICT equipment.

Context

Information relating to the sanitisation of ICT equipment and media can be found in the *Product Sanitisation and Disposal* section of this chapter and the *Media Sanitisation* section of the *Media Security* chapter.

Controls

Maintenance and repairs

Making unauthorised repairs to products and ICT equipment could impact the integrity of the product or equipment.

Using cleared technicians on-site is considered the most desired approach to maintaining and repairing ICT equipment. This ensures that if sensitive or classified information is disclosed during the course of maintenance or repairs the technicians are aware of the protection requirements for the information.

Control: 1079; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: DSD
Agencies must seek DSD approval before undertaking any repairs to high assurance products and HGCE.

Control: 0305; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Where possible, maintenance and repairs for ICT equipment should be carried out on-site by an appropriately cleared technician.

Maintenance and repairs by an uncleared technician

Agencies choosing to use uncleared technicians to maintain or repair ICT equipment need to be aware of the requirement for cleared personnel to escort the uncleared technicians during maintenance or repair activities.

Control: 0307; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
If an uncleared technician is used to undertake maintenance or repairs of ICT equipment, agencies should sanitise and reclassify or declassify the equipment and associated media before maintenance or repair work is undertaken.

Control: 0306; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
If an uncleared technician is used to undertake maintenance or repairs of ICT equipment, the technician must be escorted by someone who:

- is appropriately cleared and briefed
- takes due care to ensure that sensitive or classified information is not disclosed
- takes all responsible measures to ensure the integrity of the equipment
- has the authority to direct the technician.

Control: 0308; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should ensure that the ratio of escorts to uncleared technicians allows for appropriate oversight of all activities.

Control: 0943; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

If an uncleared technician is used to undertake maintenance or repairs of ICT equipment, the technician should be escorted by someone who is sufficiently familiar with the equipment to understand the work being performed.

Off-site maintenance and repairs

Agencies choosing to have ICT equipment maintained or repaired off-site need to be aware of requirements for the company's off-site facilities to be approved to process and store the products at an appropriate level as specified by the *Australian Government Physical Security Management Protocol*.

Agencies choosing to have ICT equipment maintained or repaired off-site can sanitise and reclassify or declassify the equipment prior to transport and subsequent maintenance or repair activities to lower the physical transfer, processing and storage requirements specified by the *Australian Government Information Security Management Protocol* and *Australian Government Physical Security Management Protocol*.

Control: 0310; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies having ICT equipment maintained or repaired off-site must ensure that the physical transfer, processing and storage requirements are appropriate for the sensitivity or classification of the equipment and that procedures are complied with at all times.

Maintenance and repair of Information and Communications Technology equipment from secured spaces

When ICT equipment resides in an area that also contains ICT equipment of a higher classification, a technician could modify the lower classified ICT equipment in an attempt to compromise co-located ICT equipment of a higher classification.

Control: 0944; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies having ICT equipment maintained or repaired off-site should treat the equipment as per the requirements for the highest classification processed, stored or communicated in the area that the equipment will be returned to.

References

Nil.

Product Sanitisation and Disposal

Objective

Products and ICT equipment are sanitised and disposed of in an approved manner.

Scope

This section describes sanitising and disposing of both evaluated products and general ICT equipment.

Context

Additional information on the sanitisation, destruction and disposal of media can be found in the *Media Security* chapter.

With the convergence of technology, for example some televisions and even electronic whiteboards now contain non-volatile media, sanitisation requirements are becoming increasingly more complex.

Media typically found in ICT equipment includes:

- electrostatic memory devices such as laser printer cartridges and photocopier drums
- non-volatile magnetic memory such as hard disks
- non-volatile semi-conductor memory such as flash cards
- volatile memory such as Random Access Memory sticks.

Controls

Disposal of Information and Communications Technology equipment

When disposing of ICT equipment, agencies need to sanitise any media in the equipment that is capable of storing sensitive or classified information, remove the media from the equipment and dispose of it separately or destroy the equipment in its entirety. Once the media in ICT equipment has been sanitised or removed, the equipment can be considered sanitised. Following subsequent declassification approval from the owner of the information previously processed by the ICT equipment, it can be disposed of into the public domain.

DSD provides specific advice on how to securely dispose of high assurance products, HGCE and TEMPEST rated ICT equipment. There are a number of security risks that can occur due to improper disposal including providing an attacker with an opportunity to gain insight into government capabilities.

Control: 0313; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must have a documented process for the disposal of ICT equipment.

Control: 0311; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
When disposing of ICT equipment containing sensitive or classified media, agencies must sanitise the equipment by either:

- sanitising the media within the equipment
- removing the media from the equipment and disposing of it separately
- destroying the equipment in its entirety.

Control: 0314; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must contact DSD and comply with any requirements for the disposal of high assurance products.

Control: 0315; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: DSD
Agencies must contact DSD and comply with any requirements for the disposal of HGCE.

Control: 0321; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: DSD
Agencies must contact DSD and comply with any requirements for disposing of TEMPEST rated ICT equipment.

Control: 0312; Revision: 2; Updated: Sep-11; Applicability: P, C, S, TS; Compliance: should; Authority: AA
Agencies should return ICT equipment and associated media that have processed or stored Australian Eyes Only or Australian Government Access Only information to Australia for disposal.

Control: 0316; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must formally authorise the disposal of ICT equipment, or waste, into the public domain.

Sanitising printer cartridges and copier drums

Printing random text with no blank areas on each colour printer cartridge or drum ensures that no residual information will be kept on the printer or copier. DSD is able to provide a suitable sanitisation file to use upon request.

Control: 0317; Revision: 1; Updated: Sep-09; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must print at least three pages of random text with no blank areas on each colour printer cartridge or copier drum.

Destroying printer cartridges and copier drums

When printer cartridges and copier drums cannot be sanitised due to a hardware failure, or when they are empty, there is no other option available but to destroy them.

Control: 0318; Revision: 1; Updated: Sep-09; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies unable to sanitise printer cartridges or copier drums must destroy the cartridge or drum in accordance with the requirements for electrostatic memory devices.

Disposal of televisions and computer monitors

Turning up the brightness to the maximum level on televisions and computer monitors will allow agencies to easily determine if information has been burnt in or persists upon the screen.

Control: 0319; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must visually inspect televisions and computer monitors by turning up the brightness to the maximum level to determine if any information has been burnt into or persists on the screen.

Sanitising televisions and computer monitors

All types of televisions and computer monitors are capable of retaining information on the screen if appropriate mitigation measures are not taken during the lifetime of the screen. Cathode ray tube monitors and plasma screens can be affected by burn-in while liquid crystal display screens can be affected by image persistence.

Control: 1076; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must attempt to sanitise televisions and computer monitors with minor burn-in or image persistence by displaying a solid white image on the screen for an extended period of time.

References

Nil.

Media Security

Media Handling

Objective

Media is classified and labelled.

Scope

This section describes classifying and labelling media.

Context

Information relating to classifying and labelling Information and Communications Technology (ICT) equipment can be found in the *Product Classifying and Labelling* section of the *Product Security* chapter. Information on accounting for ICT media can be found in the *ICT Equipment and Media* section of the *Physical Security* chapter.

Controls

Reclassification and declassification procedures

When reclassifying or declassifying media, the process is based on an assessment of relevant issues, including:

- the consequences of damage from unauthorised disclosure or misuse
- the effectiveness of any sanitisation or destruction procedure used
- the intended destination of the media.

Control: 0322; **Revision:** 0; **Updated:** Sep-08; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must document procedures for the reclassification and declassification of media.

Classifying media storing information

Media that is not correctly classified can be stored, identified and handled inappropriately or accessed by a person who does not have the appropriate security clearance.

Control: 0323; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must classify media to the highest sensitivity or classification stored on the media since any previous reclassification.

Classifying media connected to systems

There is no guarantee that sensitive or classified information has not been copied to media while connected to a system unless either read-only devices or read-only media are used.

Control: 0325; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

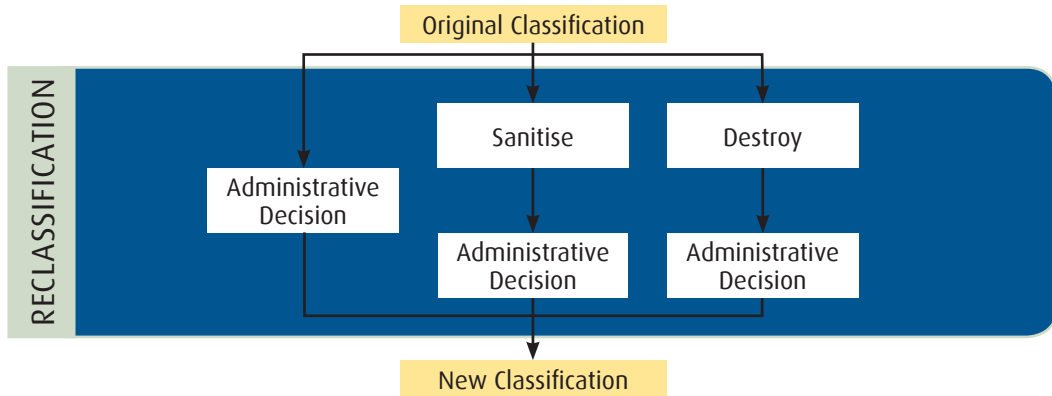
Agencies must classify any media connected to a system the same sensitivity or classification as the system, unless either:

- the media is read-only
- the media is inserted into a read-only device
- the system has a mechanism through which read-only access can be assured.

Reclassifying media

The media will always need to be protected according to the sensitivity or classification of the information it stores. If the sensitivity or classification of the information on the media changes, then so will the protection afforded to the media.

The following diagram shows an overview of the mandated reclassification process.



Control: 0330; **Revision:** 2; **Updated:** Nov-10; **Applicability:** P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies wishing to reclassify media to a lower classification must ensure that:

- the reclassification of all information on the media has been approved by the originator, or the media has been appropriately sanitised or destroyed.
- a formal administrative decision is made to reclassify the media.

Control: 0331; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must reclassify media if either:

- information copied onto the media is of a higher classification than the sensitivity or classification of the information already on the media
- information contained on the media is subjected to a classification upgrade.

Labelling media

Labelling helps personnel to identify the sensitivity or classification of media and ensure that they afford the media the correct security measures.

Control: 0332; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should label media with a marking that indicates the sensitivity or classification applicable to the information it stores; unless it is internally mounted fixed media and the ICT equipment containing the media is labelled.

Control: 0333; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must ensure that the sensitivity or classification of all media is easily visually identifiable.

Control: 0334; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

When using non-textual protective markings for media due to operational security reasons, agencies must document the labelling scheme and train personnel appropriately.

Labelling sanitised media

It is not possible to apply the sanitisation and reclassification process to non-volatile media in a cascaded manner. Therefore, SECRET media that has been sanitised and reclassified to a CONFIDENTIAL level must be labelled as to avoid inadvertently being reclassified to a lower classification a second time.

The sanitisation of TOP SECRET non-volatile media does not allow for the reduction of its classification. The classification of TOP SECRET non-volatile media can only be reduced via destruction.

Control: 0335; **Revision:** 3; **Updated:** Sep-11; **Applicability:** S; **Compliance:** must; **Authority:** AH

Agencies must label non-volatile media that has been sanitised and reclassified with a notice similar to: 'Warning: media has been sanitised and reclassified from SECRET to CONFIDENTIAL. Further lowering of classification only via destruction.'

References

For further information on media security see the *Australian Government Physical Security Management Protocol* and *Australian Government Information Security Management Protocol*.

Media Usage

Objective

Media is used with systems in a controlled and accountable manner.

Scope

This section describes the requirements needed to use media with sensitive or classified information. This section includes information on connecting media to systems, using media to transfer information and storage of media. The controls are equally applicable to all devices containing media, such as external hard drives, cameras, mobile phones, digital audio players and portable media players.

Context

Further information on using media to transfer data between systems can be found in the *Data Transfer* section of the *Network Security* chapter. More information on reducing storage and physical transfer requirements can be found in the *Cryptographic Fundamentals* section of the *Cryptography* chapter.

Controls

Using media with systems

To prevent data spills agencies need to prevent sensitive or classified media from being connected to, or used with, systems not accredited to process, store or communicate the information on the media.

Control: 0337; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must not; **Authority:** AH

Agencies must not use media with a system that is not accredited to process, store or communicate the information on the media.

Storage of media

The requirements for the storage and physical transfer of sensitive or classified information media are specified in the *Australian Government Physical Security Management Protocol* and *Australian Government Information Security Management Protocol*.

Control: 0338; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must ensure that sensitive or classified media meets the minimum physical security storage requirements in the *Australian Government Physical Security Management Protocol*.

Connecting media to systems

Some operating systems provide the functionality to automatically execute certain types of programs that reside on optical media and flash drives. While this functionality was designed with a legitimate purpose in mind—such as automatically loading a graphical user interface for the system user to browse the contents of the media, or to install software residing on the media—it can also be used for malicious purposes.

An attacker can create a file on media that the operating system believes it should automatically execute. When the operating system executes the file, it can have the same effect as when a system user explicitly executes malicious code. However, in this case the system user is taken out of the equation as the operating system executes the file without explicitly asking the system user for permission.

Some operating systems will cache information on media to improve performance. Using media with a system could therefore cause data to be read from the media without user intervention.

Device access control and data loss prevention software allows greater control over media that can be connected to a system and the manner in which it can be used. This assists in preventing unauthorised media being connected to a system and, if desired, preventing information from being written to it.

Media can also be prevented from connecting to a system by physical means including, but not limited to, using wafer seals or applying epoxy to the connection ports. If physical means are used to prevent media connecting to a system, then procedures covering detection and reporting processes are needed in order to respond to attempts to bypass these controls.

Control: 0341; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must disable any automatic execution features in operating systems for connectable media.

Control: 0342; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must prevent unauthorised media from connecting to a system via the use of either:

- device access control or data loss prevention software
- physical means.

Control: 0343; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should prevent media being written to, via the use of device access control or data loss prevention software, if there is no business need.

External interface connections that allow Direct Memory Access

Known vulnerabilities have been demonstrated where attackers can connect media to a locked workstation via a communications port that allows Direct Memory Access (DMA) and subsequently gain access to encryption keys in memory. Furthermore, with DMA an attacker can read or write any content to memory that they desire. The best defence against this vulnerability is to disable access to communication ports using either software controls or physically preventing access to the communication ports so that media cannot be connected. Communication ports that can connect media that utilise DMA are IEEE 1394 (FireWire), ExpressCard and Thunderbolt.

Control: 0344; Revision: 3; Updated: Sep-11; Applicability: G, P; Compliance: should; Authority: AA
Agencies should disable external interfaces on a system that allows DMA, if there is no business need.

Control: 0345; Revision: 3; Updated: Sep-11; Applicability: C, S, TS; Compliance: must; Authority: AH
Agencies must disable external interfaces on a system that allows DMA, if there is no business need.

Transferring media

As media is often transferred through areas not certified and accredited to process the sensitive or classified information on the media, protection mechanisms need to be put in place to protect the information. When applying encryption to media it may reduce the requirements for storage and physical transfer in the *Australian Government Physical Security Management Protocol* and *Australian Government Information Security Management Protocol*. Any reduction in requirements is based on the original sensitivity or classification of information residing on the media and the level of assurance in the cryptographic product being used to encrypt the media.

Further information on reducing storage and physical transfer requirements can be found in the *Cryptographic Fundamentals* section of the *Cryptography* chapter.

Control: 0831; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must ensure that media containing sensitive or classified information meets the minimum physical transfer requirements as specified in the *Australian Government Information Security Management Protocol*.

Control: 0832; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must encrypt media with at least a DSD Approved Cryptographic Algorithm (DACA) if it is to be transferred through an area not certified and accredited to process the sensitivity or classification of the information on the media.

Control: 1059; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should encrypt media with at least a DACA even if being transferred through an area certified and accredited to process the sensitivity or classification of the information on the media.

Using media for data transfers

Agencies transferring data between systems of different security domains, sensitivities or classifications are strongly encouraged to use write-once optical media. This will ensure that information from the one of the systems cannot be accidentally transferred onto the media then onto another system when the media is reused for the next transfer.

Control: 0347; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should not; Authority: AA

Agencies transferring data manually between two systems of different security domains, sensitivities or classifications should not use rewriteable media.

Media in secured areas

Ensuring certain types of media—including Universal Serial Bus, FireWire, Thunderbolt and eSATA capable media—must be explicitly approved in a TOP SECRET environment provides an additional level of system user awareness. This practice should be used in addition to device access control software on workstations in case system users are unaware of, or choose to ignore, security requirements for media.

Control: 1169; Revision: 0; Updated: Sep-11; Applicability: S; Compliance: should not; Authority: AA

Agencies should not permit any media that uses external interface connections in a SECRET area without prior written approval from the accreditation authority.

Control: 0346; Revision: 2; Updated: Nov-10; Applicability: TS; Compliance: must not; Authority: AH

Agencies must not permit any media that uses external interface connections in a TOP SECRET area without prior written approval from the accreditation authority.

References

For further information on media security see the *Australian Government Physical Security Management Protocol* and *Australian Government Information Security Management Protocol*.

Media Sanitisation

Objective

Media that is no longer required is sanitised.

Scope

This section describes sanitising media.

Context

Additional information relating to sanitising ICT equipment can be found in the *Product Sanitisation and Disposal* section of the *Product Security* chapter.

Sanitising media

Sanitisation is the process of removing information from media. It does not automatically change the sensitivity or classification of the media, nor does it involve the destruction of media.

Product selection

Agencies are permitted to use non-evaluated products to sanitise media. However, the product still needs to conform to the requirements for sanitising media as outlined in this section.

Hybrid hard drives

When sanitising hybrid hard drives, the sanitisation and post sanitisation requirements for flash memory devices apply.

Solid state drives

When sanitising solid state drives, the sanitisation and post sanitisation requirements for flash memory devices apply.

Government systems

All references to 'Government' in the tables relate to media containing unclassified but sensitive information not intended for public release, such as Dissemination Limiting Marker information. 'Government' is not a classification under the *Australian Government Security Classification System* as mandated by the Attorney-General's Department.

Controls

Sanitisation procedures

Sanitising media prior to reuse in a different environment ensures that information is not inadvertently accessed by unauthorised personnel or protected by insufficient security measures.

Using approved sanitisation methods provides a high level of assurance that no remnant data is left on the media.

The procedures used in this manual are designed not only to prevent common attacks that are currently feasible but also to protect from attacks that could emerge in the future.

When sanitising media, it is necessary to read back the contents of the media to verify that the overwrite process completed successfully.

Control: 0348; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
 Agencies must document procedures for the sanitisation of media.

Media that cannot be sanitised

Some types of media cannot be sanitised and therefore must be destroyed. It is not possible to use these types of media while maintaining a high level of assurance that no previous data can be recovered.

Control: 0350; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
 Agencies must destroy the following media types prior to disposal, as they cannot be sanitised:

- microfiche
- microfilm
- optical discs
- printer ribbons and the impact surface facing the platen
- programmable read-only memory
- read-only memory
- faulty media that cannot be successfully sanitised.

Volatile media sanitisation

When sanitising volatile media, the specified time to wait following removal of power is based on applying a safety factor to times recommended in research on recovering the contents of volatile media.

Control: 0351; Revision: 2; Updated: Sep-11; Applicability: G, P; Compliance: must; Authority: AH
 Agencies must sanitise volatile media by either:

- removing power from the media for at least 10 minutes
- overwriting all locations of the media with a random pattern followed by a read back for verification.

Control: 0352; Revision: 2; Updated: Sep-11; Applicability: C, S, TS; Compliance: must; Authority: AH
 Agencies must sanitise volatile media by overwriting the media at least once in its entirety with a random pattern, followed by a read back for verification, followed by removing power from the media for at least 10 minutes.

Treatment of volatile media following sanitisation

Published literature supports short-term remanence effects (residual information that remains on media after erasure) in volatile media. Data retention times are reported to be in the magnitude of minutes (at normal room temperatures) to hours (in extreme cold). Further, published literature has shown that some volatile media can suffer from long-term remanence effects resulting from physical changes to the media due to continuous storage of static data for an extended period of time. It is for these reasons that under certain circumstances TOP SECRET volatile media must always remain at this classification, even after sanitisation.

Control: 0353; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
 Following sanitisation, volatile media must be treated no less than as indicated below.

PRE-SANITISATION HANDLING	POST-SANITISATION HANDLING
TOP SECRET	Unclassified (under certain circumstances)
SECRET	Unclassified
CONFIDENTIAL	Unclassified
PROTECTED	Unclassified
Government	Unclassified

Circumstances preventing reclassification of volatile media

Typical circumstances preventing the reclassification of TOP SECRET volatile media include a static cryptographic key being stored in the same memory location during every boot of a device and a static image being displayed on a device and stored in volatile media for a period of months.

Control: 0835; Revision: 1; Updated: Nov-10; Applicability: TS; Compliance: must not; Authority: AH

Volatile media must not be reclassified below TOP SECRET if the volatile media either:

- stored sensitive, static, data for an extended period of time
- sensitive data was repeatedly stored or written to the same memory location for an extended period of time.

Non-volatile magnetic media sanitisation

Both the host protected area and device configuration overlay table of non-volatile magnetic hard disks are normally not visible to the operating system or the computer's basic input/output system. Hence any sanitisation of the readable sectors on the media will not overwrite these hidden sectors leaving any information contained in these locations untouched. Some sanitisation programs include the ability to reset devices to their default state removing any host protected areas or device configuration overlays. This allows the sanitisation program to see the entire contents of the media during the subsequent sanitisation process.

Modern non-volatile magnetic hard disks automatically reallocate space for bad sectors at a hardware level. These bad sectors are maintained in what is known as the growth defects table or 'g-list'. If information was stored in a sector that is subsequently added to the g-list, sanitising the media will not overwrite these non-addressable bad sectors. While these sectors may be considered bad by the device, quite often this is due to the sectors no longer meeting expected performance norms for the device and not due to an inability to read/write to the sector. The Advanced Technology Attachment (ATA) secure erase command was built into the firmware of post-2001 devices and is able to access sectors that have been added to the g-list. Modern non-volatile magnetic hard disks also contain a primary defects table or 'p-list'. The p-list contains a list of bad sectors found during post-production processes. No information is ever stored in sectors on the p-list for a device as they are inaccessible before the media is used for the first time.

Control: 0354; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must sanitise non-volatile magnetic media by:

- if pre-2001 or under 15 Gigabytes: overwriting the media at least three times in its entirety with an random pattern followed by a read back for verification
- if post-2001 or over 15 Gigabytes: overwriting the media at least once in its entirety with an random pattern followed by a read back for verification.

Control: 1065; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should reset the host protected area and device configuration overlay table of non-volatile magnetic hard disks prior to overwriting the media.

Control: 1066; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should attempt to overwrite the growth defects table (g-list) on non-volatile magnetic hard disks.

Control: 1067; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should use the ATA secure erase command, where available, for sanitising non-volatile magnetic hard disks instead of using block overwriting software.

Control: 1068; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must boot from separate media to the media being sanitised to undertake the sanitisation process.

Treatment of non-volatile magnetic media following sanitisation

Highly classified non-volatile magnetic media cannot be sanitised below its original classification due to concerns with the sanitisation of the host protected area, device configuration overlay table and growth defects table.

Control: 0356; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
Following sanitisation, non-volatile magnetic media must be treated no less than as indicated below.

PRE-SANITISATION HANDLING	POST-SANITISATION HANDLING
TOP SECRET	TOP SECRET
SECRET	CONFIDENTIAL
CONFIDENTIAL	Unclassified
PROTECTED	Unclassified
Government	Unclassified

Non-volatile Erasable Programmable Read-only Memory media sanitisation

When erasing non-volatile Erasable Programmable Read-only Memory (EPROM), the manufacturer's specification for ultraviolet erasure time is multiplied by a factor of three to provide an additional level of certainty in the process.

Control: 0357; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
Agencies must sanitise non-volatile EPROM media by erasing in accordance with the manufacturer's specification, increasing the specified ultraviolet erasure time by a factor of three, then overwriting the media at least once in its entirety with a random pattern, followed by a read back for verification.

Non-volatile Electrically Erasable Programmable Read-only Memory media sanitisation

A single overwrite with a random pattern is considered best practice for sanitising non-volatile Electrically Erasable Programmable Read-only Memory (EEPROM) media.

Control: 0836; **Revision:** 1; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
Agencies must sanitise non-volatile EEPROM media by overwriting the media at least once in its entirety with a random pattern, followed by a read back for verification.

Treatment of non-volatile Erasable Programmable Read-only Memory and Electrically Erasable Programmable Read-only Memory media following sanitisation

As little research has been conducted on the ability to recover data on non-volatile EPROM or EEPROM media after sanitisation, highly classified media retains its original classification.

Control: 0358; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
Following sanitisation, non-volatile EPROM and EEPROM media must be treated no less than as indicated below.

PRE-SANITISATION HANDLING	POST-SANITISATION HANDLING
TOP SECRET	TOP SECRET
SECRET	CONFIDENTIAL
CONFIDENTIAL	Unclassified
PROTECTED	Unclassified
Government	Unclassified

Non-volatile flash memory media sanitisation

In flash memory media, a technique called wear levelling ensures that writes are distributed evenly across each memory block in flash memory. This feature necessitates flash memory being overwritten with a random pattern twice, rather than once, as this helps ensure that all memory blocks are overwritten during sanitisation.

Control: 0359; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must sanitise non-volatile flash memory media by overwriting the media at least twice in its entirety with a random pattern, followed by a read back for verification.

Treatment of non-volatile flash memory media following sanitisation

Due to the use of wear levelling in flash memory, it is possible that not all physical memory locations are written to when attempting to overwrite the media. Information can therefore remain on the media. This is why TOP SECRET, SECRET and CONFIDENTIAL flash memory media must always remain at their respective classification, even after sanitisation.

Control: 0360; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Following sanitisation, non-volatile flash memory media must be treated no less than as indicated below.

PRE-SANITISATION HANDLING	POST-SANITISATION HANDLING
TOP SECRET	TOP SECRET
SECRET	SECRET
CONFIDENTIAL	CONFIDENTIAL
PROTECTED	Unclassified
Government	Unclassified

Sanitising media prior to reuse

Sanitising media prior to reuse assists with enforcing the need-to-know principle.

Control: 0947; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should sanitise all media prior to reuse.

References

Further information on recoverability of information from volatile media can be found in the paper *Data Remanence in Semiconductor Devices* at http://www.usenix.org/events/sec01/full_papers/gutmann/gutmann.pdf.

The Random Access Memory (RAM) testing tool memtest86+ can be obtained from <http://memtest.org/>.

The graphics card RAM testing tool MemtestG80 can be obtained from <https://simtk.org/home/memtest>.

HDDerase is a freeware tool developed by the Center for Magnetic Recording Research at the University of California San Diego. It is capable of calling the ATA secure erase command for non-volatile magnetic hard disks. It is also capable of resetting host protected area and device configuration overlay table information on the media. The tool is available for download from <http://cmrr.ucsd.edu/people/Hughes/SecureErase.shtml>.

Information on *Reliably Erasing Data From Flash-Based Solid State Drives* can be found at <http://cseweb.ucsd.edu/users/swanson/papers/Fast2011SecErase.pdf>.

For further information on media security see the *Australian Government Physical Security Management Protocol* and *Australian Government Information Security Management Protocol*.

Media Destruction

Objective

Media that cannot be sanitised is destroyed.

Scope

This section describes the destruction of media.

Context

Additional information relating to the destruction of ICT equipment can be found in the *Product Sanitisation and Disposal* section of the *Product Security* chapter.

Government systems

All references to 'Government' in the tables relate to media containing unclassified but sensitive information not intended for public release, such as Dissemination Limiting Marker information. 'Government' is not a classification under the *Australian Government Security Classification System* as mandated by the Attorney-General's Department.

Controls

Destruction procedures

Documenting procedures for media destruction will ensure that agencies carry out media destruction in an appropriate and consistent manner.

Control: 0363; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must document procedures for the destruction of media.

Media destruction

The destruction methods given are designed to ensure that recovery of information is impossible or impractical.

Control: 0364; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
To destroy media, agencies must either:

- break up the media
- heat the media until it has either burnt to ash or melted
- degauss the media.

Control: 0366; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must use one of the methods shown in the table below.

ITEM	DESTRUCTION METHODS					
	FURNACE/ INCINERATOR	HAMMER MILL	DISINTEGRATOR	GRINDER/ SANDER	CUTTING	DEGAUSSER
Electrostatic memory devices	Yes	Yes	Yes	Yes	No	No
Magnetic floppy disks	Yes	Yes	Yes	No	Yes	Yes

ITEM	DESTRUCTION METHODS					
	FURNACE/ INCINERATOR	HAMMER MILL	DISINTEGRATOR	GRINDER/ SANDER	CUTTING	DEGAUSSER
Magnetic hard disks	Yes	Yes	Yes	Yes	No	Yes
Magnetic tapes	Yes	Yes	Yes	No	Yes	Yes
Optical disks	Yes	Yes	Yes	Yes	Yes	No
Semi-conductor memory	Yes	Yes	Yes	No	No	No

Media destruction equipment

Australian Security Intelligence Organisation (ASIO) T4 Protective Security evaluates security equipment for the purpose of destroying media. Approved security equipment is listed in the *Security Equipment Catalogue* published by the Security Construction and Equipment Committee (SCEC).

The National Security Agency/Central Security Service's Evaluated Products List – Degausser (EPLD) contains a list of certified degaussers.

The Government Communications Headquarters/Communications-Electronics Security Group's certified data erasure products list contains a list of certified degaussers.

Control: 0365; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must employ security equipment approved by the SCEC, and published in the *Security Equipment Catalogue*, for the purpose of media destruction.

Control: 1160; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must employ degaussers certified by the National Security Agency/Central Security Service or the Government Communications Headquarters/Communications-Electronics Security Group for the purpose of degaussing media.

Storage and handling of media waste particles

Following destruction, normal accounting and auditing procedures do not apply for media. It is therefore essential that when media is recorded as being destroyed, destruction is assured.

Control: 0368; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must, at minimum, store and handle the resulting media waste for all methods, except for furnace/incinerator and degausser, as indicated below.

INITIAL MEDIA HANDLING	SCREEN APERTURE SIZE PARTICLES CAN PASS THROUGH			
	LESS THAN OR EQUAL TO 3MM	LESS THAN OR EQUAL TO 6MM	LESS THAN OR EQUAL TO 9MM	LESS THAN OR EQUAL TO 12MM
TOP SECRET	Unclassified	PROTECTED	CONFIDENTIAL	SECRET
SECRET	Unclassified	Unclassified	PROTECTED	CONFIDENTIAL
CONFIDENTIAL	Unclassified	Unclassified	Unclassified	PROTECTED
PROTECTED	Unclassified	Unclassified	Unclassified	Unclassified
Government	Unclassified	Unclassified	Unclassified	Unclassified

Degaussers

Coercivity varies between media types and between brands and models of the same type of media. Care is needed when determining the desired coercivity since a degausser of insufficient strength will not be effective. The National Security Agency/Central Security Service's EPLD contains a list of common types of media and their associated coercivity ratings.

Since 2006 perpendicular magnetic media have become available. Some degaussers are only capable of sanitising longitudinal magnetic media. Care therefore needs to be taken to ensure that a suitable degausser is used when sanitising perpendicular magnetic media.

Agencies will need to comply with any product specific directions provided by product manufacturers and certification authorities to ensure that degaussers are being used in the correct manner to achieve an effective destruction outcome.

Control: 0361; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must use a degausser of sufficient field strength for the coercivity of the media.

Control: 0838; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must use a degausser capable of the magnetic orientation (longitudinal or perpendicular) of the media.

Control: 0362; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must comply with any product specific directions provided by product manufacturers and certification authorities.

Supervision of destruction

To ensure that media is appropriately destroyed it needs to be supervised to the point of destruction and have its destruction overseen by at least one person cleared to the sensitivity or classification of the media being destroyed.

Control: 0370; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must perform the destruction of media under the supervision of at least one person cleared to the sensitivity or classification of the media being destroyed.

Control: 0371; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Personnel supervising the destruction of media must:

- supervise the handling of the media to the point of destruction
- ensure that the destruction is completed successfully.

Supervision of accountable materiel destruction

Since accountable materiel is more sensitive than standard classified media, it needs to be supervised by at least two personnel and have a destruction certificate signed by the personnel supervising the process.

Control: 0372; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must perform the destruction of accountable materiel under the supervision of at least two personnel cleared to the sensitivity or classification of the media being destroyed.

Control: 0373; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Personnel supervising the destruction of accountable media must:

- supervise the handling of the material to the point of destruction
- ensure that the destruction is completed successfully
- sign a destruction certificate.

Outsourcing media destruction

ASIO T4 Protective Security maintains a list of commercial providers that are accredited to destroy media in an approved manner.

Control: 0839; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should not; **Authority:** AA
Agencies should not outsource the destruction of TOP SECRET media or accountable materiel.

Control: 0840; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
Agencies outsourcing the destruction of media to a commercial facility must use a facility that has been approved by ASIO T4 Protective Security.

Transporting media for off-site destruction

Requirements for the physical transfer of media between agencies and commercial facilities can be found in the *Australian Government Information Security Management Protocol*.

Control: 1069; **Revision:** 1; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Auth:** AA
Agencies should sanitise media, if possible, prior to transporting it to an off-site location for destruction.

References

Further information on the *Security Equipment Catalogue* and the SCEC can be found at <http://scec.gov.au/>.

The National Security Agency/Central Security Service's EPLD can be found at http://www.nsa.gov/ia/guidance/media_destruction_guidance/index.shtml.

The Government Communications Headquarters/Communications-Electronics Security Group's certified data erasure products list can be found at http://www.cesg.gov.uk/find_a/cert_products/index.php.

Information on the ASIO T4 protective security requirements can be found at <http://www.asio.gov.au/ASIO-and-National-Security/Units/T4-Protective-Security.html>.

For further information on media security see the *Australian Government Physical Security Management Protocol* and *Australian Government Information Security Management Protocol*.

Media Disposal

Objective

Media is declassified and approved for release before disposal into the public domain.

Scope

This section describes the disposal of media.

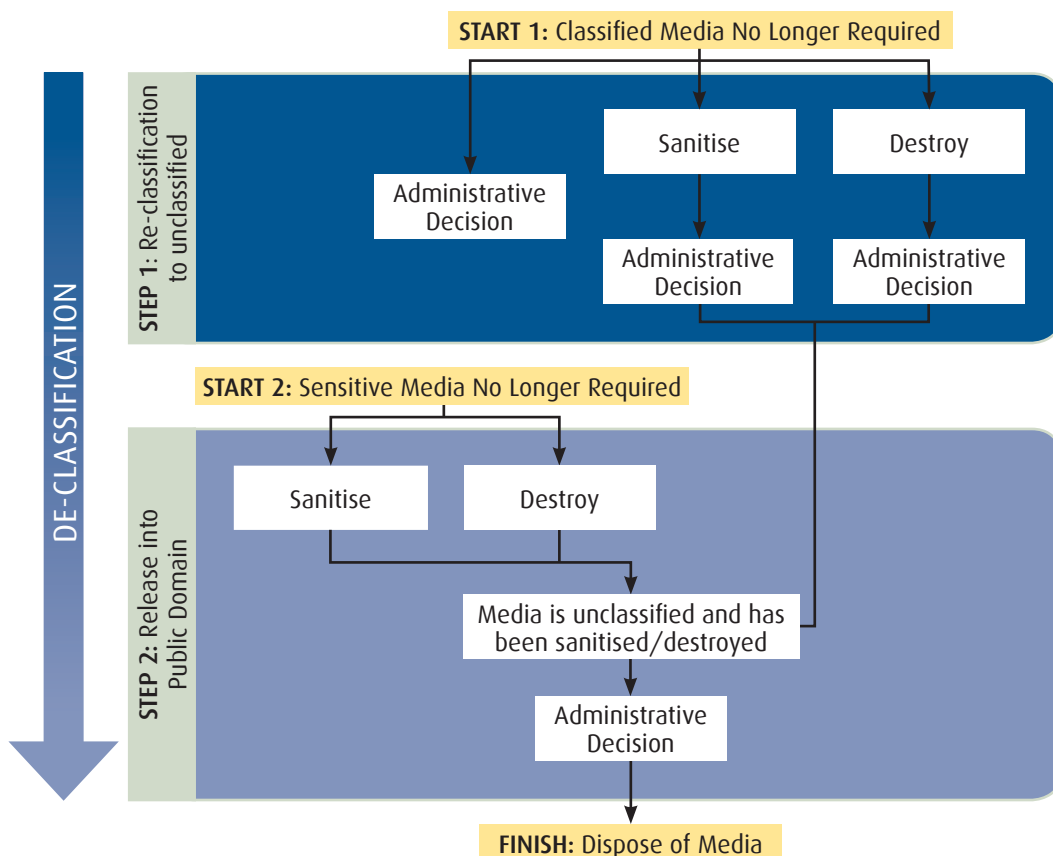
Context

Additional information relating to the disposal of ICT equipment can be found in the *Product Sanitisation and Disposal* section of the *Product Security* chapter.

Controls

Disposal procedures

The following diagram shows an overview of the typical disposal process. In the diagram there are two starting points, one for classified media and one for sensitive media. Also note that declassification is the entire process, including any reclassifications and administrative decisions, that must be completed before media and media waste can be released into the public domain.



Control: 0374; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
 Agencies must document procedures for the disposal of media.

Control: 0329; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
 Agencies declassifying media must ensure that:

- the media has been reclassified to an unclassified level either through an administrative decision, sanitisation or destruction
- a formal administrative decision is made to release the unclassified media, or its waste, into the public domain.

Declassifying media

The process of reclassifying, sanitising or destroying media is not sufficient for media to be declassified and released into the public domain. In order to declassify media a formal administrative decision will need to be made to release the media or waste into the public domain.

Control: 0375; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
 Agencies must declassify all media prior to disposing of it into the public domain.

Disposal of media

Disposing of media in a manner that does not draw undue attention ensures that previously sensitive or classified media is not subjected to additional scrutiny over that of regular waste.

Control: 0378; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
 Agencies must dispose of media in a manner that does not draw undue attention to its previous sensitivity or classification.

References

For further information on media security see the *Australian Government Physical Security Management Protocol* and *Australian Government Information Security Management Protocol*.

Software Security

Standard Operating Environments

Objective

Standard Operating Environments (SOEs) are secure.

Scope

This section describes the hardening of SOEs used on workstations and servers.

Context

The standards endorsed by the Whole of Government Common Operating Environment (COE) policy come into effect when an agency is ready to deploy a new version of their base SOE. Agencies are now required to build the SOE in accordance with the standards endorsed by the Australian Government Information Management Office (AGIMO).

Controls

Developing hardened Standard Operating Environments

Removing or disabling unneeded software and operating system components and functionality from a system reduces its attack surface. This could include removing hardware such as optical media burners or drivers for undesired inbuilt hardware components such as Bluetooth, wireless and webcams.

Antivirus and other Internet security software, while important, can be defeated by malicious code that has yet to be identified by vendors. This can include targeted attacks, where new malware is engineered or existing malware is modified to defeat the signature-based detection schemes used by most software.

The use of antivirus and other Internet security software adds value to the defence of workstations and servers, but it cannot be relied upon by itself to protect them. Hardened SOEs still need to be deployed to help protect against a broader range of security risks.

Control: 0380; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must develop a hardened SOE for workstations and servers, covering:

- removal of unneeded software, operating system components and hardware
- disabling of unused or undesired functionality in software, operating systems and hardware
- use of data execution prevention functionality, preferably hardware based, when available
- implementation of access controls on relevant objects to limit system users and programs to the minimum access required
- installation of antivirus or other Internet security software
- installation of software-based firewalls limiting inbound and outbound network connections
- configuration of either remote logging or the transfer of local event logs to a central server.

Maintaining hardened Standard Operating Environments

While a SOE can be sufficiently hardened when it is deployed, its security will progressively degrade over time.

Agencies can address the degradation of the security of a SOE by ensuring that:

- system users do not have the ability to install or disable software
- system users cannot disable or bypass security functionality
- antivirus and other Internet security software is appropriately maintained with the latest signatures.

Control: 0382; Revision: 2; Updated: Sept-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure that for all servers and workstations, system users do not have the ability to install or disable software.

Control: 1033; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure that for antivirus and other Internet security software on servers and workstations:

- detection heuristics are set to a high level
- pattern signatures are checked for updates on a daily basis
- pattern signatures are updated as soon as possible after vendors make them available
- all disks are regularly scanned for malicious code.

Vulnerabilities and patch availability awareness

It is important that agencies monitor relevant sources for information about new vulnerabilities and security patches. This way, they can take proactive steps to address vulnerabilities in their systems.

Control: 0297; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should monitor relevant sources for information about new vulnerabilities and security patches for software and Information and Communications Technology (ICT) equipment they use.

Patching vulnerabilities

Applying patches needs to be considered as part of an agency's security risk management program.

Critical patches are patches that address high risk vulnerabilities, such as vulnerabilities enabling unauthorised code execution by an attacker using the Internet.

If a patch is released for a high assurance product, the Defence Signals Directorate (DSD) will conduct an assessment of the patch and might revise the product's usage guidance. Likewise, for patches released for High Grade Cryptographic Equipment (HGCE), DSD will subsequently conduct an assessment of the cryptographic vulnerability and might revise usage guidance in the Consumer Guide for the product.

Control: 1143; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must have a patch management strategy.

Control: 0940; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must apply all security patches as soon as possible.

Control: 1144; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should apply all critical security patches within 2 days.

Control: 0298; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure that security patches are applied through centralised patch management wherever possible to better implement and control the patching of software.

Control: 0300; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must not; Authority: DSD

Agencies must not patch high assurance products or HGCE without the patch being approved by DSD.

When security patches are not available

When a security patch is not available for a known vulnerability there are a number of approaches to reducing the security risk to a system. This includes resolving the vulnerability through alternative means, preventing exploitation of the vulnerability, containing the exploit or implementing security measures to detect attacks attempting to exploit the vulnerability.

Control: 0941; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Where known vulnerabilities cannot be patched, or security patches are not available, agencies should implement one or more of:

- controls to resolve the vulnerability by either:
 - disabling the functionality associated with the vulnerability through product configuration
 - asking the vendor for an alternative method of managing the vulnerability
 - moving to a different product with a more responsive vendor
 - engaging a software developer to correct the software
- controls to prevent exploitation of the vulnerability by either:
 - applying external input sanitisation (if an input triggers the exploit)
 - applying filtering or verification on the software output (if the exploit relates to an information disclosure)
 - applying additional access controls that prevent access to the vulnerability
 - configuring firewall rules to limit access to the vulnerable software
- controls to contain the exploit by either:
 - applying firewall rules limiting outward traffic that is likely in the event of an exploitation
 - applying mandatory access control preventing the execution of exploitation code
 - setting file system permissions preventing exploitation code from being written to disk
- controls to detect attacks by either:
 - deploying an Intrusion Detection System (IDS)
 - monitoring logging alerts
 - using other mechanisms as appropriate for the detection of exploits using the known vulnerability.

Firmware updates

As firmware provides the underlying functionality for hardware it is essential that the integrity of any firmware images or updates are maintained.

Control: 0303; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AA

Agencies must ensure that any firmware updates are performed in a manner that verifies the integrity and authenticity of the updating process.

Unsupported software and products

Once a cessation date for support is announced for software or ICT equipment, agencies will find it increasingly difficult to protect against vulnerabilities found in the software or equipment as no security patches will be made available by the vendor. Once a cessation date for support is announced agencies should investigate new solutions that will be appropriately supported.

Control: 0304; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must assess the risk of using software or ICT equipment when a cessation date for support is announced or when the software or equipment is no longer supported by the vendor.

Default passphrases and accounts

Default passphrases and accounts for operating systems are often exploited by attackers as they are well documented in product manuals and can be easily checked in an automated manner with little effort required. When default passphrases are changed they must meet the requirements in the *Access Control* chapter of this manual.

Control: 0383; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must reduce potential vulnerabilities in their SOEs by:

- removing unused accounts
- renaming or deleting default accounts
- replacing default passphrases.

Functional separation between servers

Servers with a high value include those in a gateway environment such as web, email, file and Internet Protocol (IP) telephony servers.

Agencies may also implement separation through the use of techniques to restrict a process to a limited portion of the file system, but this is less effective.

Control: 0385; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Where high value servers have connectivity to public network infrastructure, agencies should:

- maintain effective functional separation between servers allowing them to operate independently
- minimise communications between servers at both the network and file system level as appropriate
- limit system users and programs to the minimum access needed to perform their duties.

Control: 0953; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure that functional separation between servers is achieved either:

- physically, using single dedicated machines for each function
- using virtualisation technology to create separate virtual machines for each function in the same security domain.

Using virtualisation for functional separation between servers

Virtualisation is approved as a method of achieving functional separation between servers if the servers reside in the same security domain. Virtualisation is not approved as a domain separation method.

Control: 0841; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should not; Authority: AA

Virtualisation technology should not be used for functional separation between servers in different security domains at the same classification.

Control: 0842; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must not; Authority: AH

Virtualisation technology must not be used for functional separation between servers of different classifications.

Characterisation

Characterisation is a technique used to analyse and record a system's configuration. It is important since it can be used to verify the system's integrity at a later date.

Methods of characterising files and directories include:

- performing a cryptographic checksum on files/directories when they are known to be virus/malware free
- documenting the name, type, size and attributes of legitimate files and directories, along with any changes to this information expected under normal operating conditions
- for a Windows system, taking a system difference snapshot.

There are known techniques for defeating basic characterisations. Therefore other methods of intrusion detection are also needed, particularly in situations where it is impractical to use a trusted operating environment for the generation of the characterisation data. However, it is very useful in post-intrusion forensic investigations where an infected disk can be compared to stored characterisation data in order to determine what files have been changed or introduced.

Control: 0386; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should:

- characterise all servers whose functions are critical, and those identified as being at a high risk of compromise
- store the characterisation information securely off the server in a manner that maintains its integrity
- update the characterisation information after every legitimate change to a system
- as part of the audit schedule, compare the stored characterisation information against current characterisation information to determine whether a compromise, or a legitimate but incorrectly completed system modification, has occurred
- perform the characterisation from a trusted environment rather than the standard operating system wherever possible
- resolve any detected changes in accordance with cyber security incident management procedures.

Control: 0954; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should meet the requirement for characterisation using a DSD Approved Cryptographic Algorithm to perform cryptographic checksums.

Automated outbound connections by software

Examples of applications that include beaconing functionality are applications that initiate a connection to the vendor website over the Internet (a continuous signalling of error or location information) and applications for inbound remote management.

Control: 0387; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should review all software applications to determine whether they attempt to establish any external connections.

Control: 0388; Revision: 1; Updated: Sep-09; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
If automated outbound connection functionality is included, agencies should make a business decision to determine whether to permit or deny these connections, including an assessment of the security risks involved in doing so.

Knowledge of software used on systems

Information about installed software that could be disclosed includes:

- user agent on web requests disclosing the web browser type
- network and email client information in email headers
- email server software headers.

This information could provide a malicious entity with knowledge of how to tailor attacks to exploit vulnerabilities in the systems.

Control: 0381; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should limit the disclosure of software installed on their systems.

References

Independent testing of different antivirus and other Internet security software and their effectiveness can be found at <http://www.av-comparatives.org/>.

Further information on the Whole of Government COE can be found at <http://www.finance.gov.au/e-government/strategy-and-governance/Whole-of-Government-ICT-Policies.html>.

Application Whitelisting

Objective

Only approved applications are used on operating systems.

Scope

This section describes the use of technical controls to restrict the specific applications that can be accessed by a system user or group of system users.

Context

Application whitelisting is an approach in which all executables and applications are prevented from executing by default. Those that are allowed to execute are explicitly specified.

Controls

Application whitelisting

Application whitelisting can be an effective mechanism to prevent the compromise of a system resulting from the exploitation of vulnerabilities in an application or from the execution of malicious code.

Defining a list of trusted executables—a whitelist—is a more practical and secure method of securing a system than relying on a list of bad executables to be prevented from running—a blacklist.

Application whitelisting is just one part of a defence-in-depth strategy for preventing attacks and reducing the consequences of attacks.

Control: 0843; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must implement application whitelisting as part of the SOE for both workstations and servers.

System user permissions

An average system user requires access to only a few applications, or groups of applications, in order to conduct their work. Restricting the system user's permissions to this limited set of applications reduces the opportunities for attacking the system.

Control: 0844; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must prevent a system user from running arbitrary executables.

Control: 0845; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must restrict a system user's rights in order to permit them to only execute a specific set of predefined executables as required for them to complete their duties.

Control: 0846; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must ensure that a system user cannot disable the application whitelisting mechanism.

Control: 0847; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must ensure that application whitelisting does not replace antivirus and other Internet security software already in place for a system.

System administrator permissions

Since the consequences of running malicious code as a privileged user are much more severe than as an unprivileged user, application whitelisting must also be enforced for system administrators.

Control: 0848; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must ensure that system administrators are not exempt from application whitelisting policy.

Application whitelisting configuration

A decision to execute should be made based on cryptographic hash as it is more secure than a decision based on the executable's signature, path or parent folder.

In order for application whitelisting to be effective, an agency must initially gather information on necessary executables and applications in order to ensure that the implementation is fully effective.

Different application whitelisting controls, such as restricting execution based on cryptographic hash or folder, have various advantages and disadvantages. Agencies need to be aware of this when implementing application whitelisting.

Application whitelisting based on parent folder or executable path is futile if access control list permissions allow a system user to write to the folders or overwrite permitted executables.

Adequate logging information can allow system administrators to further refine the application whitelisting implementation and detect patterns of occurrences of system users being denied access.

Control: 0849; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must ensure that the default policy is to deny the execution of software.

Control: 0851; Revision: 0; Updated: Sep-09; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should plan and test application whitelisting thoroughly prior to implementation.

Control: 0955; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should restrict the decision whether to run an executable based on the following, in the order of preference shown:

- cryptographic hash
- executable absolute path
- digital signature
- parent folder.

Control: 0956; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should restrict the write access to folders of any executables which are permitted to run by the application whitelisting controls.

Control: 0957; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should ensure logs from the application whitelisting implementation include all relevant information such as the enforcement setting, file name, date and time, and user name.

References

Further information on application whitelisting as implemented using AppLocker by Microsoft can be found at [http://technet.microsoft.com/en-us/library/dd723678\(W5.10\).aspx](http://technet.microsoft.com/en-us/library/dd723678(W5.10).aspx).

Web Content and Connections

Objective

Access to web content is implemented in a secure and accountable manner.

Scope

This section describes web browsers, plug-ins and active content including developing and implementing appropriate usage policies. The requirements in this section apply equally to websites accessed via the Internet as well as websites accessed on an intranet.

Context

This section covers factors that need to be taken into consideration when creating policy for the use of web applications to ensure the confidentiality, integrity and availability of information and to protect against the execution and spread of malware.

Controls

Web usage policy

If agencies allow system users to access the Web they will need to define the extent of web access that is granted. This can be achieved through a web usage policy and education of system users.

Control: 0258; **Revision:** 1; **Updated:** Sep-09; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
Agencies must have a policy governing appropriate web usage.

Web proxy

Web proxies provide valuable information in determining if malicious code is performing regular interactions over web traffic. Web proxies also provide usable information if system users are violating web usage policies.

Control: 0260; **Revision:** 0; **Updated:** Sep-08; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should use a web proxy for all web browsing activities.

Control: 0261; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
A web proxy should authenticate system users and provide logging that includes the following details about websites accessed:

- address (uniform resource locator)
- time/date
- system user
- amount of data uploaded and downloaded
- internal IP address
- external IP address.

Control: 1149; **Revision:** 1; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should block system users without a demonstrated business requirement from downloading executable files from external websites.

Applications and plug-ins

Web browsers can be configured to allow the automatic launching of downloaded files. This can occur with or without the system user's knowledge thus making the workstation vulnerable to attack.

Control: 0262; **Revision:** 0; **Updated:** Sep-08; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should block the automatic launching of files downloaded from external websites.

Secure Sockets Layer and Transport Layer Security filtering

Since Secure Sockets Layer (SSL) and Transport Layer Security (TLS) web traffic travelling over Hypertext Transfer Protocol Secure (HTTPS) connections can deliver content without any filtering, agencies can reduce this security risk by using SSL and TLS inspection so that web traffic can be filtered.

An alternative to SSL and TLS inspection for HTTPS websites is to allow websites that have a low risk of delivering malicious code and have a high privacy requirement, such as Internet banking, to continue to have end-to-end encryption.

Control: 0263; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies permitting SSL and TLS through their gateways should implement either:

- a solution that decrypts and inspects the SSL and TLS traffic as per content filtering requirements
- a whitelist specifying the addresses (uniform resource locators) to which encrypted connections are permitted, with all other addresses either blocked or decrypted and inspected as per content filtering requirements.

Inspection of Secure Sockets Layer and Transport Layer Security traffic

As encrypted SSL and TLS traffic may contain personally identifiable information agencies are recommended to seek legal advice on whether inspecting such traffic could be in breach of the *Privacy Act 1988*.

Control: 0996; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should seek legal advice regarding the inspection of encrypted SSL and TLS traffic by their gateways.

Whitelisting websites

Defining a whitelist of permitted websites and blocking all unlisted websites effectively removes one of the most common data delivery and exfiltration techniques used by malicious code. However, if system users have a legitimate requirement to access a numerous and rapidly changing list of websites, agencies will need to consider the costs of such an implementation.

Control: 0958; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should implement whitelisting for all Hypertext Transfer Protocol traffic being communicated through their gateways.

Control: 0995; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies using a whitelist on their gateways to specify the external addresses to which connections are permitted, should specify whitelist addresses by domain name or IP address.

Categorising websites

Websites can be grouped into categories and non work related categories can be blocked via a web content filter. There are specialised devices that categorise and allow access to websites.

Control: 1170; **Revision:** 0; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
If agencies do not whitelist websites they should implement categories for all websites and block prohibited categories and uncategorised sites.

Blacklisting websites

Blacklists are collections of websites that have been deemed to be inappropriate due to their content or hosting of malicious content. Sites are listed individually and can be categorised.

Agencies can extend blacklists to include dynamic and other domains where domain names can be registered anonymously for free. Intrusions commonly use such domains due to their lack of attribution.

Control: 0959; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

If agencies do not whitelist websites they should blacklist websites to prevent access to known malicious websites.

Control: 0960; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies blacklisting websites should update the blacklist on a daily basis to ensure that it remains effective.

Control: 1171; **Revision:** 0; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should block attempts to access a website through its IP address instead of through its domain name.

Client-side active content

Software that runs on systems should be controlled. Active content delivered through websites should be constrained so that it cannot arbitrarily access system users' files or deliver malicious code. Unfortunately the implementations of web browsers regularly contain flaws that permit such activity.

Control: 0961; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should block client-side active content, such as Java and ActiveX, which might not have a large business impact.

Control: 0962; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should:

- use client-side controls that allow JavaScript on a per website basis
- add JavaScript functions used only for malicious purposes to the web content filter or IDS.

Web content filter

Using a web proxy provides an opportunity to filter out potentially harmful information to system users and their workstations.

Control: 0963; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should use the web proxy to filter content that is potentially harmful to system users and their workstations.

References

A web whitelisting software application that allows for the management of whitelists can be obtained from <http://whitetrash.sourceforge.net/>.

The sites <http://www.shallalist.de/> and <http://www.urlblacklist.com/> contain lists and categories of sites that can be used to block access too.

Examples of client-side JavaScript controls are available at <http://noscript.net/>.

A list of JavaScript functions that are typically used for malicious purposes is listed on the OnSecure website at <https://members.onsecure.gov.au/>.

Email Applications

Objective

Email messages have appropriate protective markings and active content is controlled.

Scope

This section describes protective markings on email and active content in email.

Context

Information on email infrastructure is located in the *Email Infrastructure* section of the *Network Security* chapter.

Automatically generated emails

The requirements for emails in this section apply equally to automatically generated emails.

Controls

Email usage policy

There are many security risks associated with the non-secure nature of email that are often overlooked. Documenting them will inform information owners about these security risks and how they might affect business operations.

Control: 0264; **Revision:** 1; **Updated:** Sep-09; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
Agencies must have a policy governing the use of email.

Email active content

Software that runs on systems should be controlled. Active content delivered though email, especially on Internet facing systems, should be constrained so that it cannot arbitrarily access system users' files or deliver malicious code. Unfortunately the implementation of email permits such activity.

If active content is displayed automatically in the preview pane it can run even though an email item has not been explicitly opened. If active content is allowed, restricting the preview pane to only render content as plaintext ensures emails from a suspicious source would need a system user to make a conscious decision to open an email before the active content is displayed.

Control: 1172; **Revision:** 0; **Updated:** Sep-11; **Applicability:** G, P; **Compliance:** should; **Authority:** AA
Agencies should block client-side active content, by viewing email in plaintext mode instead of in Rich Text Format or Hypertext Markup Language mode.

Email distribution

Often the membership and nationality of members of email distribution lists is unknown. Therefore system users sending sensitive emails with Australian Eyes Only (AUSTEO), Australian Government Access Only (AGAO) or other nationality releasability marked information to distribution lists could accidentally cause a data spill.

Control: 0269; **Revision:** 1; **Updated:** Sep-09; **Applicability:** P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should ensure that emails containing AUSTEO, AGAO or other nationality releasability marked information are only sent to named recipients and not to groups or distribution lists unless the nationality of all members of the distribution lists can be confirmed.

Marking emails

As for paper-based information, all electronic-based information needs to be marked with an appropriate protective marking. This ensures that appropriate security measures are applied to the information and prevents unauthorised information being released into the public domain.

When a protective marking is applied to an email it is important that it reflects the sensitivity or classification of the information in the body of the email and in any attachments to the email.

Emails that do not contain official government information are recommended to be marked with an UNOFFICIAL protective marking to clearly indicate the email is of a personal nature.

Control: 0273; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
All official emails must have a protective marking.

Control: 0275; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
Email protective markings must accurately reflect each element of an email, including attachments.

Emails from outside the government

If an email is received from outside government the system user has an obligation to determine the appropriate security measures for the email if it is to be responded to, forwarded on or printed out.

Control: 0278; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
Where an unmarked email has originated outside the government, system users must assess the information and determine how it is to be handled.

Marking personal emails

Applying incorrect protective markings to emails that do not contain government information places an extra burden on protecting emails that do not need protection.

Control: 0852; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should not; **Authority:** AA
Where an email is of a personal nature and does not contain government information, protective markings for official information should not be used.

Receiving unmarked emails

If an email is received without a protective marking the system user has an obligation to contact the originator to seek clarification on the appropriate security measures for the email. Alternatively, where the system user receives unmarked non-government emails as part of its business practice the application of protective markings can be automated by a system.

Control: 0967; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Where an unmarked email has originated from an Australian or overseas government agency, system users should contact the originator to determine how it is to be handled.

Receiving emails with unknown protective markings

If an email is received with a protective marking that the system user is not familiar with, they have an obligation to contact the originator to clarify the protective marking and the appropriate security measures for the email.

Control: 0968; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Where an email is received with an unknown protective marking from an Australian or overseas government agency, system users should contact the originator to determine appropriate security measures.

Protective marking standard

Applying markings that reflect the protective requirements of an email informs the recipient on how to appropriately handle the email.

The application of protective markings as per the AGIMO standard facilitates interoperability across government must be followed.

Control: 0270; **Revision:** 1; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
Agencies must comply with the standard for the application of protective markings to emails as promulgated by AGIMO.

Marking tools

Requiring system user intervention in the marking of system user generated emails assures a conscious decision by the system user, lessening the chance of incorrectly marked emails.

Allowing system users to choose only protective markings for which the system is accredited lessens the chance of a system user inadvertently over-classifying an email. It also reminds them of the maximum sensitivity or classification of information permitted on the system.

Gateway filters can only check the most recent protective marking applied to an email. Therefore when system users are forwarding or responding to an email, forcing them to apply a protective marking that is at least as high as that of the email they received will help gateway filters prevent emails being sent to systems that are not accredited to handle the original sensitivity or classification of the email.

Control: 0271; **Revision:** 0; **Updated:** Sep-08; **Applicability:** G, P, C, S, TS; **Compliance:** should not; **Authority:** AA
Agencies should not allow a protective marking to be inserted into system user generated emails without their intervention.

Control: 0272; **Revision:** 1; **Updated:** Sep-09; **Applicability:** G, P, C, S, TS; **Compliance:** should not; **Authority:** AA
Agencies providing a marking tool should not allow system users to select protective markings that the system has not been accredited to process, store or communicate.

Control: 1089; **Revision:** 1; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should not; **Authority:** AA
Agencies providing a marking tool should not allow system users replying to or forwarding an email to select a protective marking that is lower than previously used for the email.

Printing

The *Australian Government Information Security Management Protocol* requires that paper-based information have the protective marking of the information placed at the top and bottom of each piece of paper.

Control: 0969; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should configure systems so that the protective markings appear at the top and bottom of every page when the email is printed.

References

The AGIMO email protective markings standard and its associated implementation guide are available from <http://www.finance.gov.au/e-government/security-and-authentication/authentication-identity.html>.

Software Application Development

Objective

Secure programming methods and testing are used for software application development.

Scope

This section describes developing, upgrading and maintaining application software used on systems.

Context

By following the guidelines in this section, the software flaws and vulnerabilities which are able to be exploited by an attacker will be considered and addressed.

Controls

Software development environments

Segregating development, testing and production environments limits the spread of malicious code and minimises the likelihood of faulty code being put into production.

Limiting access to development and testing environments will reduce the information that can be gained by an internal attacker.

Control: 0400; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure that software development environments are configured such that:

- there are at least three environments covering:
 - development
 - testing
 - production
- information flow between the environments is strictly limited according to a defined and documented policy, with access granted only to system users with a clear business requirement
- new development and modifications only take place in the development environment
- write access to the authoritative source for the software is disabled.

Secure programming

Designing software to use the lowest privilege level needed to achieve its task will limit the privileges an attacker could gain should they subvert the software security.

Validating all inputs will ensure that the input is within expected ranges, reducing the chance that malicious or erroneous input causes unexpected results.

Control: 0401; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure that software developers use secure programming practices when writing code, including:

- designing software to use the lowest privilege level needed to achieve its task
- denying access by default
- checking return values of all system calls
- validating all inputs.

Software testing

Software reviewing and testing will lessen the possibility of vulnerabilities being introduced into a production environment.

Using an independent party for software testing will remove any bias that can occur when a developer tests their own software.

Control: 0402; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Software should be reviewed or tested for vulnerabilities before it is used in a production environment.

Control: 0403; Revision: 1; Updated: Sep-09; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Software should be reviewed or tested by an independent party as well as the developer.

References

An example of a “Secure Development Lifecycle” model, used by Microsoft in the development of all versions of Windows since Windows 2003 can be found at <http://msdn.microsoft.com/en-us/library/ms995349.aspx>.

Web Application Development

Objective

Security measures are incorporated into all web applications.

Scope

This section describes developing, upgrading and maintaining web applications used on systems.

Context

Protecting web servers

Even though web servers may only contain information authorised for release into the public domain there still remains a need to protect the integrity and availability of the information. Web servers are therefore to be treated in accordance with the requirements of the sensitivity or classification of the system they are connected to.

Web application components

Web application components at a high level consist of a web server for presentation, a web application for processing and a database for content storage. There can be more or less components, however in general there is a presentation layer, application layer and database layer.

Controls

Website content

Reviewing web applications on web servers will assist in identifying and mitigating information security issues such as buffer overflows and Structured Query Language injection vulnerabilities.

Control: 0389; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should review all web applications on their web servers for information security issues.

Segregation of web application components

Web applications are typically very exposed services that provide complex interactions with system users. This greatly increases the security risk of being compromised. Segregating components limits the impact of potential application flaws.

Control: 0390; **Revision:** 0; **Updated:** Sep-08; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should minimise connectivity and access between each web application component.

Web applications

The Open Web Application Security Project guide provides a comprehensive resource to consult when developing web applications.

Control: 0971; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should follow the documentation provided in the Open Web Application Security Project guides to building secure web applications and web services.

References

Further information on web application security is available from the Open Web Application Security Project at https://www.owasp.org/index.php/Main_Page.

Databases

Objective

Database content is limited to system users with a need-to-know.

Scope

This section describes databases and their interfaces, such as search engines.

Context

The use of data labelling, control of access and logging system users' access to databases and search engines will protect the confidentiality of information and ensure that information can only be accessed by those intended and authorised to do so.

Controls

Data labelling

Protective markings can be applied to records, tables or to the database as a whole, depending on its structure and use.

Control: 0391; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S; **Compliance:** should; **Authority:** AA

Agencies should ensure that all information stored in a database is associated with an appropriate protective marking if either the information:

- could be exported to a different system
- contains differing sensitivities or classifications.

Control: 0393; **Revision:** 3; **Updated:** Sep-11; **Applicability:** TS; **Compliance:** must; **Authority:** AH

Agencies must ensure that all information stored in a database is associated with an appropriate protective marking if either the information:

- could be exported to a different system
- contains differing sensitivities or classifications.

Control: 0392; **Revision:** 0; **Updated:** Sep-08; **Applicability:** G, P, C, S; **Compliance:** should; **Authority:** AA

Agencies should ensure that protective markings are applied with a level of granularity sufficient to clearly define the handling requirements for any information retrieved or exported from a database.

Control: 0394; **Revision:** 0; **Updated:** Sep-08; **Applicability:** TS; **Compliance:** must; **Authority:** AH

Agencies must ensure that protective markings are applied with a level of granularity sufficient to clearly define the handling requirements for any information retrieved or exported from a database.

Database files

Even though a database may provide access controls to the information it provides, the database files will still need to be protected.

Control: 0395; **Revision:** 0; **Updated:** Sep-08; **Applicability:** G, P, C, S; **Compliance:** should; **Authority:** AA

Agencies should protect database files from access that bypasses the database's normal access controls.

Control: 0396; **Revision:** 0; **Updated:** Sep-08; **Applicability:** TS; **Compliance:** must; **Authority:** AH

Agencies must protect database files from access that bypasses the database's normal access controls.

Accountability

If system users' interactions with databases are not logged and audited, agencies will not be able to appropriately investigate any misuse or compromise of database content.

Control: 0397; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure that databases provide functionality to allow for auditing of system users' actions.

Search engines

Even if a search engine prevents system users viewing information that they do not have sufficient security clearances to access, the associated metadata could contain information above the security clearances of the system user. In such cases, restricting access to, or sanitising, this metadata prevents system users seeing information they are not cleared to view.

Control: 0398; Revision: 1; Updated: Sep-09; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure that system users who do not have sufficient security clearances to view database contents cannot see associated metadata in a list of results from a search engine query.

Control: 0399; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

If results from database queries cannot be appropriately filtered, agencies must ensure that all query results are appropriately sanitised to meet the minimum security clearances of system users.

References

Nil.

Access Control

Identification and Authentication

Objective

Passphrase selection policies and passphrase management practices are implemented on systems.

Scope

This section describes the identification and authentication for all system users.

Context

Methods for user identification and authentication

User authentication can be achieved by various means, including biometrics, cryptographic tokens, passphrases, passwords and smartcards. Where this manual refers to passphrases it equally applies to passwords.

Multi-factor authentication uses independent means of evidence to assure an entity's identity. The three authentication methods are:

- something one *knows*, such as a passphrase or a response to a challenge
- something one *has*, such as a passport, physical token or an identity card
- something one *is*, such as biometric data, like a fingerprint or face geometry.

Any two of these authentication methods must be used to achieve multi-factor authentication. If something that one *knows*, such as the passphrase, is written down or typed into a file and stored in plain text, this evidence becomes something that one *has* and can defeat the purpose of multi-factor authentication.

Strong identification and authentication mechanisms significantly reduce the security risk that unauthorised users will gain access to a system.

Controls

Policies and procedures

Developing policies and procedures will ensure consistency in identification, authentication and authorisation.

Control: 0413; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must:

- develop and maintain a set of policies and procedures covering system users':
 - identification
 - authentication
 - authorisation
- make their system users aware of the policies and procedures.

System user identification

Having uniquely identifiable system users ensures accountability.

Control: 0414; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must ensure that all system users are:

- uniquely identifiable
- authenticated on each occasion that access is granted to a system.

Identification of foreign nationals

Where systems contain Australian Eyes Only (AUSTEO), Australian Government Access Only (AGAO) or other nationality releasability marked information, with foreign nationals having access to such systems, it is important that agencies implement appropriate security measures to ensure identification of system users who are foreign nationals. Such security measures can help prevent the release of particularly sensitive information to those not authorised to access it.

Control: 0420; **Revision:** 3; **Updated:** Sep-11; **Applicability:** P, C, S, TS; **Compliance:** must; **Authority:** AH

Where systems contain AUSTEO, AGAO or other nationality releasability marked information, agencies must implement appropriate security measures to ensure identification of system users who are foreign nationals, including seconded foreign nationals.

Control: 0975; **Revision:** 3; **Updated:** Sep-11; **Applicability:** P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies implementing security measures to ensure identification of system users who are foreign nationals, including seconded foreign nationals, should ensure that this identification includes their specific nationality.

Shared accounts

Using shared non user-specific accounts can hamper efforts to attribute actions on a system to specific personnel. Agencies allowing the use of non user-specific accounts need to determine an appropriate method of attributing actions undertaken by such accounts to specific personnel. For example, a logbook may be used to document the date and time that a person takes responsibility for using a shared account and the actions logged against the account by the system.

Control: 0973; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S; **Compliance:** should not; **Authority:** AA

Agencies should not use shared non user-specific accounts.

Control: 0415; **Revision:** 1; **Updated:** Nov-10; **Applicability:** TS; **Compliance:** must not; **Authority:** AH

Agencies must not use shared non user-specific accounts.

Control: 0416; **Revision:** 0; **Updated:** Sep-08; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

If agencies choose to allow shared, non user-specific accounts they must ensure that another method of determining the identification of the system user is implemented.

Methods for system user identification and authentication

A numerical passphrase (or personal identification number) employs a small character set (0-9), making it susceptible to brute force attacks that will be successful in a short period of time.

A simple six character passphrase can be brute-forced in minutes by software available on the Web. Passphrases with at least nine characters utilising upper and lower case alphabetic characters, numeric characters and special characters have a much greater resistance to brute force attacks.

Due to the computer processing technology available to an attacker, passphrases not meeting the requirements in this manual are able to be retrieved using brute force attacks in a short period of time. Passphrases will have to increase in length and complexity as better processing technology becomes available. To provide a secure authentication mechanism that is not as susceptible to brute force attacks, multi-factor authentication should be used for all accounts. Using multi-factor authentication will reduce the demands on system users to remember long passphrases.

Privileged accounts are targeted by attackers as they can potentially allow access to the entire system. Stronger authentication must also be used for positions of trust, such as an account that is able to approve financial transactions or accounts that have access to sensitive information. Positions of trust, including access to sensitive information and databases, and privileged accounts must use multi-factor authentication to provide a secure authentication mechanism.

As privileged access should not be used off-site, and if the access for positions of trust is not required remotely, the multi-factor evidence used for something one *has* should be kept in the office and physically secured according to the requirements in the *Australian Government Physical Security Management Protocol* as per the sensitivity or classification of the system that it is used to access.

Control: 0417; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must not; Authority: AH
Agencies must not use a numerical passphrase (or personal identification number) as the sole method of authenticating a system user.

Control: 0421; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S; Compliance: should; Authority: AH
Agencies using passphrases as the sole method of authenticating a system user should implement a passphrase policy enforcing either:

- a minimum length of 12 alphabetic characters with no complexity requirement; or
- a minimum length of nine characters, consisting of at least three of the following character sets:
 - lowercase alphabetic characters (a-z)
 - uppercase alphabetic characters (A-Z)
 - numeric characters (0-9)
 - special characters.

Control: 0422; Revision: 1; Updated: Sep-11; Applicability: TS; Compliance: must; Authority: AH
Agencies using passphrases as the sole method of authenticating a system user must implement a passphrase policy enforcing either:

- a minimum length of 15 alphabetic characters with no complexity requirement; or
- a minimum length of 10 characters, consisting of at least three of the following character sets:
 - lowercase alphabetic characters (a-z)
 - uppercase alphabetic characters (A-Z)
 - numeric characters (0-9)
 - special characters.

Control: 1173; Revision: 0; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must use multi-factor authentication for privileged access, positions of trust and remote access.

Control: 0974; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should use multi-factor authentication for all system users.

Control: 1174; **Revision:** 0; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

For authenticating positions of trust and privileged access, agencies should secure the multi-factor evidence used for something one *has*, such as cards and tokens, on the premises where they are used according to the requirements in the *Australian Government Physical Security Management Protocol* as per the sensitivity or classification of the system that it is used to access.

Protecting stored authentication information

Limiting the storage of unprotected authentication information reduces the security risk of an attacker finding and using the information to access a system under the guise of a valid system user.

Control: 0418; **Revision:** 0; **Updated:** Sep-08; **Applicability:** G, P, C, S, TS; **Compliance:** must not; **Authority:** AH

Agencies must not allow storage of unprotected authentication information that grants system access or decrypts an encrypted device, to be located on, or with, the system or device to which the authentication information grants access.

Protecting authentication data in transit

Secure transmission of authentication information reduces the security risk of an attacker intercepting and using the authentication information to access a system under the guise of a valid system user.

Control: 0419; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must ensure that system authentication data is protected when in transit across networks.

Passphrase management

Requiring a passphrase to be changed at least every 90 days limits the time period in which a disclosed passphrase could be used by an unauthorised system user.

Preventing a system user from changing their passphrase more than once a day stops the system user from immediately changing their passphrase back to their old passphrase.

Checking passphrases for compliance with the passphrase selection policy allows system administrators to detect unsafe passphrase selection and ensure that the system user changes it.

Forcing a system user to change a passphrase when resetting accounts ensures that the system user changes the passphrase and it is a passphrase that only they know and remember.

Disallowing predictable reset passphrases reduces the security risk of brute force attacks and passphrase guessing attacks.

Using different passphrases when resetting multiple accounts prevents a system user whose account has been recently reset from logging into another such account.

Disallowing passphrases from being reused within eight changes prevents a system user from cycling between a small subset of passphrases.

Disallowing sequential passphrases reduces the security risk of an attacker easily guessing a system user's next passphrase based on their knowledge of the system user's previous passphrase.

Control: 0423; **Revision:** 0; **Updated:** Sep-08; **Applicability:** G, P, C, S; **Compliance:** should; **Authority:** AA

Agencies should:

- ensure that passphrases are changed at least every 90 days
- prevent system users from changing their passphrase more than once a day
- check passphrases for compliance with their passphrase selection policy where the system cannot be configured to enforce complexity requirements
- force the system user to change an expired passphrase on initial logon or if reset.

Control: 0425; Revision: 1; Updated: Nov-10; Applicability: TS; Compliance: must; Authority: AH

Agencies must:

- ensure that passphrases are changed at least every 90 days
- prevent system users from changing their passphrase more than once a day
- check passphrases for compliance with their passphrase selection policy where the system cannot be configured to enforce complexity requirements
- force the system user to change an expired passphrase on initial logon or if reset.

Control: 0424; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S; Compliance: should not; Authority: AA

Agencies should not:

- allow predictable reset passphrases
- reuse passphrases when resetting multiple accounts
- store passphrases in the clear on the system
- allow passphrases to be reused within eight passphrase changes
- allow system users to use sequential passphrases.

Control: 0426; Revision: 1; Updated: Nov-10; Applicability: TS; Compliance: must not; Authority: AH

Agencies must not:

- allow predictable reset passphrases
- reuse passphrases when resetting multiple accounts
- store passphrases in the clear on the system
- allow passphrases to be reused within eight passphrase changes
- allow system users to use sequential passphrases.

Resetting passphrases

To reduce the likelihood of social engineering attacks aimed at service desks, agencies need to ensure that system users provide sufficient evidence to verify their identity when requesting a passphrase reset for their system account. This evidence could be in the form of the system user either:

- physically presenting themselves and their security pass to service desk personnel who then reset their passphrase
- physically presenting themselves to a known colleague who uses an approved online tool to reset their passphrase
- establishing their identity by responding correctly to a number of challenge response questions before resetting their own passphrase.

Control: 0976; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure system users provide sufficient evidence to verify their identity when requesting a passphrase reset for their system account.

Passphrase authentication

Local Area Network (LAN) Manager's authentication mechanism uses a very weak hashing algorithm known as the LAN Manager hash algorithm. Passphrases hashed using the LAN Manager hash algorithm can easily be compromised using rainbow tables or brute force attacks.

Control: 1055; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should disable LAN Manager for passphrase authentication on workstations and servers.

Session termination

Developing a policy to automatically logout and shutdown workstations after an appropriate time of inactivity helps prevent the compromise of a workstation that has been authenticated to and contains sensitive or classified information in memory. Such a policy also reduces the power consumption of systems during non-operational hours.

Control: 0853; **Revision:** 0; **Updated:** Sep-09; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should develop and implement a policy to automatically logout and shutdown workstations after an appropriate time of inactivity.

Session and screen locking

Screen and session locking prevents unauthorised access to a system to which an authorised system user has already been authenticated to.

Ensuring that the screen does not appear to be turned off while in the locked state prevents system users forgetting they are still logged in and will prevent other system users mistakenly thinking there is a problem with a workstation and resetting it.

Control: 0427; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S; **Compliance:** should; **Authority:** AA

Agencies should:

- configure systems with a session or screen lock
- configure the lock to activate either:
 - after a maximum of 15 minutes of system user inactivity
 - if manually activated by the system user
- configure the lock to completely conceal all information on the screen
- ensure that the screen is not turned off or enters a power saving state before the screen or session lock is activated
- have the system user reauthenticate to unlock the system
- deny system users the ability to disable the locking mechanism.

Control: 0428; **Revision:** 2; **Updated:** Nov-10; **Applicability:** TS; **Compliance:** must; **Authority:** AH

Agencies must:

- configure systems with a session or screen lock
- configure the lock to activate either:
 - after a maximum of 10 minutes of system user inactivity
 - if manually activated by the system user
- configure the lock to completely conceal all information on the screen
- ensure that the screen is not turned off or enters a power saving state before the screen or session lock is activated
- have the system user reauthenticate to unlock the system
- deny system users the ability to disable the locking mechanism.

Suspension of access

Locking a system user account after a specified number of failed logon attempts reduces the security risk of brute force attacks.

Removing a system user account when it is no longer required prevents personnel accessing their old account and reduces the number of accounts that an attacker can target.

Suspending inactive accounts after a specified number of days reduces the number of accounts that an attacker can target.

Investigating repeated account lockouts reduces the security risk of any ongoing brute force logon attempts and allows security management to act accordingly.

Control: 0429; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P; **Compliance:** should; **Authority:** AA

Agencies should:

- if an incremental delay is not used, lock system user accounts after five failed logon attempts
- have a system administrator reset locked accounts
- remove or suspend system user accounts as soon as possible when personnel no longer need access due to changing roles or leaving the agency
- remove or suspend inactive accounts after a specified number of days.

Control: 0430; **Revision:** 2; **Updated:** Nov-10; **Applicability:** C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must:

- if an incremental delay is not used, lock system user accounts after five failed logon attempts
- have a system administrator reset locked accounts
- remove or suspend system user accounts as soon as possible when personnel no longer need access due to changing roles or leaving the agency
- remove or suspend inactive accounts after a specified number of days.

Investigating repeated account lockouts

Repeated account lockouts may be an indication of malicious activity being directed towards compromising a particular account.

Control: 0431; **Revision:** 1; **Updated:** Nov-10; **Applicability:** C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should ensure that repeated account lockouts are investigated before reauthorising access.

Logon banner

A logon banner for a system reminds system users of their responsibilities when using the system.

Control: 0408; **Revision:** 1; **Updated:** Sep-09; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should have a logon banner that requires a system user to acknowledge and accept their security responsibilities before access to the system is granted.

Control: 0979; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should seek legal advice on the exact wording of logon banners.

Control: 0980; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Logon banners should cover issues such as:

- access only being permitted to authorised system users
- the system user's agreement to abide by relevant information security policies
- the system user's awareness of the possibility that system usage is being monitored
- the definition of acceptable use for the system
- legal ramifications of violating the relevant policies.

Displaying when a system user last logged in

Displaying when a system user has last logged onto a system helps system users identify any unauthorised use of their account. Accordingly, when any case of unauthorised use of an account is identified, it should be reported to an Information Technology Security Manager immediately so that it can be investigated.

Control: 0977; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should configure systems to display the date and time of the system user's previous login during the login process.

References

Information relating to physical security is contained in the *Australian Government Physical Security Management Protocol*.

System Access

Objective

Access to information on systems is controlled through appropriate access controls.

Scope

This section describes how systems are accessed. Additional information on security clearance, briefing and authorisation requirements can be found in the *Privileged Access* section of this chapter and the *Authorisations, Security Clearances and Briefings* section of the *Personnel Security for Systems* chapter.

Context

Enforcing authorisations of system users through the use of access controls on a system helps enforce the need-to-know principle.

Controls

Access from foreign controlled systems and facilities

If an Australian system is to be accessed from overseas, it needs to be from at least a facility owned by a foreign government with which Australia has a security of information arrangement. Furthermore, due to the sensitivities involved with AUSTEO and AGAO systems, such systems can only be accessed from facilities under the sole control of the government of Australia.

Control: 0855; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should not; **Authority:** AA

Unless a security of information arrangement is in place with a foreign government, agencies should not allow access to sensitive or classified information from systems and facilities not under the sole control of the government of Australia.

Control: 0854; **Revision:** 1; **Updated:** Nov-10; **Applicability:** P, C, S, TS; **Compliance:** must not; **Authority:** AH

Agencies must not allow access to AUSTEO or AGAO information from systems and facilities not under the sole control of the government of Australia.

Enforcing authorisations on systems

Enforcing authorisations of system users through the use of access controls on a system helps enforce the need-to-know principle. Agencies should follow a process for developing an access control list, such as:

- establish groups of all system resources based on similar security objectives
- determine the information owner for each group of resources
- establish groups encompassing all system users based on similar functions or security objectives
- determine the group owner or manager for each group of system users
- determine the degree of access to the resource for each system user group
- decide on the degree of delegation for security administration, based on the internal security policy.

Control: 0856; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must have system users' authorisations enforced by access controls.

Protecting compartmented information on systems

Compartmented information is particularly sensitive. Therefore, extra security measures need to be put in place on systems to restrict access to those with sufficient authorisations, briefings and a demonstrated need-to-know.

Control: 0857; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must have access to compartmented information enforced by the system access controls.

References

Nil.

Privileged Access

Objective

Privileged access to systems is appropriately controlled and monitored.

Scope

This section describes what must be in place to control and monitor privileged access to systems.

Context

In this section, privileged access is considered to be access which can give a system user one or more of:

- the ability to change key system configurations
- the ability to change control parameters
- access to audit and security monitoring information
- the ability to circumvent security measures
- access to data, files and accounts used by other system users, including backups and media
- special access for troubleshooting the system.

Controls

Use of privileged accounts

Inappropriate use of any feature or facility of a system that enables a privileged user to override system or application controls can be a major contributory factor to failures on systems that lead to cyber security incidents.

Privileged access allows system-wide changes to be made. An appropriate and effective mechanism to log privileged users will provide greater accountability and auditing capabilities.

Privileged accounts are targeted by attackers as these can potentially give full access to the system. By ensuring that privileged accounts do not have a channel from inside the agency to the Internet minimises opportunities for these accounts to be compromised.

Control: 1175; Revision: 0; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must not; Authority: AH
Agencies must not allow privileged accounts access to the Internet or to email.

Control: 0445; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must:

- ensure that the use of privileged accounts is controlled and accountable
- ensure that system administrators are assigned an individual account for the performance of their administration tasks
- keep privileged accounts to a minimum
- allow the use of privileged accounts for administrative work only.

Privileged system access by foreign nationals

As privileged users often have the ability to bypass controls on a system it is strongly encouraged that foreign nationals are not given privileged access to systems processing particularly sensitive information.

Control: 0446; Revision: 1; Updated: Sep-09; Applicability: P, C, S, TS; Compliance: must not; Authority: AH
Agencies must not allow foreign nationals, including seconded foreign nationals, to have privileged access to systems that process, store or communicate AUSTEO information.

Control: 0447; Revision: 1; Updated: Sep-09; Applicability: P, C, S, TS; Compliance: must not; Authority: AH
Agencies must not allow foreign nationals, excluding seconded foreign nationals, to have privileged access to systems that process, store or communicate AGAO information.

Control: 0448; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should not; Authority: AA
Agencies should not allow foreign nationals, including seconded foreign nationals, to have privileged access to systems that process, store or communicate sensitive or classified information.

References

Nil.

Remote Access

Objective

Remote access to systems is authorised and authenticated.

Scope

This section describes the authentication required by personnel to access a system from a remote location.

Context

Information about working off-site can be found in the *Working Off-Site* chapter.

Remote access

Remote access is considered to be any access that originates from outside an agency network and enters the network through an Internet gateway.

Controls

Authentication

Authenticating remote system users and devices ensures that only authorised system users and devices are allowed to connect to systems.

Control: 0858; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must authenticate each remote connection before permitting access to a system.

Control: 0706; **Revision:** 1; **Updated:** Sep-09; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should authenticate both the remote system user and device during the authentication process.

Remote privileged access

The extent of a compromise of remote access to a system can be limited by preventing the use of remote privileged access.

Control: 0985; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P; **Compliance:** should; **Authority:** AA

Agencies should not allow the use of privileged access remotely, including logging in as an unprivileged system user and then escalating privileges.

Control: 0709; **Revision:** 1; **Updated:** Sep-09; **Applicability:** C, S, TS; **Compliance:** must not; **Authority:** AH

Agencies must not allow the use of privileged access remotely, including logging in as an unprivileged system user and then escalating privileges.

References

Nil.

Event Logging and Auditing

Objective

Security related events are logged and audited.

Scope

This section describes automatic logging of information relating to network activities.

Context

Information on manual logging of system management activities can be found in the *Privileged Access* section of this chapter.

Event logging helps raise the security posture of a system by increasing the accountability of all system user actions, thereby improving the chances that malicious behaviour will be detected. Agencies should ensure sufficient detail is recorded in order for the logs to be useful when reviewed and determine an appropriate length of time for them to be retained. Conducting audits of event logs should be seen as an integral part of the maintenance of systems, since they will help detect and attribute any violations of information security policy, including cyber security incidents, breaches and intrusions.

Controls

Logging requirements

Event logging helps raise the security posture of a system by increasing the accountability for all system user actions.

Event logging increases the chances that malicious behaviour will be detected by logging the actions of a malicious party.

Well configured event logging allows for easier and more effective auditing if a cyber security incident occurs.

Control: 0580; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must develop and document logging requirements covering:

- the logging facility, including:
 - log server availability requirements
 - the reliable delivery of log information to the log server
- the list of events associated with a system or software component to be logged
- event log protection and retention requirements.

Events to be logged

The events to be logged are listed in their importance to monitoring the security posture of systems and contributing to reviews, audits and investigations.

Control: 0582; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S; Compliance: should; Authority: AA

Agencies should log, at minimum, the following events for all software components:

- all privileged operations
- failed attempts to elevate privileges
- security related system alerts and failures
- system user and group additions, deletions and modification to permissions
- unauthorised access attempts to critical systems and files.

Control: 0583; Revision: 1; Updated: Nov-10; Applicability: TS; Compliance: must; Authority: AH

Agencies must log, at minimum, the following events for all software components:

- all privileged operations
- failed attempts to elevate privileges
- security related system alerts and failures
- system user and group additions, deletions and modification to permissions
- unauthorised access attempts to critical systems and files.

Control: 1176; Revision: 0; Updated: Sep-11; Applicability: G, P; Compliance: should; Authority: AA

Agencies should log the following events for all software components:

- logons
- failed logon attempts
- logoffs.

Control: 0584; Revision: 0; Updated: Sep-08; Applicability: C, S, TS; Compliance: must; Authority: AH

Agencies must log the following events for all software components:

- logons
- failed logon attempts
- logoffs.

Additional events to be logged

The additional events to be logged below can be useful for reviewing, auditing or investigating software components of systems.

Control: 0987; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should log the events listed below for specific software components.

SOFTWARE COMPONENT	EVENTS TO LOG
Database	System user access to the database
	Attempted access that is denied
	Changes to system user roles or database rights
	Addition of new system users, especially privileged users
	Modifications to the data
	Modifications to the format of the database

SOFTWARE COMPONENT	EVENTS TO LOG
Network/operating system	Successful and failed attempts to logon and logoff
	Changes to system administrator and system user accounts
	Failed attempts to access data and system resources
	Attempts to use special privileges
	Use of special privileges
	System user or group management
	Changes to the security policy
	Service failures and restarts
	System startup and shutdown
	Changes to system configuration data
	Access to sensitive data and processes
	Data export operations
Web application	System user access to the web application
	Attempted access that is denied
	System user access to the web documents
	Search engine queries initiated by system users

Event log facility

The act of logging events is not enough in itself. For each event logged, sufficient detail needs to be recorded in order for the logs to be useful when reviewed.

Control: 0585; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

For each event identified as needing to be logged, agencies must ensure that the log facility records at least the following details, where applicable:

- date and time of the event
- relevant system users or process
- event description
- success or failure of the event
- event source (for example, application name)
- Information and Communications Technology equipment location/identification.

Control: 0988; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should establish an accurate time source, and use it consistently throughout their systems, to assist with the correlation of logged events across multiple systems.

Event log protection

Effective log protection and storage (possibly involving the use of a dedicated event log server) will help ensure the integrity and availability of the collected logs when they are audited.

Control: 0586; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Event logs must be protected from:

- modification and unauthorised access
- whole or partial loss within the defined retention period.

Control: 0989; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure that:

- systems are configured to save event logs to a separate secure log server
- event log data is archived in a manner that maintains its integrity.

Control: 0587; Revision: 1; Updated: Nov-10; Applicability: C, S, TS; Compliance: should; Authority: AA

Agencies should configure systems to save event logs to separate secure servers as soon as possible after each event occurs.

Event log retention

It is important that agencies determine an appropriate length of time to retain event logs for systems. Since event logs can assist in reviews, audits and investigations, logs should ideally be retained for the life of the system and potentially longer. The retention requirement for these records under National Archives of Australia's (NAA's) *Administrative Functions Disposal Authority* is a minimum of 7 years after action is completed.

Control: 0859; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must retain event logs for a minimum of 7 years after action is completed in accordance with the NAA's *Administrative Functions Disposal Authority*.

Control: 0991; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should retain Domain Name System and proxy logs for at least 18 months.

Event log auditing

Conducting audits of event logs should be seen as an integral part of the maintenance of systems, since they will help detect and attribute any violations of information security policy, including cyber security incidents, breaches and intrusions. Agencies can use a Security Information and Event Management solution to correlate logs from multiple sources to identify patterns of suspicious behaviour.

Control: 0109; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must develop and document event log auditing requirements covering:

- the scope of audits
- the audit schedule
- action to be taken when violations are detected
- reporting requirements
- specific responsibilities.

References

Nil.

Cryptography

Cryptographic Fundamentals

Objective

Cryptographic products, algorithms and protocols that have been evaluated by the Defence Signals Directorate (DSD) are used.

Scope

This section describes the fundamentals of cryptography including the use of encryption to protect data at rest and in transit.

Context

Information on product security such as product selection, acquisition, installation and configuration can be found in the *Product Security* chapter.

Detailed information on algorithms and protocols approved to protect sensitive or classified information can be found in the *DSD Approved Cryptographic Algorithms* and *DSD Approved Cryptographic Protocols* sections of this chapter.

Purpose of cryptography

The purpose of cryptography is to provide confidentiality, integrity, authentication and non-repudiation of information.

Confidentiality is one of the most common cryptographic functions, with encryption providing protection to information by making it unreadable to all but authorised system users.

Integrity is concerned with protecting information from accidental or deliberate manipulation. It provides assurance that the information has not been modified.

Authentication is the process of ensuring that a person or entity is who they claim to be. A robust authentication system is essential for protecting access to systems.

Non-repudiation provides proof that a system user performed an action, such as sending a message, and prevents them from denying that they did so.

Using approved encryption generally reduces the likelihood of an unauthorised party gaining access to the encrypted information. However, it does not reduce the consequences of a successful attack.

Care needs to be taken, with encryption systems that do not encrypt the entire media content, to ensure that either all of the data is encrypted or that the media is handled in accordance with the sensitivity or classification of the unencrypted data.

Using encryption

Encryption of data at rest can be used to reduce the physical storage and handling requirements of media or systems containing sensitive or classified information to an unclassified level.

Encryption of data in transit can be used to provide protection for sensitive or classified information being communicated over public network infrastructure.

When agencies use encryption for data at rest, or in transit, they are not reducing the sensitivity or classification of the information. However, because the information is encrypted, the consequences of it being accessed by unauthorised parties are considered to be less. Therefore the security requirements applied to such information can be reduced. However, as the sensitivity or classification of the information does not change, the lowered security requirements cannot be used as a baseline to further lower requirements with an additional cryptographic product.

Product specific cryptographic requirements

This section describes the use of cryptography to protect sensitive or classified information. Additional requirements can exist in consumer guides for products once they have completed a DSD Cryptographic Evaluation (DCE). Such requirements supplement this manual and where conflict occurs the product specific requirements take precedence.

Using products with DSD Approved Cryptographic Algorithms and Protocols

Where this manual states a requirement for a product that implements a DSD Approved Cryptographic Algorithm (DACA) or DSD Approved Cryptographic Protocol (DACP) to be used to provide protection for information at rest or in transit, the product does not need to have undergone a DCE.

Federal Information Processing Standard 140

The Federal Information Processing Standard (FIPS) 140 is a United States standard for the validation of both hardware and software cryptographic modules.

FIPS 140 is in its second iteration and is formally referred to as FIPS 140-2. This section refers to the standard as FIPS 140 but applies to both FIPS 140-1 and FIPS 140-2. The third iteration, FIPS 140-3, has been released in draft and this section also applies to that iteration.

FIPS 140 is not a substitute for a DCE of a product with cryptographic functionality. FIPS 140 is concerned solely with the cryptographic functionality of a module and does not consider any other security functionality.

Cryptographic evaluations of products will normally be conducted by DSD. Where a product's cryptographic functionality has been validated under FIPS 140, DSD can, at its discretion, and in consultation with the vendor, reduce the scope of a DCE.

DSD will review the FIPS 140 validation report to confirm compliance with Australia's national cryptographic policy.

Controls

Reducing storage and physical transfer requirements

When encryption is applied to media, whether the media resides in Information and Communications Technology (ICT) equipment or not, it provides an additional layer of defence. Encryption does not change the sensitivity or classification of the information, but when encryption is used the storage and physical transfer requirements of the ICT equipment or media can be treated at an unclassified level.

Control: 1161, Revision: 1, Updated: Sep-11; Applicability: G; Compliance: must; Authority: AH

Agencies must use an encryption product that implements a DACA if they wish to reduce the storage or physical transfer requirements for ICT equipment or media that contains sensitive information to an unclassified level.

Control: 0457; Revision: 2; Updated: Nov-10; Applicability: P; Compliance: must; Authority: AH

Agencies must use an Evaluation Assurance Level (EAL) 2 encryption product from DSD's Evaluated Products List (EPL) that has completed a DCE if they wish to reduce the storage or physical transfer requirements for ICT equipment or media that contains classified information to an unclassified level.

Control: 0460; Revision: 3; Updated: Sep-11; Applicability: C, S, TS; Compliance: must; Authority: DSD

Agencies must use High Grade Cryptographic Equipment (HGCE) if they wish to reduce the storage or physical transfer requirements for ICT equipment or media that contains classified information to an unclassified level.

Encrypting information at rest

Full disk encryption provides a greater level of protection than file based encryption. While file based encryption may encrypt individual files there is the possibility that unencrypted copies of the file may be left in temporary locations used by the operating system.

Control: 0459; Revision: 2; Updated: Nov-10; Applicability: G, P; Compliance: should; Authority: AA

Agencies using encryption to secure data at rest should use either:

- full disk encryption
- partial encryption where the access control will only allow writing to the encrypted partition.

Control: 0461; Revision: 3; Updated: Sep-11; Applicability: C, S, TS; Compliance: must; Authority: DSD

Agencies using encryption to secure data at rest must use either:

- full disk encryption
- partial encryption where the access control will only allow writing to the encrypted partition.

Encrypting particularly sensitive information at rest

As Australian Eyes Only (AUSTEO) and Australian Government Access Only (AGAO) information is particularly sensitive, it needs to be encrypted when at rest.

Control: 1080; Revision: 0; Updated: Nov-10; Applicability: P, C, S, TS; Compliance: must; Authority: AH

In addition to any encryption already in place, agencies must, at minimum, use a DACA to protect AUSTEO and AGAO information when at rest on a system.

Data recovery

The requirement for an encryption product to provide a key escrow function, where practical, was issued under a Cabinet directive in July 1998.

Control: 0455; Revision: 1; Updated: Nov-10; Applicability: G, P; Compliance: must; Authority: AH

Where practical, cryptographic products must provide a means of data recovery to allow for circumstances where the encryption key is unavailable due to loss, damage or failure.

Control: 0456; Revision: 1; Updated: Sep-11; Applicability: C, S, TS; Compliance: must; Authority: DSD

Where practical, cryptographic products must provide a means of data recovery to allow for circumstances where the encryption key is unavailable due to loss, damage or failure.

Handling encrypted Information and Communications Technology equipment

When a system user authenticates to ICT equipment employing encryption functionality, all information becomes accessible. At such a time, the ICT equipment will need to be handled as per the sensitivity or classification of the information it processes, stores or communicates.

Control: 0462; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

When a system user authenticates to ICT equipment storing encrypted information, it must be treated in accordance with the original sensitivity or classification of the equipment.

Reducing network infrastructure requirements

When encryption is applied to sensitive or classified information being communicated over networks, less assurance needs to be placed in the protection of the network infrastructure. In some cases, where no security can be applied to the network infrastructure—for example where information is in the public domain—encryption of sensitive or classified information is the only mechanism to prevent the information being compromised.

Control: 1162; Revision: 1; Updated: Sep-11; Applicability: G; Compliance: must; Authority: AH

Agencies must use an encryption product that implements a DACP if they wish to communicate sensitive information over public network infrastructure.

Control: 0465; Revision: 3; Updated: Sep-11; Applicability: P; Compliance: must; Authority: AH

Agencies must use an EAL 2 encryption product from DSD's EPL that has completed a DCE if they wish to communicate classified information over public network infrastructure.

Control: 0467; Revision: 3; Updated: Sep-11; Applicability: C, S, TS; Compliance: must; Authority: DSD

Agencies must use HGCE if they wish to communicate classified information over public network infrastructure.

Encrypting particularly sensitive information in transit

As AUSTEO and AGAO information is particularly sensitive it needs to be encrypted when being communicated across network infrastructure.

Control: 0469; Revision: 1; Updated: Nov-10; Applicability: P, C, S, TS; Compliance: must; Authority: AH

In addition to any encryption already in place for communication mediums, agencies must, at minimum, use a DACP to protect AUSTEO and AGAO information when in transit.

References

Further information on the FIPS 140 standards can be found at:

- <http://www.csrc.nist.gov/publications/fips/fips140-2/fips1402.pdf>
- <http://csrc.nist.gov/publications/PubsFIPS.html>.

The storage and physical transfer requirements for sensitive or classified information can be found in the *Australian Government Physical Security Management Protocol* and *Australian Government Information Security Management Protocol*.

DSD Approved Cryptographic Algorithms

Objective

Information at rest is protected by a DACA.

Scope

This section describes cryptographic algorithms that DSD has approved for use in government.

Context

Implementations of the algorithms in this section need to undergo a DCE before they can be approved to protect classified information.

High grade cryptographic algorithms, which are not covered in this section, can be used for the protection of classified information if they are found suitably implemented in a product that has undergone a high grade cryptographic evaluation by DSD. Further information on high grade cryptographic algorithms can be obtained by contacting DSD.

DSD Approved Cryptographic Algorithms

There is no guarantee or proof of security of an algorithm against presently unknown attacks. However, the algorithms listed in this section have been extensively scrutinised by industry and academic communities in a practical and theoretical setting and have not been found to be susceptible to any feasible attacks. There have been some cases where theoretically impressive vulnerabilities have been found, however these results are not of practical application.

DACAs fall into three categories: asymmetric/public key algorithms, hashing algorithms and symmetric encryption algorithms.

The approved asymmetric/public key algorithms are:

- Diffie-Hellman (DH) for agreeing on encryption session keys
- Digital Signature Algorithm (DSA) for digital signatures
- Elliptic Curve Diffie-Hellman (ECDH) for agreeing on encryption session keys
- Elliptic Curve Digital Signature Algorithm (ECDSA) for digital signatures
- Rivest-Shamir-Adleman (RSA) for digital signatures and passing encryption session keys or similar keys.

The approved hashing algorithm is:

- Secure Hashing Algorithm 2 (SHA-224, SHA-256, SHA-384 and SHA-512).

The approved symmetric encryption algorithms are:

- Advanced Encryption Standard (AES) using key lengths of 128, 192 and 256 bits
- Triple Data Encryption Standard (3DES).

Where there is a range of possible key sizes for an algorithm, some of the smaller key sizes do not provide an adequate safety margin against attacks that might be found in the future. For example, future advances in number factorisation could render the use of smaller RSA moduli a vulnerability.

Controls

Using DSD Approved Cryptographic Algorithms

If a product implementing a DACA has been inappropriately configured, it is possible that relatively weak cryptographic algorithms could be selected without the system user's knowledge. In combination with an assumed level of security confidence, this can represent a significant level of security risk.

When configuring unevaluated products that implement a DACA, agencies can ensure that only the DACA can be used by disabling the unapproved algorithms in the products (which is preferred) or advising system users not to use them via a policy.

Control: 0471; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies using an unevaluated product that implements a DACA must ensure that only DACAs can be used.

Approved asymmetric/public key algorithms

Over the last decade, DSA and DH cryptosystems have been subject to increasingly successful sub-exponential index-calculus based attacks. ECDH and ECDSA offer more security per bit increase in key size than either DH or DSA and are considered more secure alternatives.

Control: 0994; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should use ECDH and ECDSA in preference to DH and DSA.

Using Diffie-Hellman

A modulus of at least 1024 bits for DH is considered best practice by the cryptographic community.

Control: 0472; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies using DH for the approved use of agreeing on encryption session keys must use a modulus of at least 1024 bits.

Using the Digital Signature Algorithm

A modulus of at least 1024 bits for DSA is considered best practice by the cryptographic community.

Control: 0473; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies using DSA for the approved use of digital signatures must use a modulus of at least 1024 bits.

Using Elliptic Curve Diffie-Hellman

A field/key size of at least 160 bits for ECDH is considered best practice by the cryptographic community.

Control: 0474; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies using ECDH for the approved use of agreeing on encryption session keys must use a field/key size of at least 160 bits.

Using the Elliptic Curve Digital Signature Algorithm

A field/key size of at least 160 bits for ECDSA is considered best practice by the cryptographic community.

Control: 0475; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies using ECDSA for the approved use of digital signatures must use a field/key size of at least 160 bits.

Using Rivest-Shamir-Adleman

A modulus of at least 1024 bits for RSA is considered best practice by the cryptographic community.

Control: 0476; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies using RSA, for the approved use of digital signatures and passing encryption session keys or similar keys, must use a modulus of at least 1024 bits.

Control: 0477; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies using RSA, both for the approved use of digital signatures and for passing encryption session keys or similar keys, must ensure that the public keys used for passing encrypted session keys are different from the keys used for digital signatures.

Approved hashing algorithms

Recent research conducted by the cryptographic community suggests that SHA-1 may be susceptible to collision attacks. While no practical collision attacks have been published for SHA-1, they may become feasible in the near future.

Control: 1054; **Revision:** 1; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should use a hashing algorithm from the SHA-2 family.

Approved symmetric encryption algorithms

The use of Electronic Code Book mode in block ciphers allows repeated patterns in plaintext to appear as repeated patterns in the ciphertext. Most cleartext, including written language and formatted files, contains significant repeated patterns. An attacker can use this to deduce possible meanings of ciphertext by comparison with previously intercepted data. The use of other modes such as Cipher Block Chaining, Cipher Feedback, Output Feedback or Counter prevents such attacks.

Control: 0479; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should not; **Authority:** AA

Agencies using AES or 3DES should not use electronic codebook mode.

Using the Triple Data Encryption Standard

Using three distinct keys is the most secure option, while using two distinct keys in the order key 1, key 2, key 1 is also deemed secure for practical purposes. All other keying options are equivalent to single DES, which is not deemed secure for practical purposes.

Control: 0480; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies using 3DES must use either two distinct keys in the order key 1, key 2, key 1 or three distinct keys.

References

The following references are provided for the approved asymmetric/public key algorithms, hashing algorithms and encryption algorithms:

- Further information on DH can be found in Diffie, W and Hellman, ME 'New Directions in Cryptography', IEEE Transactions on Information Theory, vol. 22, is. 6, pp. 644-654, November 1976
- Further information on DSA can be found in FIPS 186
- Further information on ECDH can be found in ANSI X9.63 and ANSI X9.42
- Further information on ECDSA can be found in FIPS 186-2 + Change Notice, ANSI X9.63 and ANSI X9.62
- Further information on RSA can be found in Public Key Cryptography Standards #1, RSA Laboratories
- Further information on SHA can be found in AS 2805.13.3 and FIPS 180-2.

DSD Approved Cryptographic Protocols

Objective

Information in transit is protected by a DACP implementing a DACA.

Scope

This section describes cryptographic protocols that DSD has approved for use in government.

Context

Implementations of the protocols in this section need to undergo a DCE before they can be approved to protect classified information.

High grade cryptographic protocols, which are not covered in this section, can be used for the protection of classified information if they are found suitably implemented in a product that has undergone a high grade cryptographic evaluation by DSD. Further information on high grade cryptographic protocols can be obtained by contacting DSD.

DSD Approved Cryptographic Protocols

In general, DSD only approves the use of cryptographic products that have passed a formal evaluation. However, DSD approves the use of some commonly available cryptographic protocols even though their implementations in specific products have not been formally evaluated by DSD. This approval is limited to cases where they are used in accordance with the requirements in this manual.

The DACPs are:

- Secure Sockets Layer (SSL) and Transport Layer Security (TLS)
- Secure Shell (SSH)
- Secure Multipurpose Internet Mail Extension (S/MIME)
- OpenPGP Message Format
- Internet Protocol Security (IPSec).

Controls

Using DSD Approved Cryptographic Protocols

If a product implementing a DACP has been inappropriately configured, it is possible that relatively weak cryptographic algorithms could be selected without the system user's knowledge. In combination with an assumed level of security confidence, this can represent a significant level of security risk.

When configuring unevaluated products that implement a DACP, agencies can ensure that only the DACA can be used by disabling the unapproved algorithms in the products (which is preferred) or advising system users not to use them via a policy.

While many DACPs support authentication, agencies should be aware that these authentication mechanisms are not foolproof. To be effective, these mechanisms must also be securely implemented and protected. This can be achieved by:

- providing an assurance of private key protection
- ensuring the correct management of certificate authentication processes including certificate revocation checking
- using a legitimate identity registration scheme.

Control: 0481; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies using a product that implements a DACP must ensure that only DACAs can be used.

References

Further information on the OpenPGP Message Format can be found in the OpenPGP Message Format specification at <http://tools.ietf.org/html/rfc4880>.

Secure Sockets Layer and Transport Layer Security

Objective

SSL and TLS are implemented correctly as a DACP.

Scope

This section describes the conditions under which SSL and TLS can be used as DACPs. Additionally, as File Transfer Protocol over SSL is built on SSL and TLS, it is also considered in scope.

Context

When using a product that implements SSL and TLS, requirements for using DACPs also need to be consulted in the *DSD Approved Cryptographic Protocols* section of this chapter.

Further information on handling SSL and TLS traffic through gateways can be found in the *Web Content and Connections* section of the *Software Security* chapter.

Controls

Using Secure Sockets Layer and Transport Layer Security

Version 1.0 of SSL was never released and version 2.0 had significant security flaws leading to the development of SSL 3.0. SSL has since been superseded by TLS, with the latest version being TLS 1.2 which was released in August 2008.

Control: 0482; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should not; Authority: AA
Agencies should not use versions of SSL prior to version 3.0.

Control: 1139; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should use the current version of TLS instead of SSL.

References

Further information on SSL and TLS can be found in:

- the SSL 3.0 specification at <http://tools.ietf.org/id/draft-ietf-tls-ssl-version3-00.txt>
- the TLS 1.2 definition at <http://tools.ietf.org/html/rfc5246>.

Secure Shell

Objective

SSH is implemented correctly as a DACP.

Scope

This section describes the conditions under which implementations of SSH can be used as a DACP. Additionally, secure copy and Secure File Transfer Protocol use SSH and are therefore also covered by this section.

Context

When using a product that implements SSH, requirements for using DACPs also need to be consulted in the *DSD Approved Cryptographic Protocols* section of this chapter.

Controls

Using Secure Shell

The configuration directives provided are based on the OpenSSH implementation of SSH. Agencies implementing SSH will need to adapt these settings to suit other SSH implementations.

SSH version 1 is known to have vulnerabilities. In particular, it is susceptible to a man-in-the-middle attack, where an attacker who can intercept the protocol in each direction can make each node believe they are talking to the other. SSH version 2 does not have this vulnerability.

SSH has the ability to forward connections and access privileges in a variety of ways. This means that an attacker who can exploit any of these features can gain unauthorised access to a potentially large amount of information.

Host-based authentication requires no credentials (for example, passphrase or public key) to authenticate (though in some cases it might make use of a host key). This renders SSH vulnerable to an Internet Protocol (IP) spoofing attack.

An attacker who gains access to a system with system administrator privileges will have the ability to not only access information but to control that system completely. Given the clearly more serious consequences of this, system administrator login should not be permitted.

Control: 0484; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

The settings below should be implemented when using SSH.

CONFIGURATION DESCRIPTION	CONFIGURATION DIRECTIVE
Disallow the use of SSH version 1	Protocol 2
On machines with multiple interfaces, configure the SSH daemon to listen only on the required interfaces	ListenAddress xxx.xxx.xxx.xxx
Disable connection forwarding	AllowTCPForwarding no
Disable gateway ports	Gatewayports no
Disable the ability to login directly as root	PermitRootLogin no
Disable host-based authentication	HostbasedAuthentication no

CONFIGURATION DESCRIPTION	CONFIGURATION DIRECTIVE
Disable rhosts-based authentication	RhostsAuthentication no
	IgnoreRhosts yes
Do not allow empty passphrases	PermitEmptyPassphrases no
Configure a suitable login banner	Banner/directory/filename
Configure a login authentication timeout of no more than 60 seconds	LoginGraceTime xx
Disable X forwarding	X11Forwarding no

Authentication mechanisms

Public key-based systems have greater potential for strong authentication—put simply, people cannot remember particularly strong passphrases. Passphrase-based authentication schemes are also more susceptible to interception than public key-based authentication schemes.

Passphrases are more susceptible to guessing attacks, therefore if passphrases are used in a system, counter-measures should be put into place to reduce the chance of a successful brute force attack.

Control: 0485; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should use public key-based authentication in preference to using passphrase-based authentication.

Control: 0486; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies that allow passphrase authentication should use techniques to block brute force attempts against the passphrase.

Automated remote access

If passphrase-less authentication is enabled, allowing access from unknown IP addresses would allow untrusted parties to automatically authenticate to systems without needing to know the passphrase.

If port forwarding is not disabled, or it is not configured securely, an attacker may be able to gain access to forwarded ports and thereby create a communication channel between the attacker and the host.

If agent credential forwarding is enabled, an intruder could connect to the stored authentication credentials and then use them to connect to other trusted hosts or even intranet hosts, if port forwarding has been allowed as well.

X11 is a computer software system and network protocol that provides a graphical user interface for networked computers. Failing to disable X11 display remoting could result in an attacker being able to gain control of the computer displays as well as keyboard and mouse control functions.

Allowing console access allows every system user who logs into the console to run programs that are normally restricted to the root user.

Control: 0487; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies that use logins without a passphrase for automated purposes should disable:

- access from IP addresses that do not need access
- port forwarding
- agent credential forwarding
- X11 display remoting
- console access.

Control: 0488; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies that use remote access without the use of a passphrase should use the 'forced command' option to specify what command is executed.

Control: 0997; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should use parameter checking when using the 'forced command' option.

SSH-agent

SSH-agent or other similar key caching programs hold and manage private keys stored on workstations and respond to requests from remote systems to verify these keys. When an SSH-agent launches, it will request the system user's passphrase. This passphrase is used to unlock the user's private key. Subsequent access to remote systems is performed by the agent and does not require the user to re-enter their passphrase. Screen locks and expiring key caches ensure that the user's private key is not left unlocked for long periods of time.

Agent credential forwarding is required when multiple SSH connections are chained to allow each system in the chain to authenticate the system user.

Control: 0489; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies that use SSH-agent or other similar key caching programs should:

- only use the software on workstation and servers with screen locks
- ensure that the key cache expires within four hours of inactivity
- ensure that agent credential forwarding is used when multiple SSH transversal is needed.

References

Further information on SSH can be found in the SSH specification at <http://tools.ietf.org/html/rfc4252>.

Secure Multipurpose Internet Mail Extension

Objective

S/MIME is implemented correctly as a DACP.

Scope

This section describes the conditions under which S/MIME can be used as a DACP.

Context

When using a product that implements S/MIME, requirements for using DACPs also need to be consulted in the *DSD Approved Cryptographic Protocols* section of this chapter.

Information relating to the development of passphrase selection policies and passphrase requirements can be found in the *Identification and Authentication* section of the *Access Control* chapter.

Controls

Using Secure Multipurpose Internet Mail Extension

S/MIME 2.0 required the use of weaker cryptography (40-bit keys) than is approved for use in this manual. Version 3.0 was the first version to become an Internet Engineering Task Force standard.

Agencies choosing to implement S/MIME should be aware of the inability of many content filters to inspect encrypted messages and any attachments for inappropriate content, and for server-based antivirus and other Internet security software to scan for viruses and other malicious code.

Control: 0490; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should not; **Authority:** AA
Agencies should not allow versions of S/MIME earlier than 3.0 to be used.

References

Further information on S/MIME can be found in the S/MIME charter at <http://www.ietf.org/html.charters/smime-charter.html>.

Internet Protocol Security

Objective

IPSec is implemented correctly as a DACP.

Scope

This section describes conditions under which IPSec can be used as a DACP.

Context

When using a product that implements IPSec, requirements for using DACPs also need to be consulted in the *DSD Approved Cryptographic Protocols* section of this chapter.

Modes of operation

IPSec can be operated in two modes: transport mode or tunnel mode.

Cryptographic protocols

IPSec contains two major protocols: Authentication Header (AH) and Encapsulating Security Payload (ESP).

Cryptographic algorithms

Most IPSec implementations can handle a number of cryptographic algorithms for encrypting data when the ESP protocol is used. These include 3DES and AES.

Key exchange

Most IPSec implementations handle a number of methods for sharing keying material used in hashing and encryption processes. Available methods are manual keying and Internet Key Exchange (IKE), versions 1 and 2, using the Internet Security Association Key Management Protocol (ISAKMP). Both methods are considered suitable for use.

Internet Security Association Key Management Protocol authentication

Most IPSec implementations handle a number of methods for authentication as part of ISAKMP. These can include digital certificates, encrypted nonces or pre-shared keys. These methods are considered suitable for use.

IKE Extended Authentication

Agencies should disable the use of IKE Extended Authentication (XAUTH) for IPSec connections using IKEv1.

Internet Security Association Key Management Protocol modes

Agencies using ISKMP in IKEv1 should disable aggressive mode.

Controls

Mode of operation

The tunnel mode of operation provides full encapsulation of IP packets while the transport mode of operation only encapsulates the payload of the IP packet.

Control: 0494; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should use tunnel mode for IPSec connections.

Control: 0495; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies choosing to use transport mode should additionally use an IP tunnel for IPSec connections.

Protocols

In order to provide a secure Virtual Private Network style connection, both authentication and encryption are needed. AH and ESP can provide authentication for the entire IP packet and the payload respectively. However, ESP is generally preferred for authentication since AH by its nature has network address translation limitations. ESP is the only way of providing encryption.

If, however, maximum security is desired at the expense of network address translation functionality, then ESP can be wrapped inside of AH which will then authenticate the entire IP packet and not just the encrypted payload.

Control: 0496; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should use the ESP protocol for IPSec connections.

Internet Security Association Key Management Protocol modes

Using ISAKMP main mode instead of aggressive mode provides greater security since all exchanges are protected.

Control: 0497; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies using ISAKMP in IKEv1 should disable aggressive mode for IKE.

Security association lifetimes

Using a secure association lifetime of four hours, or 14400 seconds, provides a balance between security and usability.

Control: 0498; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should use a security association lifetime of less than four hours, or 14400 seconds.

Hashed Message Authentication Code algorithms

MD5 and SHA-1 are no longer DACAs that can be used with Hashed Message Authentication Code (HMAC). The approved HMAC algorithms are HMAC-SHA256, HMAC-SHA384 or HMAC-SHA512.

Control: 0998; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must use HMAC-SHA256, HMAC-SHA384 or HMAC-SHA512 as a HMAC algorithm.

Diffie-Hellman groups

Using a larger DH group provides more entropy for the key exchange.

Control: 0999; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should use the largest modulus size available for the DH exchange.

Perfect Forward Secrecy

Using Perfect Forward Secrecy reduces the impact of the compromise of a security association.

Control: 1000; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should use Perfect Forward Secrecy for IPSec connections.

IKE Extended Authentication

XAUTH using IKEv1 has documented vulnerabilities associated with its use.

Control: 1001; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should disable the use of XAUTH for IPSec connections using IKEv1.



References

Further information on IPSec can be found in the *Security Architecture for the Internet Protocol* at <http://tools.ietf.org/html/rfc4301>.



Key Management

Objective

Cryptographic keying material is protected by key management procedures.

Scope

This section describes the general management of cryptographic system material.

Context

Due to the wide variety of cryptographic systems and technologies available, and the varied security risks for each, only general key management guidance can be provided in this manual.

If HGCE is being used, agencies are advised to consult the respective Australian Communications Security Instruction (ACSI) for the equipment.

Cryptographic systems

In general, the requirements specified for systems apply equally to cryptographic systems. Where the requirements for cryptographic systems are different, the variations are contained in this section, and overrule all requirements specified elsewhere in this manual.

Controls

Compromise of key material

If the private certificate and associated key used for encrypting messages is suspected of being compromised (that is, stolen, lost or transmitted over the Internet), then no assurance can be placed in the integrity of subsequent messages that are signed by that private key. Likewise no assurance can be placed in the confidentiality of a message encrypted using the public key, since third parties could intercept the message and decrypt it using the private key.

Control: 1091; **Revision:** 1; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must immediately revoke key pairs or certificates when they are suspected of being compromised.

High Grade Cryptographic Equipment

ACSI 53 and ACSI 105 provide product specific policy for HGCE.

Control: 0499; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** DSD

Agencies must comply with ACSI 53 and ACSI 105 when using HGCE.

Transporting commercial grade cryptographic equipment

Transporting commercial grade cryptographic equipment in a keyed state exposes the equipment to the potential for interception and compromise of the key stored in the equipment. Therefore, when commercial grade cryptographic equipment is transported in a keyed state, it needs to be done according to the requirements for the sensitivity or classification of the key stored in the equipment.

Control: 1002; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P; **Compliance:** should not; **Authority:** AA

Agencies should not transport commercial grade cryptographic equipment in a keyed state.

Control: 0500; Revision: 2; Updated: Nov-10; Applicability: G, P; Compliance: must; Authority: AH

Unkeyed commercial grade cryptographic equipment must be distributed and managed by a means approved for the transportation and management of government property.

Control: 0501; Revision: 3; Updated: Sep-11; Applicability: G, P; Compliance: must; Authority: AH

Keyed commercial grade cryptographic equipment must be distributed managed and stored by a means approved for the transportation and management of government property based on the sensitivity or classification of the key in the equipment.

Communications security custodian access

Since communications security custodian access involves granting privileged access to a cryptographic system, extra precautions need to be put in place surrounding the personnel chosen to be cryptographic system administrators.

Control: 0502; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Before personnel are granted communications security custodian access, agencies must ensure that they have:

- a demonstrated need for access
- read and agreed to comply with the relevant Key Management Plan (KMP) for the cryptographic system they are using
- a security clearance at least equal to the sensitivity or classification of information processed by the cryptographic system
- agreed to protect the authentication information for the cryptographic system at the sensitivity or classification of information it secures
- agreed not to share authentication information for the cryptographic system without approval
- agreed to be responsible for all actions under their accounts
- agreed to report all potentially security related problems to an Information Technology Security Manager.

Accounting

As cryptographic equipment, and the keys they store, provides a significant security function for systems, it is important that agencies are able to account for all cryptographic equipment.

Control: 0503; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should be able to readily account for all transactions relating to cryptographic system material, including identifying hardware and software that was issued with the cryptographic equipment and materials, when they were issued and where they were issued.

Audits

Cryptographic system audits are used as a process to account for cryptographic equipment.

Control: 0504; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should conduct audits of cryptographic system material:

- on handover/takeover of administrative responsibility for the cryptographic system
- on change of personnel with access to the cryptographic system
- at least annually.

Control: 1003; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should perform audits to:

- check all cryptographic system material as per the accounting documentation
- confirm that agreed security measures documented in the KMP are being followed.

Control: 1004; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should conduct audits using two personnel with communications security custodian access.

Area security and access control

As cryptographic equipment contains particularly sensitive information, additional physical security measures need to be applied to the equipment. Further information relating to physical security is contained in the *Australian Government Physical Security Management Protocol*.

Control: 0505; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Cryptographic equipment should be stored in a room that meets the requirements for a server room of an appropriate level based on the sensitivity or classification of information the cryptographic system processes.

Control: 0506; Revision: 1; Updated: Sep-09; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Areas in which cryptographic system material is used should be separated from other areas and designated as a cryptographic controlled area.

Developing Key Management Plans for cryptographic systems

Most modern cryptographic systems are designed to be highly resistant to cryptographic analysis but it must be assumed that a determined attacker could obtain details of the cryptographic logic either by stealing or copying relevant material directly or by suborning an Australian national or allied national. The safeguarding of cryptographic system material by using adequate personnel, physical, documentation and procedural security measures is therefore crucial.

Control: 0507; Revision: 2; Updated: Nov-10; Applicability: G, P; Compliance: should; Authority: AA
Agencies should develop a KMP when they have implemented a cryptographic system using commercial grade cryptographic equipment.

Control: 0509; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: DSD
Agencies must develop a KMP when they have implemented a cryptographic system using HGCE.

Contents of Key Management Plans

When agencies implement the recommended contents for KMPs they will have a good starting point for the protection of cryptographic systems and their material.

Control: 0510; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
The minimum contents which should be documented in the KMP are described below.

TOPIC	CONTENT
Accounting	How accounting will be undertaken for the cryptographic system
	What records will be maintained
	How records will be audited
Cyber security incidents	A description of the conditions under which compromise of key material should be declared
	References to procedures to be followed when reporting and dealing with cyber security incidents

TOPIC	CONTENT
Key management	Who generates keys
	How keys are delivered
	How keys are received
	Key distribution, including local, remote and central
	How keys are installed
	How keys are transferred
	How keys are stored
	How keys are recovered
	How keys are revoked
	How keys are destroyed
Maintenance	Maintaining the cryptographic system software and hardware
	Destroying cryptographic equipment and media
Objectives	Objectives of the cryptographic system and KMP, including agency aims
References	Relevant ACSIs
	Vendor documentation
	Related policies
Sensitivity or classification	Sensitivity or classification of the cryptographic system hardware
	Sensitivity or classification of the cryptographic system software
	Sensitivity or classification of the cryptographic system documentation
System description	Sensitivity or classification of information protected
	The use of keys
	The environment
	Administrative responsibilities
	Key algorithm
	Key length
	Key lifetime
Topology	Diagrams and description of the cryptographic system topology including data flows

Control: 0511; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

The level of detail included in a KMP must be consistent with the criticality and sensitivity or classification of the information to be protected.

Access register

Access registers can assist in documenting personnel who have privileged access to cryptographic systems along with previous accounting and audit activities for the system.

Control: 1005; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should hold and maintain an access register that records cryptographic system information such as:

- details of personnel with system administrator access
- details of those whose system administrator access was withdrawn
- details of system documents
- accounting activities
- audit activities.

References

Further information key management practices can be found in AS 11770.1:2003, *Information Technology – Security Techniques – Key Management*.

ACSI 53 and ACSI 105 can also be consulted for additional information on high grade cryptography.

Further information relating to physical security is contained in the *Australian Government Physical Security Management Protocol*.

Network Security

Network Management

Objective

The configuration of networks is controlled through appropriate change management processes.

Scope

This section describes the management of network infrastructure.

Context

Agencies can structure and configure their networks to reduce the number of potential entry points that could be used to gain unauthorised access to information or disrupt agency services. Appropriate network management practices and procedures can assist in identifying and addressing network vulnerabilities.

Controls

Configuration management

If the network is not centrally managed there could be sections of the network that do not comply with information security policies.

Changes should be approved by a change management process involving representatives from all parties involved in the management of the network. This process ensures that changes are understood by all parties and reduces the likelihood of an unexpected impact on the network.

Control: 0513; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should keep the network configuration under the control of a central network management authority.

Control: 0514; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

All changes to the configuration should be documented and approved through a formal change control process.

Control: 0515; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should regularly review their network configuration to ensure that it conforms to the documented network configuration.

Control: 1007; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should deploy an automated tool that compares the running configuration of network devices against the documented configuration.

Network documentation

Detailed network documentation and configuration details can contain information about Internet Protocol (IP) addresses, software version numbers and patch status, security enforcing devices and information about enclaves contain highly valuable information. This information could be used by an attacker to compromise an agency's network.

Control: 1177; Revision: 0; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Detailed network configuration documentation must be classified to at least the same level as the network or enclave it documents (e.g. for a SECRET network, the network configuration documents should at least be classified SECRET).

Control: 1178; Revision: 0; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies providing network documentation to a third party, such as to a commercial provider, must only provide information necessary for them to undertake their contractual services and functions, in line with the need-to-know principle.

Control: 1179; Revision: 0; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must perform a security risk assessment before providing network documentation to a third party, such as a commercial provider.

Control: 1180; Revision: 0; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must not; Authority: AH

Agencies must not publish sensitive or classified network configuration information in tender documentation.

Network diagrams

A network diagram illustrates all network devices such as firewalls, Intrusion Detection Systems (IDSs), routers and switches. It does not need to illustrate all Information and Communications Technology (ICT) equipment on the network, such as workstations or printers, although the inclusion of significant devices such as servers could aid in its interpretation.

As most decisions are made on the documentation that illustrates the network, it is important that:

- a network diagram exists
- the network diagram is an accurate depiction of the network
- the network diagram indicates when it was last updated.

Control: 0516; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

For each network an agency must have:

- a high-level diagram showing all connections into the network
- a logical network diagram showing all network devices.

Updating network diagrams

Due to the importance of the network diagram and decisions made based upon its contents, the network diagram should be updated as changes are made to the network. This will assist system administrators to completely understand and adequately protect the network.

Control: 0517; Revision: 1; Updated: Nov-10; Applicability: G, P; Compliance: should; Authority: AA

Network diagrams should:

- be updated as network changes are made
- include a 'Current as at [date]' statement on each page.

Control: 0518; Revision: 1; Updated: Nov-10; Applicability: C, S, TS; Compliance: must; Authority: AH

Network diagrams must:

- be updated as network changes are made
- include a 'Current as at [date]' statement on each page.

Limiting network access

If an attacker has limited opportunities to connect to a given network, they have limited opportunities to attack that network. Network access controls not only prevent attackers gaining access to a network but also prevent system users carelessly connecting a network to another network. It is also useful in segregating sensitive or compartmented information for specific system users with a need-to-know.

Circumventing some network access controls can be trivial. However, their use is primarily aimed at the protection they provide against accidental connection to another network.

Control: 0520; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
 Agencies should implement network access controls (e.g. through use of the IEEE 802.1x standard) on all networks.

Network segmentation

Separating an agency's network into multiple functional segments makes it difficult for an intruder to propagate inside the agency's network. Proper network segmentation assists in the creation and maintenance of proper network access control lists.

Control: 1181; **Revision:** 0; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
 Agencies should divide their network into logical segments according to the function and security requirements of the devices connected to the network. For example, user workstations should be on one network segment and authentication servers on a separate network segment.

Control: 1182; **Revision:** 0; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
 Agencies should implement network access controls to limit traffic within and between network segments to only those that are required for business operations. For example, computer management traffic should be permitted between systems used for administration and workstations, but not permitted from workstation to workstation.

Management traffic

Implementing security measures specifically for management traffic provides another layer of defence on a network should an attacker find an opportunity to connect to the network. This also makes it more difficult for an attacker to enumerate their target network.

Control: 1006; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
 Agencies should implement security measures to minimise the security risk of unauthorised access to network management traffic travelling across a network.

References

Nil.

Virtual Local Area Networks

Objective

Virtual Local Area Networks (VLANs) are deployed in a secure manner that does not compromise the security of information and systems.

Scope

This section describes the use of VLANs in networks.

Context

Multi Protocol Label Switching

For the purposes of this section, Multi Protocol Label Switching is considered to be equivalent to VLANs and is subject to the same controls.

Separation of networks in the same security domain

A single network, managed in accordance with a single System Security Plan (SSP), for which some separation is needed for administrative or similar reasons, can use VLANs to achieve that separation.

VLANs can also be used to separate IP telephony traffic from data traffic at the same sensitivity or classification.

Controls

Using Virtual Local Area Networks

Limiting the sharing of a common switch between VLANs of differing security domains reduces the chance of data leaks that could occur due to VLAN vulnerabilities. Furthermore, disabling trunking on switches that carry VLANs of differing security domains will also reduce the security risk of data leakage across the VLANs.

Control: 0529; Revision: 2; Updated: Nov-10; Applicability: C, S, TS; Compliance: must not; Authority: AH

Agencies must not use VLANs between classified networks and any other network of a lower classification.

Control: 1138; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must not; Authority: AH

Agencies must not use VLANs between a sensitive or classified network and public network infrastructure.

Control: 0535; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must not; Authority: AH

VLAN trunking must not be used on switches managing VLANs of differing security domains.

Configuration and administration

When administrative access is limited to originating from the most trusted network on a switch, the security risk of a data spill is reduced.

Control: 0530; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Administrative access must only be permitted from the most trusted network.

Disabling unused ports

Disabling unused ports on a switch will reduce the attack surface from which attacks could be launched.

Control: 0533; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S; Compliance: should; Authority: AA
Unused ports on the switches should be disabled.

Control: 0534; Revision: 0; Updated: Sep-08; Applicability: TS; Compliance: must; Authority: AH
Unused ports on the switches must be disabled.

References

Nil.

Wireless Local Area Networks

Objective

Wireless Local Area Networks (WLANs) are deployed in a secure manner that does not compromise the security of information and systems.

Scope

This section describes 802.11 WLANs.

Context

Information covering wireless communications other than 802.11 WLANs can be found in the *Communications Systems and Devices* chapter

Controls

Providing wireless communications for public access

To ensure that a wireless network provided for the general public to access cannot be used as a launching platform for further attacks, it must be physically segregated from all other systems.

Control: 0536; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies deploying a wireless network for the general public to access must physically segregate it from all other agency networks.

Using wireless communications

As the accreditation authority for TOP SECRET systems, the Defence Signals Directorate (DSD) has mandated that all agencies considering deploying a wireless TOP SECRET network must seek approval from DSD before initiating any projects.

Control: 0538; **Revision:** 2; **Updated:** Nov-10; **Applicability:** TS; **Compliance:** must not; **Authority:** AH

Agencies must not use wireless networks unless the security of the wireless deployment has been approved by DSD.

Wired Equivalent Privacy

Wired Equivalent Privacy (WEP) has serious flaws which allow it to be easily compromised. A WEP network should be considered equivalent to an unprotected network.

Control: 0539; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must not; **Authority:** AH

Agencies must not use WEP for wireless deployments.

Wi-Fi Protected Access

Wi-Fi Protected Access (WPA) has been superseded by WPA2. Agencies are strongly encouraged to deploy WPA2 wireless networks instead of WPA based wireless networks.

Control: 0540; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should not; **Authority:** AA

Agencies should not use Wi-Fi Protected Access for wireless deployments.

Authentication

Authenticating each end of a wireless link will prevent a range of man-in-the-middle and rogue Wireless Access Point (WAP) attacks.

The use of WPA2 with Extensible Authentication Protocol-Transport Layer Security (EAP-TLS), or an evaluated Virtual Private Network solution, will satisfy the requirement for mutual authentication and reduce the security risk of off-line brute-forcing of passphrases when using pre-shared keys.

Control: 0541; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should use WPA2 with EAP-TLS for wireless deployments.

Control: 0542; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies not using WPA2 with EAP-TLS should use an authentication protocol that authenticates each end of the link.

Encryption

As wireless transmissions are capable of radiating outside of secured areas into unsecured areas, they need to be encrypted to the same level as information communicated over cabled infrastructure in unsecured areas.

Control: 0543; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies using wireless networks to communicate sensitive or classified information must use encryption approved for communicating such information over public network infrastructure.

Pre-shared keys

While the use of pre-shared keys is not recommended for wireless authentication, the longer the pre-shared keys are the greater the security they provide.

Control: 1010; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should not; Authority: AA
Agencies should not use pre-shared keys for wireless authentication.

Control: 1011; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
If pre-shared keys are used, agencies should ensure random keys of the maximum allowable length are implemented.

Management frames

Effective denial-of-service attacks can be performed on the 802.11 protocol by exploiting unprotected management frames using inexpensive commercial hardware. WPA2 provides no protection for management frames and therefore does not prevent spoofing or denial-of-service attacks.

Control: 1012; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should take steps to ensure the confidentiality, integrity and authenticity of 802.11 management frames.

Documentation

Wireless device driver and WAP vulnerabilities are very exposed to the threat environment and require specific attention as exploits can provide immediate unauthorised access to the network.

Control: 0544; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Key generation, distribution and rekeying procedures should be documented in a SSP for the wireless network.

Control: 0860; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Wireless device drivers and their versions should be documented in the SSP for the wireless network.

Devices connecting to non-agency controlled wireless networks

When devices connect to non-agency controlled wireless networks, particularly public wireless hotspots, the devices may be exposed to viruses, malware or other malicious code circulating on the network. If a device becomes infected and is later connected to an agency controlled wireless network then a crossover of viruses, malware or malicious code could occur.

Control: 1081; **Revision:** 1; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should advise system users of the security risks connecting devices to non-agency controlled wireless networks.

Radio Frequency controls

Minimising the output power of wireless devices and using Radio Frequency (RF) shielding on facilities will assist in limiting the wireless communications to areas under the control of the agency.

Control: 1013; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should limit the effective range of communications outside their area of control by:

- minimising the output power level of wireless devices
- RF shielding.

References

Nil.

Video Conferencing and Internet Protocol Telephony

Objective

Video conferencing and IP telephony, including Voice over Internet Protocol (VoIP), is deployed in a secure manner that does not compromise the security of information and systems.

Scope

This section describes security requirements for video conferencing and IP telephony, including VoIP. Although IP telephony refers to the transport of telephone calls over IP networks, the scope of this section includes connectivity to the Public Switched Telephone Network (PSTN) as well as remote sites.

Context

Additional information on topics covered in this section can be found in the *Product Security* chapter, the *Telephones and Telephone Systems* section of the *Communications Systems and Devices* chapter, the *Mobile Devices* section of the *Working Off-Site* chapter, the *Gateway Security* chapter and any section relating to the protection of data networks in this manual.

Video and voice-aware firewall requirement

Where an analogue telephone network, such as the PSTN, is connected to a data network the *Gateways* section of the *Gateway Security* chapter does not apply.

Where a video conferencing or IP telephony network is connected to another video conferencing or IP telephony network in a different security domain the *Gateways* section of the *Gateway Security* chapter applies.

Hardening video conferencing and Internet Protocol telephony infrastructure

Video conferencing and IP telephony traffic in a data network consists of IP packets and should be treated the same as other data. As such, hardening can be applied to video conferencing units, handsets, software, servers, firewalls and gateways. For example, a Session Initiation Protocol server must:

- have a fully patched operating system
- have fully patched software
- run only required services
- use encrypted non-replayable authentication.

Apply network restrictions that only allow secure Session Initiation Protocol and secure Real-time Transport Protocol (RTP) traffic from video conferencing units and IP phones on a VLAN to reach the server.

Controls

Video and voice-aware firewalls

The use of video and voice-aware firewalls ensures that only video and voice traffic (e.g. signalling and data) is allowed for a given call and that the session state is maintained throughout the transaction.

The requirement to use a video or voice-aware firewall does not necessarily require separate firewalls be deployed for video conferencing, IP telephony and data traffic. If possible, agencies are encouraged to implement one firewall that is either video and data-aware, voice and data-aware; or video, voice and data-aware depending on their needs.

Control: 0546; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies using video conferencing or IP telephony that have a requirement to implement an evaluated firewall in a gateway environment should use an evaluated video or voice-aware firewall of at least the same level of assurance.

Protecting video conferencing and Internet Protocol telephony traffic

Video conferencing and IP telephony traffic is vulnerable to eavesdropping but can be easily protected with encryption. This helps protect against denial-of-service, man-in-the-middle and call spoofing attacks made possible by inherent weaknesses in the video conferencing and IP telephony protocols.

When protecting video conferencing and IP telephony traffic, voice control signalling can be protected using Transport Layer Security (TLS) and the 'sips://' identifier to force the encryption of all legs of the connection. Similar protections are available for RTP and the Real-time Control Protocol.

Control: 0547; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should protect video conferencing and IP telephony signalling and data to ensure confidentiality, integrity, availability, authenticity and non-replayability.

Establishment of secure signalling and data protocols

Use of secure signalling and data protects against eavesdropping, some types of denial-of-service, man-in-the-middle and call spoofing attacks.

Control: 0548; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure that video conferencing and IP telephony functions can only be established using the secure signalling and data protocols.

Local area network traffic separation

Availability and quality of service are the main drivers for logical and physical separation.

Control: 0549; Revision: 1; Updated: Sep-11; Applicability: G, P; Compliance: should; Authority: AA

Agencies should either physically or logically separate the video conferencing and IP telephony traffic from other data traffic.

Control: 0550; Revision: 1; Updated: Sep-11; Applicability: C, S, TS; Compliance: must; Authority: AH

Agencies must either physically or logically separate the video conferencing and IP telephony traffic from other data traffic.

Video conferencing unit and Internet Protocol phone setup

Video conferencing units and IP phones need to be hardened and logically or physically separated from the data network to ensure they do not provide an easy entry point to the network for an attacker.

Universal Serial Bus (USB) ports on video conferencing units and IP phones may be used to circumvent USB workstation policy while unprotected management interfaces may be used to upload malicious firmware for call recording/spoofing and entry into the data network. Unauthorised devices and unauthenticated devices should be blocked by default to reduce the security risk of a denial of service.

Control: 0554; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

An encrypted and non-replayable two-way authentication scheme should be used for call authentication and authorisation.

Control: 0553; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Authentication and authorisation should be used for all actions on the video conferencing network, including:

- call setup
- changing settings.

Control: 0555; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Authentication and authorisation should be used for all actions on the IP telephony network, including:

- registering a new IP phone
- changing phone users
- changing settings
- accessing voice mail.

Control: 0551; Revision: 2; Updated: Sep-11; Applicability: G, P; Compliance: should; Authority: AA

Agencies should:

- configure IP phones to authenticate themselves to the call controller upon registration
- disable phone auto-registration and only allow a whitelist of authorised devices to access the network
- block unauthorised devices by default
- disable all unused and prohibited functionality.

Control: 0552; Revision: 2; Updated: Sep-11; Applicability: C, S, TS; Compliance: must; Authority: AH

Agencies must:

- configure IP phones to authenticate themselves to the call controller upon registration
- disable phone auto-registration and only allow a whitelist of authorised devices to access the network
- block unauthorised devices by default
- disable all unused and prohibited functionality.

Control: 1014; Revision: 3; Updated: Sep-11; Applicability: C, S, TS; Compliance: should; Authority: AA

Agencies should use individual logins for IP phones.

Video conferencing unit and Internet Protocol phone connections to workstations

Availability and quality of service are the main drivers for logical and physical separation.

Control: 0556; Revision: 2; Updated: Sep-11; Applicability: G, P; Compliance: should not; Authority: AA

Agencies should not connect workstations to video conferencing units or IP phones unless the workstation or the device uses VLANs or similar mechanisms to maintain separation between video conferencing, IP telephony and other data traffic.

Control: 0557; Revision: 2; Updated: Sep-11; Applicability: C, S, TS; Compliance: must not; Authority: AH

Agencies must not connect workstations to video conferencing units or IP phones unless the workstation or the device uses VLANs or similar mechanisms to maintain separation between video conferencing, IP telephony and other data traffic.

Lobby and shared area phones

Lobby IP phones are in public areas and may give an attacker an opportunity to access the internal data network (depending on separation arrangements) by replacing the IP phone with another device, or installing a device in-line. There are also the security risks of social engineering (since the call may appear to be internal) and data leakage from poorly protected voicemail boxes.

Control: 0558; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Where an agency uses an IP phone in a lobby or shared area they should limit the IP phones:

- ability to access data networks
- functionality for voice mail and directory services.

Control: 1015; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should use traditional analog phones in lobby and shared areas.

Software used for softphones and webcams

Software used for softphones and webcams can introduce additional vulnerabilities into the network as they are exposed to threats from the data network via the workstation and can subsequently be used to gain access to the video conferencing or IP telephony network.

Softphones and webcams typically require workstation to workstation communication on (potentially) a number of randomly assigned ports to facilitate RTP data exchange. This presents a security risk as workstations generally should be separated, using host-based firewalls that deny all connections between workstations, to make malicious code propagation inside the network difficult.

On workstations using softphones and webcams, separate network cards can facilitate a simple VLAN separation. Host-based firewalls ensure a minimal set of ports are exposed to a minimal set of workstations.

Control: 0559; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should not; Authority: AA

Agencies should not use softphones or webcams.

Control: 1016; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies using softphones or webcams should have separate dedicated network interface cards on the host for video conferencing and IP telephony network access.

Control: 1017; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies using softphones and webcams should install a host-based firewall on workstations that only allows traffic to and from the minimum number of ports required.

Workstations using Universal Serial Bus phones and webcams

Adding USB phones and webcams to a whitelist of allowed USB devices on a workstation will assist with restricting access to only authorised devices, and allowing the Standard Operating Environment to maintain defences against removable media storage and other unauthorised USB devices.

Control: 1018; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should use access control software to control USB ports on workstations using USB phones and webcams by using the specific vendor and product identifier of authorised USB phones and webcams.

Developing a denial of service response plan

Telephony is considered critical for any business and is therefore especially vulnerable to a denial of service. The guidance provided will assist in protecting against video conferencing and IP telephony denial-of-service attacks, signalling floods, established call teardown and RTP data floods.

Control: 1019; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should develop a denial of service response plan including:

- how to diagnose the source of the denial of service
- what actions can be taken to clear the denial of service
- how capabilities could be maintained during a denial of service.

Content of a denial of service response plan

A denial of service response plan will need to address the following:

- how to identify the source of the denial of service, either internal or external (location and content of logs)
- how to minimise the effect on video conferencing and IP telephony of a denial of service of the data network (for example, Internet or internal denial of service), including separate links to other office locations and quality of service prioritisation
- strategies that can mitigate the denial of service (banning certain devices/IPs at the call controller and firewalls, implementing quality of service, changing authentication, changing dial-in authentication)
- alternative communication options (such as personal mobile phones) that have been identified for use in case of an emergency.

Control: 1020; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should develop a denial of service response plan include monitoring and use of:

- router and switch logging and flow data
- packet captures
- proxy and call manager logs and access control lists
- video and voice-aware firewalls and gateways
- network redundancy
- load balancing
- PSTN failover.

References

Nil.

Email Infrastructure

Objective

Email servers are hardened and protective marking of email messages is enforced.

Scope

This section describes email infrastructure security.

Context

Information on using email applications can be found in the *Email Applications* section of the *Software Security* chapter.

Controls

Blocking emails

The intent of blocking specific types of emails is to reduce the likelihood of phishing emails and emails containing malicious code.

Control: 0561; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should block:

- inbound and outbound email, including any attachments, that contain either:
 - malicious code
 - content in conflict with the email policy
 - content that cannot be identified
 - encrypted content, when that content cannot be inspected for malicious code or authenticated as originating from a trusted source
- emails addressed to internal email aliases with source addresses located from outside the domain
- all emails arriving via an external connection where the source address uses an internal domain name.

Preventing unmarked or inappropriately marked emails

Unmarked or inappropriately marked emails can be blocked at two points, the workstation or the email server. The email server is the preferred location to block emails as it is a single location, under the control of system administrators, where the requirements for the entire network can be enforced. In addition email servers can apply controls for emails generated by applications.

While blocking at the email server is considered the most appropriate control there is still an advantage to blocking at the workstation as this adds an extra layer of security and will also reduce the likelihood of a data spill occurring on the email server.

For all systems it is important to note that all emails must have an appropriate protective marking. This requirement is described in the *Email Applications* section of the *Software Security* chapter and mirrors the requirements in the *Australian Government Information Security Management Protocol* for paper-based material.

Control: 1022; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should prevent unmarked and inappropriately marked emails being sent to intended recipients by blocking the email at the workstation.

Control: 0562; Revision: 2; Updated: Nov-10; Applicability: G, P; Compliance: should; Authority: AA

Agencies should prevent unmarked and inappropriately marked emails being sent to intended recipients by blocking the email at the email server.

Control: 0875; Revision: 0; Updated: Sep-09; Applicability: C, S, TS; Compliance: must; Authority: AH

Agencies must prevent unmarked and inappropriately marked emails being sent to intended recipients by blocking the email at the email server.

Blocking of outbound emails

Blocking an outbound email with a protective marking higher than the sensitivity or classification of the path over which it would be communicated stops data spills that could occur due to interception or storage of the email at any point along the path.

Agencies may remove protective markings from emails destined for private citizens and businesses once they have been approved for release from their gateways.

Control: 0563; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must configure systems to block any outbound emails with a protective marking indicating that the content of the email exceeds the sensitivity or classification of the path over which the email would be communicated.

Control: 0564; Revision: 1; Updated: Sep-09; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should configure systems to log every occurrence of a blocked email.

Blocking of inbound emails

Blocking an inbound email with a protective marking higher than the sensitivity or classification that the receiving system is accredited to prevents a data spill from occurring on the receiving system.

Control: 0565; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must configure email systems to reject, log and report inbound emails with protective markings indicating that the content of the email exceeds the sensitivity or classification of the receiving system.

Control: 1023; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should notify the intended recipient of any blocked emails.

Undeliverable messages

Undeliverable or bounce emails are commonly sent by email servers to the original sender when the email cannot be delivered, usually because the destination address is invalid. Due to the common spamming practice of spoofing sender addresses, this often results in a large amount of bounce emails being sent to an innocent third party. Sending bounces only to senders that can be verified via Sender Policy Framework (SPF), or other trusted means, avoids contributing to this problem and allows trusted parties to receive legitimate bounce messages.

Control: 1024; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should only send notification of undeliverable, bounced or blocked emails to senders that can be verified via SPF or other trusted means.

Automatic forwarding of emails

Automatic forwarding of emails, if left unsecured, can pose a security risk to the unauthorised disclosure of sensitive or classified information. For example, a system user could setup a server-side rule to automatically forward all emails received on an Internet connected system to their personal email account outside work.

Control: 0566; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure that the requirements for blocking unmarked and outbound emails are also applied to automatically forwarded emails.

Open relay email servers

An open relay email server (or open mail relay) is a server that is configured to allow anyone on the Internet to send emails through the server. Such configurations are highly undesirable as they allow spammers and worms to exploit this functionality.

Control: 0567; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must disable open email relaying so that email servers will only relay messages destined for their domains and those originating from inside the domain.

Email server maintenance activities

Email servers perform a critical business function. It is important that agencies perform regular email server auditing, security reviews and vulnerability analysis activities.

Control: 0568; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should perform regular email server auditing, security reviews and vulnerability analysis activities.

Centralised email gateways

Without a centralised email gateway it is exceptionally difficult to deploy SPF, DomainKeys Identified Mail (DKIM) and outbound email protective marking verification.

Attackers will almost invariably avoid using the primary email server when sending malicious emails. This is because the backup or alternative email gateways are often poorly maintained in terms of out-of-date blacklists and content filtering.

Control: 0569; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should route email through a centralised email gateway.

Control: 0570; Revision: 3; Updated: Sept-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Where backup or alternative email gateways are in place, additional email gateways must be maintained at the same standard as the primary email gateway.

Control: 0571; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Where system users send email from outside their network, an authenticated and encrypted channel must be configured to allow email to be sent via the centralised email gateway.

Email server transport encryption

Email can be intercepted anywhere between the originating email server and the destination email server. Enabling TLS on the originating and accepting email server will defeat passive attacks on the network, with the exception of cryptanalysis against email traffic. TLS encryption between email servers will not interfere with email content filtering schemes. Email servers will remain compatible with other email servers as Internet Engineering Task Force (IETF) Request for Comments (RFC) 3207 specifies the encryption as opportunistic.

Control: 0572; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must enable opportunistic TLS encryption as defined in IETF RFC 3207 on email servers that make incoming or outgoing email connections over public network infrastructure.

Sender Policy Framework

SPF, and alternative implementations such as Sender ID, aid in the detection of spoofed emails. The SPF record specifies a list of IP addresses or domains that are allowed to send email from a specific domain. If the email server that sent the email is not in the list, the verification fails. There are a number of different fail types available.

Control: 0574; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must specify their mail servers using SPF or Sender ID.

Control: 1183; Revision: 0; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should use a hard fail SPF record when specifying their mail servers.

Control: 1151; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should use SPF or Sender ID to verify the authenticity of incoming emails.

Control: 1152; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must block, mark or identify incoming emails that fail SPF checks in a manner that is visible to the email recipient.

DomainKeys Identified Mail

DKIM enables a method of determining spoofed email content. The DKIM record specifies a public key that will sign the content of the message. If the signed digest in the email header does not match the signed content of the email, the verification fails.

Control: 0861; Revision: 0; Updated: Sep-08; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should enable DKIM signing on all email originating from their domain.

Control: 1025; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should use DKIM in conjunction with SPF.

Control: 1026; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should verify DKIM signatures on emails received, taking into account that email distribution list software typically invalidates DKIM signatures.

Control: 1027; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies operating email distribution list software used by external senders should configure the software so that it does not break the validity of the sender's DKIM signature.

Active web addresses in emails

Spoofed emails often contain an active web address directing system users to a malicious website to either illicit information or infect their workstation with malicious code. To reduce the success rate of such attacks agencies can strip active web addresses from emails and replace them with non-active versions that a system user can type or copy and paste into their web browser.

Control: 1057; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Email servers should strip active web addresses from emails and replace them with non-active versions.

References

Further information on email security is available from the following IETF documents:

- RFC 3207, *SMTP Service Extension for Secure SMTP over Transport Layer Security*
- RFC 4408, *Sender Policy Framework*
- RFC 4686, *Analysis of Threats Motivating DomainKeys Identified Mail*
- RFC 4871, *DomainKeys Identified Mail Signatures*
- RFC 5617, *DomainKeys Identified Mail (DKIM) Author Domain Signing Practices (ADSP)*.

Further information on email server security can be obtained from National Institute of Standards and Technology publication SP 800-45 v2, *Guidelines on Electronic Mail Security*.

Intrusion Detection and Prevention

Objective

An intrusion detection strategy is implemented for Internet connected systems.

Scope

This section describes detecting and preventing malicious code propagating through networks as well as detecting and preventing unusual or malicious activities.

Context

Methods of infections or delivery

Malicious code can spread through a system from a number of sources including:

- files containing macro viruses or worms
- email attachments and web downloads with malicious active content
- executable code in the form of applications
- security weaknesses in a system or network
- security weaknesses in an application
- contact with an infected system or media.

Controls

Intrusion detection strategy

An IDS when configured correctly, kept current and supported by appropriate processes can be an effective way of identifying and responding to known attack profiles. Appropriate resources need to be allocated to an IDS to allow maintenance and monitoring including training and time assigned to the validation of IDS alerts and the tuning of rules.

Control: 0576; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must develop, implement and maintain an intrusion detection strategy that includes:

- appropriate intrusion detection mechanisms, including network-based IDSs and host-based IDSs as necessary
- the audit analysis of event logs, including IDS logs
- a periodic audit of intrusion detection procedures
- information security awareness and training programs
- a documented Incident Response Plan
- the capability to detect cyber security incidents and attempted network intrusions on gateways and provide real-time alerts.

Control: 1184; Revision: 0; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure that if an IDS is deployed, appropriate resources are allocated to maintenance and monitoring.

Control: 1185; Revision: 0; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

When deploying an IDS on a network that is not connected to the Internet, either directly or indirectly via a cascaded connection, agencies must use an IDS that monitors unusual patterns of behaviours or traffic flows, rather than incorporating signatures that detect specific Internet-based communications protocols.

Intrusion Detection Systems on gateways

If the firewall is configured to block all traffic on a particular range of port numbers, then the IDS should inspect traffic for these port numbers and generate an alert if they are detected.

Control: 0577; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should deploy IDSs in all gateways between their networks and public network infrastructure.

Control: 1029; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should deploy IDSs at all gateways between their networks and any network they do not manage.

Control: 1028; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should locate IDSs in the gateway environment, immediately inside the outermost firewall.

Signature-based intrusion detection

When signature-based intrusion detection is used the effectiveness of the IDS will degrade over time as new intrusion methods are developed. It is for this reason that signatures for the IDS need to be kept current to identify the latest intrusion methods.

Control: 0578; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
When signature-based intrusion detection is used, agencies must keep the signatures current.

Malicious code counter-measures

Implementing policies and procedures for preventing and dealing with malicious code outbreaks enables agencies to provide consistent incident response, as well as giving clear directions to system users about what to do in the case of a cyber security incident.

Control: 0579; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must:

- develop and maintain a set of policies and procedures covering how to:
 - minimise the likelihood of malicious code being introduced into a system
 - prevent all unauthorised code from executing on their networks
 - detect any malicious code installed on a system
- make their system users aware of the policies and procedures
- ensure that all instances of detected malicious code outbreaks are handled according to the procedures.

Configuring the Intrusion Detection System

Generating alerts for information flows that contravene any rule in the firewall rule set helps security personnel respond to suspicious or malicious traffic entering an agency's system due to a failure or configuration change to the firewall.

Control: 1030; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
In addition to defined configuration requirements, IDSs located behind a firewall should be configured to generate a log entry, and an alert, for any information flows that contravene any rule in the firewall rule set.

Control: 1031; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should test IDSs rule sets prior to implementation to ensure that they perform as expected.

Event management and correlation

Deploying tools to manage the archival and correlation of events of interest across all networks helps identify suspicious patterns in information flows.

Control: 1032; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should deploy tools for:

- the management and retention of security event information, with the appropriate metadata for the maintenance of the information's integrity
- the correlation of events of interest across all networks.

Host-based Intrusion Detection Systems

Host-based IDSs use behaviour-based detection schemes and can therefore detect malicious code that has yet to be identified by vendors.

Control: 1034; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should install host-based IDSs on high value servers, such as authentication servers (e.g. Active Directory Domain Controllers and RADIUS servers), Domain Name System (DNS) servers, web servers, file servers and email servers.

Active content blocking

Filtering unnecessary content and disabling unwanted functionality reduces the number of possible entry points that an attacker can exploit.

Control: 1035; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should use:

- filters to block unwanted content and exploits against applications that cannot be patched
- settings in the applications to disable unwanted functionality
- digital signatures to restrict active content to trusted sources only.

References

Additional information relating to intrusion detection and audit analysis is contained in HB 171:2003, *Guidelines for the Management of Information Technology Evidence*.

Internet Protocol Version 6

Objective

Internet Protocol version 6 (IPv6) is disabled until it is ready to be deployed.

Scope

This section describes IPv6 and its deployment in networks.

Context

Where this manual specifies requirements for network devices, the requirements apply equally whether deploying IPv6 or Internet Protocol version 4.

Controls

Purchasing of compatible hardware

Agencies should ensure that all hardware and software that is purchased is IPv6 capable.

Control: 1186; **Revision:** 0; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should ensure that new security hardware and software (e.g. firewalls and IDSs) is IPv6 capable.

Use of dual-stack functionality

In order to reduce the risk of attack to their systems, agencies need to disable unused services and functions in network devices, ICT equipment and operating systems. This includes dual-stack functionality if it is not being used.

Control: 0521; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies not using IPv6, but which have deployed dual-stack network devices, ICT equipment or operating systems that support IPv6, must disable the functionality.

Using Internet Protocol version 6

The security implications around the use of IPv6 are still largely unknown and untested. As many of the current network protection technologies such as firewalls and IDSs do not currently support IPv6, agencies choosing to implement IPv6 face a significant security risk of being compromised.

Control: 0523; **Revision:** 1; **Updated:** Sep-09; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies using IPv6 must conduct a security risk assessment on any security risks that could be introduced as a result of running a dual stack environment or transitioning completely to IPv6.

Introducing Internet Protocol version 6 into gateways

Introducing IPv6 into gateways introduces a significant number of new security risks. Undergoing reaccreditation when IPv6 is introduced will ensure that any IPv6 functionality that is not intended to be used cannot be exploited by an attacker before appropriate security measures have been put in place.

Control: 0524; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies deploying IPv6 in their gateways should undergo reaccreditation.

Enabling Internet Protocol version 6 in gateways

Once agencies have completed the transition to a dual-stack environment or completely to an IPv6 environment, reaccreditation will assist in ensuring that the associated security measures for IPv6 are working effectively

Control: 0525; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies enabling IPv6 in their gateways must undergo reaccreditation.

References

A Strategy for the Transition to IPv6 for Australian Government agencies can be found on the Australian Government Information Management Office website at <http://www.finance.gov.au/e-government/infrastructure/internet-protocol-version-6.html>.

Additional IPv6 information can be found at:

- http://www.nsa.gov/ia/guidance/security_configuration_guides/IPv6.shtml
- http://www.cpni.gov.uk/Documents/Publications/2006/2006005-TN0206_Security_IPv6.pdf
- http://www.cpni.gov.uk/documents/publications/2011/2011mar22-infosec-cpni_viewpoint_security_implications_of_ipv6.pdf

Data Transfers

Objective

Data is transferred between systems in a controlled and accountable manner.

Scope

This section describes data transfers between systems. It applies equally to data transfers using removable media and to data transfers via gateways.

Context

Additional requirements for data transfers using removable media can be found in the *Media Usage* section of the *Media Security* chapter while additional requirements for data transfers via gateways can be found in the *Data Import and Export* section of the *Gateway Security* chapter.

Controls

System user responsibilities

When system users transfer data to or from a system they need to be aware of the potential consequences of their actions. This could include data spills of sensitive or classified data onto systems not accredited to handle the data, or the unintended introduction of malicious code to a system. Accordingly system users need to be held accountable for all data transfers that they make.

Control: 0661; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must ensure that system users transferring data to and from a system are held accountable for the data they transfer.

Data transfer processes and procedures

Ensuring that correct processes and procedures are adhered to facilitates the appropriate and consistent application of security controls as well as the generation of necessary audit records.

Control: 0662; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P; **Compliance:** should; **Authority:** AA

Agencies should ensure that data transfers are performed in accordance with processes and procedures approved by the accreditation authority.

Control: 0663; **Revision:** 2; **Updated:** Nov-10; **Applicability:** C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must ensure that data transfers are performed in accordance with processes and procedures approved by the accreditation authority.

Data transfer authorisation

System users can help prevent cyber security incidents by:

- checking protective markings to ensure that the destination system is appropriate for the data being transferred
- performing antivirus checks on data to be transferred to and from a system
- following all processes and procedures for the transfer of data.

Control: 0664; **Revision:** 3; **Updated:** Sep-11; **Applicability:** C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must ensure that all data transferred to a system of a lesser sensitivity or classification is approved by a trusted source.

Trusted sources

Trusted sources include security personnel such as the Chief Information Security Officer, the Information Technology Security Advisor, Information Technology Security Managers and Information Technology Security Officers.

Control: 0665; **Revision:** 2; **Updated:** Nov-10; **Applicability:** C, S, TS; **Compliance:** must; **Authority:** AH

Trusted sources must be:

- a strictly limited list derived from business requirements and the result of a security risk assessment
- approved by the accreditation authority.

Import of data

Scanning imported data for malicious content reduces the security risk of a system being infected, thus allowing the continued confidentiality, integrity and availability of the system.

Format checks provide a method to prevent known malicious formats from entering the system. Keeping and regularly auditing these logs allow for the system to be checked for any unusual usage.

Control: 0657; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P; **Compliance:** must; **Authority:** AH

Agencies importing data to a system must ensure that the data is scanned for malicious and active content.

Control: 0658; **Revision:** 2; **Updated:** Nov-10; **Applicability:** C, S, TS; **Compliance:** must; **Authority:** AH

Agencies importing data to a system must implement the following controls:

- scanning for malicious and active content
- data format checks
- log of each event
- monitoring to detect overuse/unusual usage patterns.

Export of data

When data is exported between systems, protective marking checks can reduce the security risk of data being transferred to a system that is not accredited to handle it or into the public domain.

When highly formatted textual data with no free-text fields is transferred between systems the checking requirements are lessened due to the strongly defined format of the data.

As data that it is not highly formatted textual data cannot be thoroughly checked in an automated manner, a number of checking measures are needed to ensure that classified data is not accidentally transferred to a system not accredited to handle it or into the public domain.

Control: 1187; **Revision:** 0; **Updated:** Sep-11; **Applicability:** G, P; **Compliance:** must; **Authority:** AH

When exporting data, agencies must implement protective marking checks.

Control: 0669; **Revision:** 1; **Updated:** Nov-10; **Applicability:** C, S, TS; **Compliance:** must; **Authority:** AH

When exporting formatted textual data with no free-text fields and all fields have a predefined set of permitted values, agencies must implement the following controls:

- protective marking checks
- log of each event
- monitoring to detect overuse/unusual usage patterns.

Control: 0670; Revision: 2; Updated: Nov-10; Applicability: C, S, TS; Compliance: must; Authority: AH

When exporting data, other than highly formatted textual data, agencies must implement the following controls:

- protective marking checks
- log of each event
- monitoring to detect overuse/unusual usage patterns
- data format checks
- limitations on data types
- keyword searches
- size limits.

Preventing export of particularly sensitive data to foreign systems

In order to reduce the security risk of spilling data with a caveat onto foreign systems, it is important that procedures are developed to detect Australian Eyes Only (AUSTEO) and Australian Government Access Only (AGAO) data and to prevent it from crossing into foreign systems.

Control: 0678; Revision: 1; Updated: Nov-10; Applicability: P, C, S, TS; Compliance: must; Authority: AH

Agencies must:

- ensure that keyword searches are performed on all textual data
- ensure that any identified data is quarantined until reviewed and approved for release by a trusted source other than the originator
- develop procedures to prevent AUSTEO and AGAO information in both textual and non-textual formats from being exported.

References

Nil.

Peripheral Switches

Objective

An evaluated peripheral switch is used when sharing keyboards, monitors and mice between different systems.

Scope

This section describes the use of keyboard/video/mouse switches.

Context

For more information on DSD's Evaluated Products List (EPL) see the *Product Security* section.

Controls

Peripheral switches

The level of assurance needed in a peripheral switch is determined by the highest and lowest sensitivity or classification of systems connected to the switch.

When accessing systems through a peripheral switch it is important that sufficient assurance is available in the operation of the switch to ensure that information does not accidentally pass between the connected systems

Control: 0591; Revision: 3; Updated: Sep-11; Applicability: G, P; Compliance: must; Authority: AH

Agencies accessing a classified system and a sensitive system via a peripheral switch must use an Evaluation Assurance Level (EAL) 2 product from DSD's EPL.

Control: 0593; Revision: 3; Updated: Sep-11; Applicability: C, S, TS; Compliance: must; Authority: AH

Agencies accessing a highly classified system and a less classified system or sensitive system via a peripheral switch must use a high assurance product from DSD's EPL.

Peripheral switches for particularly sensitive systems

As AUSTEO and AGAO systems are particularly sensitive additional security measures need to be put in place when connecting them to other systems.

Control: 0594; Revision: 2; Updated: Nov-10; Applicability: P, C, S, TS; Compliance: should; Authority: AA

Agencies accessing a system containing AUSTEO or AGAO information and a system of the same classification that is not accredited to process the same caveat should use an EAL 2 product from DSD's EPL.

References

Nil.

Ensuring Service Continuity

Objective

Agencies take steps to ensure that their services are available if an adversary attempts to flood their network with unwanted traffic.

Scope

This section outlines steps for minimising the effect of attacks aimed at disrupting or degrading services provided by an agency.

Context

Additional information on business continuity and disaster recovery can be found in the *Information Security Monitoring* chapter.

Controls

Contacting Internet service providers

Agencies' Internet service providers are in a unique position to assist in the mitigation of Distributed Denial-of-Service (DDoS) attacks. Proper coordination between agencies and their Internet service providers is essential to ensure resilience against such attacks.

Control: 1188; **Revision:** 0; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should ensure their Internet service provider can respond in the event of a DDoS attack against the agency's network.

Planning

Effective planning with an Internet service provider is a key part of defending against DDoS attacks.

Control: 1189; **Revision:** 0; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should have a denial of service mitigation plan with their Internet service provider, outlining pre-approved actions that can be taken in the event of a DDoS attack.

Maintaining multiple Internet links

The use of multiple Internet links increases an agency's options for responding to DDoS attacks, and increases the complexity required for a successful DDoS attack.

Control: 1190; **Revision:** 0; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should use multiple Internet links provided by different Internet service providers.

Control: 1191; **Revision:** 0; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

If an agency has multiple Internet links, it should use separate links for public facing services (e.g. web servers and public DNS) and routine agency business (e.g. Internet access for system users and remote connectivity).

References

Nil.

Gateway Security

Gateways

Objective

Gateways facilitate secure information transfers between systems of different security domains.

Scope

This section describes the use of gateways including cross domain solutions.

Context

Gateways act as information flow control mechanisms at the network layer and may also control information at the transport, session, presentation and application layers of the Open System Interconnect (OSI) model. Cross domain solutions provide information flow control mechanisms at each layer of the OSI model with a higher level of assurance than typical gateways. This section is equally applicable to both typical gateways and cross domain solutions.

Additional information relating to topics covered in this section can be found in the following chapters:

- *System Accreditation*
- *Information Security Monitoring*
- *Physical Security for Systems*
- *Product Security*
- *Access Control*
- *Network Security*
- *Gateway Security*.

Deploying gateways

This section describes a baseline for deploying gateways. Agencies need to consult additional sections of this manual depending on the specific type of gateways deployed.

For devices used to control data flow in bi-directional gateways the *Traffic Flow Filters* section of this chapter needs to be consulted.

For devices used to control data flow in uni-directional gateways the *Diodes* section of this chapter needs to be consulted.

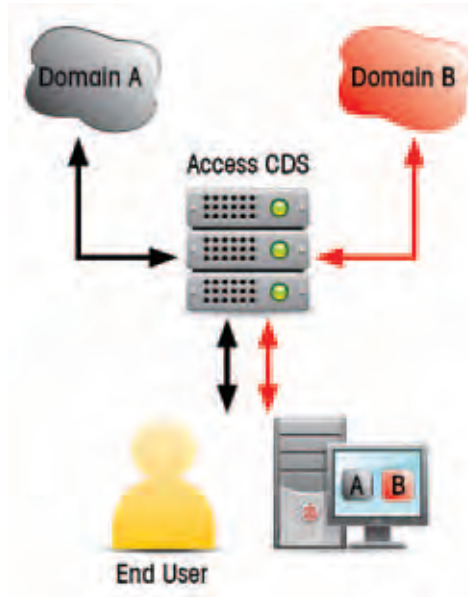
For both bi-directional and uni-directional gateways the *Data Transfers* section of the *Network Security* chapter and the *Data Import and Export* section of this chapter need to be consulted for requirements on appropriately controlling data flows.

The requirements in this manual for content filtering, data import and data export apply to all types of gateways.

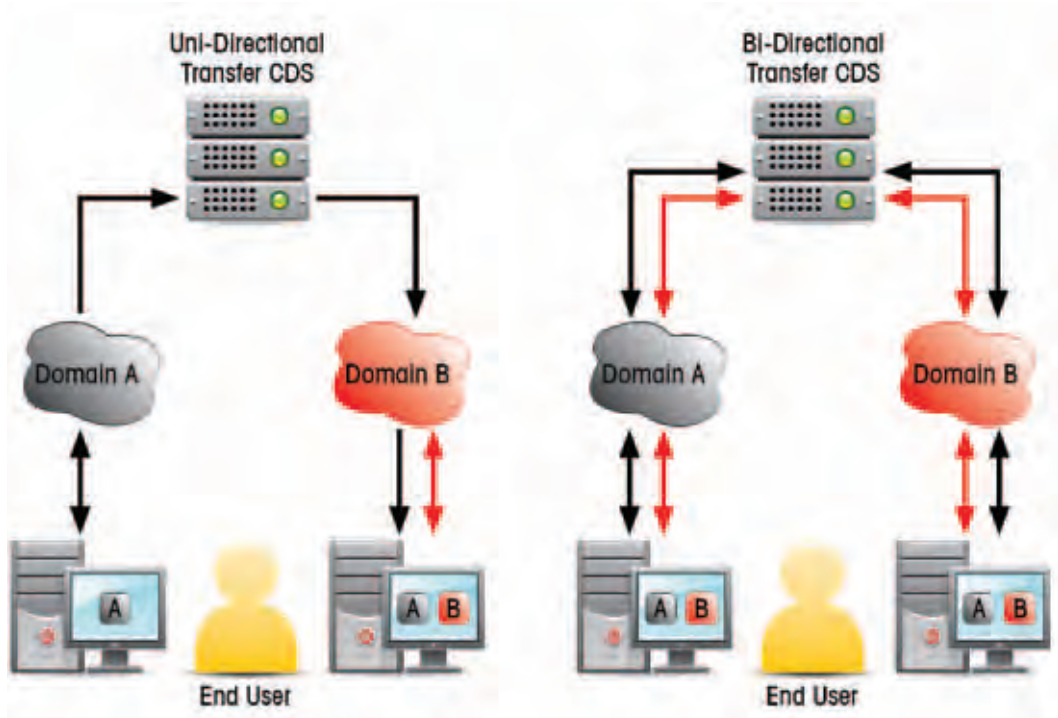
Types of gateways

This manual defines three types of gateways: access gateways, multilevel gateways and transfer gateways.

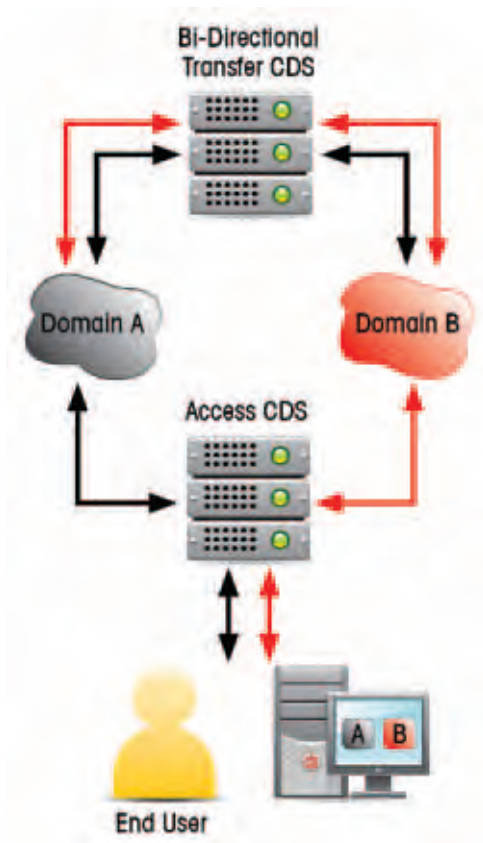
An access gateway provides the system user with access to multiple security domains from a single device.



A transfer gateway facilitates the transfer of information, in one (uni-directional) or multiple (bi-directional) directions between different security domains. A typical gateway to the Internet is considered a form of transfer gateway.



A multilevel gateway enables access, based on authorisations, to data at multiple classifications and sensitivity levels.



Applying the controls

For the purposes of this section, the gateway assumes the highest sensitivity or classification of the connected security domains.

Controls

Allowable gateways

There are significant security risks associated with connecting highly classified systems to the Internet or to a sensitive or lesser classified system. An attacker having control or access to a gateway can invoke a serious security risk.

Control: 0626; **Revision:** 3; **Updated:** Sep-11; **Applicability:** C, S, TS; **Compliance:** must; **Authority:** AH

Agencies connecting a TOP SECRET, SECRET or CONFIDENTIAL network to any other network from a different security domain must implement a cross domain solution.

Implementing gateways

Cross domain solutions should implement products that have completed a high assurance evaluation. The Defence Signals Directorate's (DSD's) Evaluated Products List (EPL) includes products that have been evaluated in the high assurance scheme. However, the EPL is not an exhaustive list of products which are suitable for use in cross domain solutions. While cross domain solutions are not listed on the EPL, DSD can provide guidance on the agency implementation in response to a formal request for advice and assistance.

Connecting multiple sets of gateways and cross domain solutions increases the threat surface and, consequently, the likelihood and consequence of a network compromise. When a gateway and a cross domain solution share a common network, it opens the higher security domain to exploitation from the lower security domain, which may include the Internet. DSD will be able to provide the necessary adjustments to the security controls of one or more of these connections to maintain adequate protection of networks connected through the cross domain solution.

Control: 0597; Revision: 3; Updated: Sep-11; Applicability: C, S, TS; Compliance: must; Authority: AH

When designing and deploying a cross domain solution, agencies must consult with DSD and comply with all directions provided.

Control: 0627; Revision: 2; Updated: Nov-10; Applicability: C, S, TS; Compliance: must; Authority: AH

Agencies connecting a typical gateway and a cross domain solution to a common network must consult with DSD on the impact to the security of the cross domain solution and comply with all directions provided.

Using gateways

The system owner of the higher security domain of connected security domains would be most familiar with the controls required to protect the more sensitive information and as such is best placed to manage any shared components of gateways. However, in some cases where multiple security domains from different agencies are connected to a gateway it may be more appropriate to have a qualified third party manage the gateway on behalf of all connected agencies.

Control: 0628; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure that:

- all systems are protected from systems in other security domains by one or more gateways
- all gateways contain mechanisms to filter data flows at the network layer.

Control: 1192; Revision: 0; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure that all gateways contain mechanisms to inspect and filter data flows for the transport and higher layers as defined in the OSI model.

Control: 0629; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

For gateways between networks in different security domains, any shared components must be managed by the system owners of the highest security domain or by a mutually agreed party.

Configuration of gateways

Given the criticality of gateways in controlling the flow of information between security domains, any failure – particularly at the higher classifications – may have serious consequences. Hence mechanisms for alerting personnel to situations that may cause cyber security incidents are especially important for gateways.

Control: 0631; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure that gateways:

- are the only communications paths into and out of internal networks
- by default, deny all connections into and out of the network
- allow only explicitly authorised connections
- are managed via a secure path isolated from all connected networks (physically at the gateway or on a dedicated administration network)
- provide sufficient logging and audit capabilities to detect cyber security incidents and attempted intrusions
- provide real-time alerts.

Operation of gateways

Providing a sufficient logging and auditing capability helps detect cyber security incidents and attempted network intrusions, allowing the agency to implement counter-measures to reduce the security risk of future attempts.

Storing event logs on a separate secure log server increases the difficulty for attackers to delete logging information in an attempt to destroy evidence of their attack.

Control: 0634; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure that all gateways connecting networks in different security domains:

- include a traffic flow filter on all gateways to filter and log network traffic attempting to enter the gateway
- are configured to save event logs to a separate secure log server
- are protected by authentication, logging and auditing of all physical access to gateway components
- have all controls tested to verify their effectiveness after any changes to their configuration.

Separation of data flows

Gateways connecting highly classified systems to other potentially Internet connected systems need to implement diodes, content filtering and physically separate paths to provide stronger control of information flows. Such gateways are generally restricted to highly formatted formal messaging traffic.

Control: 0635; Revision: 3; Updated: Sep-11; Applicability: C, S, TS; Compliance: must; Authority: AH

Agencies must ensure that all bi-directional gateways between TOP SECRET, SECRET or CONFIDENTIAL networks and any other network have separate upward and downward network paths using a diode, content filtering and physically separate infrastructure for each path.

Demilitarised zones

Demilitarised zones are used to prevent direct access to information and services on internal networks. Agencies that require certain information and services to be accessed from the Internet can place them in the less trusted demilitarised zone instead of on internal networks.

Control: 0637; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must use demilitarised zones to house services accessed externally and mediate external access to information held on internal networks.

Security risk assessment

Performing a security risk assessment on the gateway and its configuration before its implementation assists in the early identification and mitigation of security risks.

Control: 0598; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must perform a security risk assessment on gateways and their configuration before their implementation.

Security risk transfer

Gateways can connect networks in different security domains including across agency boundaries. As a result, all system owners must understand and accept the security risks from all other networks before gateways are implemented.

Control: 0605; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

All owners of systems connected via a gateway must understand and accept the residual security risk of the gateway and from any connected security domains including those connected via a cascaded connection.

Control: 1041; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should annually review the security architecture of the gateway and security risks of all connected security domains including those connected via a cascaded connection.

Information stakeholders

As changes to a security domain connected to a gateway potentially affects the security posture of other connected security domains, system owners need to become information stakeholders in other security domains to which they are connected via a gateway.

Control: 0607; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P; **Compliance:** should; **Authority:** AA

Once connectivity is established, system owners should become information stakeholders for all connected security domains.

Control: 0608; **Revision:** 1; **Updated:** Nov-10; **Applicability:** C, S, TS; **Compliance:** must; **Authority:** AH

Once connectivity is established, system owners must become information stakeholders for all connected security domains.

System user training

It is important that system users know how to use gateways securely. This can be achieved through appropriate training before being granted access.

Control: 0609; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P; **Compliance:** should; **Authority:** AA

All system users should be trained on the secure use and security risks of gateways before access to systems connected to a gateway is granted.

Control: 0610; **Revision:** 3; **Updated:** Sep-11; **Applicability:** C, S, TS; **Compliance:** must; **Authority:** AH

All system users must be trained on the secure use and security risks of gateways before access to the systems connected to a gateway is granted.

Administration of gateways

Administrator privileges need to be minimised and roles need to be separated to minimise the security risk posed by a malicious user with extensive access to the gateway.

Agencies must provide system administrators with formal training to ensure they are fully aware of and accept their roles and responsibilities regarding the management of gateways. Formal training could be through commercial providers, or simply through Standard Operating Procedures or reference documents bound by a formal agreement.

Control: 0611; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must limit access to gateway administration functions.

Control: 0612; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must ensure that system administrators are formally trained to manage gateways.

Control: 0613; Revision: 2; Updated: Nov-10; Applicability: P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure that all system administrators of gateways that process Australian Eyes Only (AUSTEO) or Australian Government Access Only (AGAO) information are Australian nationals.

Control: 0616; Revision: 2; Updated: Nov-10; Applicability: G, P; Compliance: should; Authority: AA

Agencies should separate roles for the administration of gateways (e.g. separate network and security policy configuration roles).

Control: 0617; Revision: 2; Updated: Nov-10; Applicability: C, S, TS; Compliance: must; Authority: AH

Agencies must separate roles for the administration of gateways (e.g. separate network and security policy configuration roles).

System user authentication

Authentication to networks as well as gateways can reduce the security risk of unauthorised access and provide an auditing capability to support the investigation of cyber security incidents. Additional information on multi-factor authentication is in the *Access Control* chapter.

Control: 0619; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must authenticate system users to all sensitive or classified networks accessed through gateways.

Control: 0620; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must ensure that only system users authenticated and authorised to a gateway can use the gateway.

Control: 1039; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should use multi-factor authentication for access to gateways.

Information and Communications Technology equipment authentication

Authenticating Information and Communications Technology (ICT) equipment to networks accessed through gateways assists in preventing unauthorised ICT equipment connecting to a network.

Control: 0622; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should authenticate ICT equipment (e.g. 802.1x or by media access control address) to networks accessed through gateways.

Configuration control

Changes that could introduce vulnerabilities, new security risks or increase security risks in a gateway need to be appropriately considered and documented before being implemented.

Control: 0624; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must update the Security Risk Management Plan before changes are made to the gateway to ensure all security risks have been accepted.

Control: 0625; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must document and assess all changes to gateway architecture in accordance with the agency's change management process.

Testing of gateways

Testing security measures on gateways assists in ensuring that the integrity of the gateway is being maintained. Testing at irregular intervals should be performed as an attacker aware of regular testing activities may cease any malicious activities during the known testing period to avoid detection.

Control: 1037; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies should ensure that testing of security measures is performed at random intervals no more than six months apart.

References

Additional information on implementing a cross domain solution can be accessed from the OnSecure website at <https://members.onsecure.gov.au/> in the *Guide to Secure Configuration of Cross Domain Solutions* publication.

Additional information on the OSI model can be found in the ISO/IEC 7498-1:1994 *Information technology – Open Systems Interconnection: The Basic Model* from <http://standards.iso.org/ittf/PubliclyAvailableStandards/index.html>.

Data Import and Export

Objective

Data is transferred through gateways in a controlled and accountable manner.

Scope

This section describes the requirements for the movement of data between systems via gateways.

Context

Fundamental requirements of data transfers between systems can be found in the *Data Transfers* section of the *Network Security* chapter.

Controls

Import of data through gateways

To ensure the continued functioning of systems, it is important to constantly analyse data being imported over a network.

Translating data from one format into another effectively destroys most malicious active content.

Control: 1156; Revision: 0; Updated: Nov-10; Applicability: G, P; Compliance: must; Authority: AH

Agencies importing data to a system must ensure that the data is scanned for malicious and active content.

Control: 1042; Revision: 3; Updated: Sep-11; Applicability: C, S, TS; Compliance: should; Authority: AA

Agencies should convert data being imported at gateways into another format before entering the network.

Control: 0659; Revision: 2; Updated: Nov-10; Applicability: C, S, TS; Compliance: must; Authority: AH

When importing data to a system through gateways, the data must be filtered by a product specifically designed for that purpose.

Control: 0660; Revision: 3; Updated: Sep-11; Applicability: C, S, TS; Compliance: must; Authority: AH

When importing data through gateways agencies must perform full or partial audits of the complete data transfer logs at least monthly.

Export of data through gateways

To ensure the continued integrity and confidentiality of data on a system, data must pass through a series of checks before it is exported through a gateway.

Control: 0667; Revision: 2; Updated: Nov-10; Applicability: G, P; Compliance: should; Authority: AA

Agencies should restrict the export of data through a gateway by filtering data using at least protective marking checks.

Control: 0673; Revision: 3; Updated: Sep-11; Applicability: C, S, TS; Compliance: must; Authority: AH

When exporting data through gateways agencies must perform full or partial audits of the complete data transfer logs at least monthly.

Export of highly formatted textual data through gateways

The security risks of releasing highly classified data are partially reduced when the data is restricted to highly formatted textual data. In such cases the data is less likely to contain hidden content. Such data can be automatically scanned through a series of checks to detect classified content. In addition, the security risk is further reduced when there is a gateway filter that refuses to export data above the sensitivity or classification of the network outside the gateway.

Control: 0671; **Revision:** 3; **Updated:** Sep-11; **Applicability:** C, S, TS; **Compliance:** must; **Authority:** AH

When the export of highly formatted textual data occurs through gateways, agencies must implement:

- data filtering performed by a product specifically designed for that purpose
- data range checks.

Export of other data through gateways

Textual data which is not highly formatted can contain hidden data. The security risk is somewhat reduced by running additional automated checks on non-formatted data being exported in addition to those for highly formatted textual data. A trusted source should also assess the classification of the content of the data, which cannot be interpreted by automated means. Further information on trusted sources can be found in the *Data Transfers* section of the *Network Security* chapter.

Control: 0672; **Revision:** 2; **Updated:** Nov-10; **Applicability:** C, S, TS; **Compliance:** must; **Authority:** AH

When exporting data other than highly formatted textual data through gateways, agencies must implement data filtering performed by a product specifically designed for that purpose.

Control: 0674; **Revision:** 3; **Updated:** Sep-11; **Applicability:** C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must perform randomly timed audits of random subsets of the data transfer logs on a weekly basis.

Preventing export of particularly sensitive data to foreign systems

As AUSTEO and AGAO networks are particularly sensitive, additional security measures need to be put in place when connecting them to other networks

Control: 1077; **Revision:** 1; **Updated:** Sep-11; **Applicability:** P, C, S, TS; **Compliance:** must; **Authority:** AH

To prevent the export of AUSTEO and AGAO data to foreign systems, agencies must implement data filtering performed by a product specifically evaluated for that purpose.

Requirement to sign exported data

Digitally signing data being exported to systems where there is access by non-trusted sources reduces the security risk of compromising data integrity.

Control: 0675; **Revision:** 1; **Updated:** Nov-10; **Applicability:** C, S, TS; **Compliance:** must; **Authority:** AH

If, to reach the transfer point, the data is communicated over a network to which personnel or systems that are not trusted sources have access, then a trusted source must sign the data to be exported.

Control: 0677; **Revision:** 2; **Updated:** Nov-10; **Applicability:** C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must ensure that the gateway confirms the signature before the release of the data to be exported.

References

Nil.

Content Filtering

Objective

The flow of data in gateways is controlled by a content filter.

Scope

This section describes the use of content filters in uni-directional or bi-directional gateways.

Context

Content filters will reduce the security risk of malicious content entering the security domain and gaining unauthorised access to information.

Controls

Limiting transfers by file type

The level of security risk will be determined by the degree of assurance agencies can place in the ability of their data transfer filters to:

- confirm the file type by examination of the contents of the file
- confirm the absence of malicious content
- confirm the absence of inappropriate content
- confirm the classification and releasability of the content
- handle compressed and encoded files appropriately.

Reducing permitted file types reduces the number of potential vulnerabilities available for an attacker to exploit.

Control: 0649; Revision: 1; Updated: Sep-09; Applicability: G, P; Compliance: should; Authority: AA

Agencies should strictly define and limit the types of files that can be transferred based on business requirements and the results of a security risk assessment.

Control: 0650; Revision: 1; Updated: Sep-09; Applicability: C, S, TS; Compliance: must; Authority: AH

Agencies must strictly define and limit the types of files that can be transferred based on business requirements and the results of a security risk assessment.

Blocking active content

Many files are executable and are potentially harmful if executed by a system user. Many file type specifications allow active content to be embedded in the file, which increases the attack surface.

Control: 0651; Revision: 2; Updated: Nov-10; Applicability: C, S, TS; Compliance: should; Authority: AA

Agencies should block all executables and active content from being communicated through gateways.

Blocking suspicious data

The definition of suspicious content will depend on the system's security risk profile and what is considered normal traffic. Some filtering techniques are described below that can be used to identify suspicious data.

TECHNIQUE	PURPOSE
Antivirus scan	Scans the data for viruses and other malicious code.
Data format check	Inspects data to ensure that it conforms to expected and permitted formats.
Data range check	Checks the data in each field to ensure that it falls within the expected and permitted ranges.
Data type check	Inspects each file header to determine the actual file type.
File extension check	Inspects the file name extension to determine the purported file type.
Keyword search	Searches data for keywords or 'dirty words' that could indicate the presence of sensitivity, classified or inappropriate material.
Metadata check	Inspects files for metadata that should be removed prior to release.
Protective marking check	Validates the protective marking of the data to ensure that it is correct.
Manual inspection	The manual inspection of data for suspicious content that an automated system could miss, which is particularly important for the transfer of multimedia or content rich files.

Control: 0652; **Revision:** 0; **Updated:** Sep-08; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must block or drop any data identified by a data filter as suspicious until reviewed and approved for transfer by a trusted source other than the originator.

References

Nil.

Traffic Flow Filters

Objective

Networks connected to bi-directional gateways implement firewalls and traffic flow filters.

Scope

This section describes filtering requirements for bi-directional gateways between networks of different security domains.

Context

When a control specifies a requirement for a diode or filter, the appropriate information can be found in the *Diodes* and *Content Filtering* sections of this chapter. Additional information that also applies to topics covered in this section can be found in the *Data Transfers* section of the *Network Security* chapter and the *Data Import and Export* section of this chapter. The *Product Security* chapter provides advice on selecting evaluated products.

Government systems

All references to 'Government' in the tables relate to systems containing unclassified but sensitive information not intended for public release, such as Dissemination Limiting Marker information. 'Government' is not a classification under the *Australian Government Security Classification System* as mandated by the Attorney-General's Department.

Controls

Traffic flow filters

Where an agency connects to another agency over public network infrastructure both agencies need to implement traffic flow filtering in their gateway environment to protect themselves from attacks that originate outside of their environment.

These gateway infrastructure requirements may not be necessary in the specific cases where:

- the public network infrastructure is used only as a transport medium
- the public network infrastructure is not a logical source or destination of data
- link encryption is used in accordance with the *Cryptography* chapter.

A proxy is a proxy server that acts as an intermediary for requests from within the agency seeking resources external to the agency. A client connects to the proxy server, requesting some service, such as a file, connection, website, or other resource, available from a source external to the agency. The proxy server evaluates the request according to its filtering rules.

The *Network Device Protection Profile* (NDPP), defined by the United States' National Information Assurance Partnership, outlines the security requirements for a network device (as opposed to an end-user device) that can be connected to a network.

Control: 1193; **Revision:** 0; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
All gateways must contain a traffic flow filter.

Control: 0638; Revision: 2; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

When selecting a traffic flow filter, agencies must use at least one of the following in the order of preference as shown:

- a firewall
- a proxy
- a router with access control lists configured.

Control: 0639; Revision: 3; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must use a firewall as part of their traffic flow filter which satisfies the following table.

YOUR NETWORK	OTHER NETWORK					
	PUBLIC	GOVERNMENT	PROTECTED	CONFIDENTIAL	SECRET	TOP SECRET
TOP SECRET	Consult with DSD	Consult with DSD	Consult with DSD	Consult with DSD	Consult with DSD	Consult with DSD
SECRET	Consult with DSD	Consult with DSD	Consult with DSD	Consult with DSD	Consult with DSD	Consult with DSD
CONFIDENTIAL	Consult with DSD	Consult with DSD	Consult with DSD	Consult with DSD	Consult with DSD	Consult with DSD
PROTECTED	NDPP-compliant firewall	NDPP-compliant firewall	NDPP-compliant firewall	Consult with DSD	Consult with DSD	Consult with DSD
Government	None*	None*	None*	Consult with DSD	Consult with DSD	Consult with DSD

* No specific firewall requirement, a though a traffic flow filter is still required in line with control 0638.

Control: 1194; Revision: 0; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

The requirement to use a firewall as part of a traffic flow filter must be met by both parties independently; shared equipment does not satisfy the requirements of both parties.

Firewalls for particularly sensitive networks

As AUSTEO and AGAO networks are particularly sensitive, additional security measures need to be put in place when connecting them to other networks.

Control: 0641; Revision: 3; Updated: Sep-11; Applicability: P, C, S, TS; Compliance: must; Authority: AH

Agencies must use a DSD approved NDPP-compliant firewall from the EPL between an AUSTEO or AGAO network and a foreign network in addition to the firewall between networks of different classifications or security domains. If no suitable NDPP-compliant firewall exists on the EPL, an Evaluation Assurance Level (EAL) 4 firewall may be used.

Control: 0642; Revision: 3; Updated: Sep-11; Applicability: P, C, S, TS; Compliance: should; Authority: AA

Agencies should use a DSD approved NDPP-compliant firewall from the EPL between an AUSTEO or AGAO network and another Australian controlled network in addition to the firewall between networks of different classifications or security domains. If no suitable NDPP-compliant firewall exists on the EPL, an EAL 4 firewall may be used.

References

Further information on the NDPP is available at http://www.niap-cccv.org/pp/pp_nd_v1.0/.

Diodes

Objective

Networks connected to uni-directional gateways implement diodes.

Scope

This section describes filtering requirements for uni-directional gateways used to facilitate data transfers.

Context

Additional information can be found in the *Data Transfers* section of the *Network Security* chapter and the *Data Import and Export* section of this chapter. The *Product Security* chapter provides advice on selecting evaluated products.

While no DSD Protection Profile exists for data diodes, the EALs specified in the following controls may be used.

Controls

Diodes

A diode enforces one-way flow of network traffic thus requiring separate paths for incoming and outgoing data. This makes it much more difficult for an attacker to use the same path to both launch an attack and release the information.

Control: 0643; Revision: 3; Updated: Sep-11; Applicability: G, P; Compliance: must; Authority: AH

Agencies must use an EAL 2 diode from DSD's EPL for controlling the data flow of uni-directional gateways between sensitive or classified networks and public network infrastructure.

Control: 0645; Revision: 2; Updated: Nov-10; Applicability: C, S, TS; Compliance: must; Authority: AH

Agencies must use a high assurance diode from DSD's EPL for controlling the data flow of uni-directional gateways between classified networks and public network infrastructure.

Control: 1157; Revision: 1; Updated: Sep-11; Applicability: G, P; Compliance: must; Authority: AH

Agencies must use an EAL 2 diode from DSD's EPL for controlling the data flow of uni-directional gateways between sensitive and classified networks.

Control: 1158; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

Agencies must use a high assurance diode from DSD's EPL for controlling the data flow of uni-directional gateways between sensitive or classified networks where the highest system is CONFIDENTIAL or above.

Diodes for particularly sensitive networks

While diodes between networks at the same classification generally are not needed, AUSTEO and AGAO networks are particularly sensitive and additional security measures need to be put in place when connecting them to other networks

Control: 0646; Revision: 2; Updated: Nov-10; Applicability: P, C, S, TS; Compliance: must; Authority: AH

Agencies must use an EAL 4 diode from DSD's EPL between an AUSTEO or AGAO network and a foreign network at the same classification.

Control: 0647; Revision: 3; Updated: Sep-11; Applicability: P, C, S, TS; Compliance: should; Authority: AA

Agencies should use an EAL 2 diode from DSD's EPL between an AUSTEO or AGAO network and another agency controlled network at the same classification.

Volume checking

Monitoring the volume of data being transferred across a diode ensures that it conforms to expectations. It can also alert the agency to potential malicious activity if the volume of data suddenly changes from the norm.

Control: 0648; Revision: 2; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA

Agencies deploying a diode to control data flow in uni-directional gateways should monitor the volume of the data being transferred.

References

Additional information on the EPL can be found on DSD's website at <http://www.dsd.gov.au/infosec/epl/index.php>.

Working Off-Site

Mobile Devices

Objective

Information on mobile devices is protected from unauthorised disclosure.

Scope

This section describes the use of mobile devices including: mobile phones, smartphones, portable electronic devices, personal digital assistants, laptops, netbooks, tablet computers and other portable Internet connected devices.

Context

Trusted Operating Environments

A Trusted Operating Environment (TOE) provides assurance that a reasonable effort has been made to secure the operating system of a mobile device such that it presents a reduced security risk to an agency's information and systems. Security measures that can be implemented to assist in the development of a TOE include:

- unneeded software and operating system components are removed
- unused or undesired functionality in software and operating systems is disabled
- antivirus or other Internet security software is installed and regularly updated
- software-based firewalls limiting inbound and outbound network connection are installed
- installed software and operating system patching is current
- split tunnelling is disabled when using a Virtual Private Network (VPN) connection between a mobile device and an agency system
- each connection is authenticated before permitting access to an agency network
- both the system user and mobile device are authenticated during the authentication process
- Bluetooth functionality is not enabled
- privileged access from the mobile device to the agency network is not allowed.

Treating workstations as mobile devices

When a workstation is issued for home-based work instead of a mobile device, the requirements in this section equally apply to the workstation.

Mobile devices with multiple operating states

Some mobile devices have functionality to allow them to operate in either an unprotected state or a protected state. In such cases the mobile devices need to be handled according to the state that it is being operated in at the time.

Bluetooth Devices

For devices such as keyboards that utilise Bluetooth and for security risks to consider, refer to the *Radio Frequency, Infrared and Bluetooth Devices* section of the *Communications Systems and Devices* chapter.

Controls

Mobile devices usage policy

Since mobile devices routinely leave the office environment, and the protection it affords, it is important that policies are developed to ensure that mobile devices are protected in an appropriate manner when used outside of controlled facilities.

Control: 1082; **Revision:** 0; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must develop a policy governing the use of mobile devices.

Control: 1195; **Revision:** 0; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should use a Mobile Device Management solution to ensure their mobile device policy is applied to all mobile devices that are used with their systems.

Control: 0687; **Revision:** 2; **Updated:** Nov-10; **Applicability:** TS; **Compliance:** must not; **Authority:** AH

Agencies must not allow mobile devices to process or store TOP SECRET information unless explicitly approved by the Defence Signals Directorate (DSD) to do so.

Personnel awareness

Mobile devices can have both a data and voice component capable of processing or communicating sensitive or classified information. In such cases, personnel need to know the sensitivity or classification of information which the mobile device has been approved to process, store and communicate.

Control: 1083; **Revision:** 1; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must advise personnel of the sensitivities and classifications permitted for data and voice communications when using mobile devices.

Non-agency owned mobile devices

If agencies choose to allow personnel to use their personal mobile devices to access the agency's systems, they will need to ensure that the device does not present a threat to the systems and does not retain any sensitive or classified information once a session has been completed. DSD recommends that agencies achieve this outcome through the use of bootable optical media or flash drive running an endorsed Standard Operating Environment (SOE). Failing this, DSD recommends the use of remote desktop software to present an endorsed SOE to personnel on their mobile devices.

Control: 1047; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G; **Compliance:** should; **Authority:** AA

Non-agency owned mobile devices accessing sensitive systems should use a TOE that also prevents sensitive information being stored on the device.

Control: 0693; **Revision:** 2; **Updated:** Nov-10; **Applicability:** P; **Compliance:** must; **Authority:** AH

Non-agency owned mobile devices accessing classified systems must use a TOE that also prevents classified information being stored on the device.

Control: 0694; **Revision:** 2; **Updated:** Nov-10; **Applicability:** C, S, TS; **Compliance:** must not; **Authority:** AH

Agencies must not allow non-agency owned mobile devices to access classified systems.

Control: 0172; **Revision:** 2; **Updated:** Sep-11; **Applicability:** TS; **Compliance:** must not; **Authority:** AH

Agencies must not permit non-agency owned mobile devices to be brought into TOP SECRET areas without prior approval from the accreditation authority.

Mobile device storage encryption

Agencies should use encryption on mobile devices to lessen the security risk associated with a lost or stolen device. While the use of encryption may not be suitable to treat the mobile device as an unclassified asset it will still prevent a significant challenge to an attacker looking to gain easy access to information stored on the device. To ensure that the benefits of encryption on mobile devices are not negated, system users are reminded that they must not store passphrases for the encryption software on, or with, the device.

Control: 0869; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should encrypt information on all mobile devices using at least a DSD Approved Cryptographic Algorithm.

Control: 1084; **Revision:** 1; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
Agencies unable to lower the storage and physical transfer requirements of a mobile device to an unclassified level through the use of encryption must physically transfer the device as a sensitive or classified asset in a Security Construction and Equipment Committee endorsed secure briefcase.

Mobile device communications encryption

If appropriate encryption is not available the mobile device must not be used for communicating sensitive or classified information. All sensitive or classified communications must be encrypted regardless of the protocol used whether it is communicated using Bluetooth, infrared, Wi-Fi, 3G, 4G or other wireless protocols.

Control: 1085; **Revision:** 1; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH
Agencies using mobile devices to communicate sensitive or classified information over public network infrastructure must use encryption approved for communicating such information over public network infrastructure.

Mobile device privacy filters

Privacy filters can be applied to the screens of mobile devices to prevent onlookers from reading the contents off the screen of the device. This assists in mitigating security risks from shoulder surfing.

Control: 1145; **Revision:** 1; **Updated:** Sep-11; **Applicability:** P, C, S, TS; **Compliance:** should; **Authority:** AA
Agencies should apply privacy filters to the screens of mobile devices.

Bluetooth functionality

Bluetooth provides little security for information that is passed between the mobile device and other devices connected to it using Bluetooth, such as car kits. Bluetooth has a number of known weaknesses that potentially enable attackers to exploit it, therefore it must not be used on mobile devices for highly classified information. To use Bluetooth to communicate sensitive or lesser classified information it must be secured appropriately.

The number of devices that are paired to a mobile device using Bluetooth should be kept to a minimum and only when required for a business need. Unintended and unneeded Bluetooth device pairing should be removed from the mobile device.

The device class can be used to restrict the range that the Bluetooth communications will operate over. Typically Bluetooth class 1 devices can communicate up to 100 metres, class 2 devices can communicate up to 10 metres and class 3 devices can communicate up to 5 metres.

Agencies must use Bluetooth version 2.1 or later as secure simple pairing and extended inquiry response was introduced in this version. Secure simple pairing improves the pairing process for Bluetooth devices, while increasing the strength, as it uses a form of public key cryptography. Extended inquiry response provides more information during the inquiry procedure to allow better filtering of devices before connecting.

Control: 0682; Revision: 3; Updated: Sep-11; Applicability: C, S, TS; Compliance: must not; Authority: AH
Agencies must not enable Bluetooth functionality on mobile devices.

Control: 1196; Revision: 0; Updated: Sep-11; Applicability: G, P; Compliance: must; Authority: AH
Agencies must ensure mobile devices are configured to remain undiscoverable to all other Bluetooth devices except during pairing.

Control: 1197; Revision: 0; Updated: Sep-11; Applicability: G, P; Compliance: should; Authority: AA
Agencies should ensure mobile devices are configured to allow only Bluetooth classes that are required.

Control: 1198; Revision: 0; Updated: Sep-11; Applicability: G, P; Compliance: must; Authority: AH
Agencies must ensure Bluetooth pairing is performed so that a connection is only made to the device intended.

Control: 1199; Revision: 0; Updated: Sep-11; Applicability: G, P; Compliance: should; Authority: AA
Agencies should ensure Bluetooth pairing is only performed for a device required for business needs and pairing that is no longer required is removed from the mobile device.

Control: 1200; Revision: 0; Updated: Sep-11; Applicability: G, P; Compliance: must; Authority: AH
Agencies must ensure mobile devices use Bluetooth version 2.1 or later.

Control: 1201; Revision: 0; Updated: Sep-11; Applicability: G, P; Compliance: should; Authority: AA
Agencies must ensure mobile devices are configured to support a single Bluetooth headset connection.

Control: 1202; Revision: 0; Updated: Sep-11; Applicability: G, P; Compliance: should; Authority: AA
Agencies should restrict the range of Bluetooth headsets to less than 10 metres by only using class 2 or class 3 devices.

Configuration control

Poorly controlled mobile devices are more vulnerable to compromise and provide an attacker with a potential access point into systems. Although agencies may initially provide a secure mobile device, the state of security may degrade over time. The security of mobile devices needs to be audited regularly to ensure their integrity.

Control: 0862; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should control the configuration of mobile devices in the same manner as devices in the office environment.

Control: 0863; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should prevent personnel from installing or uninstalling applications on a mobile device once provisioned.

Control: 0864; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH
Agencies must prevent personnel from disabling security functions on a mobile device once provisioned.

Maintaining mobile device security

It is important that mobile devices are routinely returned so that patches can be applied and the devices can be tested to ensure that they are still secure.

Control: 1049; Revision: 1; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: should; Authority: AA
Agencies should ensure that mobile devices have security updates applied on a regular basis and are regularly tested to ensure that they are still secure.

Connecting mobile devices to the Internet

During the time a mobile device is connected to the Internet for web browsing, instead of establishing a VPN connection to a system, it is directly exposed to attacks originating from the Internet. Should web browsing be needed, personnel should establish a VPN connection and browse the Web through their agency's Internet gateway.

A split tunnel VPN can allow access to systems from another network, including unsecured networks such as the Internet. If split tunnelling is not disabled there is an increased security risk that the VPN connection is susceptible to attack from such networks.

Control: 0874; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should ensure that web browsing from a mobile device is through the agency's Internet gateway rather than via a direct connection to the Internet.

Control: 0705; **Revision:** 2; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must disable split tunnelling when using a VPN connection from a mobile device to connect to a system.

Paging and message services

As paging and message services do not appropriately encrypt information they cannot be relied upon for the communication of sensitive or classified information.

Control: 0240; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must not; **Authority:** AH

Agencies must not use paging, Multimedia Message Service, Short Message Service or Instant Messaging to communicate sensitive or classified information.

Emergency destruction

Agencies need to develop emergency destruction procedures for mobile devices. Such procedures should focus on destroying information on the mobile device and not necessarily the device itself if it can be avoided. Many mobile devices used for highly classified information achieve this through the use of a cryptographic key zeroise or sanitisation function. The use of a remote wipe can be used to achieve the destruction of information.

Control: 0700; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P; **Compliance:** should; **Authority:** AA

Agencies should develop an emergency destruction plan for all mobile devices.

Control: 0701; **Revision:** 2; **Updated:** Nov-10; **Applicability:** C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must develop an emergency destruction plan for mobile devices.

Control: 0702; **Revision:** 2; **Updated:** Nov-10; **Applicability:** C, S, TS; **Compliance:** must; **Authority:** AH

If a cryptographic zeroise or sanitise function is provided for cryptographic keys on a mobile device, the function must be used as part of the emergency destruction procedures.

Unauthorised use of mobile devices

If mobile devices are issued for business purposes they should not be used for private purposes.

Control: 1086; **Revision:** 0; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** should not; **Authority:** AA

Mobile devices should not be used for personal non-business use or by people other than those specifically authorised.

References

Nil.

Working Outside the Office

Objective

Information on mobile devices is accessed with due care in public locations.

Scope

This section describes restrictions on accessing sensitive or classified information using mobile devices from unsecured locations outside of the office and home environments.

Context

This section does not apply to working from home. Requirements relating to home-based work are outlined in the *Working From Home* section in this chapter. Further information on the use of mobile devices can be found in the *Mobile Devices* section of this chapter.

Controls

Working outside the office

Personnel need to be aware of the environment they use mobile devices in to access and communicate sensitive or classified information, especially in public areas including, but not limited to, public transport, transit lounges and coffee shops. In such locations personnel should take extra care to ensure conversations are not overheard and data is not observed.

Control: 0866; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** should; **Authority:** AA

Agencies should ensure personnel are aware not to access or communicate sensitive or classified information in public locations (e.g. public transport, transit lounges and coffee shops) unless extra care is taken to reduce the chance of being overheard or having the screen of the device observed.

Carrying mobile devices

As mobile devices used outside the office will be carried through areas not certified and accredited to process the information on the device, mechanisms need to be put in place to protect the information stored on them.

When agencies apply encryption to mobile devices to reduce their physical transfer requirements, the encryption will only be effective when the decryption function of the device has been deactivated. In most cases this will mean the mobile device will be in an unpowered state (i.e. not turned on), however, some devices are capable of deauthenticating the cryptography when it enters a locked state after a predefined timeout period. Such mobile devices can be carried in a locked state in accordance with reduced physical transfer requirements based on the assurance given in the cryptographic functions.

Control: 0870; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must ensure mobile devices are carried in a secured state when not being actively used.

Using mobile devices

As mobile devices are often portable in nature and can be easily stolen it is strongly advised that personnel do not leave mobile device unattended at any time.

Control: 0871; **Revision:** 1; **Updated:** Nov-10; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

When in use mobile devices must be kept under continual direct supervision.

Travelling with mobile devices

If personnel place mobile devices or media in checked-in luggage when travelling they lose control over the devices. Such situations provide an opportunity for mobile devices to be stolen or tampered with by an attacker.

Control: 1087; Revision: 0; Updated: Nov-10; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

When travelling with mobile devices and media, personnel must retain control over them at all times, this includes not placing them in checked-in luggage or leaving them unattended for any period of time.

Control: 1088; Revision: 1; Updated: Sep-11; Applicability: G, P, C, S, TS; Compliance: must; Authority: AH

If personnel are requested to decrypt mobile devices for inspection by customs personnel, or their mobile device is taken out of sight by customs personnel, then the member must report the potential compromise of information on the device to an Information Technology Security Manager as soon as possible.

References

Nil.

Working From Home

Objective

Personnel working from home protect information in the same manner as in the office environment.

Scope

This section describes information on accessing sensitive or classified information from a home environment in order to conduct home-based work.

Context

When a workstation is issued for home-based work, instead of a mobile device, the requirements from the *Mobile Devices* section in this chapter equally apply to the workstation.

Controls

Physical security for the home environment

When agencies consider allowing personnel to work from a home environment they need to be aware that implementing physical security measures may require modifications to the person's home at the expense of the agency.

Control: 0865; **Revision:** 2; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must ensure that the area in which devices are used meets the requirements in the *Australian Government Physical Security Management Protocol*.

Securing devices in the home environment

All devices have the potential to store sensitive or classified information and therefore need protection against loss and compromise.

Control: 0685; **Revision:** 3; **Updated:** Sep-11; **Applicability:** G, P, C, S, TS; **Compliance:** must; **Authority:** AH

Agencies must ensure that when devices are not being actively used they are secured in accordance with the requirements in the *Australian Government Physical Security Management Protocol*.

References

For further information on working from home see the *Australian Government Physical Security Management Guidelines – Working Away From the Office*.



SUPPORTING INFORMATION



Supporting Information

Glossaries and Index

Glossary of Abbreviations

ABBREVIATION	MEANING
3DES	Triple Data Encryption Standard
ACSI	Australian Communications Security Instruction
AES	Advanced Encryption Standard
AGAO	Australian Government Access Only
AGD	Attorney-General's Department
AGIMO	Australian Government Information Management Office
AH	Authentication Header
AISEP	Australasian Information Security Evaluation Program
ANAO	Australian National Audit Office
AS	Australian Standard
ASA	Agency Security Advisor
ASIO	Australian Security Intelligence Organisation
ATA	Advanced Technology Attachment
AUSTEO	Australian Eyes Only
CISO	Chief Information Security Officer
COE	Common Operating Environment
CSIR	Cyber Security Incident Reporting
DACA	DSD Approved Cryptographic Algorithm
DACP	DSD Approved Cryptographic Protocol
DCE	DSD Cryptographic Evaluation
DDoS	Distributed Denial-of-Service
DH	Diffie-Hellman
DKIM	DomainKeys Identified Mail
DMA	Direct Memory Access
DNS	Domain Name System
DSA	Digital Signature Algorithm
DSD	Defence Signals Directorate
EAL	Evaluation Assurance Level
EAP-TLS	Extensible Authentication Protocol-Transport Layer Security
ECDH	Elliptic Curve Diffie-Hellman

ECDSA	Elliptic Curve Digital Signature Algorithm
EEPROM	Electrically Erasable Programmable Read-only Memory
EPL	Evaluated Products List
EPLD	Evaluated Products List – Degausser
EPROM	Erasable Programmable Read-only Memory
ESP	Encapsulating Security Payload
FIPS	Federal Information Processing Standard
HB	Handbook
HGCE	High Grade Cryptographic Equipment
HMAC	Hashed Message Authentication Code
HTTP	Hypertext Transfer Protocol
HTTPS	Hypertext Transfer Protocol Secure
ICT	Information and Communications Technology
IDS	Intrusion Detection System
IEC	International Electrotechnical Commission
IEEE	Institute of Electrical and Electronics Engineers
IETF	Internet Engineering Task Force
IKE	Internet Key Exchange
IM	Instant Messaging
IP	Internet Protocol
IPSec	Internet Protocol Security
IPv6	Internet Protocol version 6
IRC	Internet Relay Chat
IRP	Incident Response Plan
ISAKMP	Internet Security Association Key Management Protocol
ISM	Australian Government Information Security Manual
ISO	International Organization for Standardization
ISP	Information Security Policy
ITSA	Information Technology Security Advisor
ITSM	Information Technology Security Manager
ITSO	Information Technology Security Officer
KMP	Key Management Plan
LAN	Local Area Network
MFD	Multifunction Device
NAA	National Archives of Australia
NDPP	<i>Network Device Protection Profile</i>

NIST	National Institute of Standards and Technology
NZS	New Zealand Standard
OSI	Open System Interconnect
PSTN	Public Switched Telephone Network
RAM	Random Access Memory
RF	Radio Frequency
RFC	Request for Comments
RSA	Rivest-Shamir-Adleman
RTP	Real-time Transport Protocol
SCEC	Security Construction and Equipment Committee
SHA	Secure Hashing Algorithm
S/MIME	Secure Multipurpose Internet Mail Extension
SOE	Standard Operating Environment
SOP	Standard Operating Procedure
SP	Special Publication
SPF	Sender Policy Framework
SRMP	Security Risk Management Plan
SSH	Secure Shell
SSL	Secure Sockets Layer
SSP	System Security Plan
TLS	Transport Layer Security
TOE	Trusted Operating Environment
UPS	Uninterruptible Power Supply
USB	Universal Serial Bus
VLAN	Virtual Local Area Network
VoIP	Voice over Internet Protocol
VPN	Virtual Private Network
WAP	Wireless Access Point
WEP	Wired Equivalent Privacy
WLAN	Wireless Local Area Network
WPA2	Wi-Fi Protected Access 2
XAUTH	IKE Extended Authentication

Glossary of Terms

TERM	MEANING
802.11	The Institute of Electrical and Electronics Engineers standard defining Wireless Local Area Network communications.
access gateway	A gateway that provides the system user access to multiple security domains from a single device, typically a workstation.
accountable materiel	If strict control over access to, and movement of, particularly sensitive information is required, originators can make this information 'accountable materiel'. What constitutes accountable materiel will vary from agency to agency, but could include Budget papers, tender documents, sensitive ministerial briefing documents, etc.
accreditation	A procedure by which an authoritative body gives formal recognition, approval and acceptance of the associated residual security risk with the operation of a system.
accreditation authority	The authoritative body associated with accreditation activities. Advice on who should be recognised as an agency's accreditation authority can be found in this manual's <i>Conducting Accreditation</i> section of the <i>System Accreditation</i> chapter.
agency	Australian Government departments, authorities, agencies or other bodies established in relation to public purposes, including departments and authorities staffed under the <i>Public Service Act 1999</i> .
agency head	The government employee with ultimate responsibility for the secure operation of agency functions, whether performed in-house or outsourced.
application whitelisting	An approach in which all executables and applications are prevented from executing by default, with an explicitly defined set of executables allowed to execute.
asset	Anything of value, such as Information and Communications Technology equipment, software and information.
attack surface	The amount of Information and Communications Technology equipment and software used in a system. The greater the attack surface the greater the chances are of an attacker finding an exploitable vulnerability.
audit	An independent review of event logs and related activities performed to determine the adequacy of current security measures, to identify the degree of conformance with established policy or to develop recommendations for improvements to the security measures currently applied.
Australasian Information Security Evaluation Program	A program under which evaluations are performed by impartial companies against the Common Criteria. The results of these evaluations are then certified by the Defence Signals Directorate, which is responsible for the overall operation of the program.

Australian Eyes Only	A caveat indicating that the information is not to be passed to or accessed by foreign nationals.
Australian Government Access Only	A caveat used by the Department of Defence and the Australian Security Intelligence Organisation indicating the information is not to be passed to or accessed by foreign nationals, with the exception of seconded foreign nationals. Such material received in other agencies must be handled as if it were marked as Australian Eyes Only.
Australian Government Information Security Manual	National information security policy produced by the Defence Signals Directorate that aims to provide a common approach to the implementation of security measures for information and systems across government.
Authentication Header	A protocol used for authentication in Internet Protocol Security.
baseline	A release of this manual including errata and interim policy releases.
blacklist	A set of inclusive non-accepted items that confirm the item being analysed is not acceptable. It is the opposite of a whitelist which confirms that items are acceptable.
cascaded connections	Cascaded connections occur when one network is connected to another, which has a connection to a third network, and so on.
caveat	A marking that indicates that the information has special requirements in addition to those indicated by the classification. The term covers codewords, source codewords, releasability indicators and special-handling caveats.
certification	A procedure by which a formal assurance statement is given that a deliverable conforms to a specified standard.
certification authority	An official with the authority to assert that a system complies with prescribed controls in a standard.
Certification Report	A report generated by a certification body of a Common Criteria scheme that provides a summary of the findings of an evaluation.
Chief Information Security Officer	A senior executive who is responsible for coordinating communication between security and business functions as well as overseeing the application of controls and security risk management processes.
classification	The business impact level associated with information or a system.
classified information	Information that requires protection from unauthorised disclosure.
classified system	A system that processes, stores or communicates classified information.
coercivity	A property of magnetic material, used as a measure of the amount of coercive force required to reduce the magnetic induction to zero from its remnant state.
Common Criteria	An International Organization for Standardization standard (15408) for information security evaluations.

Common Criteria Recognition Arrangement	An international agreement which facilitates the mutual recognition of Common Criteria evaluations by certificate producing schemes, including the Australian and New Zealand certification scheme.
communications security	The security measures taken to deny unauthorised personnel information derived from telecommunications and to ensure the authenticity of such telecommunications.
conduit	A tube, duct or pipe used to protect cables.
connection forwarding	The use of network address translation to allow a port on a network node inside a Local Area Network to be accessed from outside the network. Alternatively, using a Secure Shell server to forward a Transmission Control Protocol connection to an arbitrary port on the local host.
Consumer Guide	Product specific advice concerning evaluated products can consist of findings from mutually recognised information security evaluations (such as the Common Criteria), findings from Defence Signals Directorate internal evaluations, any recommendations for use and references to relevant policy and standards.
content filtering	The most commonly used method to filter spam. Most antivirus methods are classified as content filters too, since they scan files, binary attachments of email and Hypertext Markup Language payload.
cross domain solution	A highly trusted implementation of a gateway for high assurance applications.
cryptographic hash	An algorithm (the hash function) which takes as input a string of any length (the message), and generates a fixed length string (the message digest or fingerprint) as output. The algorithm is designed to make it computationally infeasible to find any input which maps to a given digest, or to find two different messages that map to the same digest.
cryptographic protocol	An agreed standard for secure communication between two or more entities.
cryptographic system	A related set of hardware or software used for cryptographic communication, processing or storage, and the administrative framework in which it operates.
cryptographic system material	Material that includes, but is not limited to, cryptographic: key, equipment, devices, documents and firmware or software that embodies or describes cryptographic logic.
cyber security	Security measures relating to the confidentiality, availability and integrity of information that is processed, stored and communicated by electronic or similar means.
cyber security incident	An occurrence or activity that may threaten the confidentiality, integrity or availability of a system or the information stored, processed or communicated by it.

Cyber Security Incident Reporting scheme	A scheme established by the Defence Signals Directorate to collect information on cyber security incidents that affect government systems.
data at rest	Information residing on media or a system that is not powered or is unauthenticated to.
data in transit	Information that is being communicated across a communication medium.
data in use	Information that has been decrypted for processing by a system.
data spill	A cyber security incident that occurs when information is transferred between two security domains by an unauthorised means. This can include from a classified network to a less classified network or between two areas with different need-to-know requirements.
declassification	A process whereby information is reduced to an unclassified state and an administrative decision is made to formally authorise its release into the public domain.
degausser	An electrical device or permanent magnet assembly which generates a coercive magnetic force for the purpose of degaussing magnetic storage devices.
degaussing	A process for reducing the magnetisation of a magnetic storage device to zero by applying a reverse (coercive) magnetic force, rendering any previously stored information unreadable.
delegate	A person or group of personnel to whom the authority to authorise non-compliance with requirements in this manual has been delegated by the agency head.
demilitarised zone	A small network with one or more servers that is kept separate from the core network, either on the outside of the firewall, or as a separate network protected by the firewall. Demilitarised zones usually provide public domain information to less trusted networks, such as the Internet.
device access control software	Software that can be installed on a system to restrict access to communications ports on workstations. Device access control software can either block all access to a communications port or allow access using a whitelisting approach based on device types, manufacturer's identification, or even unique device identifiers.
Diffie-Hellman groups	A method used for specifying the modulus size used in the Hashed Message Authentication Code algorithms. Each Diffie-Hellman group represents a specific modulus size. For example, group 2 represents a modulus size of 1024 bits.
diode	A device that allows data to flow in only one direction.
dissemination limiting marker	Markings used to indicate that official information has a special handling requirement or a distribution that is restricted to a particular audience. Example dissemination limiting markers include For Official Use Only and Sensitive.

dual-stack device	A product that implements both Internet Protocol version 4 and 6 protocol stacks.
emanation security	The counter-measure employed to reduce classified emanations from a facility and its systems to an acceptable level. Emanations can be in the form of Radio Frequency energy, sound waves or optical signals.
emergency access	The process of a system user accessing a system that they do not hold appropriate security clearances for due to an immediate and critical emergency requirement.
emergency situation	A situation requiring the evacuation of a site. Examples include fires and bomb threats.
Encapsulating Security Payload	A protocol used for encryption and authentication in Internet Protocol Security.
escort	A person who ensures that when maintenance or repairs are undertaken to Information and Communications Technology equipment that uncleared personnel are not exposed to sensitive or classified information.
facility	An area that facilitates government business. For example, a facility can be a building, a floor of a building or a designated space on the floor of a building.
fax machine	A device that allows copies of documents to be sent over a telephone network.
filter	A hardware or software device that controls the flow of data in accordance with a security policy.
firewall	A network protection device that filters incoming and outgoing network data, based on a series of rules.
firmware	Software embedded in a hardware device.
flash memory media	A specific type of Electrically Erasable Programmable Read-only Memory.
fly lead	A lead that connects Information and Communications Technology equipment to the fixed infrastructure of the facility. For example, the lead that connects a workstation to a network wall socket.
foreign national	A person who is not an Australian citizen.
foreign system	A system that is not solely owned and managed by the Australian Government.
gateway	Gateways connect two or more networks from different security domains to allow access to, or transfer of, information according to defined security policies. Some gateways can be automated through a combination of physical or software mechanisms. Gateways are grouped into three categories: access gateways, multilevel gateways and transfer gateways. Typical gateways process information at the network layer while gateways that process information at all layers of the Open System Interconnect model are often known as cross domain solutions.

general user	A system user who can, with their normal privileges, make only limited changes to a system and generally cannot bypass system security.
government system	Systems containing unclassified but sensitive information not intended for public release, such as Dissemination Limiting Marker information; note 'Government' is not a security classification under the <i>Australian Government Security Classification System</i> .
hardware	A generic term for any physical component of Information and Communication Technology.
Hashed Message Authentication Code algorithms	The SHA-1 hashing algorithm, combined with additional cryptographic functions, forms the Hashed Message Authentication Code algorithms of HMAC-SHA-1-96.
High Grade Cryptographic Equipment	The equivalent to United States Type 1 cryptographic equipment.
host-based intrusion prevention system	A security device, resident on a specific host, which monitors system activities for malicious or unwanted behaviour and can react in real-time to block or prevent those activities.
hybrid hard drives	Non-volatile magnetic media that use a cache to increase read and write speeds and reduce boot time. The cache is normally flash memory media or battery backed Random Access Memory.
Incident Response Plan	A plan for responding to cyber security incidents.
information security	Security measures relating to the confidentiality, availability and integrity of information.
Information Security Policy	A high-level document that describes how an agency protects its systems. The Information Security Policy is normally developed to cover all systems and can exist as a single document or as a set of related documents.
Information Security-Registered Assessor Program	A Defence Signals Directorate initiative designed to register suitably qualified information security assessors to carry out specific types of security assessments.
Information Technology Security Advisor	The Information Technology Security Manager who has responsibility for information technology security management across the agency is designated as the Information Technology Security Advisor. This title reflects the responsibility this person has as the first point of contact for the Chief Information Security Officer and external agencies on any information technology security management issues.
Information Technology Security Manager	Information Technology Security Managers (ITSMs) are executives that coordinate the strategic directions provided by the Chief Information Security Officer and the technical efforts of Information Technology Security Officers. The main area of responsibility of ITSMs is that of the day-to-day management of information security within an agency.

Information Technology Security Officer	Information Technology Security Officers implement technical solutions under the guidance of an Information Technology Security Manager to ensure that the strategic direction for information security within the agency set by the Chief Information Security Officer is achieved.
infrared device	Devices such as mice, keyboards, pointing devices and mobile devices that have an infrared communications capability.
Internet Key Exchange Extended Authentication	Internet Key Exchange Extended Authentication is used for providing an additional level of authentication by allowing Internet Protocol Security gateways to request additional authentication information from remote users. As a result, users are forced to respond with credentials before being allowed access to the connection.
Internet Protocol Security	A suite of protocols for secure communications through authentication or encryption of Internet Protocol packets as well as including protocols for cryptographic key establishment.
Internet Protocol telephony	The transport of telephone calls over Internet Protocol networks.
Internet Protocol version 6	A protocol used for communicating over a packet switched network. Version 6 is the successor to version 4 which is widely used on the Internet. The main change introduced in version 6 is a greater address space available for identifying network devices, workstations and servers.
Intrusion Detection System	An automated system used to identify an infringement of security policy.
ISAKMP aggressive mode	An Internet Protocol Security protocol that uses half the exchanges of main mode to establish an Internet Protocol Security connection.
ISAKMP main mode	An Internet Protocol Security protocol that offers optimal security using 6 packets to establish an Internet Protocol Security connection.
ISAKMP quick mode	An Internet Protocol Security protocol that is used for refreshing security association information.
Information and Communications Technology equipment	Information and Communications Technology equipment includes, but is not limited to, workstations, printers, photocopiers, scanners and Multifunction Devices.
key management	The use and management of cryptographic keys and associated hardware and software. It includes their generation, registration, distribution, installation, usage, protection, storage, access, recovery and destruction.
Key Management Plan	A plan that describes how cryptographic services are securely deployed. It documents critical key management controls to protect keys and associated material during their life cycle, along with other controls to provide confidentiality, integrity and availability of keys.
limited higher access	The process of a system user accessing a system that they do not hold appropriate security clearances for, for a limited non-ongoing period of time.

lockable commercial cabinet	A cabinet that is commercially available, of robust construction and is fitted with a commercial lock.
logging facility	A facility that includes the software component which generates the event and associated details, the transmission (if necessary) of these logs and how they are stored.
malicious code	Any software that attempts to subvert the confidentiality, integrity or availability of a system. Types of malicious code include logic bombs, trapdoors, Trojans, viruses and worms.
malicious code infection	A cyber security incident that occurs when malicious code is used to infect a system. Example methods of malicious code infection include viruses, worms and Trojans.
management traffic	Traffic generated by system administrators over a network in order to control a device. This traffic includes standard management protocols, but also includes traffic that contains information relating to the management of the network.
media	A generic term for hardware that is used to store information.
media destruction	The process of physically damaging the media with the objective of making the data stored on it inaccessible. To destroy media effectively, only the actual material in which the data is stored needs to be destroyed.
media disposal	The process of relinquishing control of media when no longer required, in a manner that ensures that no data can be recovered from the media.
media sanitisation	The process of erasing or overwriting data stored on media.
metadata	Structured information that describes and/or allows personnel to find, manage, control, understand or preserve other information over time. Metadata fixes the record in its business context and documents the record's management and use over time. Records metadata therefore serves to identify, authenticate and contextualise the record.
Multifunction Devices	The class of devices that combines printing, scanning, copying, faxing or voice messaging functionality in the one device. These devices are often designed to connect to computer and telephone networks simultaneously.
multilevel gateway	A gateway that enables access, based on authorisation, to data at many classification and releasability levels where each data unit is individually marked according to its security domain.
need-to-know	The principle of telling a person only the information that they require to fulfil their role.
network access control	Policies used to control access to a network and actions on a network, including authentication checks and authorisation controls.

network device	Any device designed to facilitate the communication of information destined for multiple system users. For example: cryptographic devices, firewalls, routers, switches and hubs.
network infrastructure	The infrastructure used to carry information between workstations and servers or other network devices.
network protection device	A sub-class of network device used specifically to protect a network. For example, a firewall.
no-lone zone	An area in which personnel are not permitted to be left alone such that all actions are witnessed by at least one other person.
non-volatile media	A type of media which retains its information when power is removed.
off-hook audio protection	A method of mitigating the possibility of an active, but temporarily unattended handset inadvertently allowing discussions being undertaken in the vicinity of the handset to be heard by the remote party. This could be achieved through the use of a hold feature, mute feature, push-to-talk handset or equivalent.
official information	Any information developed, received or collected by, or on behalf of, the Government, through its agencies and contracted providers. This includes unclassified, sensitive and classified information.
OpenPGP Message Format	An open-source implementation of Pretty Good Privacy, a widely available cryptographic toolkit.
patch cable	A metallic (copper) or fibre optic cable used for routing signals between two components in an enclosed container or rack.
patch panel	A group of sockets or connectors that allow manual configuration changes, generally by means of connecting cables to the appropriate connector. Cables could be metallic (copper) or fibre optic.
Perfect Forward Security	Additional security for security associations in that if one security association is compromised subsequent security associations will not be compromised.
peripheral switch	A device used to share a set of peripherals between a number of computers.
privileged user	A system user who can alter or circumvent system security protections. This can also apply to system users who could have only limited privileges, such as software developers, who can still bypass security precautions. A privileged user can have the capability to modify system configurations, account privileges, audit logs, data files or applications.
protective marking	A marking that is applied to sensitive or classified information to indicate the security measures that need to be applied to the information to ensure that it is appropriately protected.
Protective Security Policy Framework	Australian Government protective security policy produced by the Attorney-General's Department which provides a common and comprehensive approach to protective security across government.

public domain information	Unclassified information authorised for unlimited public access or circulation, such as publications and websites.
public network infrastructure	Network infrastructure within the public domain that an agency has no control over, for example the Internet.
Public Switched Telephone Network	A public network where voice is communicated using analog communications.
public system	A system that processes, stores or communicates only unclassified information that has been authorised for release into the public domain.
push-to-talk	Handsets that have a button which must be pressed by the user before audio can be communicated, thus providing fail-safe off-hook audio protection.
quality of service	A process to prioritise network traffic based on availability requirements.
reaccreditation	A procedure by which an authoritative body gives formal recognition, approval and acceptance of the associated residual security risk with the continued operation of a system.
reclassification	An administrative decision to change the security measures afforded to information based on a reassessment of the potential impact of its unauthorised disclosure. The lowering of the security measures for media containing classified information often requires sanitisation or destruction processes to be undertaken prior to a formal decision to lower the security measures protecting the information.
remote access	Access to a system that originates from outside an agency network and enters the network through an Internet gateway.
removable media	Storage media that can be easily removed from a system and is designed for removal.
rogue Wireless Access Point	A Wireless Access Point operating outside of the control of an agency.
seconded foreign national	A representative of a foreign government on exchange or long-term posting.
secured space	An area that has been certified to the physical security requirements for a Zone 2 to Zone 5 area as defined in the <i>Australian Government Physical Security Management Protocol</i> .
Secure Multipurpose Internet Mail Extension	A protocol which allows the encryption and signing of Multipurpose Internet Mail Extension-encoded email messages including attachments.
Secure Shell	A network protocol that can be used to securely log into a remote workstation, executing commands on a remote workstation and securely transfer files between workstations.
security association	A collection of connection-specific parameters containing information about a one-way connection in Internet Protocol Security that is required for each protocol used.

security association lifetimes	The duration security association information is valid for.
Security Construction and Equipment Committee	A standing interdepartmental committee responsible for the evaluation and endorsement of security equipment for use by Australian Government agencies. The committee is chaired by the Australian Security Intelligence Organisation and reports to the Protective Security Policy Committee.
security domains	A system or collection of systems operating under a security policy that defines the classification and releasability of the information processed in the domain. It can be exhibited as a classification, a community of interest or releasability within a certain classification.
Security Equipment Catalogue	A catalogue produced by the Security Construction and Equipment Committee (SCEC) that lists security equipment that has been tested and endorsed as meeting relevant SCEC standards.
Security Executive	A member of the Senior Executive Service who is responsible for protective security.
security of information arrangement	A formal arrangement between the Australian Government and a foreign government on the protection of classified information exchanged between the two parties. Details of security of information arrangements can be obtained from the Attorney-General's Department.
security posture	The level of security risk to which a system is exposed. A system with a strong security posture is exposed to a low level of security risk while a system with a weak security posture is exposed to a high level of security risk.
Security Risk Management Plan	A plan that identifies security risks and appropriate risk treatments.
Security Target	An artefact of Common Criteria evaluations. It contains the information security requirements of an identified target of evaluation and specifies the functional and assurance security measures offered by that target of evaluation to meet the stated requirements.
sensitive information	Either unclassified or classified information with a dissemination limiting marker.
server	A computer (including mainframes) used to run programs that provide services to multiple users. For example, a file server, email server or database server.
softphone	A software application that allows a workstation to act as an Internet Protocol phone, using either a built-in or an externally connected microphone and speaker.
software component	An element of a system, including but not limited to, a database, operating system, network or web application.
solid state drives	Non-volatile media that uses flash memory media to retain its information when power is removed and, unlike non-volatile magnetic media, contains no moving parts.

split tunnelling	Functionality that allows personnel to access both a public network and a Virtual Private Network connection at the same time, such as an agency system and the Internet.
SSH-agent	An automated or script-based Secure Shell session.
Standard Operating Environment	A standardised build of an operating system and associated software that is deployed on multiple devices. A Standard Operating Environment can be used for servers, workstations, laptops and mobile devices.
Standard Operating Procedures	Instructions for complying with a System Security Plan. For example, how to update virus signature files.
system	A related set of hardware and software used for the processing, storage or communication of information and the governance framework in which it operates.
system owner	The person responsible for the information resource.
system classification	The classification of a system is the highest classification of information which the system is approved to store or process.
System Security Plan	A plan documenting the controls for a system.
system user	A general user or a privileged user of a system.
target of evaluation	The functions of a product subject to evaluation under the Common Criteria.
technical surveillance counter-measures	The process of surveying facilitates to detect the presence of technical surveillance devices and to identify technical security weaknesses that could aid in the conduct of a technical penetration of the surveyed facility.
telephone	A device that converts between sound waves and electronic signals that can be communicated over a distance.
telephone system	A system designed primarily for the transmission of voice traffic.
TEMPEST	A short name referring to investigations and studies of compromising emanations.
TEMPEST rated Information and Communications Technology equipment	Information and Communications Technology equipment that has been specifically designed to minimise TEMPEST emanations.
traffic flow filter	A device that has been configured to automatically filter and control the form of network data.
transfer gateway	A gateway that facilitates the transfer of information, in one or multiple directions (low to high or high to low), between different security domains.
transport mode	An Internet Protocol Security mode that provides a secure connection between two endpoints by encapsulating an Internet Protocol payload.

Trusted Operating Environment	An operating environment provides assurance that a reasonable effort has been made to secure the operating system of a mobile device such that it presents a reduced security risk to an agency's information and systems.
trusted source	A person or system formally identified as being capable of reliably producing information meeting certain defined parameters, such as a maximum data classification and reliably reviewing information produced by others to confirm compliance with certain defined parameters.
tunnel mode	An Internet Protocol Security mode that provides a secure connection between two endpoints by encapsulating an entire Internet Protocol packet.
unclassified information	Information that is assessed as not requiring a classification. Unclassified information with a dissemination limiting marker is known as sensitive information while unclassified information without a dissemination limiting marker is authorised for release into the public domain.
unsecured space	An area that has not been certified to physical security requirements to allow for the processing of classified information.
Virtual Local Area Network	Network devices and ICT equipment grouped logically based on resources, security or business requirements instead of the physical location of the devices and equipment.
Virtual Private Network	The tunnelling of a network's traffic through another network, separating the Virtual Private Network (VPN) traffic from the underlying network. A VPN can encrypt traffic if necessary.
volatile media	A type of media, such as Random Access Memory, which gradually loses its information when power is removed.
wear levelling	A technique used in flash memory that is used to prolong the life of the media. Data can be written to and erased from an address on flash memory a finite number of times. The wear levelling algorithm helps to distribute writes evenly across each memory block, thereby decreasing the wear on the media and increasing its lifetime. The algorithm ensures that updated or new data is written to the first available free block with the least number of writes. This creates free blocks that previously contained data.
whitelist	A set of inclusive accepted items that confirm the item being analysed is acceptable. It is the opposite of a blacklist which confirms that items are not acceptable.
Wi-Fi Protected Access	Certifications of the implementations of protocols designed to replace Wired Equivalent Privacy. They refer to components of the 802.11i security standard.
Wired Equivalent Privacy	A deprecated 802.11 security standard.



Wireless Access Point	A device which enables communications between wireless clients. It is typically also the device which connects the wireless local area network to the wired local area network.
wireless communications	The transmission of data over a communications path using electromagnetic waves rather than a wired medium.
Wireless Local Area Network	A network based on the 802.11 set of standards. Such networks are often referred to as wireless networks.
workstation	A stand-alone or networked single-user computer.
X11 Forwarding	X11, also known as the X Window System, is a basic method of video display used in a variety of operating systems. X11 forwarding allows the video display from one network node to be shown on another node.



Index

A

access

- event logging and auditing, 174–177
- by foreign nationals, 76, 77, 162, 171–172
- gateway, 229
- identification and authentication, 161–168
- privileged access, 163–164, 171–172
- register, 198–199
- remote access, 173
- security clearance, 75–77
- suspension of, 166
- temporary, 77
- user briefings for, 75–77

accounts

- privileged, 163–164, 171
- shared, 162

accreditation, 35–46. *see also* certification

- authorities, 39, 64
- conducting accreditations, 39–41
- conducting audits, 44–46
- conducting certifications, 42–43
- framework, 35–38
- of service providers' systems, 15

active content

- emails, 153
- gateways, 236, 238
- networks, 220, 224
- websites, 152

Administrative Functions Disposal Authority, 6, 60, 177

Advanced Encryption Standard (AES), 182, 184, 192

agency head, 4–5, 10, 24, 37, 39

Agency Security Advisor (ASA), 44, 64

algorithms. *see* DSD Approved Cryptographic Algorithm (DACA)

anomaly detection systems, 54

antivirus software, 60, 142–143, 147, 148, 191, 223, 239, 244

applicability indicators for this manual, 3

application development, 156–157, 158

application whitelisting, 148–149

Archives Act 1983, 6

assessors. *see* auditing

Attorney-General's Department (AGD), 7–8, 13, 82, 131, 136, 240

audio secure spaces, 86, 109

auditing

- and accreditation, 35, 40, 41
- assessors, 45
- Australian National Audit Office (ANAO), 6, 10, 13
- and certification of systems, 42–43, 44–46
- for compliance, 6, 10
- and cryptography, 196–197, 198
- and cyber security incidents, 55, 60, 232
- of data transfers, 223, 224, 237
- of database use, 160
- of email servers, 215
- of event logging, 174–177, 218
- report of compliance, 46
- of software, 146, 160

Australasian Information Security Evaluation Program (AISEP), 13, 112–116

Australian Communications and Media Authority, 82

Australian Communications Security Instruction (ACSI), 3, 7–8, 10, 57, 100–101, 106, 107, 112, 195, 199

Australian Eyes Only (AUSTEO) requirement, 37, 76, 153, 162, 169, 172, 180, 181, 225, 226, 234, 237, 241, 242

Australian Federal Police, 13

Australian Government Access Only (AGAO) requirement, 37, 76, 124, 153, 162, 169, 172, 180, 181, 225, 226, 234, 237, 241, 242

Australian Government Information Management Office (AGIMO), 13, 142, 155

Australian Government Information Security Management Protocol, 7

Australian Government Personnel Security Management Protocol, 8

Australian Government Physical Security Management Protocol, 8

Australian Government Protective Security Policy Framework, 8

Australian Government Security Classification System, 3

Australian National Audit Office (ANAO), 6, 10, 13

Australian Security Intelligence Organisation (ASIO), 13, 33, 44, 64, 65, 86, 137, 139

authentication

- and DSD Approved Cryptographic Protocols (DACP), 186
- and Internet Protocol Security, 192, 193
- and mobile devices, 244
- and remote access, 163, 173, 189–190
- and Secure Shell, 188–189
- of system users, 150–152, 161–168, 169–170, 171–172, 173, 178, 189–190, 234
- and video conferencing and IP telephony, 208, 209, 210, 212
- and Wireless Local Area Networks (WLANs), 205–206

Authentication Header (AH) protocol, 192, 193

authorisation, 75–77

- of data transfers, 223
- procedures, 161
- of system access, 75–77, 169–170
- and video conferencing and IP telephony, 210

authorities, 4–5, 9, 36, 39, 42, 64

awareness and training, 72–74

- email usage, 80
- gateway usage, 233
- Internet usage, 79
- mobile devices usage, 245, 249–250
- telephones and telephone systems usage, 108–110

B

backup strategy, 52

blogs, 79

Bluetooth, 102–104, 142, 244, 246, 246–247. *see also* mobile devices

briefings, 75–77

business continuity, 6, 52–53, 227

business continuity plan, 52

C

cables

- colours, 83
- fibre optic, 82, 84–85, 87, 89, 91, 99
- grouping of, 83–84
- labelling, 95–96
- patching, 98–99
- register, 96–97

cabling. *see also* cables

- cabinets, 85
- management, 82–94
- shared facilities, 87–88, 89–90, 91–94
- standards, 82

cameras, 128–130. *see also* media security

caveated information, 37, 39, 64, 76, 77

certification, 35, 40–43. *see also* accreditation

- auditing, 44–46
- authorities, 36, 42, 64
- of physical security, 64, 65
- process, 42–43
- reports, 46, 113, 114, 117

change management, 50–51, 200, 234

characterisation, 59, 145–146

Chief Information Security Officer (CISO), 17, 18, 19, 20, 39, 224

classification, reclassification and declassification

- of media, 125–126, 133, 134, 135, 140, 141
- of products, 119–120

cloud computing, 15–16

commercial providers. *see* outsourcing

Common Criteria Mutual Recognition Arrangement, 113

Common Criteria scheme, 112, 114

Commonwealth Authorities and Companies Act 1997, 9

communications infrastructure (cables), 82–86

- emanation security threat assessments, 100–101
- labelling and registration, 95–97
- for non-shared government facilities, 87–88
- patching, 98–99
- for shared government facilities, 89–90
- for shared non-government facilities, 91–94

communications security, 82–110

- of infrastructure, 82–101
- of systems and devices, 102–110

communications systems and devices, 102–110. *see also* Bluetooth devices; telephones and telephone systems

compartmented information, 37, 39, 64, 76, 77

compliance (with controls in this manual), 5, 6

- auditing, 10
- language, 4
- and legal considerations, 10
- for smaller agencies, 9–10

Computer Emergency Response Team Australia, 13

configuration

- of application whitelisting, 149
- cable patching, 98–99
- of gateways, 231, 234
- of Intrusion Detection Systems, 219
- of mobile devices, 247
- of networks, 200, 203
- of products, 117–118
- and Secure Shell (SSH), 188

configuration management, 200

content filtering, 232, 238–239

copier drums, 123–124

cross-domain solutions, 228, 231, 235

cryptography, 178–199

- cryptographic evaluations, 112, 113, 179, 182, 185
- cryptographic testing, 113
- DSD Approved Cryptographic Algorithm (DACA), 130, 179, 180, 182–184, 185, 186, 193
- DSD Approved Cryptographic Protocol (DACP), 179, 181, 185–186, 187, 188, 191, 192
- Internet Protocol Security (IPSec), 185, 192–194
- key management, 57, 195–199
- in media usage, 129
- on mobile devices, 246, 249–250
- Secure Multipurpose Internet Mail Extension (S/MIME), 185, 191
- Secure Shell (SSH), 185, 188–190
- Secure Sockets Layer (SSL), 151, 185, 187
- Transport Layer Security (TLS), 151, 185, 187, 206, 209

Cyber Security Incident Reporting (CSIR) scheme, 56, 57, 59

cyber security incidents, 54–61

- assistance with, 12, 13
- detection, 54–55, 174, 177, 218–219, 232, 234
- management, 58–61, 197
- prevention, 73, 105, 116, 171, 223, 231
- reporting, 19, 20, 30, 31, 32, 56–57

Cyber Security Policy and Coordination Committee, 13

D

data

- export, 224–225, 236–237
- import, 224, 235

labelling, 159

recovery, 180–181

spills, 59

transfers, 223–225

databases, 159–160, 175

declassification. *see* classification, reclassification and declassification

Defence Signals Directorate (DSD), 3, 9, 12. *see also* Evaluated Products List (EPL)

- Common Criteria scheme, 112, 114
- and cross-domain solutions, 231, 235
- and cryptographic evaluation, 112, 113, 179, 182, 185
- and cyber security incident reporting, 56, 60
- and disposal of high assurance products, 123
- and disposal of products, 123
- DSD Approved Cryptographic Algorithm (DACA), 130, 179, 180, 182–184, 185, 186, 193
- DSD Approved Cryptographic Protocol (DACP), 179, 181, 185–186, 187, 188, 191, 192
- and emanation security threat assessment, 100–101
- and firewalls, 241
- and High Grade Cryptographic Equipment (HGCE), 115, 117, 118
- and Protection Profiles for specific technologies, 113
- and wireless communications, 205–207

degaussers, 136, 137, 138

denial-of-service attacks

- mitigation plan, 227
- prevention, 90, 93, 206, 209

denial-of-service response plan, 211–212

Department of Foreign Affairs and Trade (DFAT), 13, 44, 65

Department of the Prime Minister and Cabinet (DPMC), 13

deployable platforms, 65, 82, 87, 89, 91, 95, 98

destruction, 31, 136–139

- equipment, 137
- procedures, 136, 248

Diffie-Hellman (DH) algorithm, 182, 183, 193

digital audio players, 128–130. *see also* media security

Digital Signature Algorithm (DSA), 182, 183

diodes, 232, 242–243

disaster recovery, 19, 20, 52–53

disaster recovery plan, 53

disposal

- of media, 132, 140–141
- of products, 123–124

Distributed Denial-of-Service (DDoS) attacks, 227

documentation, 22–34

- of authorisation, clearances and briefings, 75–77
- business continuity plan, 52
- for cyber security incidents, 58
- denial-of-service response plan, 212
- destruction procedures, 136, 248
- disaster recovery plan, 53
- emergency procedures, 25, 34
- event logging, 174
- framework, 23
- Incident Response Plan (IRP), 23, 33, 45, 58, 218
- Information Security Policy (ISP), 22, 25, 45
- for networks, 200–201
- reclassification and declassification procedures, 125
- Security Risk Management Plan (SRMP), 22, 26–27, 39, 51, 234
- Standard Operating Procedure (SOP), 23, 30–32, 45, 51, 58, 96, 233
- System Security Plan (SSP), 22, 28, 39, 51, 58, 69, 75, 97, 203
- for wireless networks, 206

DomainKeys Identified Mail (DKIM), 215, 216

DSD Approved Cryptographic Algorithm (DACA), 130, 179, 180, 182–184, 185, 186, 193

- Advanced Encryption Standard (AES), 182, 184
- Diffie-Hellman (DH), 182, 183, 193
- Digital Signature Algorithm (DSA), 182, 183
- Elliptic Curve Diffie-Hellman (ECDH), 182–183
- Elliptic Curve Digital Signature Algorithm (ECDSA), 182–183
- Rivest-Shamir-Adleman (RSA), 182, 183–184
- Secure Hashing Algorithm (SHA), 182, 184, 193
- Triple Data Encryption Standard (3DES), 182, 184, 192

DSD Approved Cryptographic Protocol (DACP), 179, 181, 185–186, 187, 188, 191, 192

- Internet Protocol Security (IPSec), 185, 192–194
- OpenPGP Message Format, 185
- Secure Multipurpose Internet Mail Extension (S/MIME), 185, 191
- Secure Shell (SSH), 185, 188–190
- Secure Sockets Layer (SSL), 151, 185, 187

E

Electrically Erasable Programmable Read-only Memory (EEPROM) media, 134

Elliptic Curve Diffie-Hellman (ECDH) algorithm, 182, 183

Elliptic Curve Digital Signature Algorithm (ECDSA), 182, 183

email

- applications, 153–155
- blocking of, 213–214
- infrastructure, 213–217
- printing, 154
- protective marking, 154–155
- servers for, 214–217, 220
- usage, 80, 153
- web-based, 78, 80

emanation security threat assessments, 100–101

emergency procedures, 25, 34

Encapsulating Security Payload (ESP) protocol, 192, 193

encryption. *see* cryptographyequipment. *see* ICT equipment

Erasable Programmable Read-only Memory (EPROM) media, 134

evacuation procedures, 34

Evaluated Products List (EPL), 112, 113, 114, 137, 180, 181, 226, 231, 241, 242

event logging, 174–177

Extensible Authentication Protocol-Transport Layer Security (EAP-TLS), 206

external hard drives, 128–130. *see also* media security

F

facilities. *see also* communications infrastructure (cables)

- evacuation, 34
- foreign, 65, 169
- non-shared government facilities, 87–88, 89, 92
- shared government facilities, 89–90, 92
- shared non-government facilities, 91–94

fax machines, 105–107. *see also* ICT equipment

Federal Information Processing Standard (FIPS), 179

fibre optic cables. *see* cables*Financial Management and Accountability Act 1997*, 9

firewalls, 113, 142, 144, 164, 201, 208–209, 211, 212, 219, 221, 240, 241, 244

firmware updates, 144

flash memory media, 68, 128–129, 131, 135, 245

foreign nationals

- identification, 162
- and privileged system access, 171–172
- and system access, 76–77

foreign systems

- access to Australian systems, 169
- data export to, 225, 237
- and emanation security threat assessment, 101

forums, 79

G

gateway security, 228–243. *see also* gateways

- content filtering, 215, 228, 232, 238–239, 240–243
- data import and export, 236–237
- diodes, 242–243
- and firewalls, 241
- traffic flow filters, 232, 240–241

gateways, 221–222. *see also* gateway security

- administration of, 233–234
- centralised email gateway, 215
- certification of services, 42, 43, 64
- configuration of, 231–232
- data transfers, 223–225
- filters, 155
- and Internet Protocol version 6 (IPv6), 221–222
- and Intrusion Detection Systems (IDS), 218–220
- remote access, 173, 189, 190
- types, 229–230
- uni-directional, 229, 238, 242–243
- use of, 231

government facilities

- non-shared, 87–88
- shared, 89–90

H

Hashed Message Authentication Code (HMAC) algorithms, 193

hashing algorithms, 165, 182, 184

high assurance products

- configuration, 117
- disposal, 123

- labelling, 119
- patching of vulnerabilities, 143
- repair, 121
- requirements, 112, 114, 115, 118

high grade cryptographic algorithms, 182

High Grade Cryptographic Equipment (HGCE), 57, 105, 112, 180, 195

- configuration, 117–118
- disposal, 123–124
- and key management, 195, 197
- labelling, 119–120
- patching, 143
- repair, 121
- requirements, 4, 12, 114, 115, 180–181

high grade cryptographic protocols, 185

home environment. *see* working off-site

Hypertext Transfer Protocol Secure (HTTPS), 151

I

ICT equipment. *see also* media security; product security

- authentication, 234
- Bluetooth devices, 102–104, 244, 246–247
- and encryption, 180–181
- fax machines, 105–107
- infrared devices, 102–103
- keyboards, 65, 102–103, 226, 244
- monitors, 124
- multifunction devices, 68–69, 105–107
- photocopiers, 68–69, 123
- printers, 68–69, 123–124, 132
- radio frequency (RF) devices, 102–104
- sanitation and disposal, 123–124
- scanners, 68–69
- telephones and telephone systems, 78, 106, 108–110, 208–212
- televisions, 124
- wireless devices, 102–104, 206–207
- workstations, 65, 68–69, 129–130, 142–147, 244, 251

IKE Extended Authentication (XAUTH), 192, 193

Incident Response Plan (IRP), 23, 33, 45, 58, 218

incidents. *see* cyber security incidents

industry engagement. *see* outsourcing

industry security program, 16



information security, 12–61. *see also* cyber security incidents

- accreditation of systems, 35–46
- Australian Government agencies (advisory roles), 12–14
- compliance with controls in this manual, 9–10
- documentation, 22–34
- engagement, 12–16
- monitoring, 47–53
- roles and responsibilities, 17–21
- use of this manual, 2–10

information security monitoring

- business continuity, 52
- change management, 50–51
- disaster recovery, 53
- vulnerability management, 47–49

Information Security Policy (ISP), 22, 25, 45

information technology security, 112–251

- access control, 161–177
- cryptography, 178–199
- gateways, 228–243
- media, 125–141
- networks, 200–227
- off-site security, 244–251
- products, 112–124
- software security, 142–160

Information Technology Security Advisor (ITSA), 12, 18, 20, 42, 56, 57, 224

Information Technology Security Manager (ITSM), 12, 15, 32, 59, 168, 196, 224, 250

- and cyber security incident reporting, 56
- role, 18, 19, 20, 24, 44
- and Standard Operating Procedures, 30–31

Information Technology Security Officer (ITSO), 19, 20, 30–31, 58, 224

infrared devices, 102–103. *see also* mobile devices

installation and configuration of products, 117–118

Instant Messaging (IM), 78, 248

Intelligence Services Act 2001, 9, 12

Internet Key Exchange (IKE), 192

Internet Protocol (IP) telephony, 78, 208–212

Internet Protocol Security (IPSec), 185, 192–194

Internet Protocol version 6 (IPv6), 221–222

Internet Relay Chat (IRC), 78

Internet Security Association Key Management Protocol (ISAKMP), 192, 193

Internet use, 78–80

intrusion detection and prevention, 54, 215, 218–220

Intrusion Detection System (IDS), 80, 144, 201, 218–220

K

key management, 195–199. *see also* cryptography

Key Management Plan (KMP), 196, 197

keyboards, 65, 102–103, 226, 244

L

labelling

- of cables, 95–97
- of data, 159
- of media, 126–127
- of products, 119–120

laptops. *see* mobile devices

leasing of products, 116

log analysis, 54

logging. *see* event logging

logon banners, 72, 167

M

magnetic media, 133–134, 138

maintenance and repairs of products, 121–122

malicious code, 59–60, 219

- and content filtering, 239
- and cyber security incidents, 55, 59, 60
- and data transfers, 223
- and email, 213, 216
- and intrusion detection and prevention, 218–220
- and media usage, 128
- and network security, 207, 211
- and product security, 115
- and Secure Multipurpose Internet Mail Extension (S/MIME), 191
- and software security, 142, 143, 148, 150, 151, 152, 153, 156
- and web-based email services, 80

media classification and declassification, 125–126, 141



media security, 68–69, 125–141
 destruction, 132, 135, 136–139
 disposal, 140–141
 handling, 125–127
 labelling, 126–127
 sanitation, 131–135
 usage, 128–130

microfiche, 132. *see also* media security

microfilm, 132. *see also* media security

mobile devices, 244–248, 249–250. *see also* media security

mobile phones. *see* mobile devices

monitors, 124

mouse, 226

Mu ti Protocol Label Switching, 203

multi-factor authentication, 161, 163, 164

multifunction devices (MFD), 68–69, 105–107

multilevel gateway, 230

Mu timedia Message Service, 248

N

National Archives of Australia (NAA), 6, 13, 60, 177

netbooks. *see* mobile devices

network. *see also* network security
 devices, 66–67
 diagrams, 201
 documentation, 200–201
 and host IDSs, 55
 infrastructure, 64–65
 logging requirements, 176

Network Device Protection Profile (NDPP), 113, 240, 241

network security, 200–227. *see also* network
 data transfers, 223–225
 email infrastructure, 213–217
 and encryption, 181
 Internet Protocol (IP) telephony, 208–212
 Internet Protocol version 6 (IPv6), 221–222
 intrusion detection and prevention, 54, 215, 218–220
 management of infrastructure, 200–202
 peripheral switches, 226
 physical security, 64–65

 servers and devices, 66–67
 service continuity, 227
 video conferencing, 208–212
 Virtual Local Area Networks (VLANs), 203–204, 208, 210–211
 Wireless Local Area Networks (WLANs), 205–207

network segmentation, 202

no-lone zones, 66

non-compliance. *see* compliance (with controls in this manual)

non-government facilities, 91–94

non-volatile media, 123–127, 133–135

O

OnSecure website, 6, 152, 235

Open Web Application Security Project guide, 158

OpenPGP Message Format, 185

optical discs, 132. *see also* media security

outsourcing
 and accreditation, 15–16, 36
 certification of gateway services, 43
 and cyber security incident reporting, 56, 57
 of documentation development, 23
 of media destruction, 139
 of services, 15–16

overseas systems. *see* foreign systems

P

paging and message services, 248

passphrases, 145, 161–165
 authentication, 165, 189
 management, 164–165
 resetting, 165

passwords. *see* passphrases

peer-to-peer applications, 78, 80

Perfect Forward Secrecy, 193

peripheral switches, 226

personnel security. *see also* awareness and training
 authorisation, clearances and briefings, 75–77
 Internet usage, 78–80

photocopiers, 68–69, 123



physical security, 46, 64–69
 authorities, 64
 certification, 46
 of facilities and network infrastructure, 64–65
 of High Grade Cryptographic Equipment (HGCE), 197
 of home environment, 251
 of ICT equipment and media, 68–69
 of servers and network devices, 66–67
 of Wireless Local Area Networks (WLANs), 205–207

Physical security of ICT equipment systems and facilities guideline, 66

pointing devices, 102

portable devices. *see* mobile devices

portable media players, 128–130. *see also* media security

printer cartridges, 124

printer ribbons, 132. *see also* media security

printers, 68–69, 123–124, 132

privacy settings, 79

privileged access, 163–164, 171–172

product security

 classifying and labelling, 119–120
 installation and configuration, 117–118
 maintenance and repairs, 121–122
 sanitation and disposal, 123–124
 selection and acquisition, 112–116

Protection Profiles for specific technologies, 113

protective marking

 of data, 236, 239
 and data transfers, 223, 224, 225
 database labelling, 159
 of emails, 80, 153–155, 213, 214, 215
 media labelling, 126
 product labelling, 119

Protective Security Policy Committee, 13

public key-based authentication, 189

Public Switched Telephone Network (PSTN), 105, 208

R

radio frequency (RF) devices, 102–104. *see also* mobile devices

Radio Frequency (RF) shielding, 207

reaccreditation, 37–38. *see also* accreditation

read-only memory, 132, 134. *see also* media security

reclassification. *see* classification, reclassification and declassification

remote access, 163, 173, 189. *see also* working off-site

report of compliance, 46

residual security risk, 41, 43, 51

risk management. *see* security risk management

Rivest-Shamir-Adleman (RSA) algorithm, 182, 183–184

roles and responsibilities

 agency head, 4–5, 10, 24, 37, 39
 Agency Security Advisor (ASA), 44, 64
 Chief Information Security Officer (CISO), 17, 39, 224
 Information Technology Security Advisor (ITSA), 12, 18, 20, 42, 56, 57, 224
 Information Technology Security Manager (ITSM), 12, 15, 18, 19, 20, 24, 30–31, 32, 44, 56, 59, 168, 196, 224, 250
 Information Technology Security Officer (ITSO), 19, 20, 30–31, 58, 224
 Security Executive, 17
 system administrator, 30, 31–32, 148–149, 171
 System Owner, 4, 5, 6, 19, 20, 21, 24, 36, 40, 42, 45, 46, 231, 233

S

sanitation

 of media, 127, 131–135
 of products, 123–124

scanners, 68–69

screen locking, 166

search engines, 160

Secure Hashing Algorithm (SHA), 182

Secure Multipurpose Internet Mail Extension (S/MIME), 185, 191

Secure Shell (SSH), 185, 188–190

Secure Shell (SSH) agent, 189

Secure Sockets Layer (SSL), 151, 185, 187

secured areas

 cabling, 95–97
 device usage in, 102
 maintenance and repairs of equipment in, 122
 media usage in, 130



security clearance, 75–77

Security Construction and Equipment Committee (SCEC), 13, 137, 246

Security Executive, 17

security risk assessment of gateways, 232–233

security risk management, 8, 17. *see also* Security Risk Management Plan (SRMP)

- and change management, 51
- residual security risk, 41, 43, 51

Security Risk Management Plan (SRMP), 22, 26–27, 45, 51, 234

Security Target and Certification Report, 113, 114, 117

Sender Policy Framework (SPF), 214, 216

servers

- for email, 214–217, 220
- functional separation of, 145, 202
- security of, 64–65, 66–67, 142–148, 158, 177
- for video conferencing and IP telephony, 208
- web servers, 158, 220, 227

service continuity, 227

service providers. *see* outsourcing

session termination, 166

shared accounts, 162–164

shared facilities, 87–88, 89–90, 91–94, 101

Short Message Service (SMS), 248

smartphones. *see* mobile devices

social networking, 79

softphones, 211. *see also* Internet Protocol (IP) telephony

software security

- application development, 156–158, 158
- application whitelisting, 148–149
- databases, 159–160
- email applications, 153–155
- software testing, 157
- Standard Operating Environments (SOE), 142–147
- web content and connections, 150–152, 158

Standard Operating Environments (SOE), 142–147

Standard Operating Procedure (SOP), 23, 30–32, 45, 51, 58, 96, 233

symmetric encryption algorithms, 182–184

system accreditation. *see* accreditation

system administrator

- permissions, 148–149, 171, 188, 196
- Standard Operating Procedures, 30–32

system integrity verification, 55

System Owner, 4, 5, 6, 19, 20, 21, 24, 36, 40, 42, 45, 46, 231, 233

System Security Plan (SSP), 22, 23, 25, 28, 29, 39, 45, 51, 58, 69, 75, 97, 203, 206

T

tablet computers. *see* mobile devices

tamper evident seals, 93–94, 115, 119–120

Telecommunications (Interception and Access) Act 1979, 60

telephones and telephone systems, 78, 106, 108–110, 208–212

televisions, 124

TEMPEST rated ICT equipment, 101, 123–124

The Privacy Act 1988, 8, 151

third-party information, 5

traffic flow filters, 232, 240–243

training and awareness. *see* awareness and training

transfer gateway, 229

Transport Layer Security (TLS), 151, 185, 187

Triple Data Encryption Standard (3DES) algorithm, 182, 184

Trusted Operating Environment (TOE), 244

trusted sources, 213, 220, 223–225, 237, 239

U

Universal Serial Bus (USB) phones, 211. *see also* Internet Protocol (IP) telephony

unsecured spaces, 65, 92, 102, 103

user authentication, 150–151, 161–168, 169–170, 171–172, 173, 178, 189–190, 234

V

video, 226

video conferencing, 78, 208–212

Virtual Local Area Networks (VLANs), 203–204, 208, 210–211

volatile media, 132–133

vulnerability

- analysis and mitigation, 48–49

- assessment, 47–49

- Direct Memory Access, 129

- management, 47–49

- of Standard Operating Environment, 143

W

web access implementation, 150–152

web applications, 150–152, 158, 176

web proxies, 150, 152

web-based email, 78, 80

webcams, 211. *see also* Internet Protocol (IP) telephony

websites

- blacklisting, 152

- categorisation, 151

- content filter, 152

- whitelisting, 151

whitelisting

- of applications, 148–149

- of websites, 151

Whole of Government Common Operating Environment (COE) policy, 142

Wi-Fi Protected Access (WPA), 205–206

Wired Equivalent Privacy (WEP), 205

Wireless Access Point (WAP) attacks, 205–206

wireless devices, 102–104, 206–207

Wireless Local Area Networks (WLANs), 205–207

working off-site, 244–251

- from home, 251

- outside the office, 249–250

- remote access, 173

- use of mobile devices, 244–248, 249–250

workstations, 65, 68–69, 129–130, 142–147, 244, 251

